Scenari Applicativi

Release 3.3.21

Link.it

22 ott 2026

Contents

1 Ambiente di esecuzione **1**
- 1.1 Prerequisiti . . . 1
- 1.2 Avvio Ambiente . . . 2
- 1.3 Progetto Postman . . . 3

2 Profilo “API Gateway” **11**
- 2.1 Erogazione pubblica . . . 11
- 2.2 Erogazione OAuth . . . 15

3 Profilo “ModI” **25**
- 3.1 Pattern “ID_AUTH” . . . 26
- 3.2 Pattern “INTEGRITY_01” . . . 54
- 3.3 Pattern “ID_AUTH” via PDND . . . 86
- 3.4 Pattern “ID_AUTH” via PDND + “INTEGRITY_01” . . . 118
- 3.5 Pattern “ID_AUTH” via PDND + “INTEGRITY_REST_02” . . . 150
- 3.6 Pattern “AUDIT_REST_01” . . . 170
- 3.7 Pattern “AUDIT_REST_02” . . . 202

4 Monitoraggio **217**
- 4.1 Transazione in errore . . . 217
- 4.2 Transazione con esito corretto . . . 221

CHAPTER 1

Ambiente di esecuzione

Per semplificare la realizzazione e la verifica degli scenari d'uso, descritti in questa sezione della documentazione di Govway, è possibile dotarsi dell'ambiente di esecuzione appositamente predisposto.

Nella sezione *Prerequisiti* vengono indicati i software di base richiesti per poter avviare l'ambiente e verificare gli scenari.

Indicazioni su come ottenere un ambiente, preconfigurato per verificare gli scenari, sono presenti nella sezione *Avvio Ambiente*.

Infine nella sezione *Progetto Postman* vengono fornite indicazioni su come ottenere un progetto Postman che contenga i client preconfigurati per attuare le richieste descritte in ogni scenario.

1.1 Prerequisiti

Per l'avvio dell'ambiente di esecuzione degli scenari è necessario disporre del seguente software di base:

- dotarsi di una installazione Docker che gestirà l'intero contesto di esecuzione degli scenari;
- dotarsi dell'applicativo Postman utilizzato come client per l'invio delle richieste a Govway.

L'ambiente di esecuzione è composto da:

- ambiente docker-compose preinizializzato con gli scenari descritti in queso manuale;
- progetto Postman preconfigurato per verificare gli scenari:
  - invocazione pubblica o OAuth su profilo "API Gateway";
  - profilo "ModI" su API REST;
  - profilo "ModI" su API SOAP.

Gli scenari configurati sull'ambiente docker devono poter accedere alle seguenti API pubbliche disponibili su internet:

- (API REST) Petstore: https://petstore.swagger.io/
- (API SOAP) Temperature Conversion: https://www.w3schools.com/xml/tempconvert.asmx

1.2 Avvio Ambiente

Dopo aver scompattato l'archivio, indicato nei prerequisiti, sarà possibile avviare un ambiente tramite docker compose preinizializzato per gli scenari descritti nel manuale. Di seguito vengono forniti tutti i passaggi da effettuare per ottenere un ambiente funzionante:

- *Archivio*: scompattare l'archivio nella cartella di destinazione scelta per ospitare l'ambiente di esecuzione degli scenari.
- *Hostname*: l'ambiente è configurato per utilizzare l'hostname "govway.localdomain". Configurare una risoluzione dell'hostname ad esempio registrando nel file /etc/hosts l'entry:

```
127.0.0.1       govway.localdomain
```

- *Ambiente Docker*: avviare l'ambiente docker compose utilizzando lo script "*starttest.sh*" presente all'interno della cartella di destinazione dell'ambiente (Fig. 1.1).

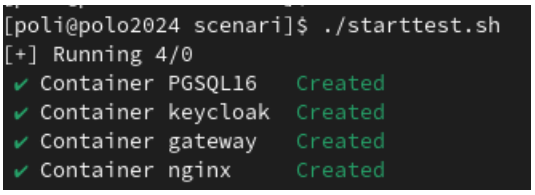


Figure1.1: Schermata di avvio «docker-compose up»

I componenti avviati sono i seguenti:

- gateway: l'istanza di Govway
- PGSQL16: il database Postgres
- keycloak: l'authorization server
- nginx: il server web

Nota

Lo script "*starttest.sh*" si occupa di inizializzare due variabili di ambiente prima di avviare l'ambiente tramite il comando "*docker-compose up*":

- SERVER_FQDN: definisce l'hostname dell'ambiente (negli esempi govway.localdomain)
- LOCAL_DATA: directory contenente gli storage locali utilizzate dalle immagini docker avviate dal compose (l'archvio fornisce già la directory ./data)

Dopo aver avviato l'ambiente è possibile verificare l'accesso alle seguenti console:

- *GovWay - Console di Gestione*: permette di visualizzare le configurazioni realizzate su Govway (Fig. 1.2).

```
endpoint: https://govway.localdomain/govwayConsole/
username: amministratore
password: 123456
```

- *GovWay - Console di Monitoraggio*: permette di consultare le transazioni gestite da Govway (Fig. 1.3).



Figure1.2: Accesso alla console di gestione

```
endpoint: https://govway.localdomain/govwayMonitor/
username: operatore
password: 123456
```

- *Keycloak - Authorization Server*: permette di consultare le configurazioni realizzate sull'Authorization Server Keycloak (Fig. 1.4).

  ```
  endpoint: https://govway.localdomain/auth/
  username: admin
  password: admin
  ```

1.3 Progetto Postman

La collezione Postman comprende tutte le configurazioni utilizzate nei vari scenari presentati (Fig. 1.5). La collection deve essere caricata sul proprio Postman tramite la funzionalità di import.

Una volta effettuato il caricamento della collezione, modificare i parametri della collezione (Fig. 1.6) al fine di indicare nella variabile "*hostname*" (Fig. 1.7) l'indirizzo ip su cui è stato attivato l'immagine docker compose (per default è presente 127.0.0.1).

Infine accedere alla configurazione generale di Postman (alcuni esempi a seconda della versione utilizzata in Fig. 1.8 e Fig. 1.9) ed assicurarsi che la voce "*SSL Certificate Verification*" nella maschera "*General*" sia disabilitata (Fig. 1.10, Fig. 1.11) e che non vi sia impostato un proxy nella maschera "*Proxy*" (Fig. 1.12, Fig. 1.13).



Figure1.3: Accesso alla console di monitoraggio

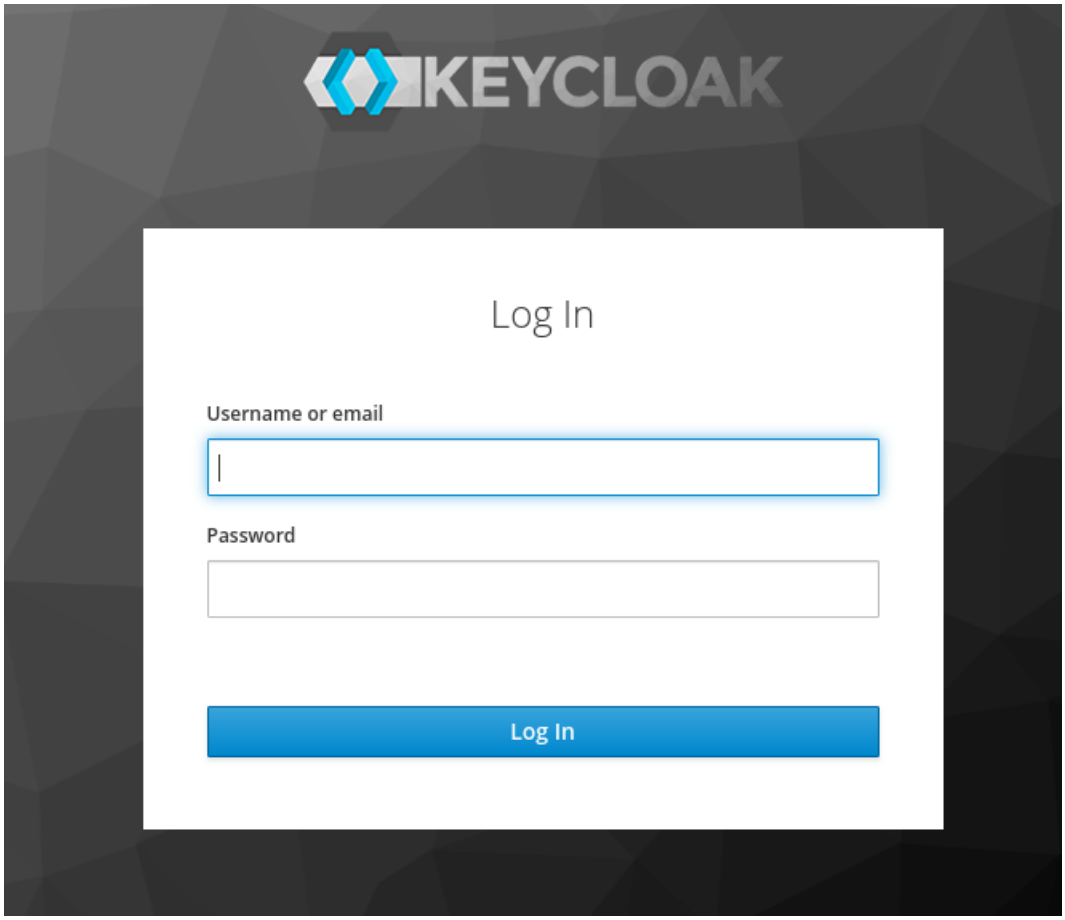


Figure1.4: Accesso alla console dell'authorization server

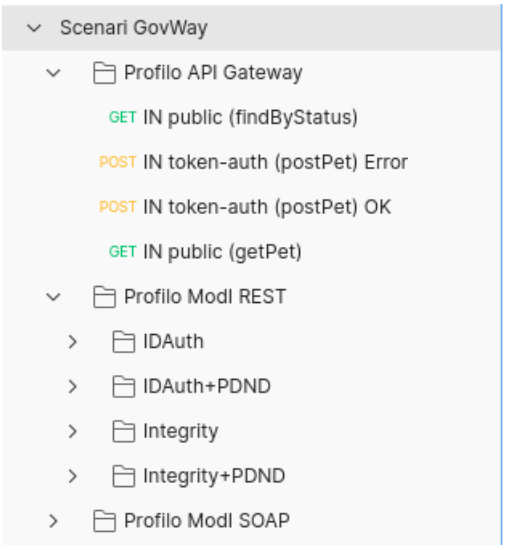


Figure1.5: Indice della collection Postman

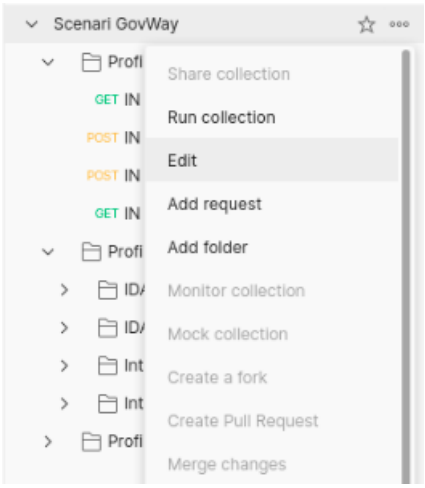


Figure1.6: Configurazione Collection Postman

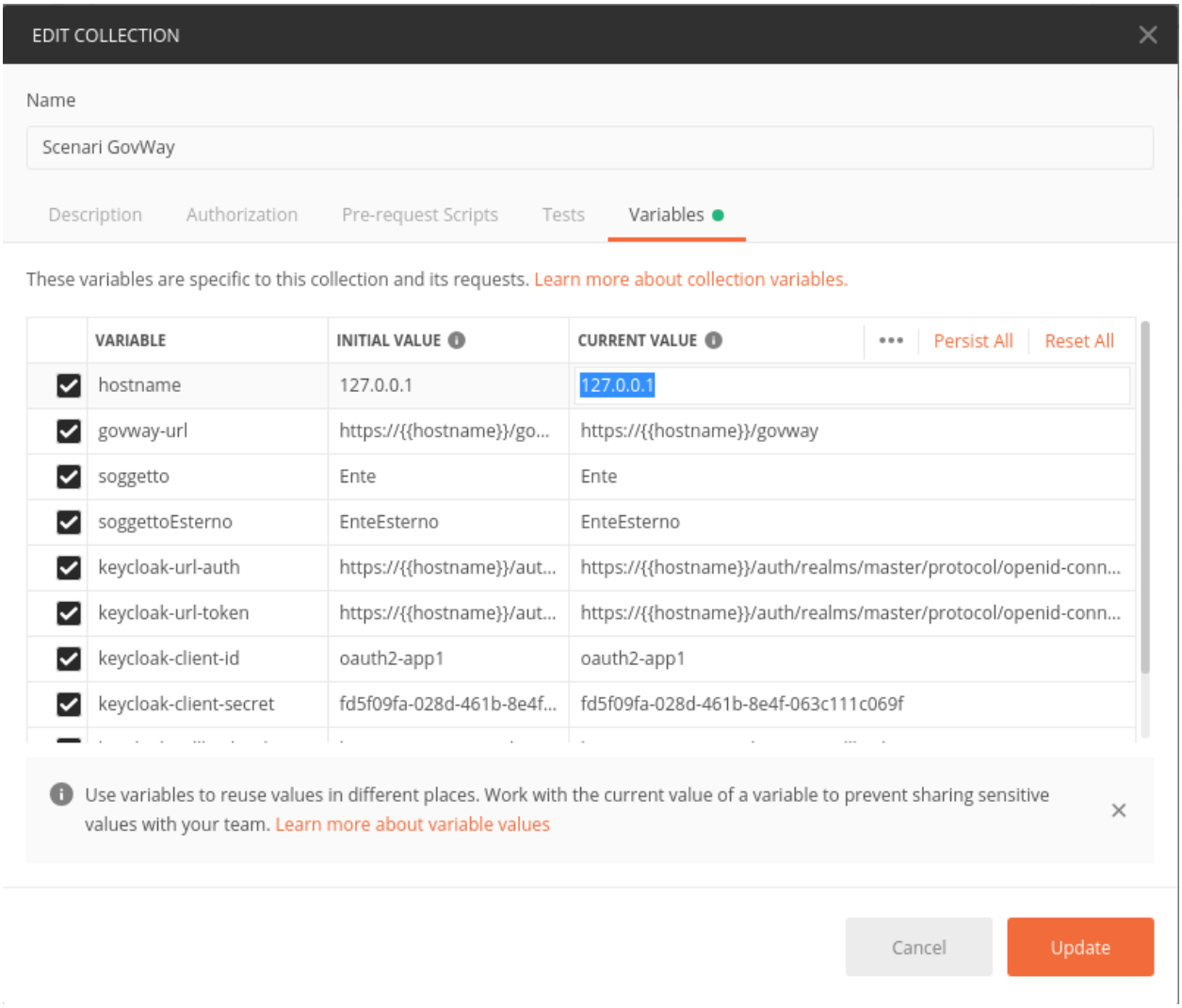


Figure1.7: Configurazione Hostname nella Collection Postman

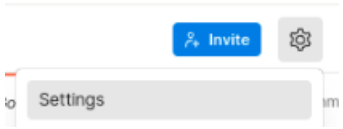


Figure1.8: Configurazione Generale Postman (versioni più recenti)

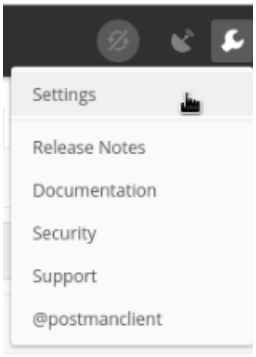


Figure1.9: Configurazione Generale Postman

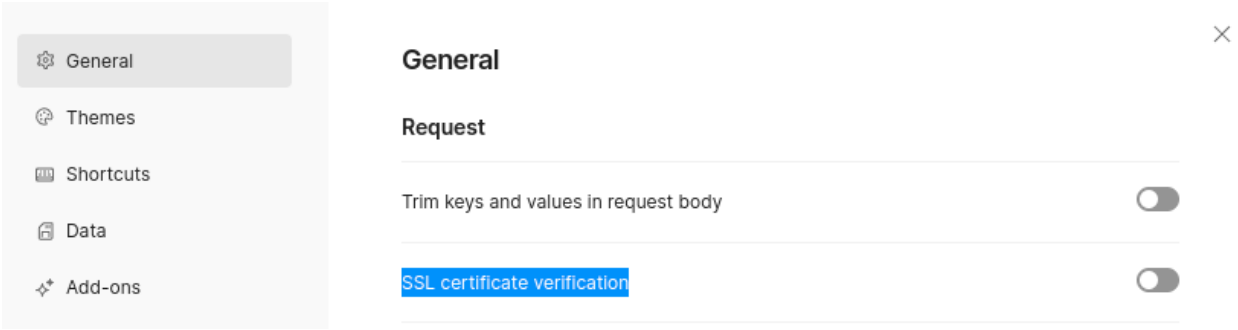


Figure1.10: Configurazione SSL Postman (versioni più recenti)

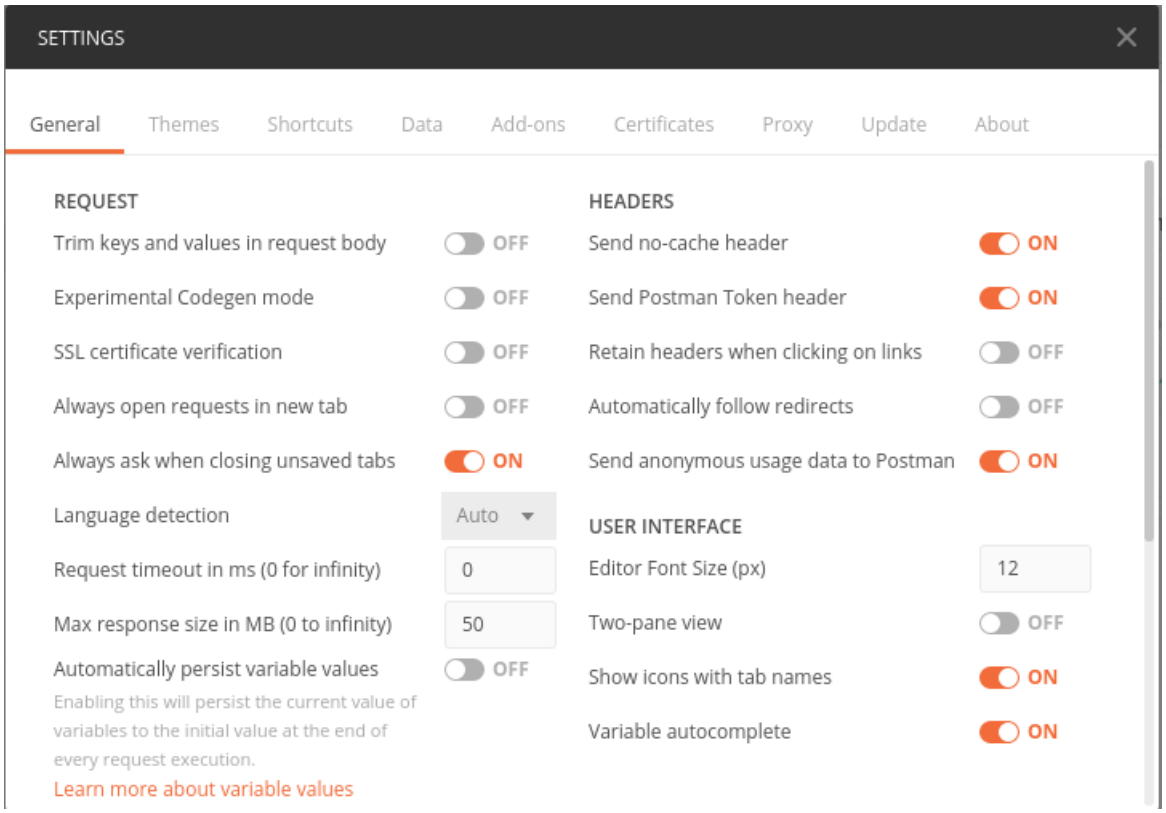


Figure1.11: Configurazione SSL Postman

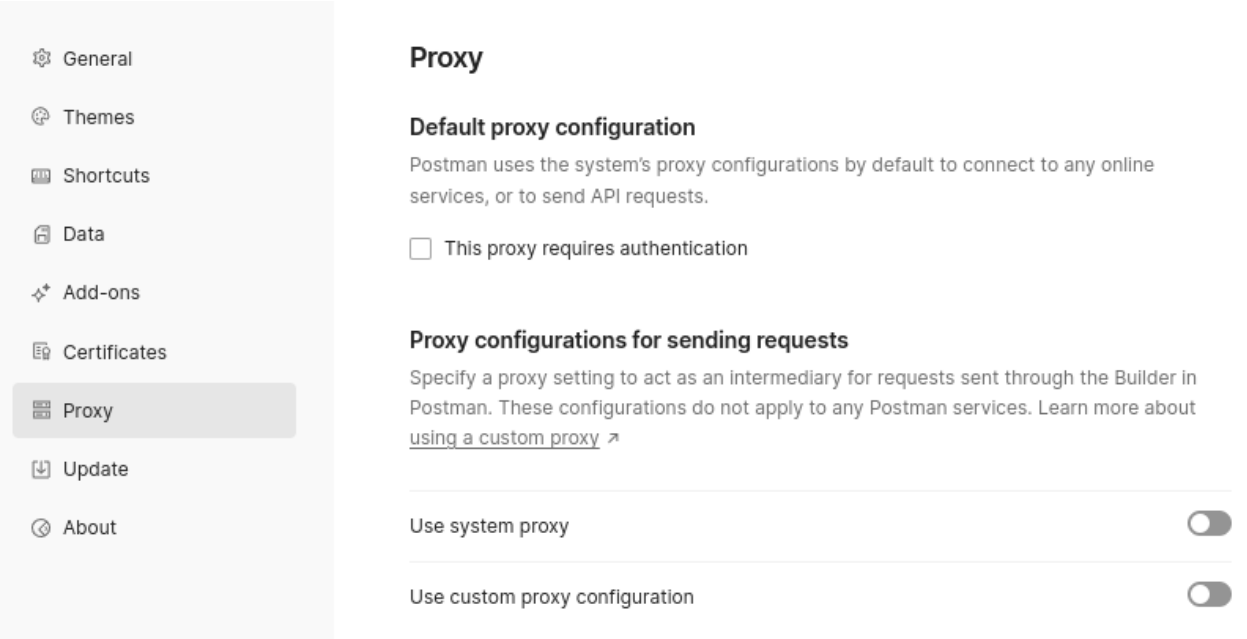


Figure1.12: Configurazione Proxy Postman (versioni più recenti)

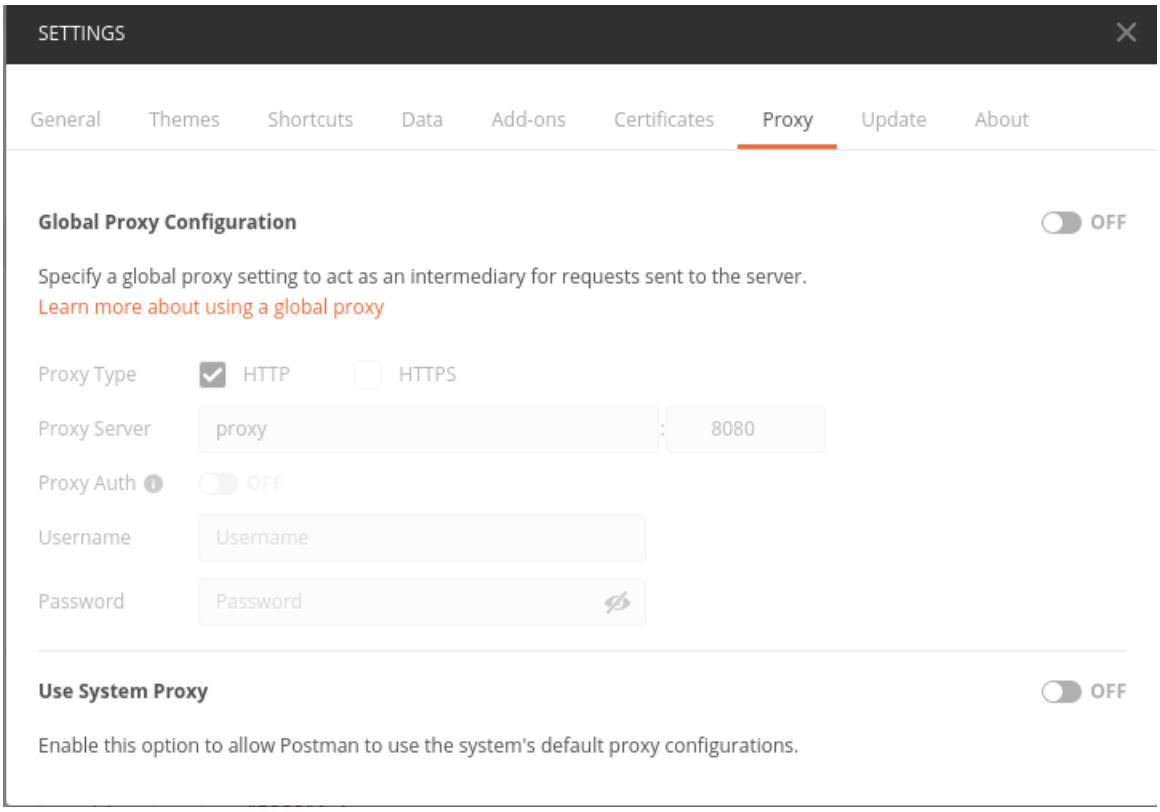


Figure1.13: Configurazione Proxy Postman

CHAPTER 2

Profilo “API Gateway”

Nelle sezioni successive verranno mostrati degli scenari di esempio di una API Rest erogata con profilo “API Gateway».

Nel primo scenario descritto la sua fruizione è a disposizione di qualsiasi client poiché non vi sono meccanismi di autenticazione/autorizzazione configurati.

Nel secondo scenario viene invece richiesto un token OAuth.

Nota

Per una consultazione mirata alle informazioni di interesse per lo scenario si consiglia di impostare nel menù in alto a destra il profilo “API Gateway” come mostrato nella figura Fig. 2.1.



Figure2.1: Selezione del profilo “API Gateway”

2.1 Erogazione pubblica

Obiettivo

Esporre tramite Govway un servizio con accesso pubblico (forma anonima).

Sintesi

In questo scenario è richiesta l’esposizione tramite gateway di un servizio da erogare, consentendo il libero accesso ai fruitori, che potranno invocare la relativa interfaccia senza presentare alcuna credenziale.

Per illustrare questo scenario, abbiamo scelto il servizio «PetStore», che sarà reso accessibile da Govway tramite l’interfaccia REST in versione OpenAPI 3.

La figura seguente descrive graficamente questo scenario.

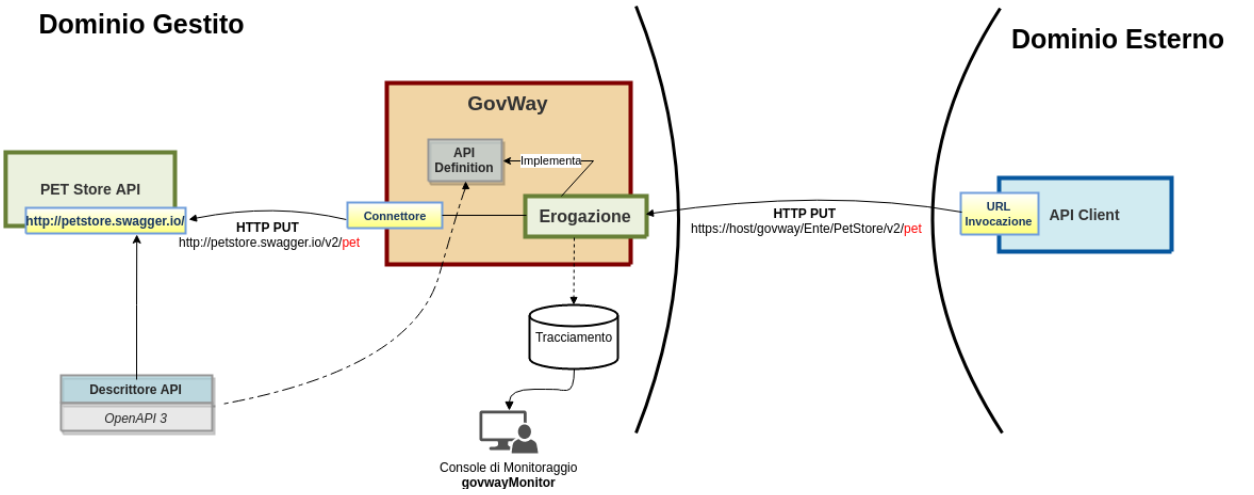


Figure2.2: Erogazione ad accesso pubblico

2.1.1 Esecuzione

I fruitori del servizio «PetStore» invocano le operazioni disponibili tramite i propri client senza utilizzare alcuna forma di autenticazione, utilizzando come "base-uri" la url di invocazione di GovWay

Avvalendosi del progetto Postman a corredo, eseguire *«IN public (findByStatus)»* per verificare l'esecuzione dell'erogazione del servizio PetStore con libero accesso.

2.1.2 Configurazione

In questa sezione vengono mostrate le parti di interesse relative alla configurazione con accesso pubblico.

Si assume che sia stata configurata una API "PetStore" con il descrittore OpenAPI 3 (scaricabile al seguente indirizzo).

Per registrare una erogazione dell'API "PetStore" pubblicamente accessibile si deve cliccare sul pulsante «Aggiungi» all'interno della sezione «Erogazione» (Fig. 2.5):

1. Selezionare l'API «PetStore v1» nel riquadro delle Informazioni Generali.
2. Selezionare l'accesso API «pubblico» nel riquadro Controllo dei Accessi.
3. Verificare che il campo «Endpoint», nel riquadro Connettore, sia stato correttamente inizializzato sulla base del valore di default presente nel descritto della API.

> **Nota**
>
> **Verifica del certificato server**
>
> Poichè il servizio PetStore è disponibile solamente in https, modificare il prefisso dell'endpoint fornito. Inoltre per validare il certificato ritornato dal server "petstore.swagger.io" deve essere effettuata una opportuna configurazione del trustStore tls come descritto nella sezione avanzate_connettori_https. Poichè non è obiettivo di questo scenario si suggerisce di disabilitare la validazione del certificato server se si rilevano problematiche di trust del certificato server.

4. Salvare la configurazione dell'erogazione.
5. Nel dettaglio della configurazione dell'erogazione è possibile vedere come non vi sia abilitato alcun controllo nella voce "Controllo Accessi".

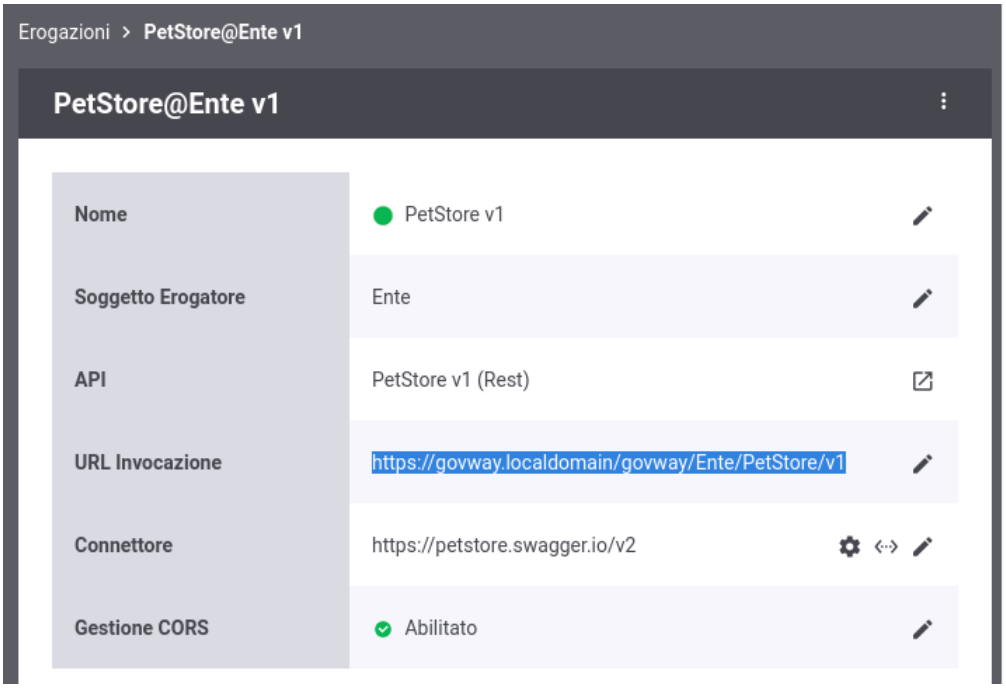


Figure2.3: Erogazione pubblica, url di invocazione

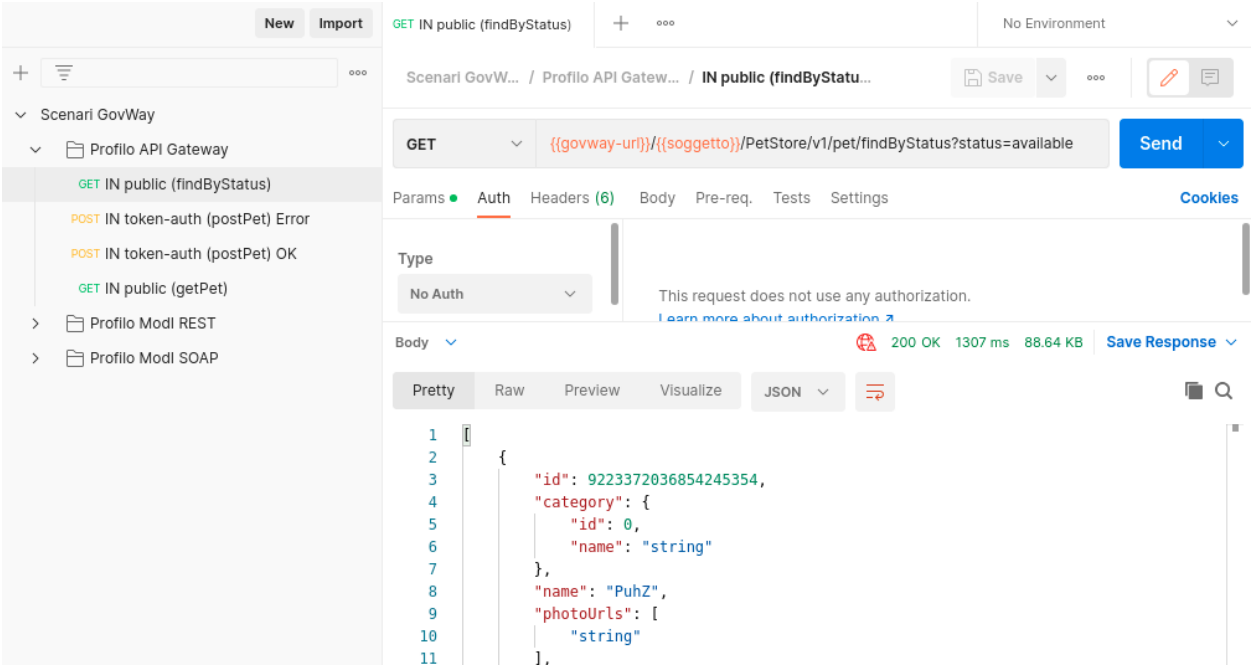


Figure2.4: Erogazione pubblica, esecuzione da Postman

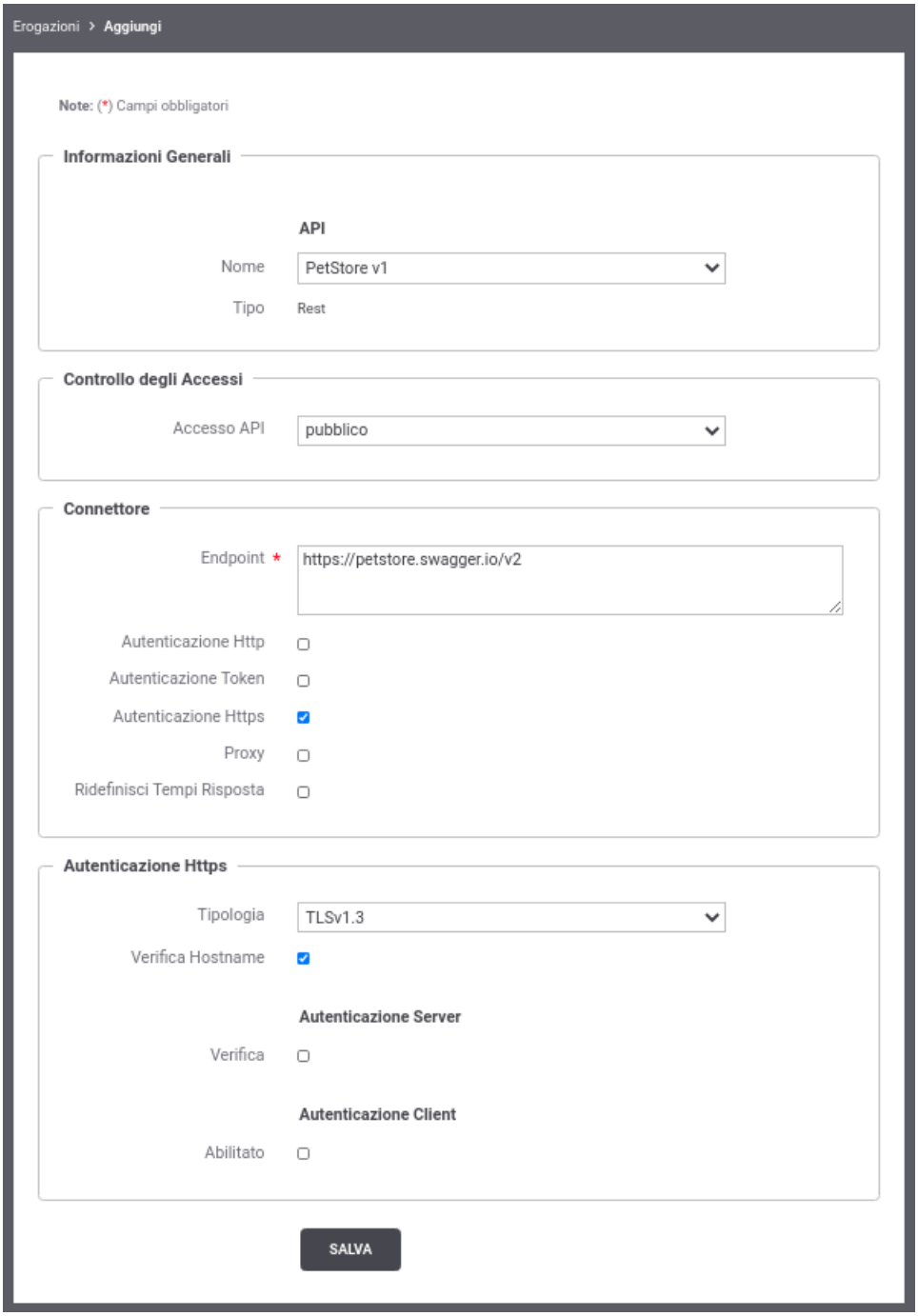


Figure2.5: Creazione di un'erogazione ad accesso pubblico

Nota

Esaminando l'erogazione preconfigurata si può notare come le risorse siano state suddivise in due gruppi in cui varia proprio il controllo degli accessi, e la risorsa invocata (GET /pet/findByStatus) rientra nel gruppo "Predefinito" dove il controllo degli accessi risulta disabilitato. L'altro gruppo verrà descritto nello scenario *Erogazione OAuth*.

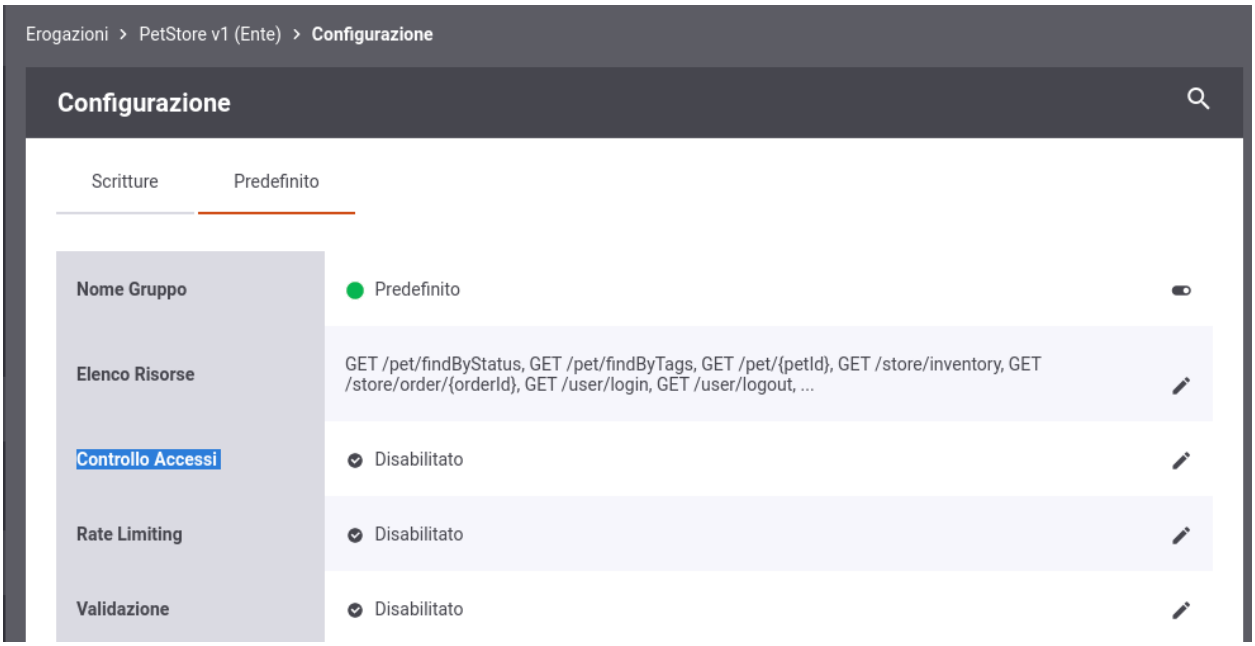


Figure2.6: Configurazione dell'erogazione

2.2 Erogazione OAuth

Obiettivo

Esporre un servizio accessibile tramite protocollo OAuth2 (Authorization Code).

Sintesi

Assumendo che sia stata effettuata la configurazione di un'erogazione ad accesso pubblico (vedi scenario *Erogazione pubblica*), verifichiamo in questo scenario come impostare il sistema di controllo degli accessi affinché il servizio richieda un token di sicurezza, come previsto dal protocollo OAuth2. In particolare la limitazione dell'accesso sarà configurata solo per le operazioni di scrittura, lasciando libero accesso per le letture.

La figura seguente descrive graficamente questo scenario.

I passi previsti sono i seguenti:

1. Il client entra in possesso del token, previa autenticazione e consenso dell'utente richiedente.
2. Il client utilizza il token per l'invio della richiesta.
3. Govway valida il token ricevuto e verifica i criteri di controllo degli accessi.
4. Se la validazione è superata, Govway inoltra la richiesta al servizio erogatore.

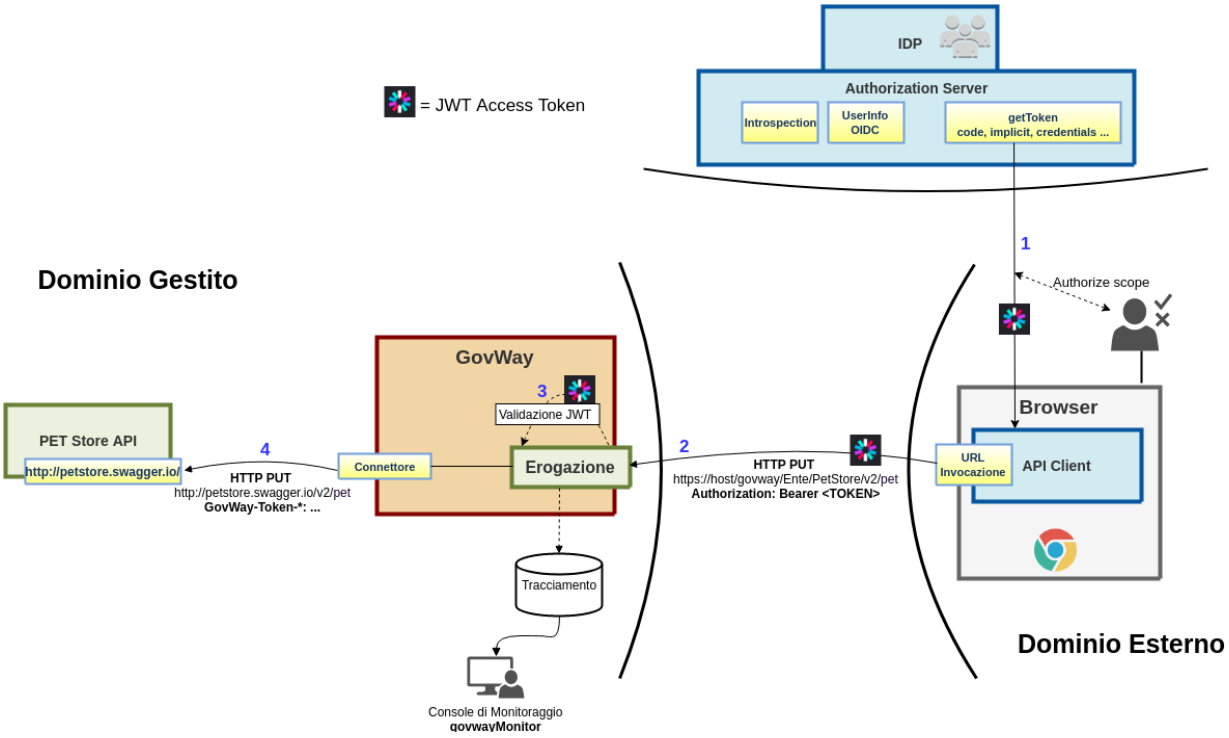


Figure2.7: Erogazione OAuth

2.2.1 Esecuzione

Facendo riferimento al progetto Postman è possibile verificare direttamente l'esecuzione dei passi di questo scenario. Passi da eseguire:

1. All'inizio possiamo verificare come il client non riesca ad accedere al servizio senza l'utilizzo del token. La request «IN token-auth (postPet) Error» effettua una chiamata alla risorsa «POST /pet» in assenza del token richiesto. Govway respinge la richiesta con la restituzione dell'errore mostrato in Fig. 2.8.
2. Successivamente si passa alla chiamata della «POST /pet» seguendo il flusso OAuth2 richiesto per l'approvvigionamento del token di autorizzazione. Posizionarsi sulla request «IN token-auth (postPet) OK»:
   - Nella sezione «Authorization» selezionare il Type «OAuth 2.0» e premere il pulsante «Get New Access Token»
   - La maschera fornita deve essere compilata con i parametri necessari ad richiedere un token all'authorization server (sono forniti esempi a seconda della versione utilizzata di Postman in Fig. 2.9 e Fig. 2.10). Utilizzare i seguenti parametri che permettono di richiedere un token all'authorization server preconfigurato per lo scenario:

     ```
     Callback URL: {{keycloak-callback-url}}
     Auth URL: {{keycloak-url-auth}}
     Access Token URL: {{keycloak-url-token}}
     Client ID: {{keycloak-client-id}}
     Client Secret: {{keycloak-client-secret}}
     ```

   - Compilati correttamente i campi per ottenere un token cliccare sul pulsante «Request Token»
   - Completare il processo di autenticazione dell'utente seguendo il flusso proposto ed utilizzando le

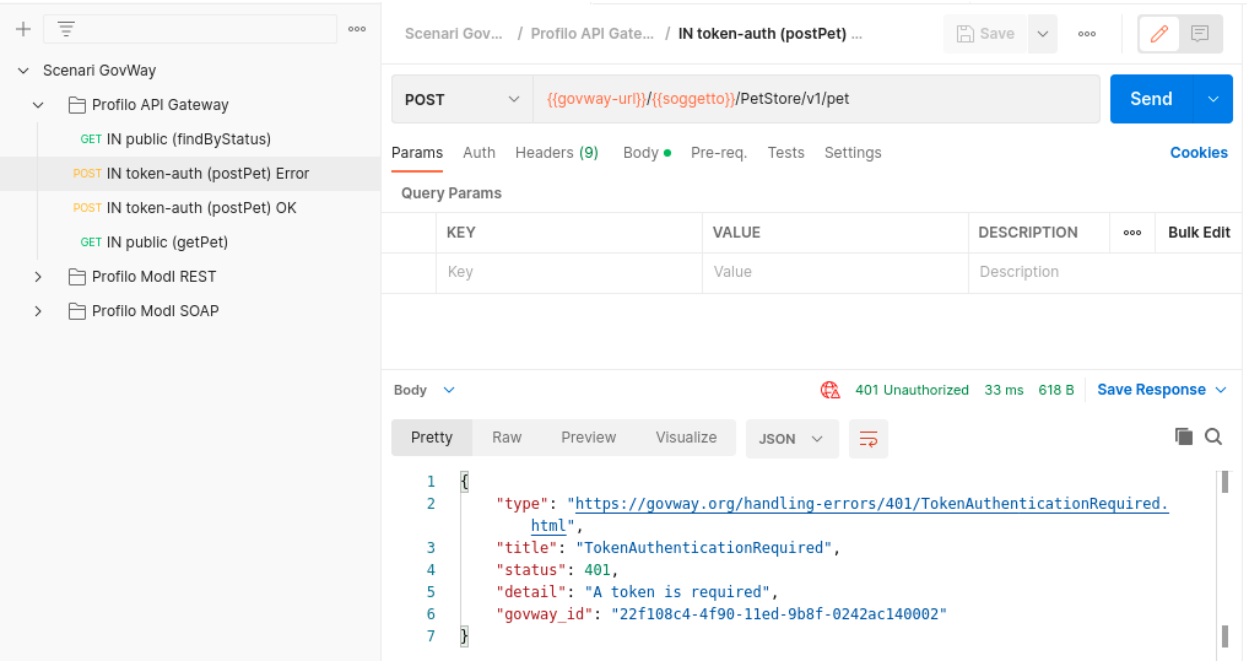


Figure2.8: Invocazione della POST /pet senza token

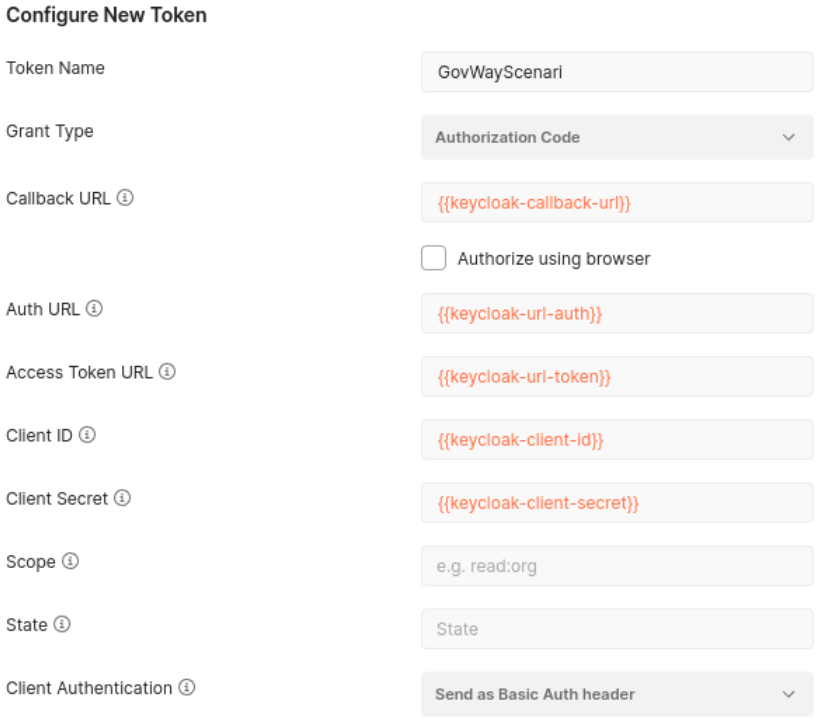


Figure2.9: Ottenimento nuovo token (versioni di Postman più recenti)

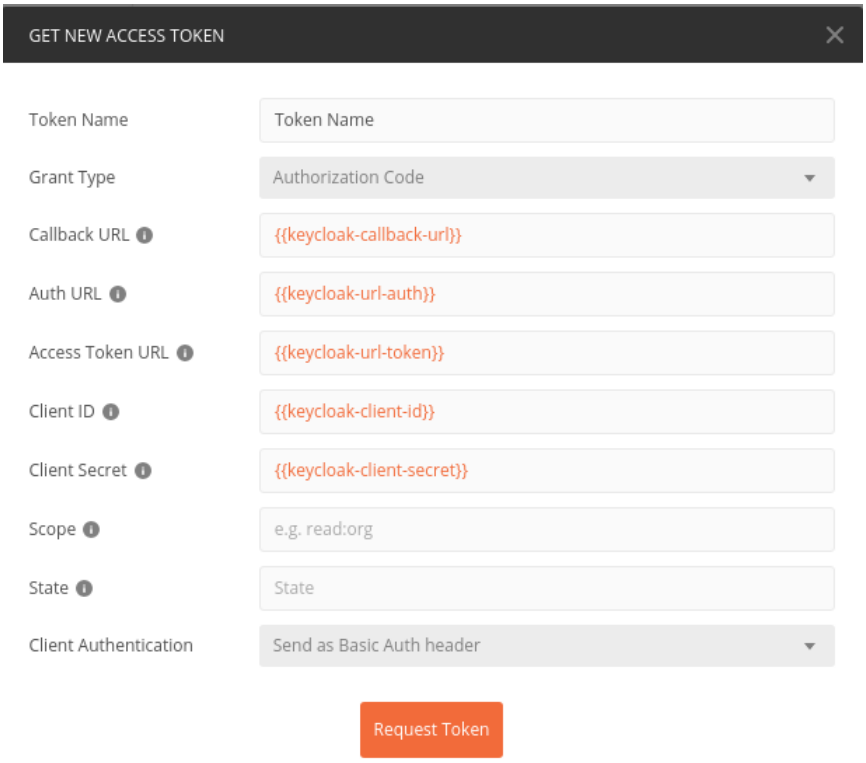


Figure2.10: Ottenimento nuovo token

credenziali dell'utente preconfigurato sull'authorization server per lo scenario di test:

```
username: paolorossi
password: 123456
```

- Superata l'autenticazione, viene restituito l'access token (mostrato a video sulla finestra popup).
- Inserire il token nella richiesta premendo il pulsante «Use Token».
- Eseguire la richiesta tramite il pulsante «Send».
- L'operazione viene eseguita con successo e restituito l'esito (Fig. 2.11).

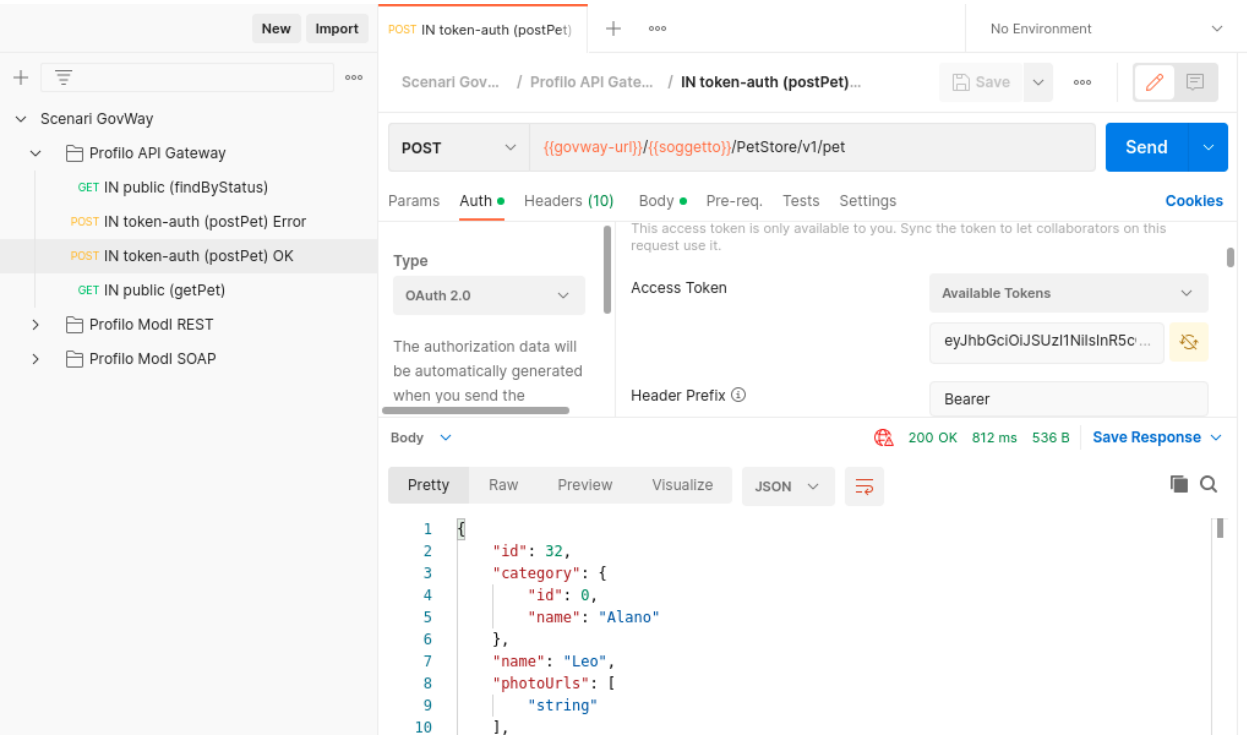


Figure2.11: Invocazione della risorsa "POST /pet" con token

3. Possiamo verificare che le limitazioni sull'accesso non sono efficaci nel caso di invocazione di operazioni di lettura. Il passo «IN public (getPet)» esegue una GET. Si noti come la sezione Authorization abbia l'impostazione del Type su «No Auth». Questa request legge il dato creato con la POST precedente e, come è possibile riscontrare al termine dell'esecuzione, viene correttamente eseguita in assenza di credenziali (Fig. 2.12).

2.2.2 Configurazione

L'erogazione è già stata preconfigurata per prevedere un controllo degli accessi differente tra le risorse che riguardano operazioni di scrittura (POST, PUT, DELETE) e le risorse che riguardano solo letture (GET).

Di seguito vengono descritti i passi che sono stati effettuati per arrivare alla configurazione esistente partendo dall'erogazione configurata con accesso pubblico.

I passi di configurazione finalizzati a limitare l'accesso alle sole operazioni di scrittura sono i seguenti:

1. Dal dettaglio dell'erogazione, si procede con la creazione di una nuova configurazione, cui diamo il nome *«Scritture»* (Fig. 2.13).

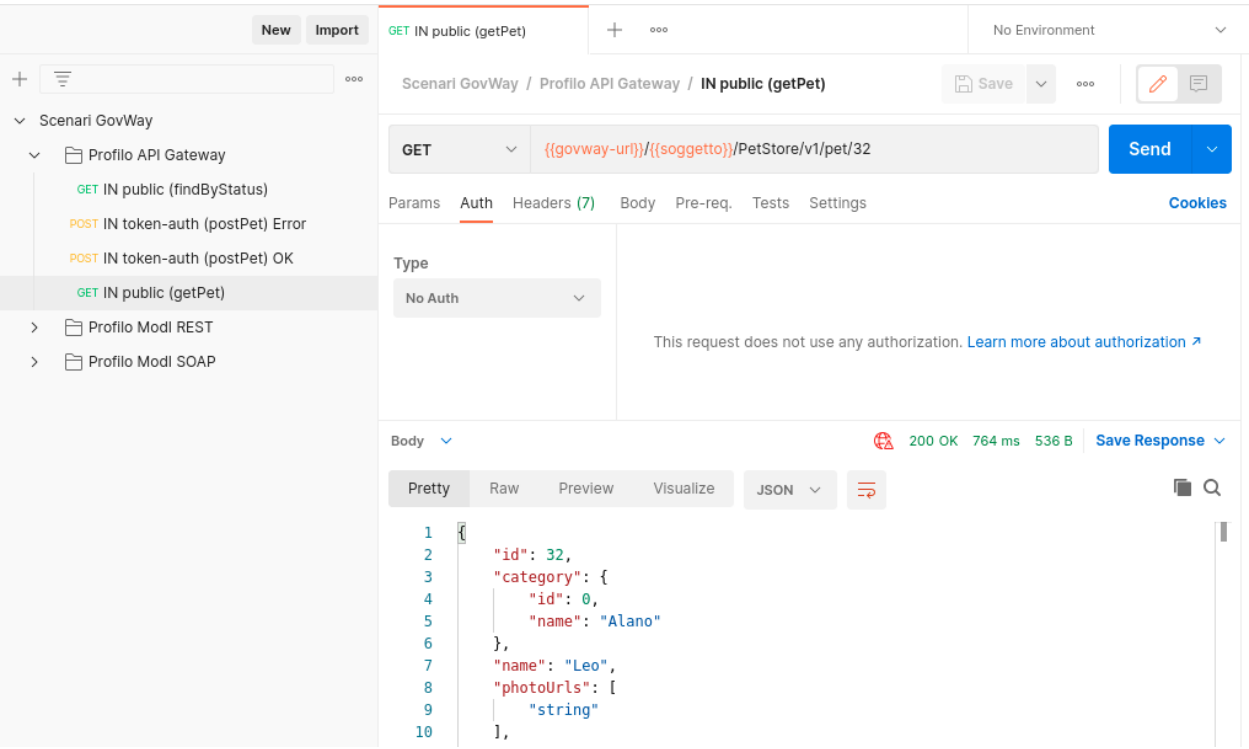


Figure2.12: Invocazione della risorsa “GET /pet/id” con token

- Selezionare dall’elenco delle risorse quelle che riguardano operazioni di scrittura (POST, PUT, DELETE)
- Indicare per la *Modalità* il valore *«Nuova»* e quindi selezionare *«autenticato»* nel campo *Accesso API*

2. Nella nuova configurazione «Scritture» si va ad aggiornare la sezione *«Controllo Accessi»* effettuando le seguenti azioni (Fig. 2.14):
   - Abilitare l’autenticazione token selezionando la policy *«KeyCloak»* (configurazione preesistente per l’integrazione all’authorization server), lasciando invariate le altre opzioni del medesimo riquadro.
   - Disabilitare le altre funzionalità di controllo degli accessi: Autenticazione Trasporto, Autorizzazione e Autorizzazione Contenuti.
3. Dopo aver salvato la nuova configurazione, verificare il riepilogo delle informazioni, che devono corrispondere a quanto riportato in Fig. 2.15.

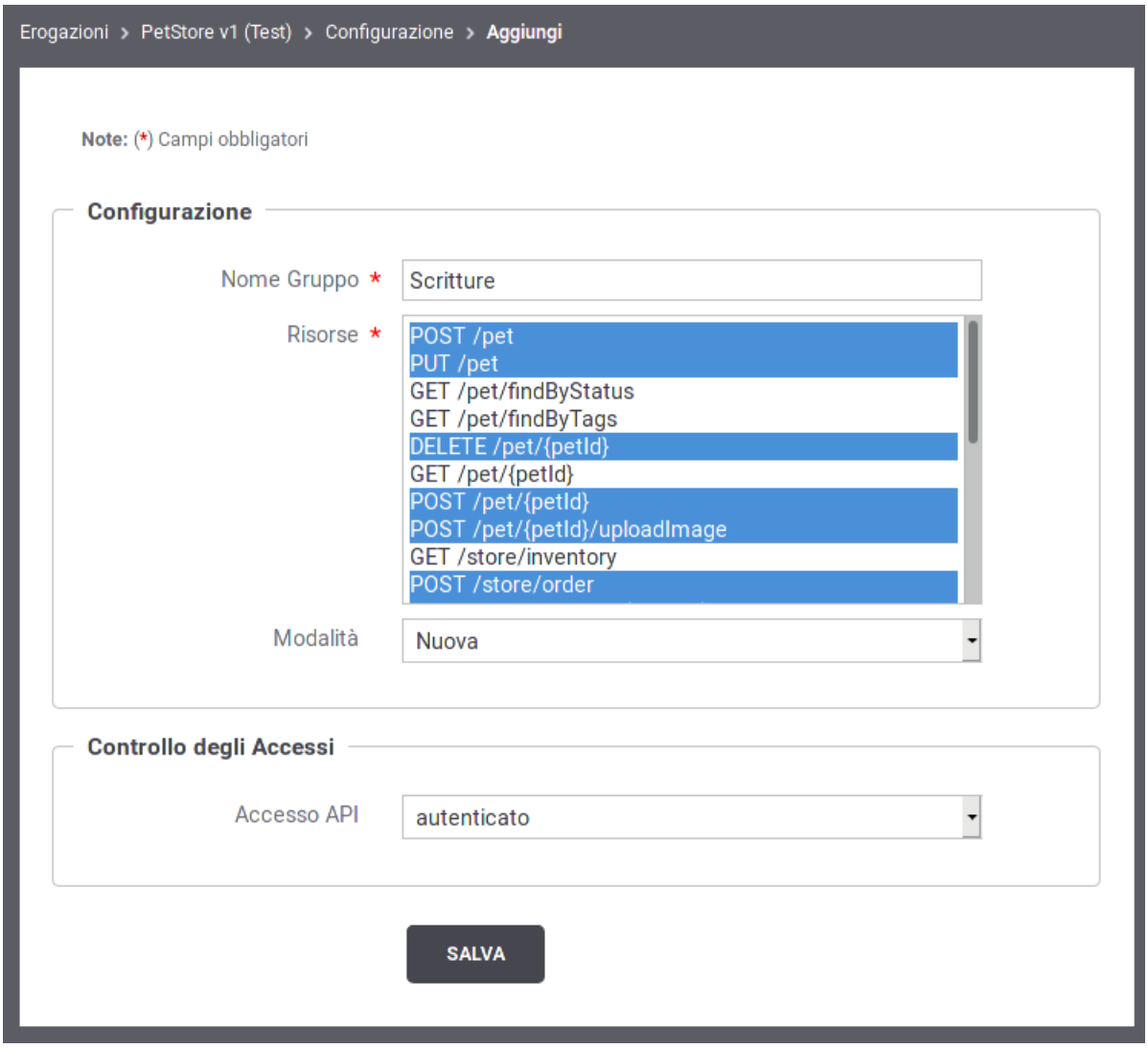


Figure2.13: Creazione di una configurazione specifica per le operazioni di scrittura

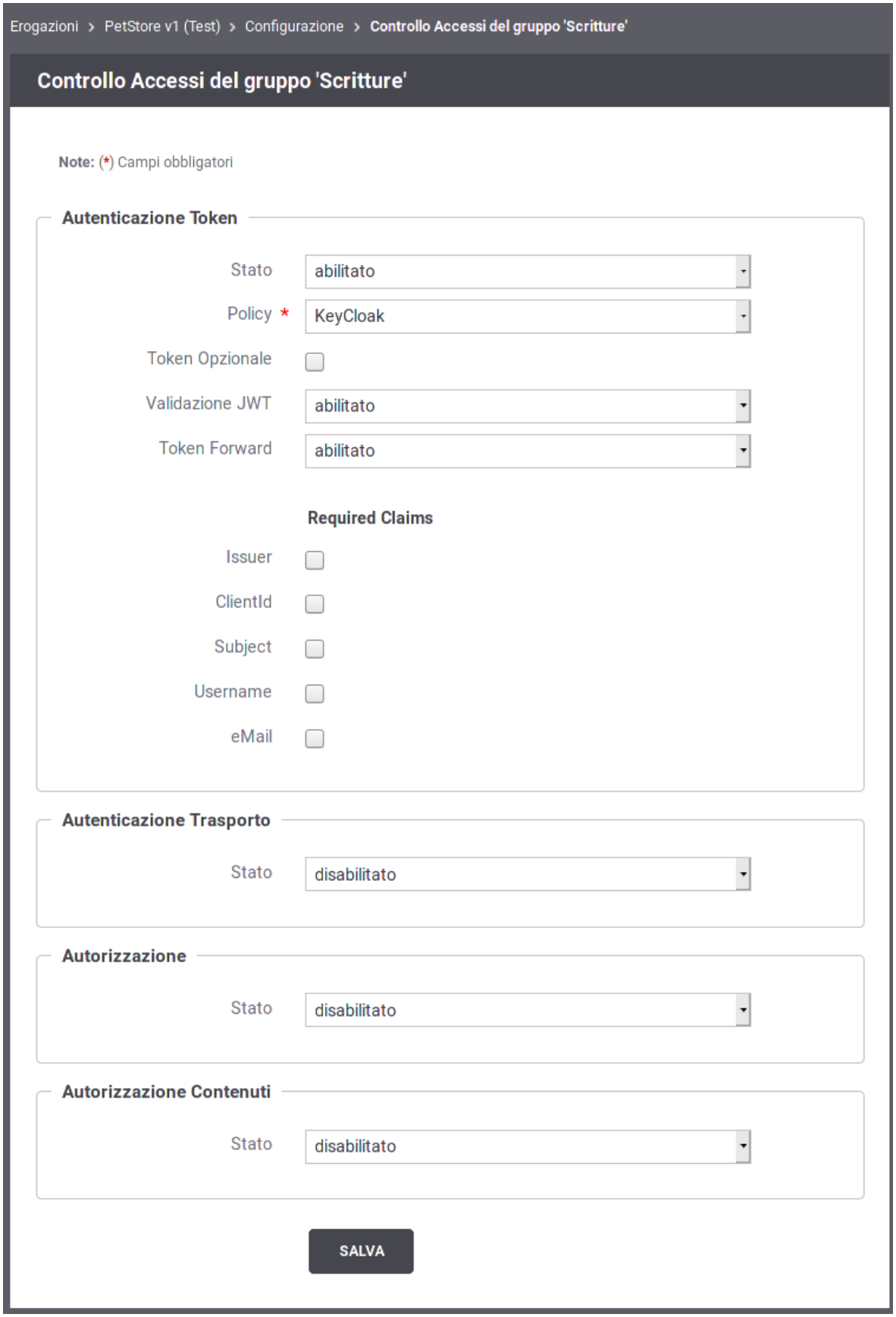


Figure2.14: Impostazione dell'autenticazione token nel controllo degli accessi

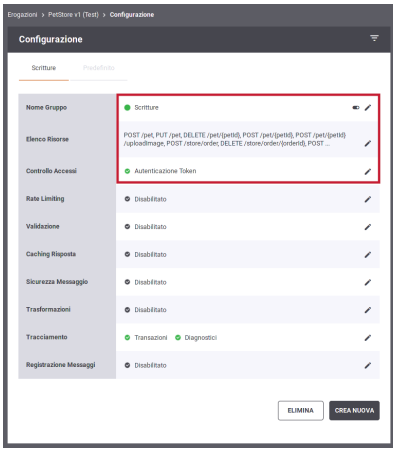


Figure2.15: Riepilogo della configurazione effettuata

CHAPTER 3

Profilo “ModI”

Nelle sezioni successive verranno mostrati degli scenari di esempio di API Rest e API SOAP erogate o fruite con profilo “ModI» in accordo alla normativa prevista dal Modello di Interoperabilità.

I scenari descritti si differenziano rispetto ai pattern di sicurezza associati alle API erogate o fruite:

- nella sezione *Pattern “ID_AUTH”* le API sono configurate tramite il pattern modipa_idar01;
- nella sezione *Pattern “INTEGRITY_01”* viene utilizzato il pattern modipa_idar03;
- nella sezione *Pattern “ID_AUTH” via PDND* le API sono configurate tramite il pattern modipa_pdnd;
- nella sezione *Pattern “ID_AUTH” via PDND + “INTEGRITY_01”* viene utilizzato il pattern modipa_pdnd_integrity;
- nella sezione *Pattern “ID_AUTH” via PDND + “INTEGRITY_REST_02”* viene utilizzato il pattern modipa_idar04;
- nella sezione *Pattern “AUDIT_REST_01”* viene descritto come aggiungere un token di audit conforme al pattern modipa_infoUtente_audit01;
- nella sezione *Pattern “AUDIT_REST_02”* il token di audit è invece conforme al pattern modipa_infoUtente_audit02.

Nota

Per una consultazione mirata alle informazioni di interesse per lo scenario si consiglia di impostare nel menù in alto a destra il profilo “ModI” e la selezione del soggetto “Ente” come mostrato nella figura Fig. 2.1.



Figure3.1: Selezione del profilo “ModI”

3.1 Pattern “ID_AUTH”

Gli scenari riportati in questa sezione riguardano API configurate con pattern modipa_idar01.

3.1.1 Erogazione API REST

Obiettivo

Esporre un servizio, definito tramite una API REST (OpenAPI 3.0), accessibile in accordo al pattern di sicurezza “ID_AUTH_REST_01” descritto nella sezione modipa_idar01.

Sintesi

Mostriamo in questa sezione come procedere per l’esposizione di un servizio REST da erogare nel rispetto della normativa italiana alla base dell’interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario, tra quelli prospettati nel Modello di Interoperabilità di AGID, che prevede il trust del certificato X.509 in modo da assicurare sia a livello di canale che a livello di messaggio l’autenticazione e autorizzazione del fruitore.

La figura seguente descrive graficamente questo scenario.

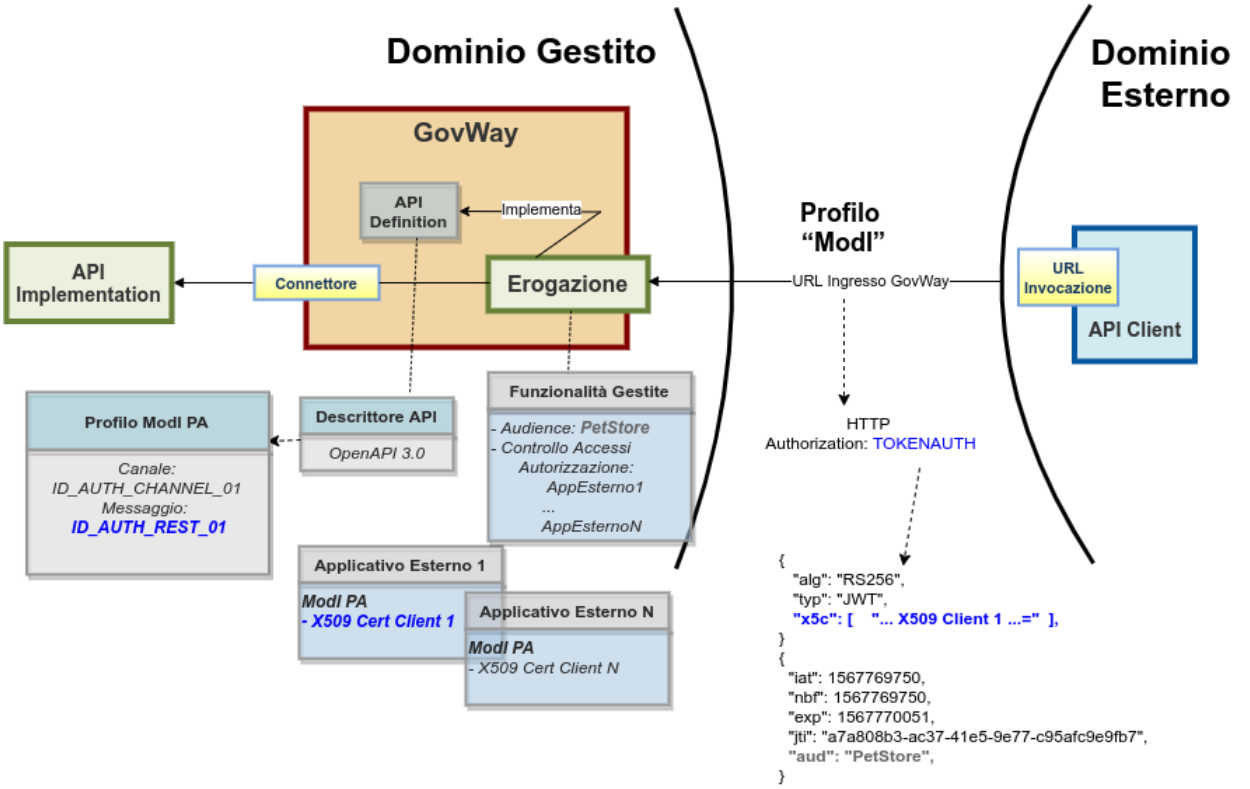


Figure3.2: Erogazione di una API REST con profilo “ModI”, pattern ID_AUTH_REST_01

Le caratteristiche principali di questo scenario sono:

1. un applicativo eroga un servizio, rivolto a fruitori di domini esterni, in conformità al Modello di Interoperabilità AGID;
2. la comunicazione con i domini esterni avviene su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_02»;

3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01».

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.3: Profilo ModI della govwayMonitor

L'esecuzione dello scenario si basa sui seguenti elementi:

- una API REST di esempio (PetStore) definita con pattern di interazione "CRUD" e pattern di sicurezza «ID_AUTH_CHANNEL_02» e «ID_AUTH_REST_01»;
- un'istanza Govway per la gestione del profilo ModI nel dominio dell'erogatore;
- un client del dominio esterno che invoca la risorsa «POST /pet» dell'erogazione esposta da Govway;
- il server PetStore di esempio che riceve le richieste inoltrate dal Govway e produce le relative risposte. Per questo scenario viene utilizzato il server disponibile on line all'indirizzo "https://petstore.swagger.io/".

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - IDAuth - IN App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

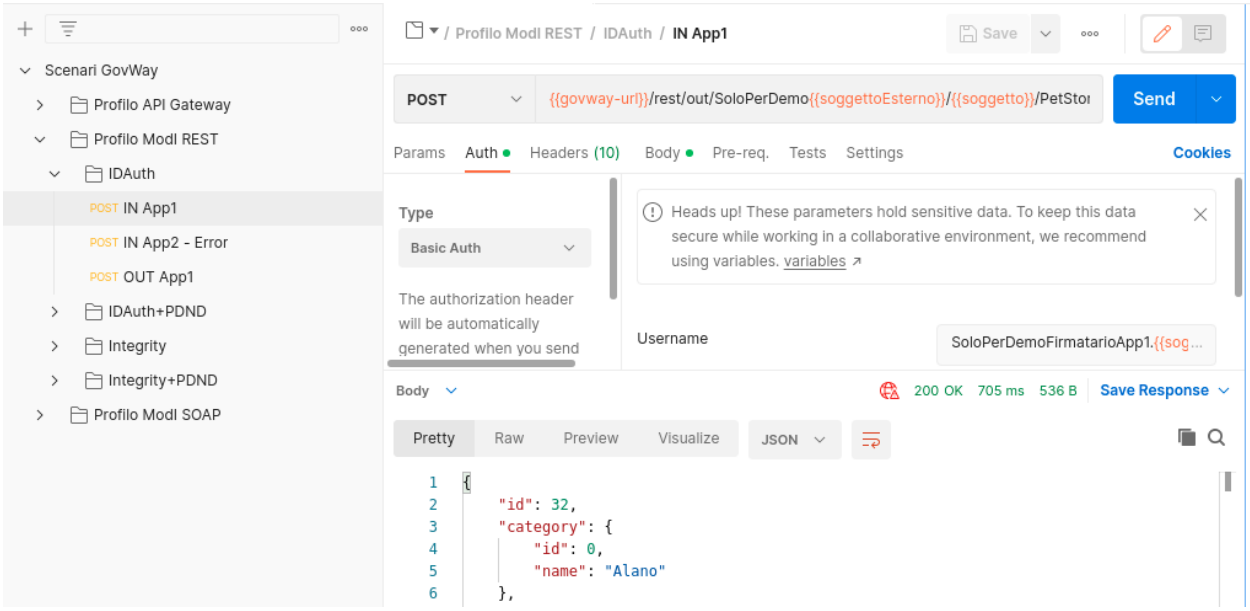


Figure3.4: Pattern IDAuth - Erogazione API REST, esecuzione da Postman

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console "govwayMonitor".

1. Lo scambio del messaggio con il dominio fruitore (comunicazione interdominio) avviene in accordo al pattern «ID_AUTH_CHANNEL_02» e quindi con protocollo SSL e autenticazione client. Dal dettaglio della transazione si possono consultare i messaggi diagnostici dove è visibile la fase di autenticazione del client con i dati di validazione del certificato ricevuto (Fig. 3.5).

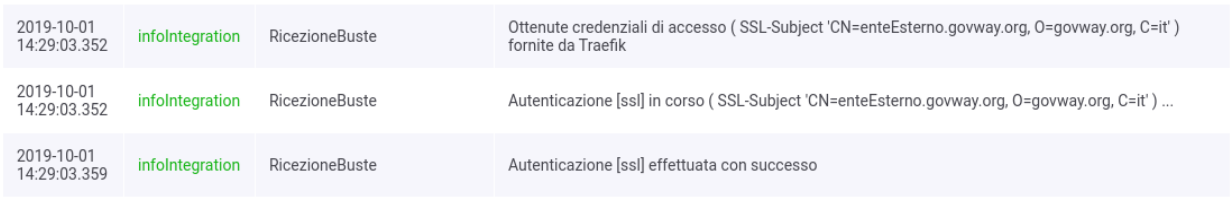


Figure3.5: Sicurezza canale «ID_AUTH_CHANNEL_02»

2. Dal dettaglio della richiesta si può visualizzare il messaggio che è stato inviato dal fruitore, come in Fig. 3.6. Come si nota, al payload JSON è associato un insieme di header HTTP tra i quali «Authorization», che contiene il token di sicurezza.

3. Grazie alle configurazioni presenti nell'erogazione, ed in particolare alla relazione di trust stabilita con il fruitore, Govway è in grado di validare i dati di sicurezza ricevuti andando a decodificare il token. Nella fase di validazione del token si può notare come la sezione header (Fig. 3.7) riporti l'identità del fruitore e il suo certificato X.509, mentre la sezione payload (Fig. 3.8) contenga i riferimenti temporali (iat, nbf, exp) e l'audience (aud).

4. Il messaggio ricevuto dal Govway viene quindi validato, sulla base dei pattern di sicurezza previsti nello scambio, verificando in questo caso l'identità del fruitore, la validità temporale, la corrispondenza dell'audience ricevuto con quello atteso. Solo in caso di superamento dell'intero processo di validazione, il messaggio viene inoltrato al servizio erogatore. Le evidenze del processo di validazione sono visibili sulla govwayMonitor, andando a consultare la traccia del messaggio di richiesta (Fig. 3.9). Nella sezione «Sicurezza Messaggio» sono riportate le informazioni estratte dal token di sicurezza presente nel messaggio.

5. Dopo l'inoltro al servizio erogatore, Govway riceve la risposta e la elabora producendo il relativo token di sicurezza utilizzando le impostazioni di firma fornite nell'ambito dell'erogazione relativamente all'elaborazione della risposta. Sulla console govwayMonitor è possibile visualizzare il messaggio di risposta in uscita, dove si rileva la presenza del token prodotto nell'header HTTP «Authorization» (analogamente a Fig. 3.6).

6. Lo scenario è preconfigurato per autorizzare puntualmente l'applicativo "App1-ModI" identificato grazie al certificato X.509 presente all'interno del token. È possibile utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - IDAuth - IN App2 - Error» per verificare che una richiesta proveniente da un differente applicativo non viene autorizzata.

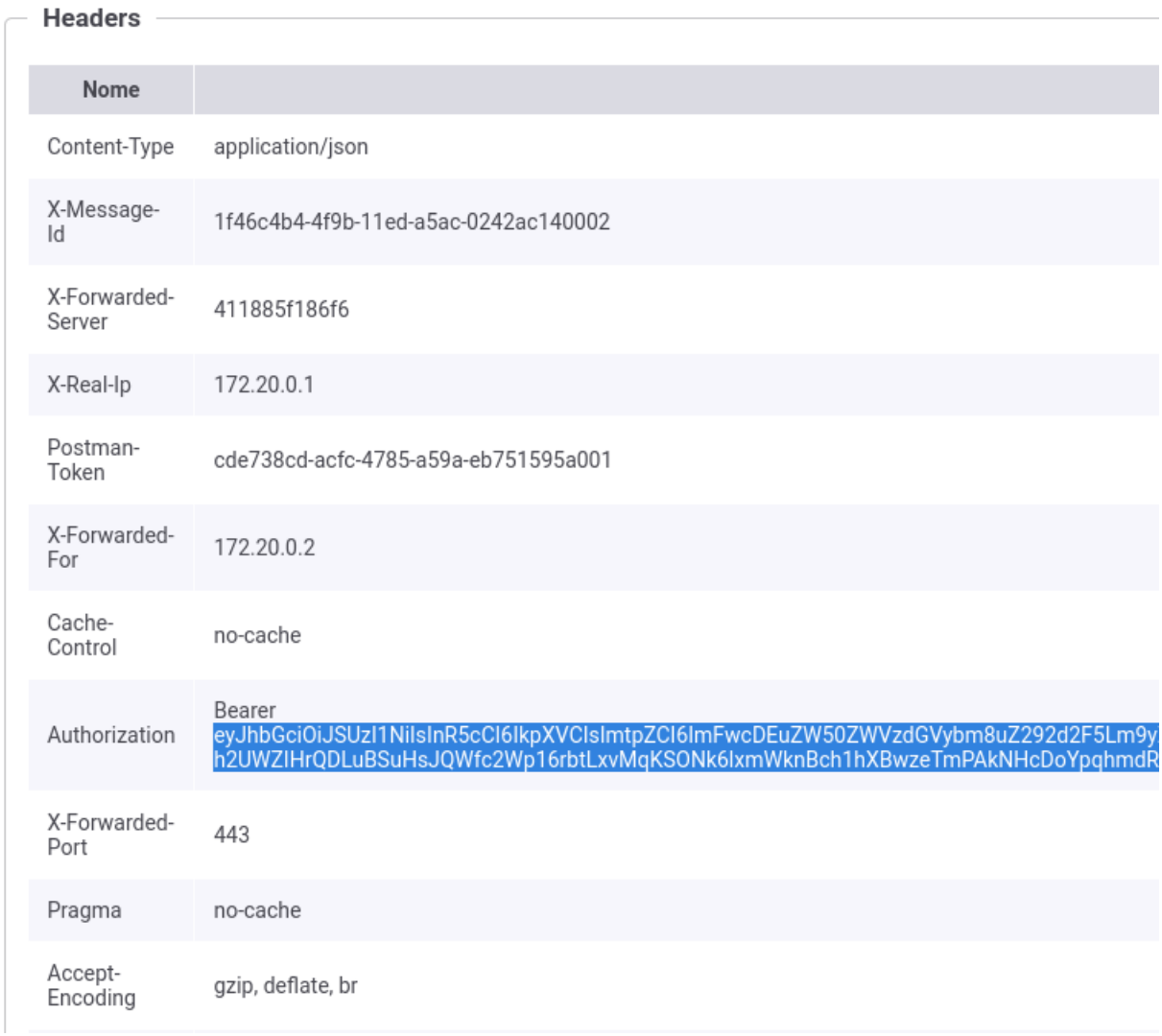
Conformità ai requisiti ModI

I requisiti iniziali, legati alla comunicazione basata su uno scenario ModI, sono verificati dalle seguenti evidenze:

1. la trasmissione è basata sul pattern «ID_AUTH_CHANNEL_02», riguardo la sicurezza canale, come evidenziato nei messaggi diagnostici dalla presenza degli elementi dell'handshake SSL e relativi dati dei certificati scambiati (Fig. 3.5);

2. la sicurezza messaggio applicata è quella dei pattern «ID_AUTH_REST_01» come ampiamente mostrato nelle tracce dei messaggi di richiesta e risposta, dove sono presenti i certificati degli applicativi e le firme dei payload (e le relative validazioni);

3. l'identificazione del fruitore avviene rispetto al certificato X.509 presente all'interno del token. È stato anche mostrato come sia possibile configurare criteri autorizzativi puntuali.



Headers

Nome	
Content-Type	application/json
X-Message-Id	1f46c4b4-4f9b-11ed-a5ac-0242ac140002
X-Forwarded-Server	411885f186f6
X-Real-Ip	172.20.0.1
Postman-Token	cde738cd-acfc-4785-a59a-eb751595a001
X-Forwarded-For	172.20.0.2
Cache-Control	no-cache
Authorization	Bearer eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6ImFwcDEuZW50ZWVzdGVybm8uZ292d2F5Lm9y h2UWZIHrQDLuBSuHsJQWfc2Wp16rbtLxvMqKSONk6lxmWknBch1hXBwzeTmPAkNHcDoYpqhmdR
X-Forwarded-Port	443
Pragma	no-cache
Accept-Encoding	gzip, deflate, br

Figure3.6: Messaggio inviato dal fruitore

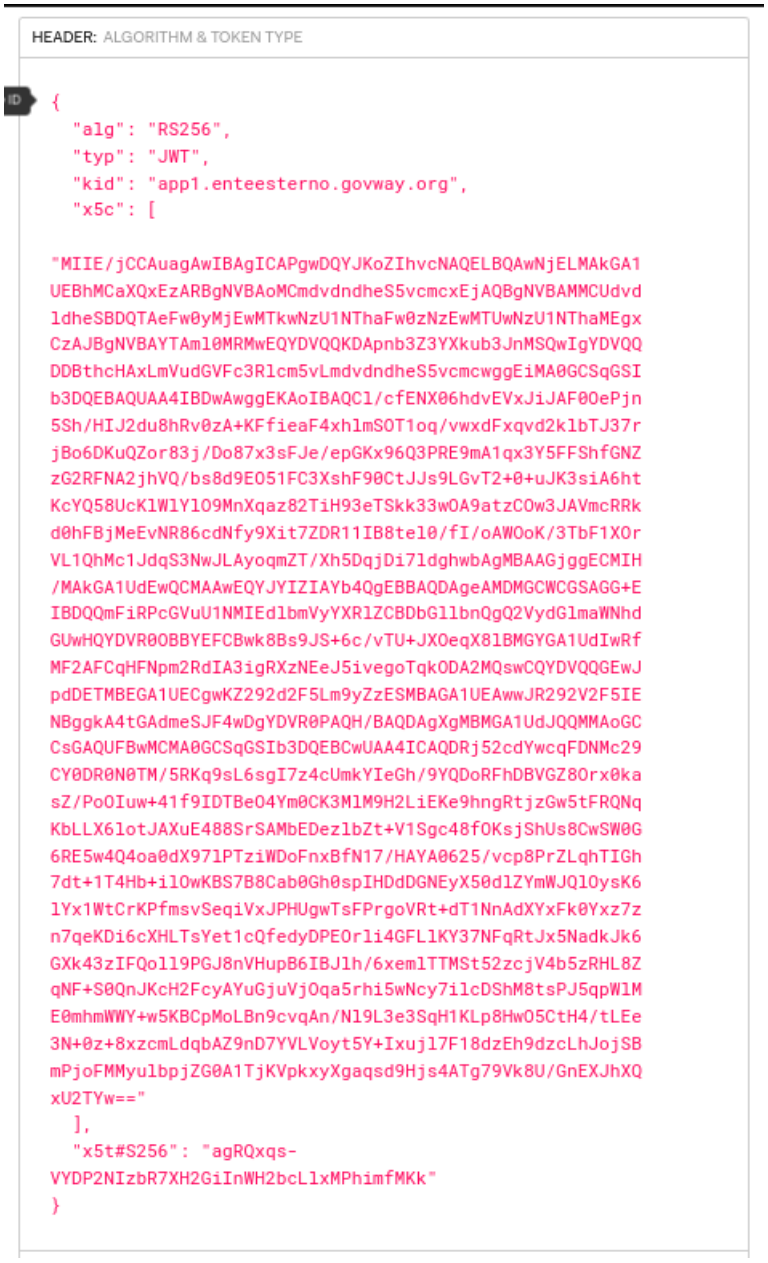


Figure3.7: Sezione «Header» del Token di sicurezza



Figure3.8: Sezione «Payload» del Token di sicurezza

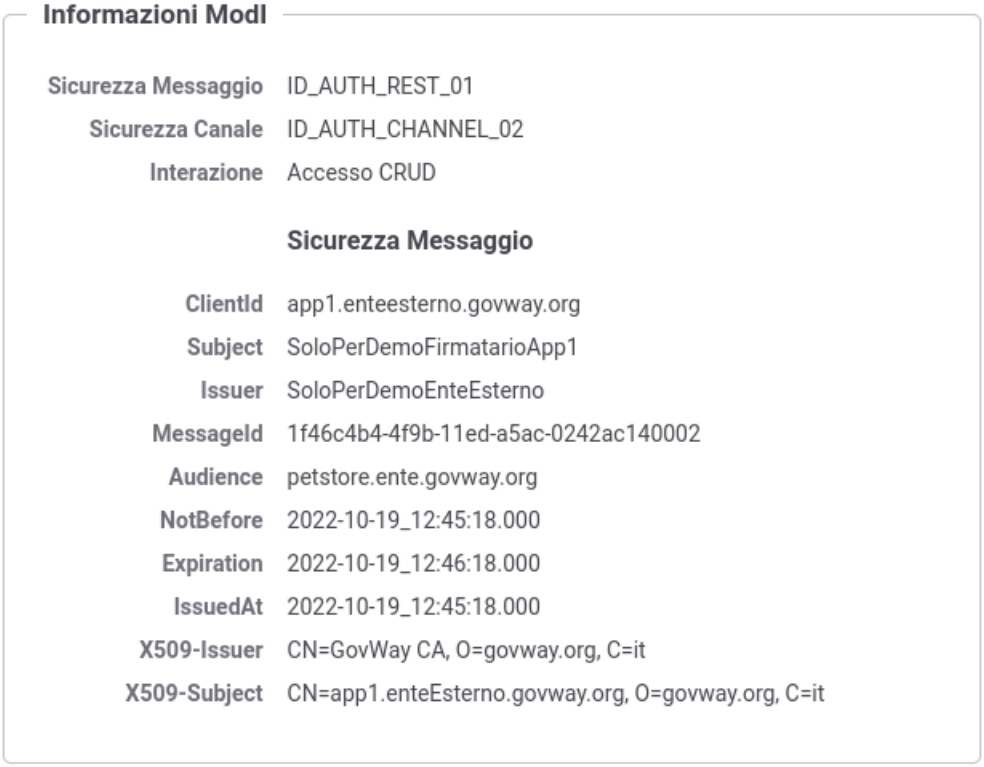


Figure3.9: Traccia della richiesta elaborata dall'erogatore

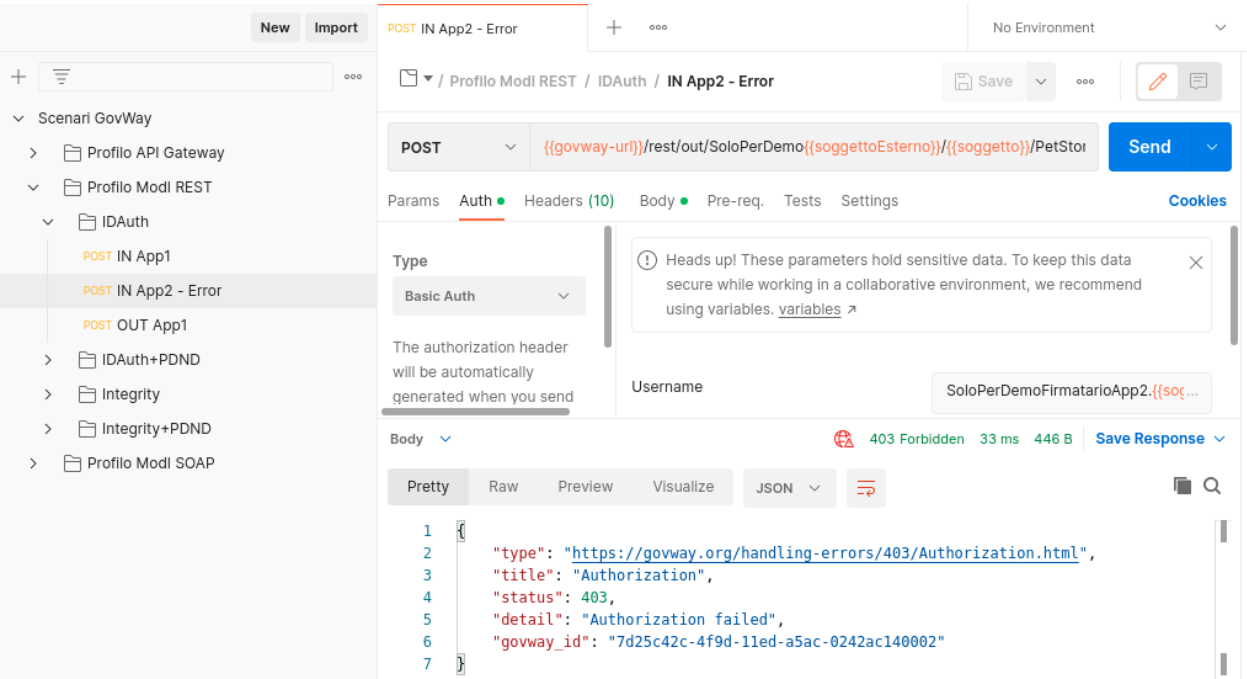


Figure3.10: Pattern IDAuth - Erogazione API REST - Autorizzazione negata, esecuzione da Postman

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.11: Profilo ModI della govwayConsole

Registrazione API

Viene registrata l'API «PetStoreAuth» con il relativo descrittore OpenAPI 3. Vengono selezionati i pattern «ID_AUTH_CHANNEL_02» (sicurezza canale) e «ID_AUTH_REST_01» (sicurezza messaggio) nella sezione «ModI» (Fig. 3.12).

Applicativo Esterno

È opzionalmente possibile registrare l'applicativo esterno che corrisponde al fruitore del servizio. Questa scelta può essere fatta in base al tipo di autorizzazione che si è impostata sui fruitori. Vediamo i seguenti casi:

- Se il truststore utilizzato da Govway per l'autenticazione dei fruitori (sicurezza messaggio) contiene i singoli certificati degli applicativi autorizzati, questo passo può anche essere omesso. La gestione del truststore è sufficiente a stabilire i singoli fruitori autorizzati.

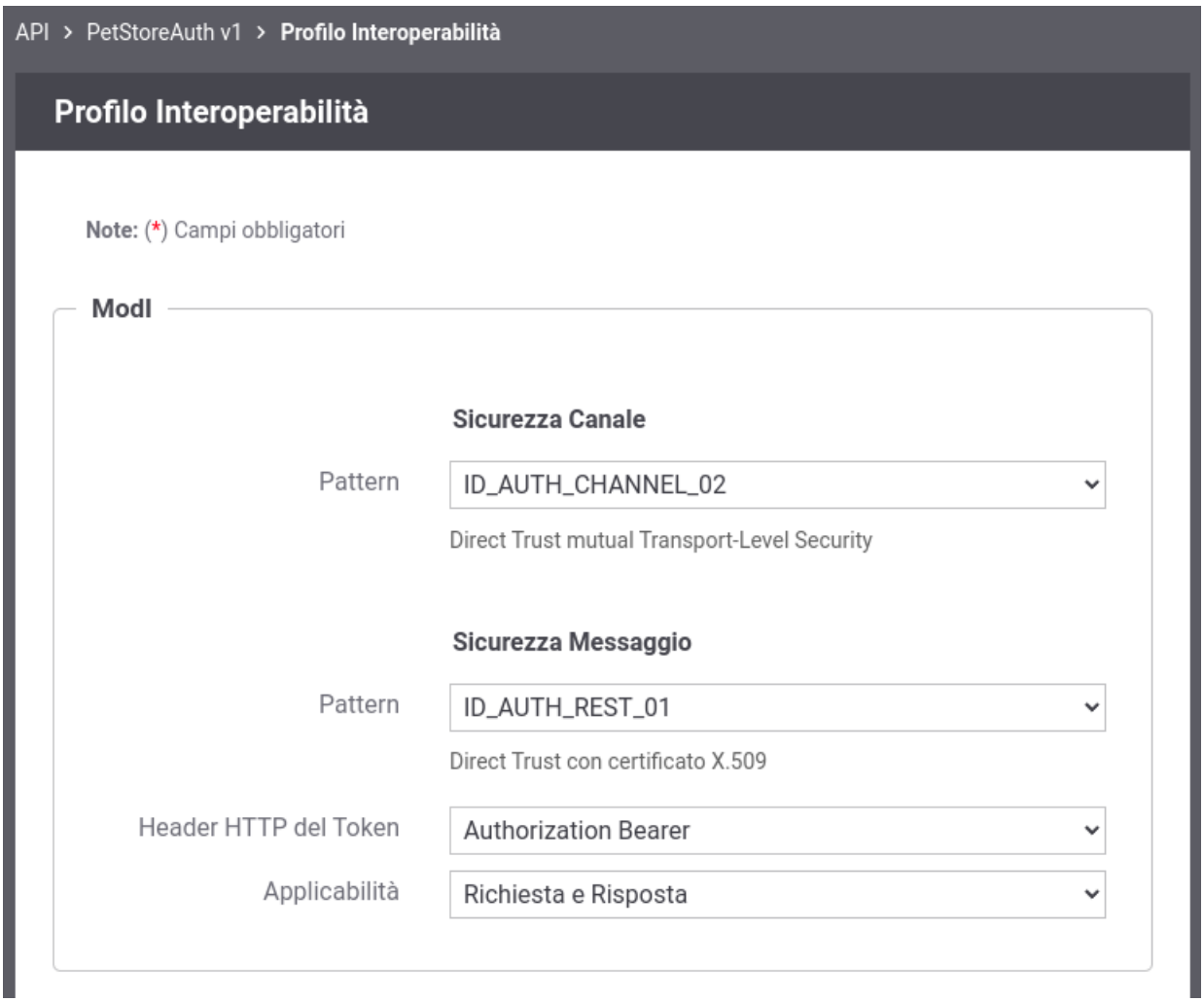


Figure3.12: Configurazione Pattern ModI «ID_AUTH_REST_01» sulla API REST

- Se il truststore contiene la CA emittente dei certificati utilizzati dai fruitori, l'autorizzazione puntuale non è possibile a meno di non procedere con la registrazione puntuale degli applicativi fornendo i singoli certificati necessari per l'identificazione (Fig. 3.13). Questo scenario è quello preconfigurato.

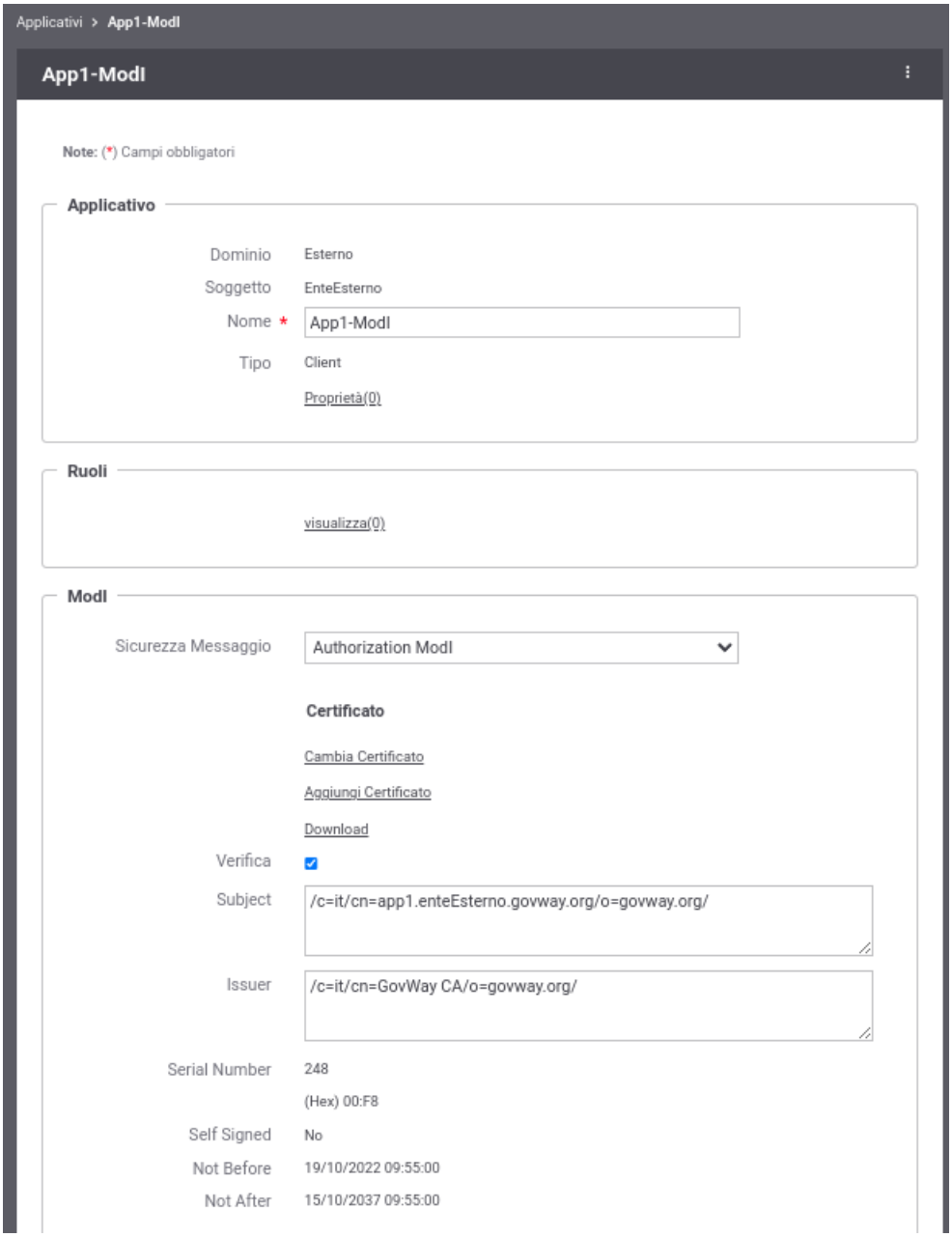


Figure3.13: Configurazione applicativo esterno (fruitore)

Erogazione

Si registra l'erogazione «PetStoreAuth», relativa all'API precedentemente inserita, indicando i dati specifici nella sezione «ModI Richiesta» (Fig. 3.14). In questo contesto vengono inseriti i dati necessari per validare le richieste in ingresso.

La sezione «ModI Risposta» si utilizza per indicare i parametri per la produzione del token di sicurezza da inserire nel messaggio di risposta (Fig. 3.15).

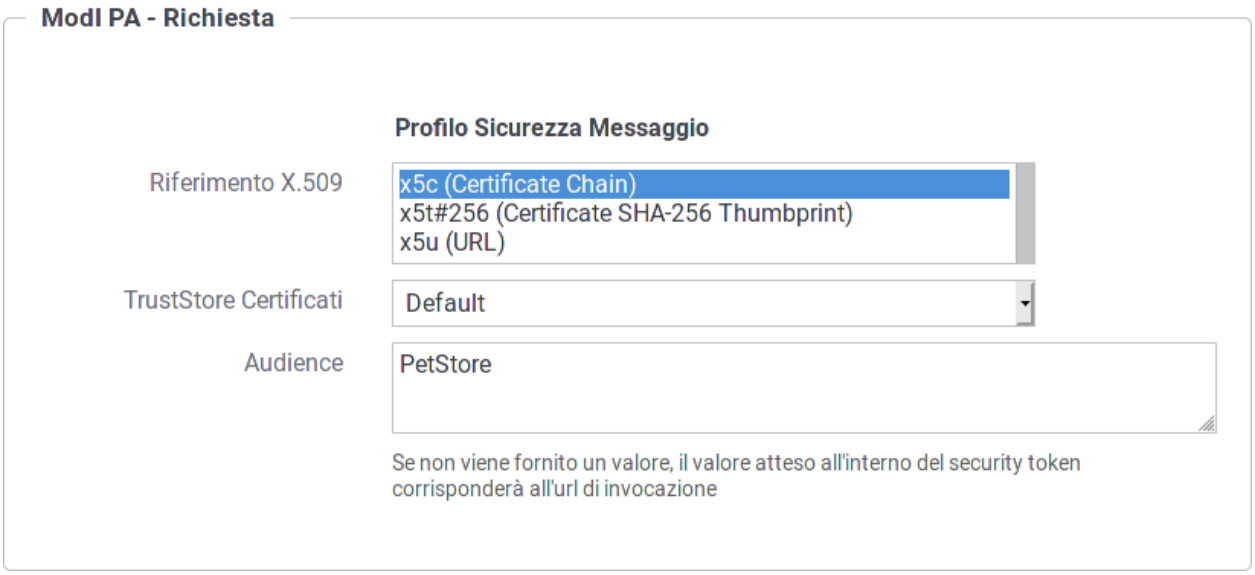


Figure3.14: Configurazione richiesta dell'erogazione

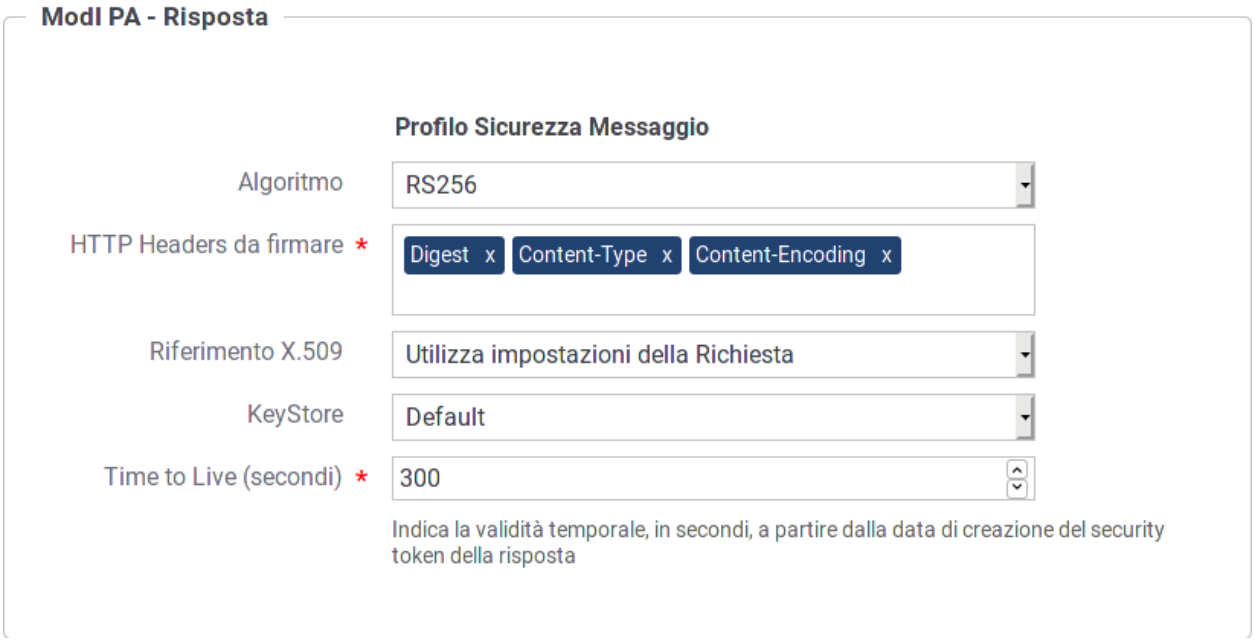


Figure3.15: Configurazione risposta dell'erogazione

Se si è scelto di registrare gli applicativi esterni, fruitori del servizio, è possibile intervenire sulla configurazione del «Controllo degli Accessi» per l'erogazione, in modo da specificare i singoli applicativi fruitori autorizzati ad effettuare richieste al servizio erogato. Questo scenario è quello preconfigurato come mostrato nelle figure Fig. 3.16 e Fig. 3.17.

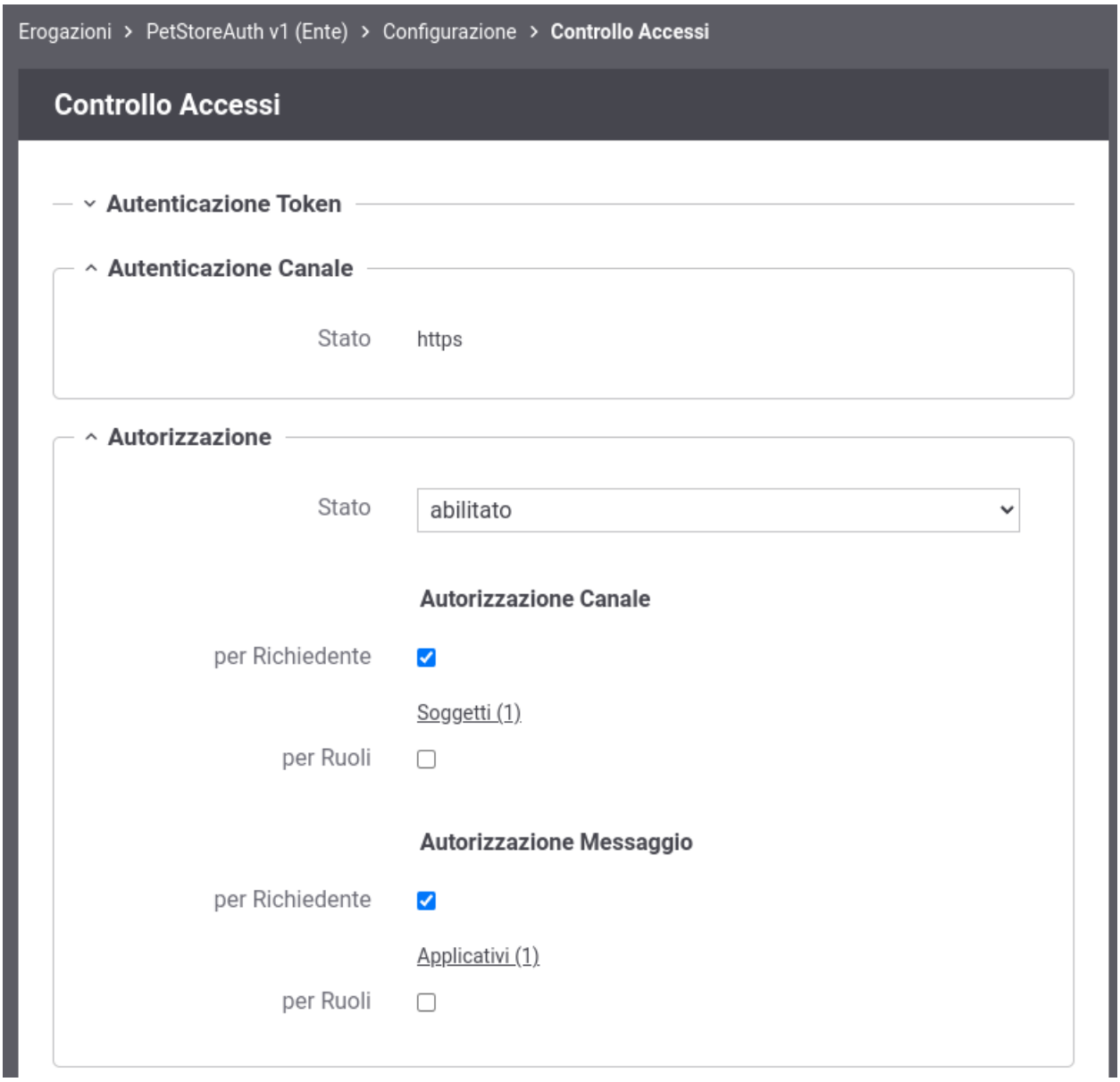


Figure3.16: Controllo accessi con autorizzazione degli applicativi esterni

3.1.2 Fruizione API REST

Obiettivo

Fruire di un servizio REST, definito tramite una API REST (OpenAPI 3.0), accessibile in accordo al pattern di sicurezza "ID_AUTH_REST_01" descritto nella sezione modipa_idar01.

Sintesi

Mostriamo in questa sezione come procedere per l'integrazione di un applicativo con un servizio REST erogato nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In

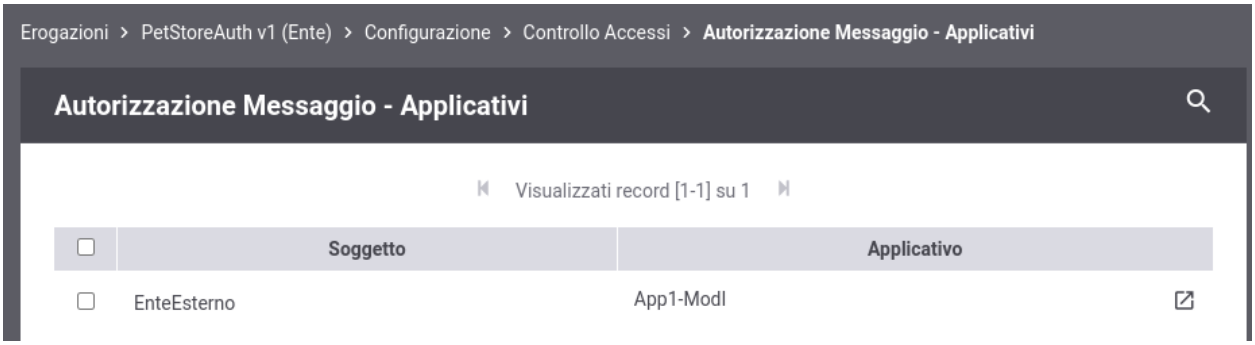


Figure3.17: Lista degli applicativi esterni autorizzati

particolare andiamo ad illustrare lo scenario, tra quelli prospettati nel Modello di Interoperabilità di AGID, che prevede il trust del certificato X.509 in modo da assicurare sia a livello di canale che a livello di messaggio l'autenticazione e autorizzazione del fruitore.

La figura seguente descrive graficamente questo scenario.

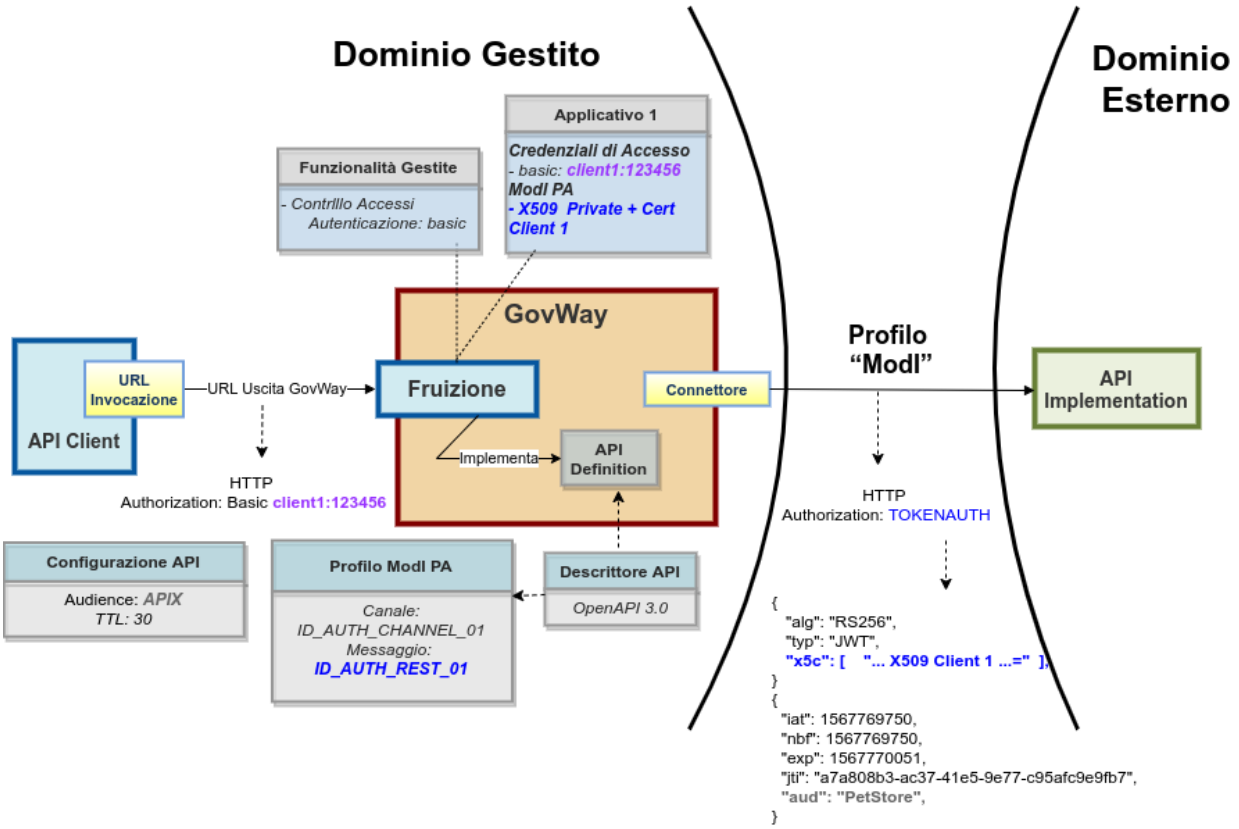


Figure3.18: Fruizione di una API REST con profilo "ModI", pattern ID_AUTH_REST_01

Le caratteristiche principali di questo scenario sono:

1. un applicativo fruitore che dialoga con il servizio erogato in modalità ModI in accordo ad una API condivisa;
2. la comunicazione diretta verso il dominio erogatore veicolata su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_02»;

3. l'autenticità della comunicazione tra fruitore ed erogatore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01».

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.19: Profilo ModI della govwayMonitor

L'esecuzione dello scenario si basa sui seguenti elementi:

- una API REST di esempio (PetStore) definita con pattern di interazione "CRUD" e pattern di sicurezza «ID_AUTH_CHANNEL_02» e «ID_AUTH_REST_01»;
- un'istanza Govway per la gestione del profilo ModI nel dominio del fruitore;
- un client che invoca la risorsa «POST /pet» con un messaggio di esempio diretto alla fruzione configurata su Govway.

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - IDAuth - OUT App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto nelle diverse fasi dell'esecuzione andando a consultare la console "govwayMonitor".

1. Il messaggio di richiesta inviato dal fruitore viene elaborato da Govway che, tramite la configurazione della firma digitale associata all'applicativo mittente, è in grado di produrre il token di sicurezza da inviare con la richiesta all'erogatore. Da govwayMonitor si può visualizzare il messaggio di richiesta in uscita che è il medesimo di quello in entrata con la differenza che è stato aggiunto il token di sicurezza tra gli header HTTP (Fig. 3.21).
2. L'header e il payload del token sono identici a quelli visualizzati nello scenario di erogazione REST, relativamente al messaggio in ingresso (Fig. 3.7 e Fig. 3.8). Le informazioni inserite nel token vengono anche tracciate e sono visibili sulla govwayMonitor, andando a consultare la traccia del messaggio di richiesta (Fig. 3.22). Nella sezione «Sicurezza Messaggio» sono riportate le informazioni estratte dal token di sicurezza presente nel messaggio.
3. Lo scambio del messaggio con il dominio erogatore (comunicazione interdominio) avviene in accordo al pattern «ID_AUTH_CHANNEL_02» e quindi con protocollo SSL e autenticazione client. Dal dettaglio della transazione si possono consultare i messaggi diagnostici dove è visibile la fase di apertura della connessione SSL (Fig. 3.23).
4. Govway riceve la risposta dell'erogatore, dalla quale estrae il token di sicurezza al fine di effettuare i relativi controlli di validità e conservare la traccia. Consultando la traccia relativa alla trasmissione della risposta, sono visibili tra le altre informazioni i dati di autenticazione dell'erogatore e i riferimenti temporali.

Conformità ai requisiti ModI

I requisiti iniziali, legati alla comunicazione basata su uno scenario ModI, sono verificati dalle seguenti evidenze:

1. la trasmissione è basata sul pattern «ID_AUTH_CHANNEL_02», riguardo la sicurezza canale, come evidenziato nei messaggi diangostici dalla presenza degli elementi dell'handshake SSL e relativi dati dei certificati scambiati

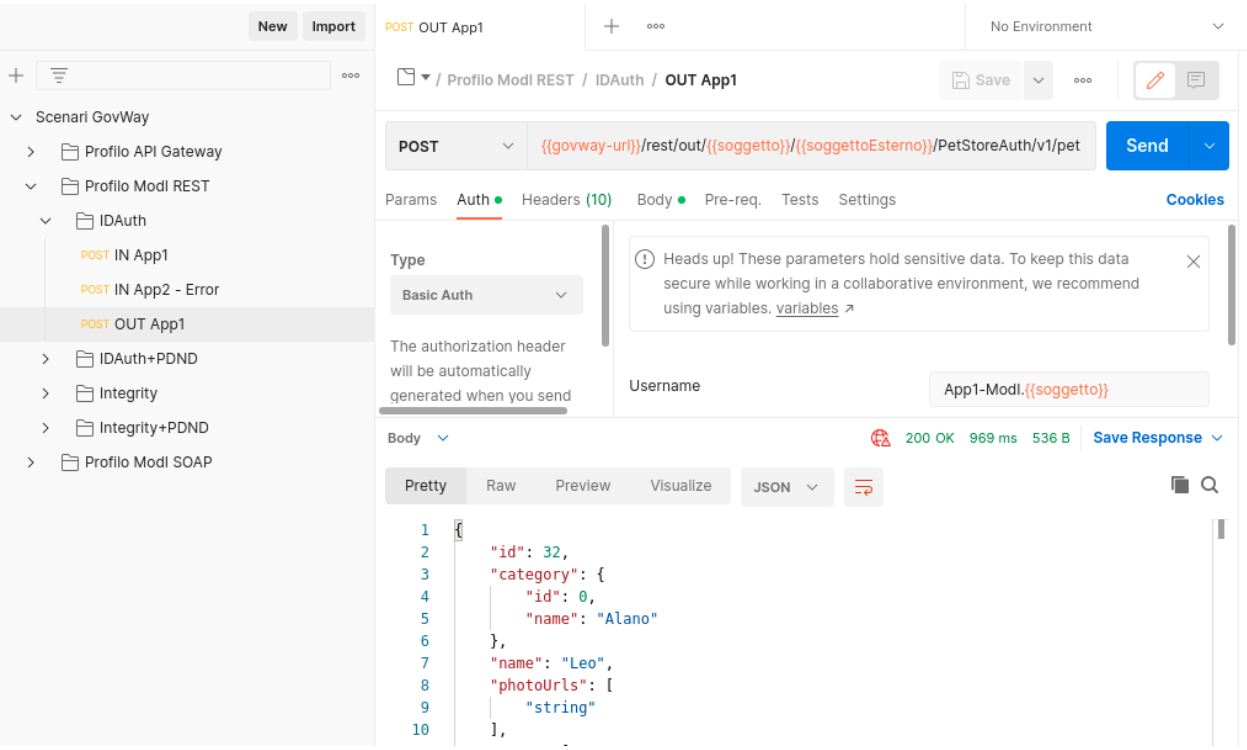


Figure3.20: Pattern IDAuth - Fruizione API REST, esecuzione da Postman

(Fig. 3.23);

2. la sicurezza messaggio applicata è quella dei pattern «ID_AUTH_REST_01», come ampiamente mostrato nelle tracce dei messaggi di richiesta e risposta, dove sono presenti i certificati degli applicativi e le firme dei payload (e le relative validazioni).

Configurazione

Nota

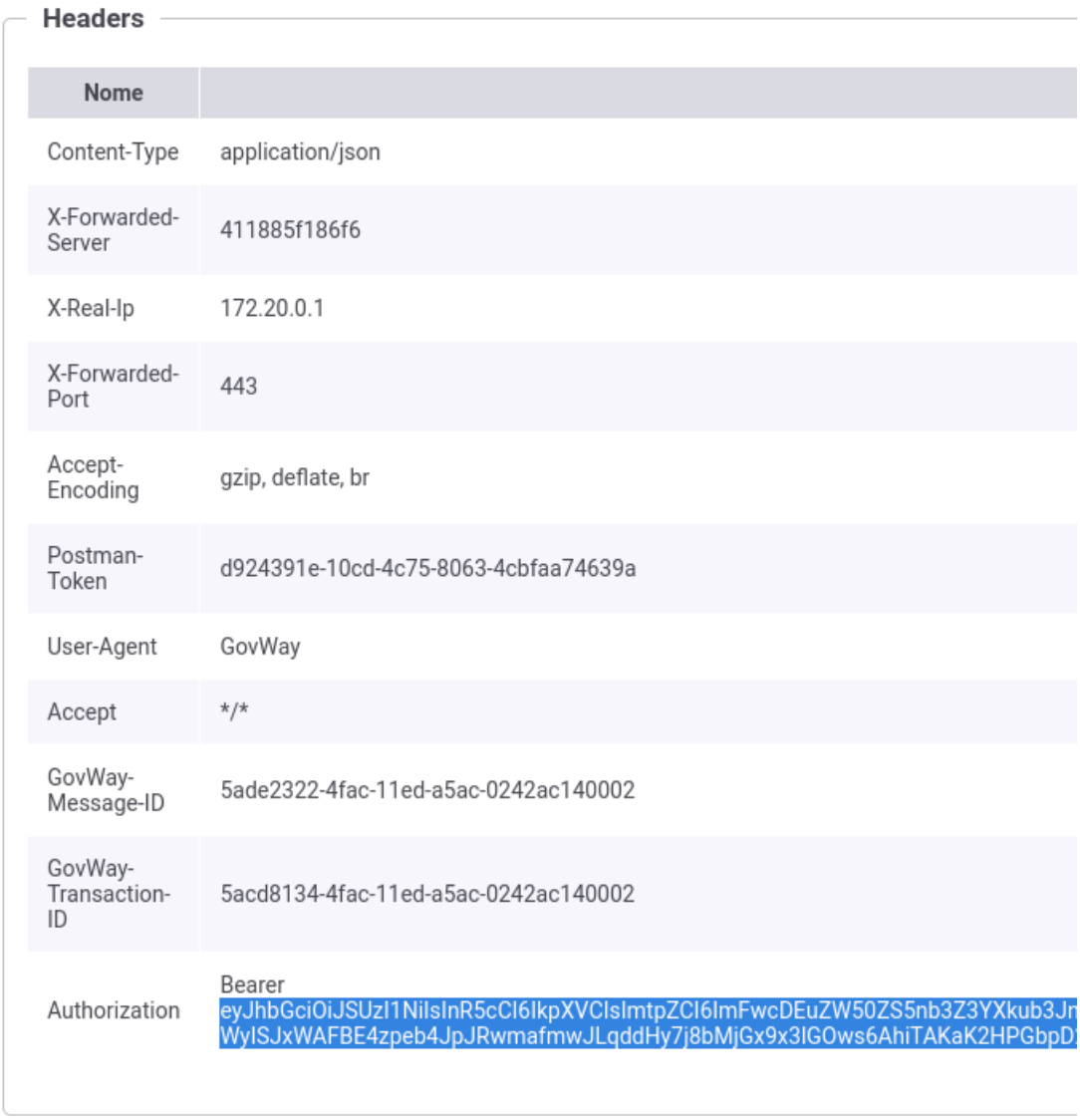
Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità «ModI». Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.24: Profilo ModI della govwayConsole

Registrazione API

Viene registrata l'API «PetStoreAuth» con il relativo descrittore OpenAPI 3. Vengono selezionati i pattern «ID_AUTH_CHANNEL_02» (sicurezza canale) e «ID_AUTH_REST_01» (sicurezza messaggio) nella sezione «ModI» (Fig. 3.25).



Headers

Nome	
Content-Type	application/json
X-Forwarded-Server	411885f186f6
X-Real-Ip	172.20.0.1
X-Forwarded-Port	443
Accept-Encoding	gzip, deflate, br
Postman-Token	d924391e-10cd-4c75-8063-4cbfaa74639a
User-Agent	GovWay
Accept	*/*
GovWay-Message-ID	5ade2322-4fac-11ed-a5ac-0242ac140002
GovWay-Transaction-ID	5acd8134-4fac-11ed-a5ac-0242ac140002
Authorization	Bearer eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6ImFwcDEuZW50ZS5nb3Z3YXkub3Jn WyISJxWAFBE4zpeb4JpJRwmafmwJLqddHy7j8bMjGx9x3lGOws6AhiTAKaK2HPGbpD

Figure3.21: Messaggio di richiesta in uscita (con token di sicurezza inserito nell'header HTTP)

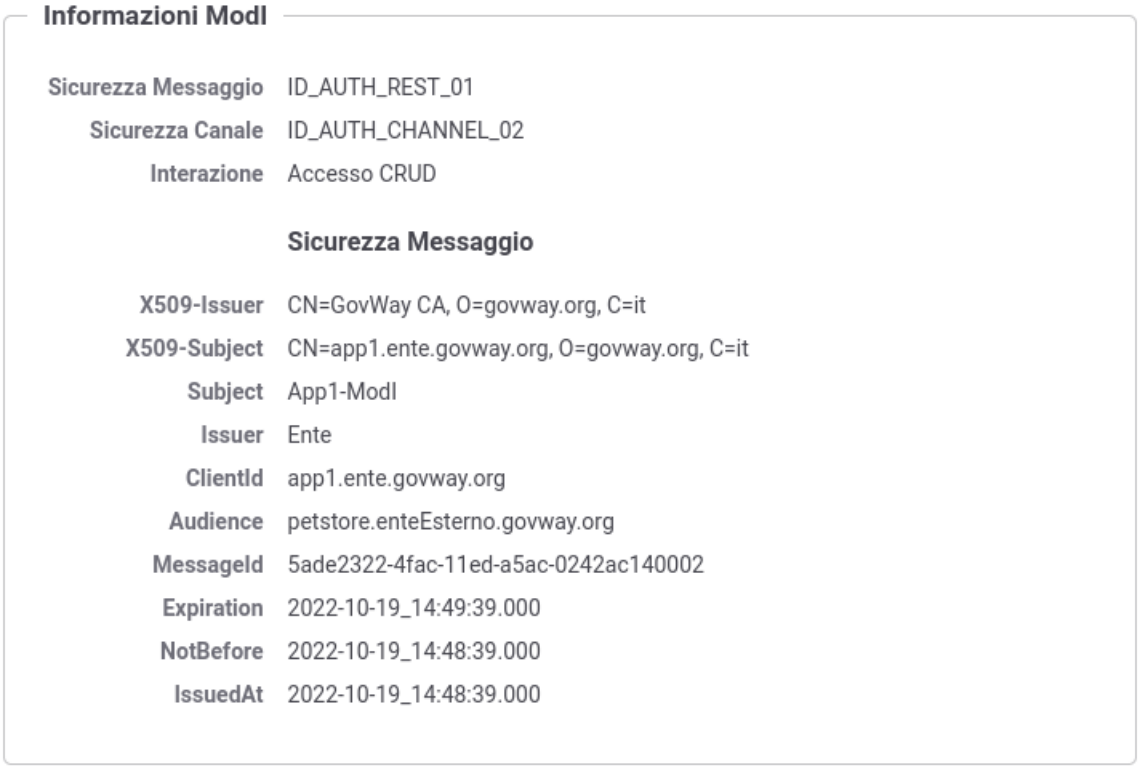


Figure3.22: Traccia della richiesta generata dal fruitore



Figure3.23: Sicurezza canale «ID_AUTH_CHANNEL_02» sulla fruizione

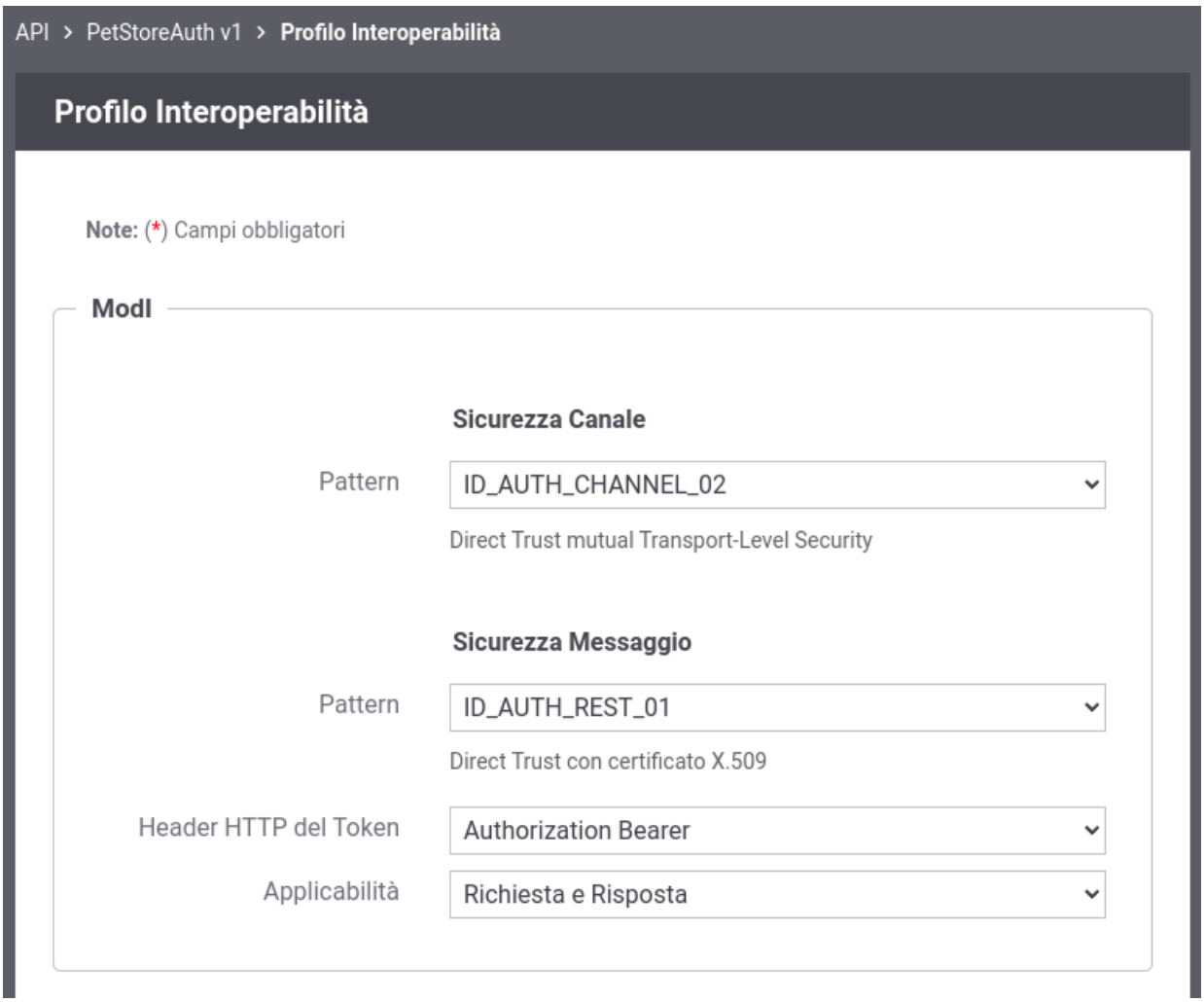


Figure3.25: Configurazione Pattern ModI «ID_AUTH_REST_01» sulla API

Applicativo

Si configura l'applicativo mittente indicando, nella sezione ModI, i parametri del keystore necessari affinché Govway possa produrre il token di sicurezza firmando per conto dell'applicativo (Fig. 3.26). Alla registrazione dell'applicativo vengono associate credenziali "basic" che consentono a GovWay di identificarlo.

Fruizione

Si registra la fruizione «PetStoreAuth», relativa all'API precedentemente inserita, indicando i dati specifici nella sezione «ModI Richiesta» (Fig. 3.27). In particolare è possibile specificare l'audience atteso dall'erogatore e il tempo di validità del token.

La sezione «ModI Risposta» definisce i criteri per la validazione dei messaggi di risposta, come la posizione del token di sicurezza e il truststore per l'autenticazione dell'erogatore (Fig. 3.28).

3.1.3 Erogazione API SOAP

Obiettivo

Esporre un servizio SOAP, definito tramite una interfaccia WSDL, accessibile in accordo al pattern di sicurezza "ID_AUTH_SOAP_01" descritto nella sezione modipa_idar01.

Sintesi

Mostriamo in questa sezione come procedere per l'esposizione di un servizio SOAP da erogare nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario, tra quelli prospettati nel Modello di Interoperabilità di AGID, che prevede il trust del certificato X.509 in modo da assicurare sia a livello di canale che a livello di messaggio l'autenticazione e autorizzazione del fruitore.

La figura seguente descrive graficamente questo scenario.

Le caratteristiche principali di questo scenario sono:

1. un applicativo eroga un servizio, rivolto a fruitori di domini esterni, in conformità al Modello di Interoperabilità AGID;
2. la comunicazione con i domini esterni avviene su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_02»;
3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_SOAP_01».

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.30: Profilo ModI della govwayMonitor

L'esecuzione dello scenario si basa sui seguenti elementi:

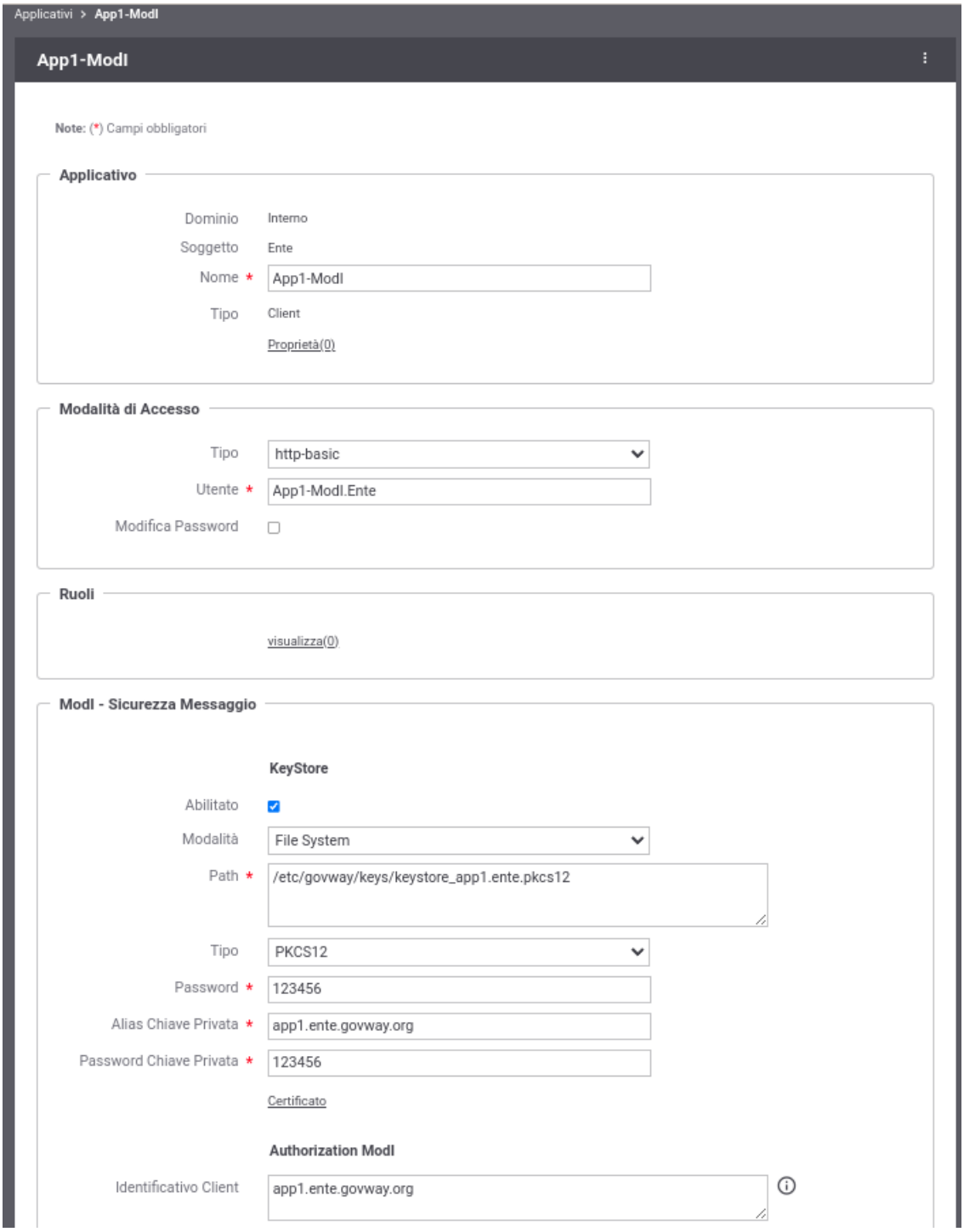


Figure3.26: Configurazione applicativo fruitore

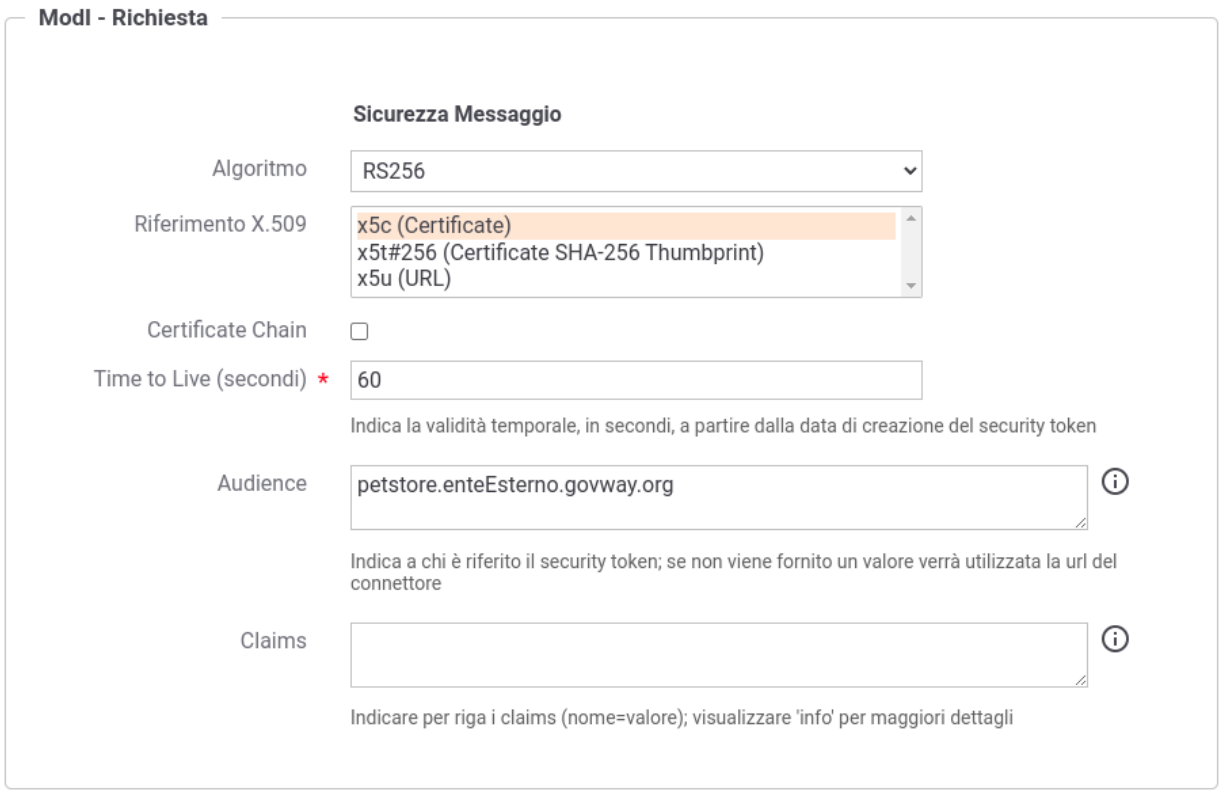


Figure3.27: Configurazione richiesta della fruizione

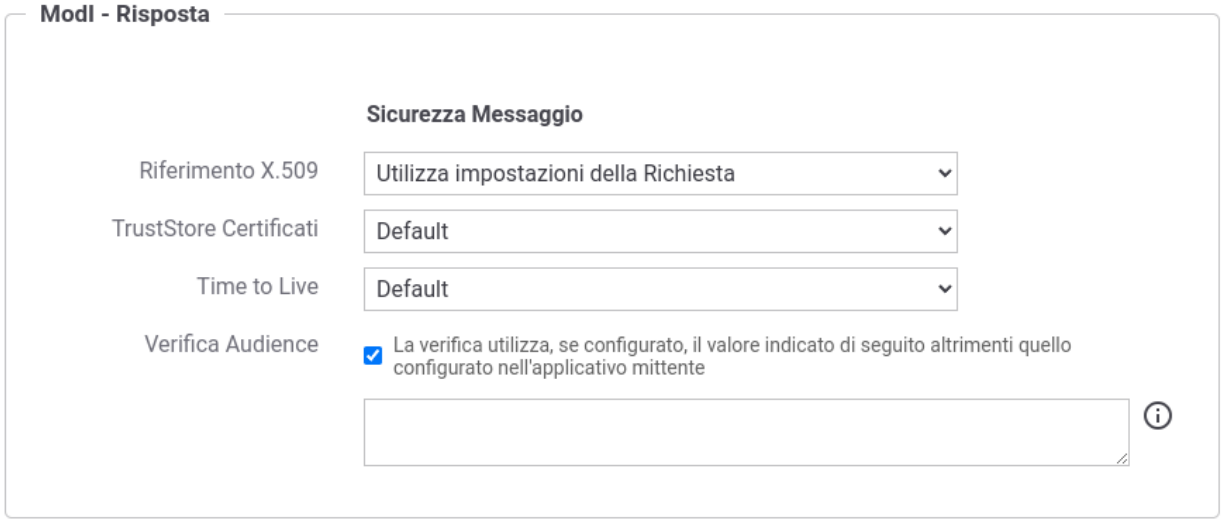


Figure3.28: Configurazione risposta della fruizione

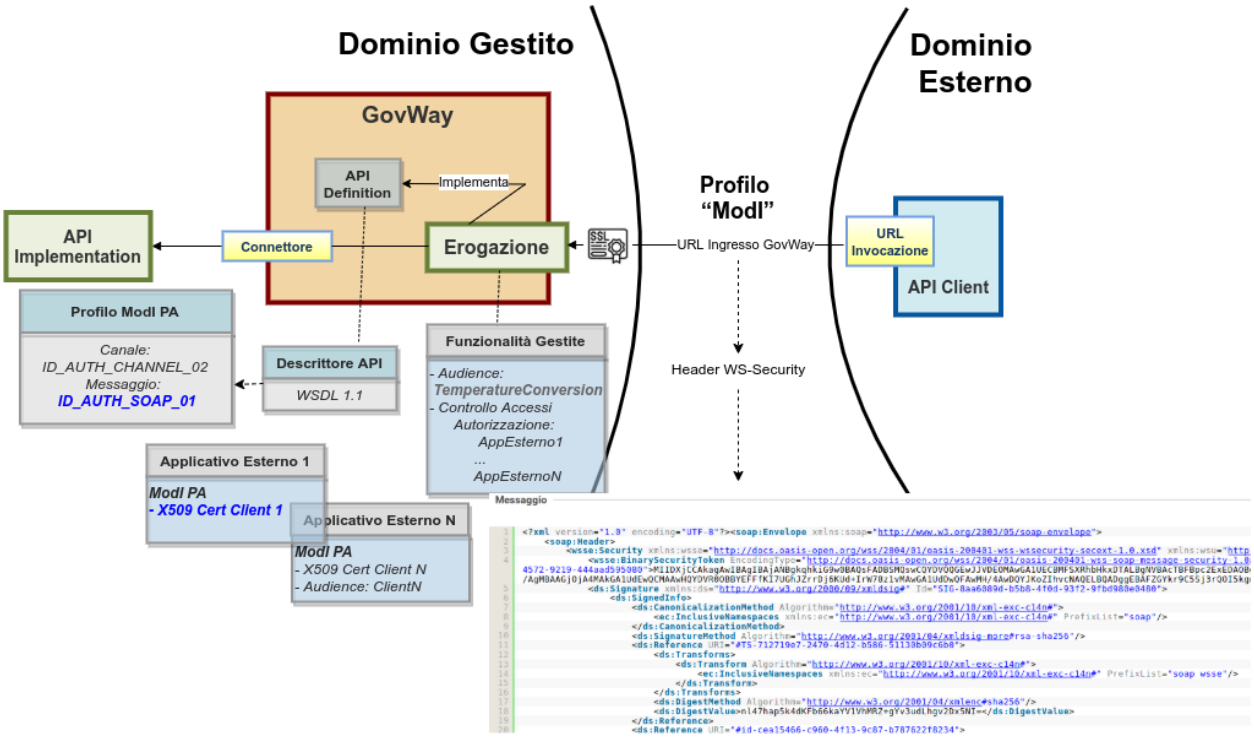


Figure3.29: Erogazione di una API SOAP con profilo "ModI", pattern ID_AUTH_SOAP_01

- una API SOAP di esempio (Temperature Conversion) definita con pattern di interazione Bloccante e pattern di sicurezza «ID_AUTH_CHANNEL_02» e «ID_AUTH_SOAP_01»»;
- un'istanza Govway per la gestione del profilo ModI nel dominio dell'erogatore;
- un client del dominio esterno che invoca l'azione di esempio «CelsiusToFahrenheit» dell'erogazione esposta da Govway;
- il server "Temperature Conversion" di esempio che riceve le richieste inoltrate dal Govway e produce le relative risposte. Per questo scenario viene utilizzato il server disponibile on line all'indirizzo "https://www.w3schools.com/xml/tempconvert.asmx".

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI SOAP - IDAuth - IN App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console govwayMonitor.

1. Per verificare l'utilizzo del canale SSL, in accordo al pattern «ID_AUTH_CHANNEL_02», si procede come già illustrato per *Esecuzione*
2. Dal dettaglio della richiesta si può visualizzare il messaggio che è stato inviato dal fruitore, come in Fig. 3.32. Come si nota, il messaggio SOAP contiene nell'header WS-Security sia il token di sicurezza (elemento «BinarySecurityToken») sia l'elemento «WSAddressing - To» prodotti dal fruitore con la relativa firma digitale (elemento «SignatureValue»).

3. Il messaggio ricevuto dal Govway viene quindi validato, sulla base dei pattern di sicurezza previsti nello scambio, verificando in questo caso l'identità del fruitore, la validità temporale, la corrispondenza dell'audience ricevuto con quello atteso. Solo in caso di superamento dell'intero processo di validazione, il messaggio viene inoltrato al servizio erogatore. Le evidenze del processo di validazione sono visibili sulla govwayMonitor, andando a consultare la traccia del messaggio di richiesta (Fig. 3.33). Nella sezione «Sicurezza Messaggio» sono riportate le informazioni estratte dal

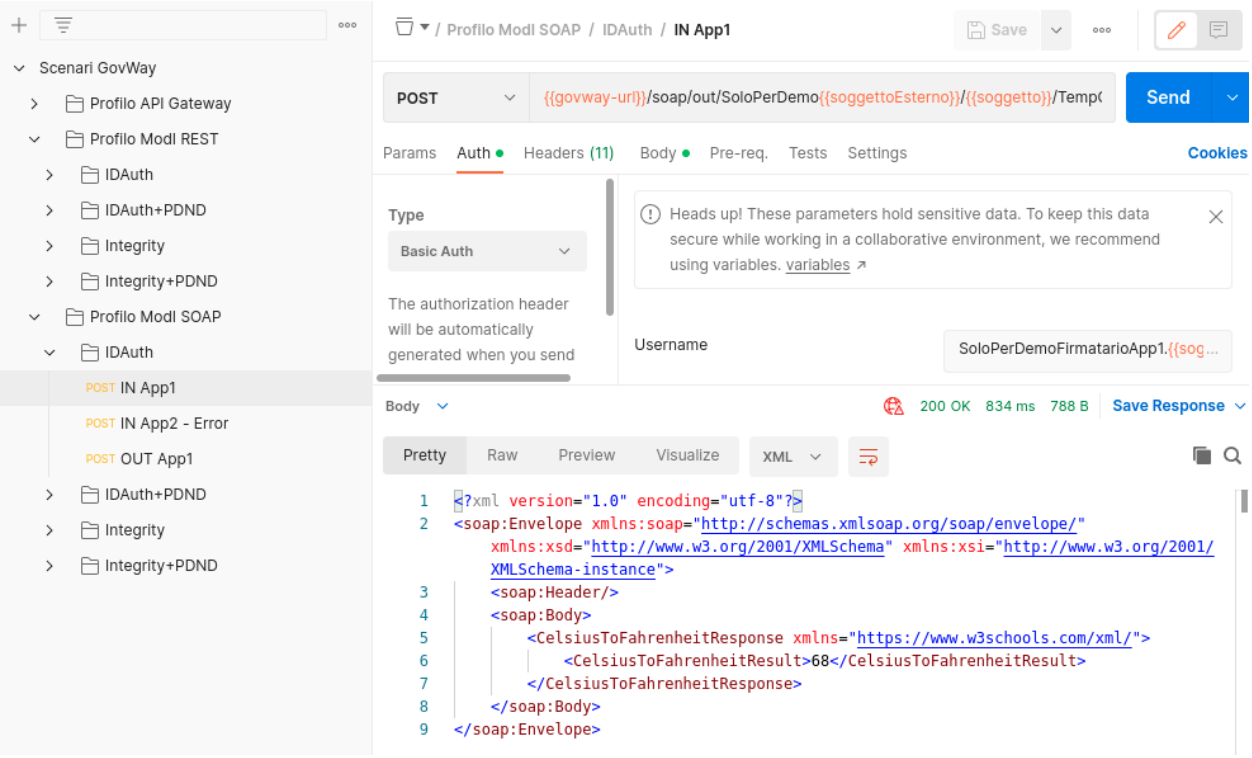


Figure3.31: Pattern IDAuth - Erogazione API SOAP, esecuzione da Postman



Figure3.32: Messaggio inviato dal fruitore

token di sicurezza presente nell'header soap.

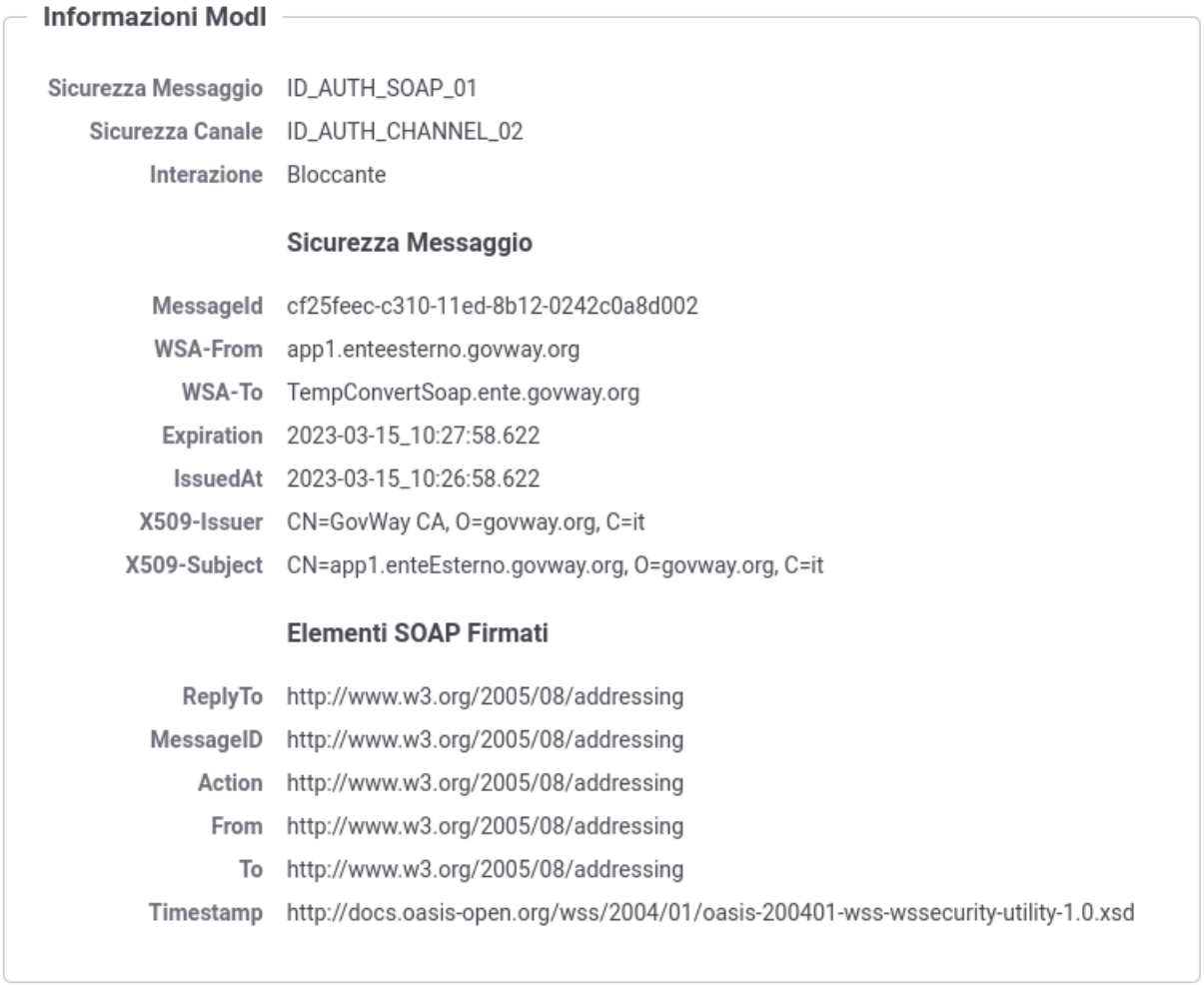


Figure3.33: Traccia della richiesta elaborata dall'erogatore

4. Dopo l'inoltro al servizio erogatore, Govway riceve la risposta e la elabora producendo il relativo header ws-security da inserire nel messaggio di risposta. Sulla console govwayMonitor è possibile visualizzare il messaggio di risposta in uscita (analogamente a Fig. 3.32).
5. Lo scenario è preconfigurato per autorizzare puntualmente l'applicativo "App1-ModI" identificato grazie al certificato X.509 presente all'interno dell'header WSSecurity. È possibile utilizzare il progetto Postman a corredo con la request «Profilo ModI SOAP - IDAuth - IN App2 - Error» per verificare che una richiesta proveniente da un differente applicativo non viene autorizzata.

Conformità ai requisiti ModI

La verifica dei requisiti ModI per questo scenario non differisce da quanto già descritto in *Esecuzione*.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di

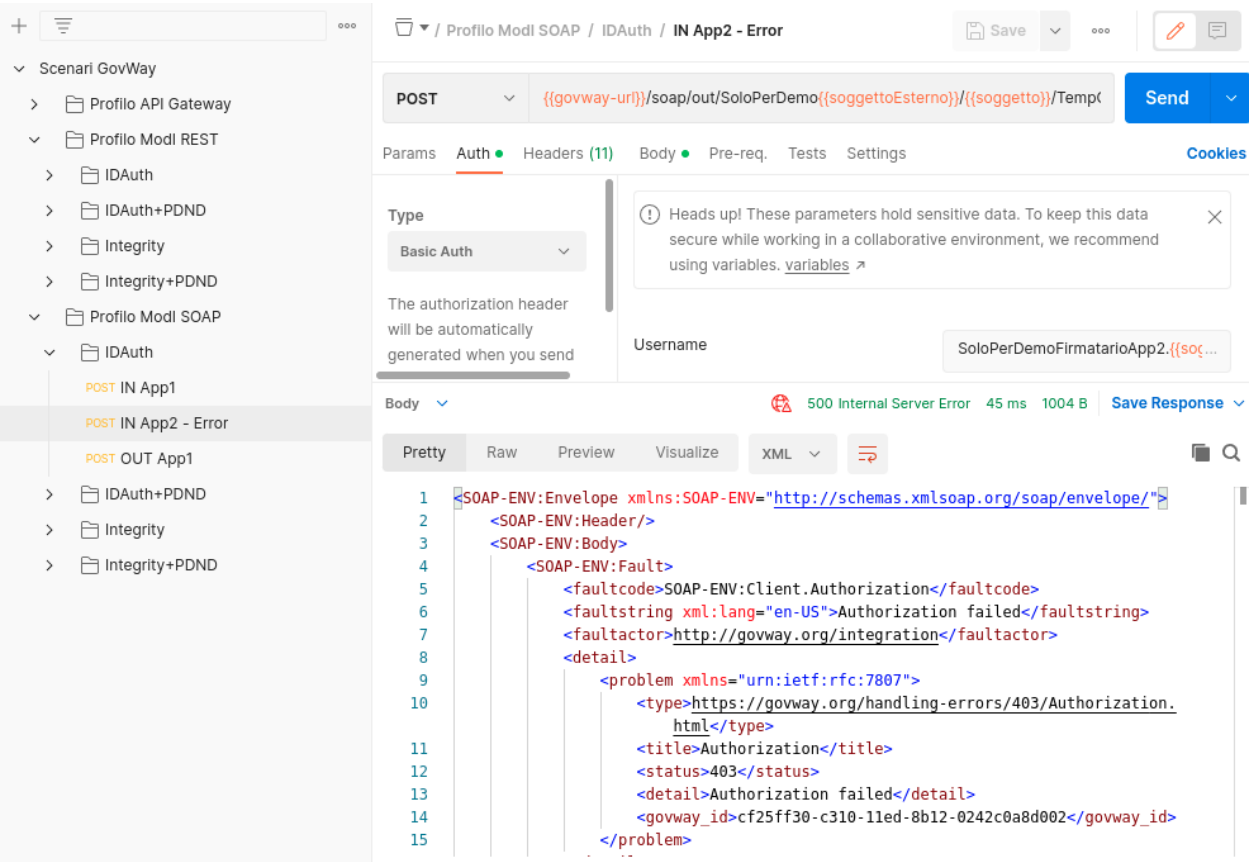


Figure3.34: Pattern IDAuth - Erogazione API SOAP - Autorizzazione negata, esecuzione da Postman

Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.35: Profilo ModI della govwayConsole

Il processo di configurazione per questo scenario è del tutto analogo a quello descritto per lo scenario *Configurazione*. Nel seguito sono evidenziate le sole differenze.

L'interfaccia wsdl del servizio soap è ottenibile all'indirizzo "https://www.w3schools.com/xml/tempconvert.asmx?wsdl".

Registrazione API

Viene registrata l'API «TemperatureConversionAuth» con il relativo descrittore WSDL. Vengono selezionati i pattern «ID_AUTH_CHANNEL_02» (sicurezza canale) e «ID_AUTH_SOAP_01» (sicurezza messaggio) nella sezione «ModI» (Fig. 3.36).

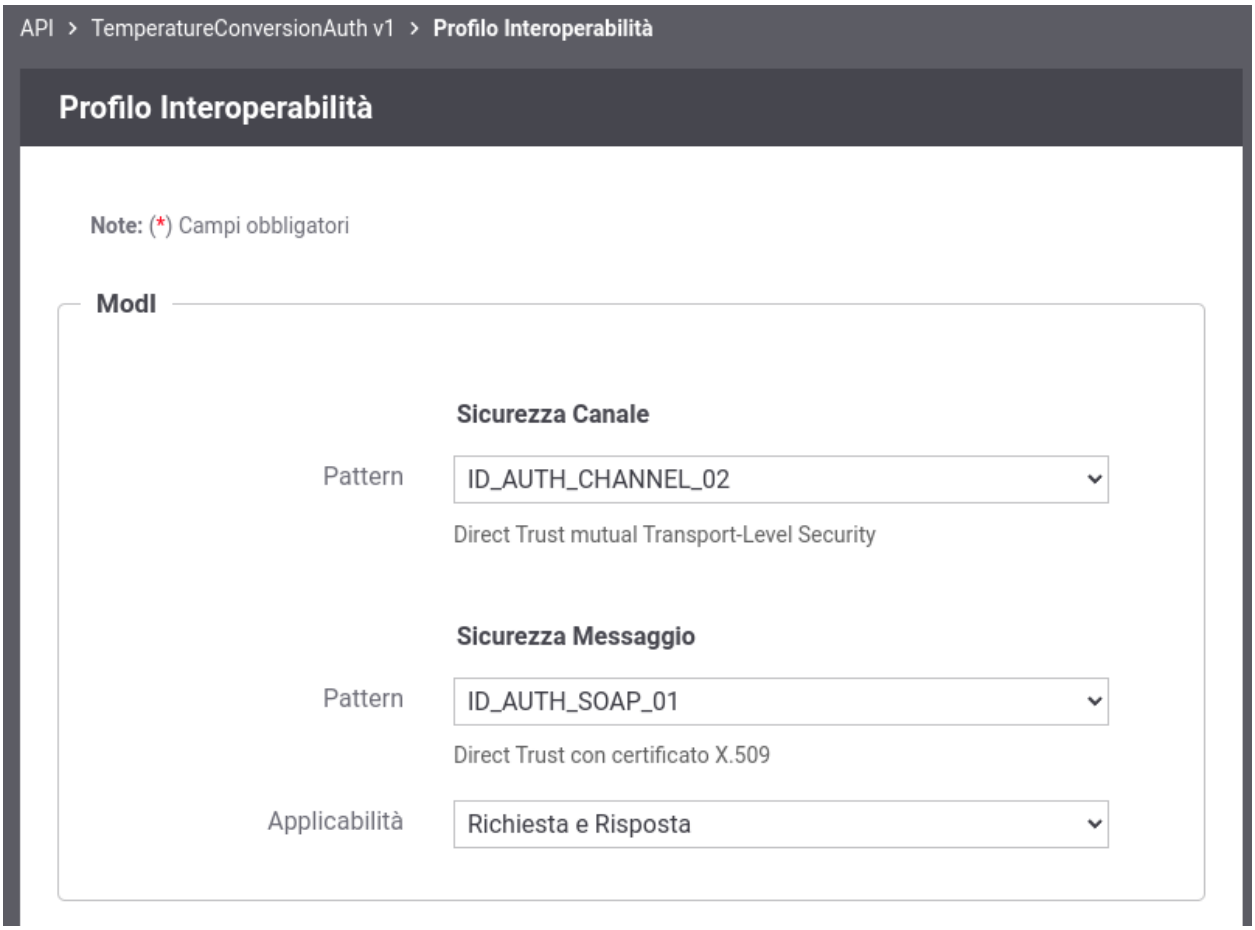


Figure3.36: Configurazione Pattern ModI «ID_AUTH_SOAP_01» sulla API SOAP

Erogazione

Si registra l'erogazione SOAP "TempConvertSoapAuth", relativa all'API precedentemente inserita, indicando i dati specifici nella sezione «ModI Richiesta» (Fig. 3.37). In questo contesto vengono inseriti i dati necessari per validare le richieste in ingresso.



Figure3.37: Configurazione richiesta dell'erogazione

La sezione «ModI Risposta» si utilizza per indicare i parametri per la produzione del token di sicurezza da inserire nel messaggio di risposta (Fig. 3.38).

3.1.4 Fruizione API SOAP

Obiettivo

Fruire di un servizio SOAP, definito tramite una interfaccia WSDL, accessibile in accordo al pattern di sicurezza "ID_AUTH_SOAP_01" descritto nella sezione modipa_idar01.

Sintesi

Mostriamo in questa sezione come procedere per l'integrazione di un applicativo con un servizio SOAP erogato nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario, tra quelli prospettati nel Modello di Interoperabilità di AGID, che prevede il trust del certificato X.509 in modo da assicurare sia a livello di canale che a livello di messaggio l'autenticazione e autorizzazione del fruitore.

La figura seguente descrive graficamente questo scenario.

Le caratteristiche principali di questo scenario sono:

1. un applicativo fruitore che dialoga con il servizio erogato in modalità ModI in accordo ad una API condivisa;
2. la comunicazione diretta verso il dominio erogatore veicolata su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_02»;
3. l'autenticità della comunicazione tra fruitore ed erogatore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_SOAP_01».

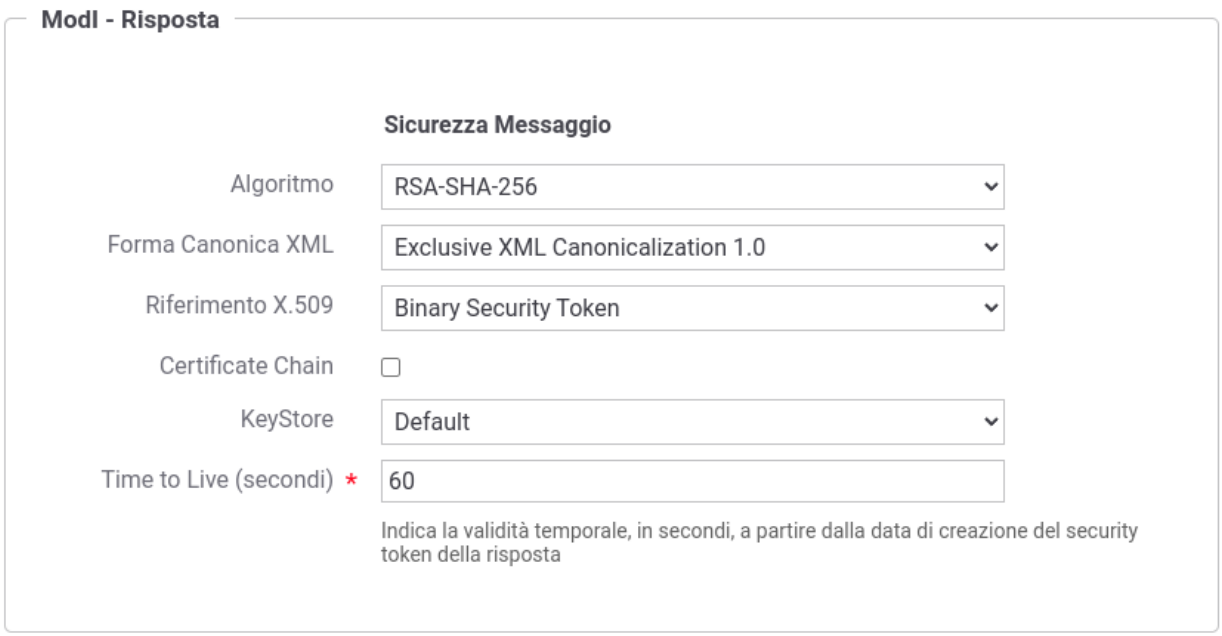


Figure3.38: Configurazione risposta dell'erogazione

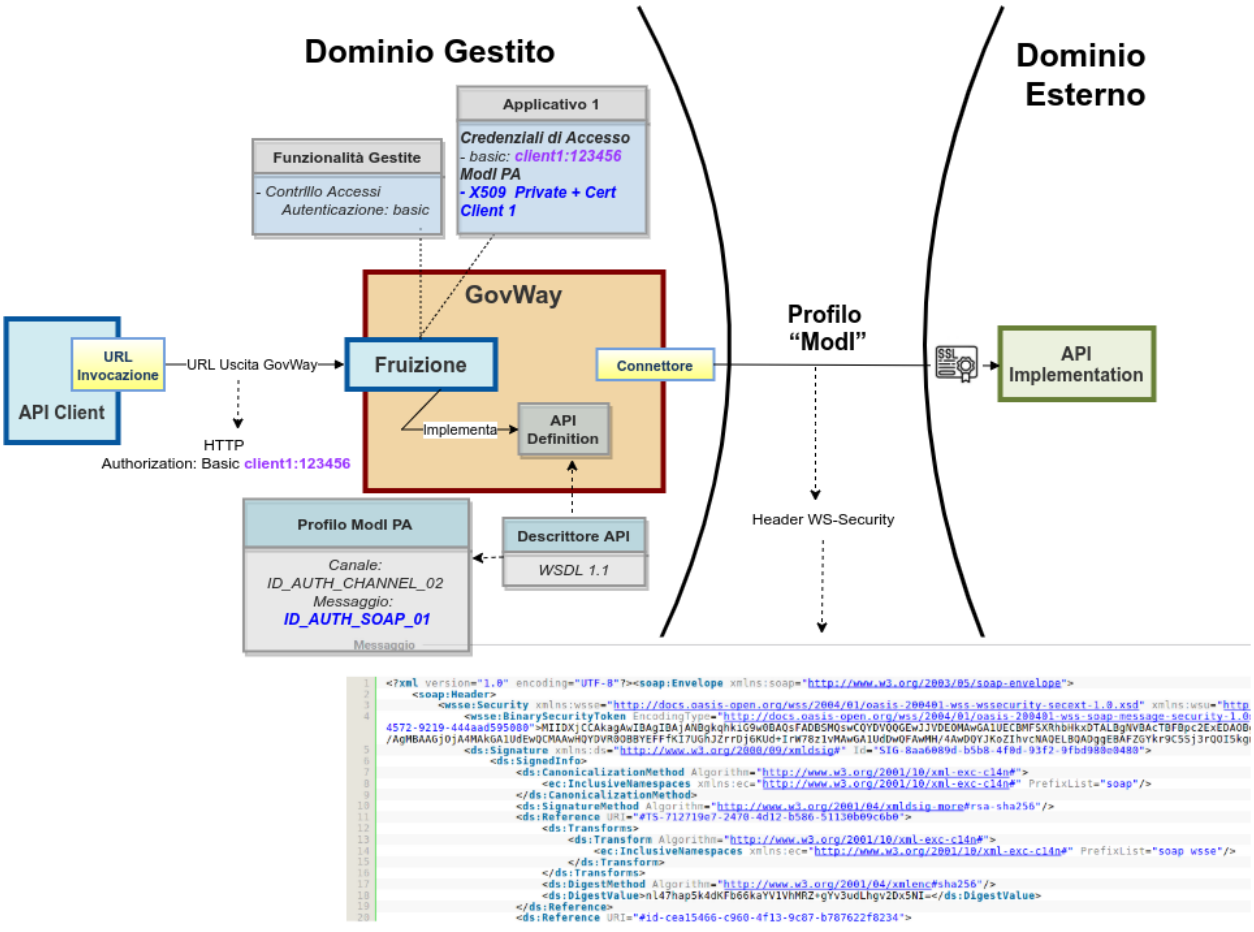


Figure3.39: Fruizione di una API SOAP con profilo "ModI", pattern ID_AUTH_SOAP_01

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.40: Profilo ModI della govwayMonitor

L'esecuzione dello scenario si basa sui seguenti elementi:

- una API SOAP di esempio (Temperature Conversion) definita con pattern di interazione Bloccante e pattern di sicurezza «ID_AUTH_CHANNEL_02» e «ID_AUTH_SOAP_01»;
- un'istanza Govway per la gestione del profilo ModI nel dominio del fruitore;
- un client del dominio gestito che invoca l'azione di esempio «CelsiusToFahrenheit» sulla fruzione configurata su Govway.

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI SOAP - IDAuth - OUT App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

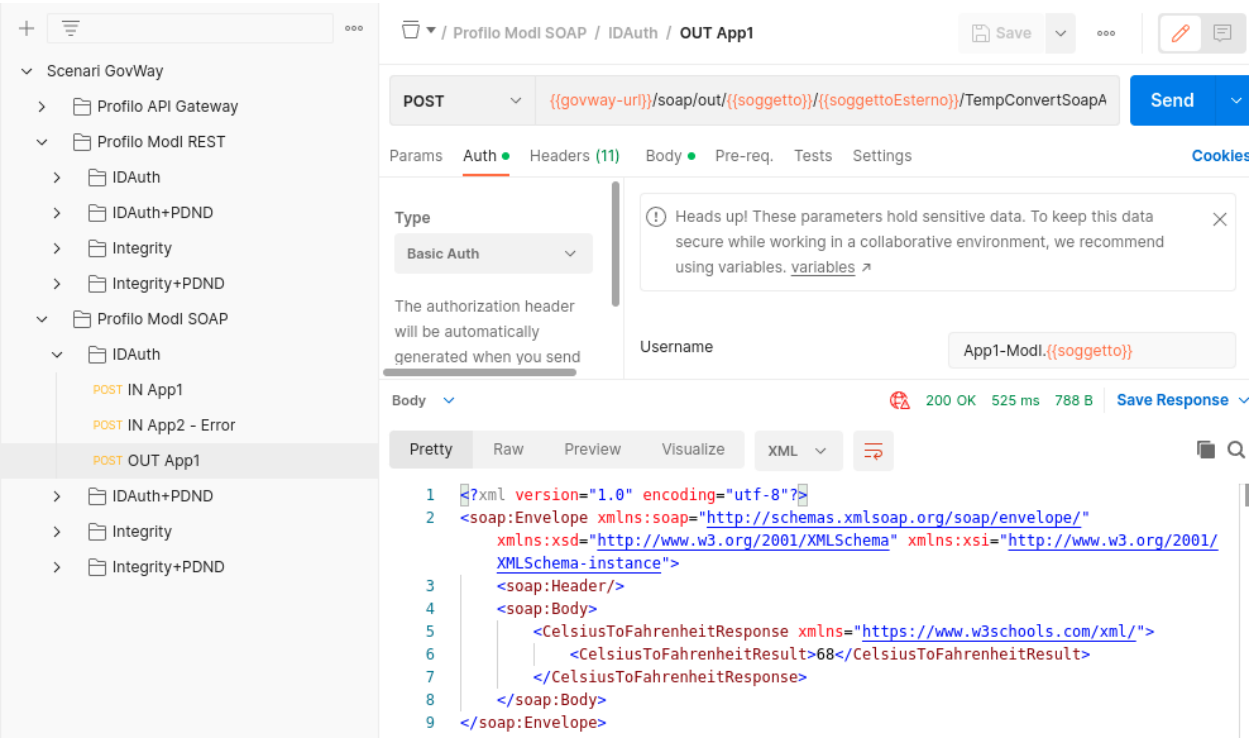


Figure3.41: Pattern IDAuth - Fruizione API SOAP, esecuzione da Postman

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console "govwayMonitor".

1. Il messaggio di richiesta inviato dal fruitore viene elaborato da Govway che, tramite la configurazione della firma digitale associata all'applicativo mittente, è in grado di produrre l'header WS-Security da inserire nella richiesta inviata all'erogatore. Da govwayMonitor si può visualizzare il messaggio di richiesta in uscita, analogo a quanto già visto in Fig. 3.32.
2. Per verificare l'utilizzo del canale SSL, in accordo al pattern «ID_AUTH_CHANNEL_02», si procede come già illustrato per *Esecuzione*.
3. Govway riceve la risposta dell'erogatore, dalla quale estrae il token di sicurezza al fine di effettuare i relativi controlli di validità e conservare la traccia. Consultando la traccia relativa alla trasmissione della risposta, sono visibili tra le altre informazioni i dati di autenticazione dell'erogatore e i riferimenti temporali.

Conformità ai requisiti ModI

La verifica dei requisiti ModI per questo scenario non differisce da quanto già descritto in *Esecuzione*.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità «ModI». Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.42: Profilo ModI della govwayConsole

Il processo di configurazione per questo scenario è del tutto analogo a quello descritto per lo scenario *Configurazione*. Nel seguito sono evidenziate le sole differenze.

Registrazione API

Viene registrata l'API «TemperatureConversionAuth» con il relativo descrittore WSDL. Vengono selezionati i pattern «ID_AUTH_CHANNEL_02» (sicurezza canale) e «ID_AUTH_SOAP_01» (sicurezza messaggio) nella sezione «ModI» (Fig. 3.36).

Fruizione

Si registra la fruizione SOAP "TempConvertSoapAuth", relativa all'API precedentemente inserita, indicando i dati specifici nella sezione «ModI Richiesta» (Fig. 3.44).

La sezione «ModI Risposta» definisce i criteri per la validazione dei messaggi di risposta (Fig. 3.45).

3.2 Pattern "INTEGRITY_01"

Gli scenari riportati in questa sezione riguardano API configurate con pattern modipa_idar03.

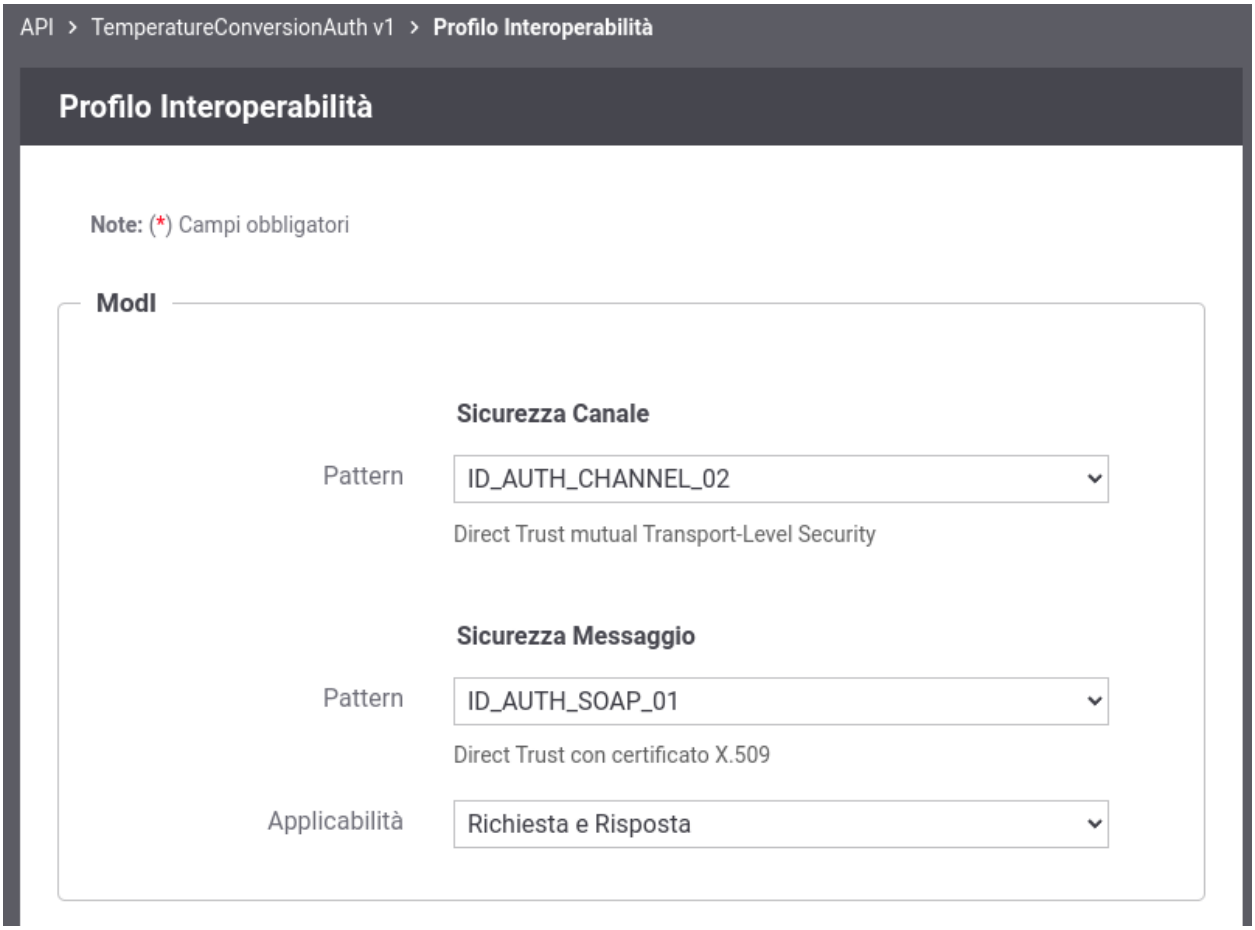


Figure3.43: Configurazione Pattern ModI «ID_AUTH_SOAP_01» sulla API SOAP

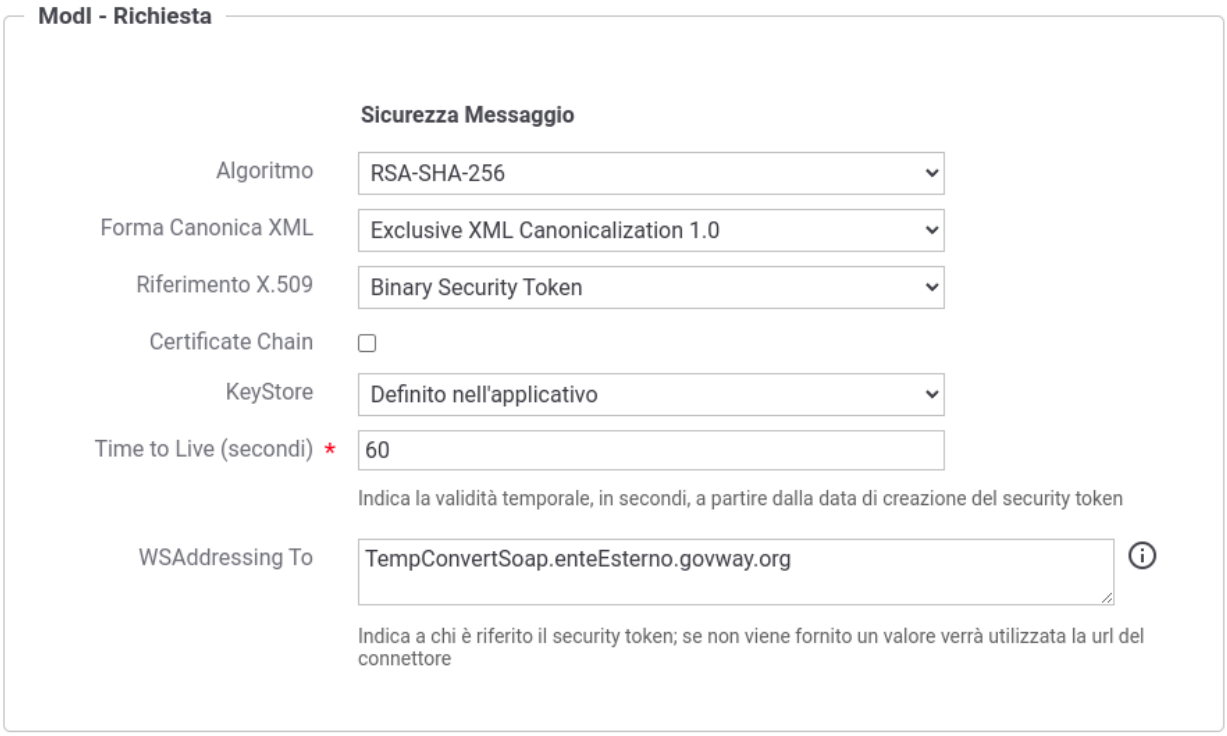


Figure3.44: Configurazione richiesta della fruizione



Figure3.45: Configurazione risposta della fruizione

3.2.1 Erogazione API REST

Obiettivo

Esporre un servizio, definito tramite una API REST (OpenAPI 3.0), accessibile in accordo al pattern di sicurezza "INTEGRITY_REST_01" descritto nella sezione modipa_idar03.

Sintesi

Mostriamo in questa sezione come procedere per l'esposizione di un servizio REST da erogare nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario, tra quelli prospettati nel Modello di Interoperabilità di AGID, che prevede oltre a garantire l'autenticazione dell'interlocutore un supporto a garanzia dell'integrità del messaggio.

La figura seguente descrive graficamente questo scenario.

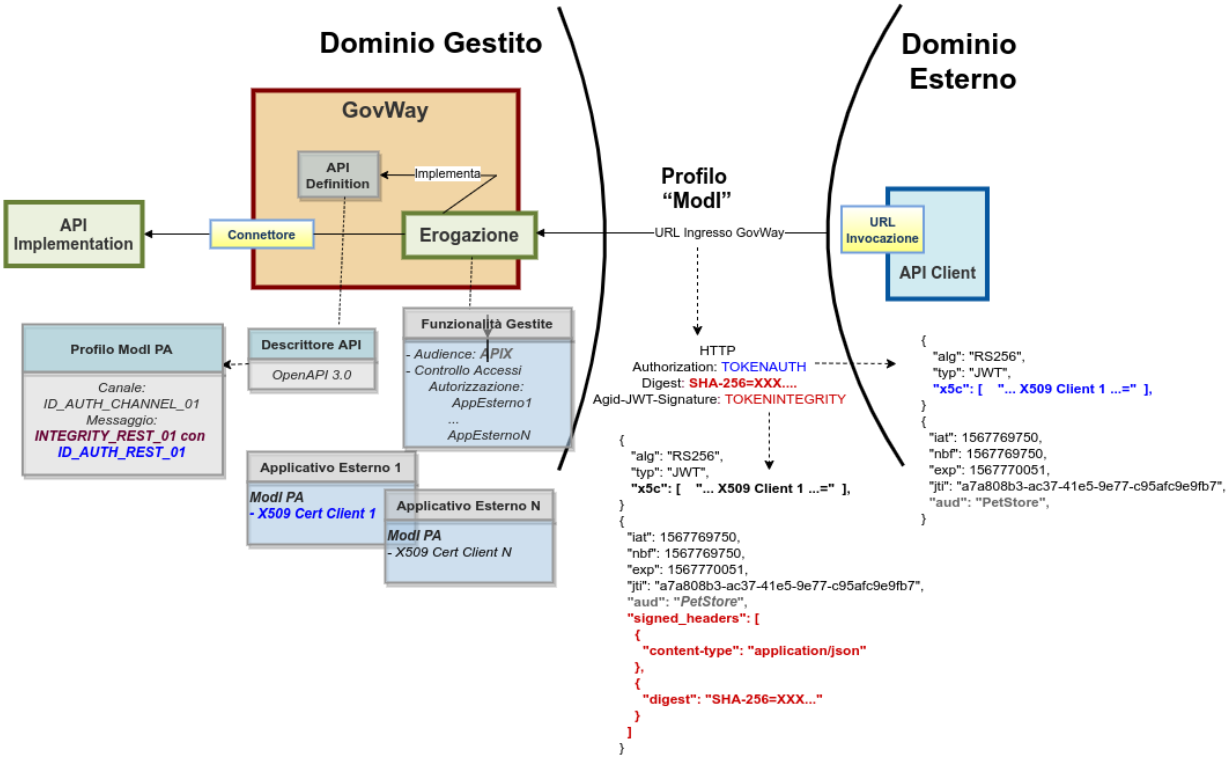


Figure3.46: Erogazione di una API REST con profilo "ModI", pattern INTEGRITY_REST_01 con ID_AUTH_REST_01

Le caratteristiche principali di questo scenario sono:

1. un applicativo eroga un servizio, rivolto a fruitori di domini esterni, in conformità al Modello di Interoperabilità AGID;
2. la comunicazione con i domini esterni avviene su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_02»;
3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01»;
4. l'integrità del messaggio scambiato è garantita tramite sicurezza messaggio aggiuntiva prevista nel pattern «INTEGRITY_REST_01».

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.47: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione* con la sola eccezione del pattern di sicurezza utilizzato che in questo scenario è «INTEGRITY_REST_01 con ID_AUTH_REST_01».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - Integrity - IN App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

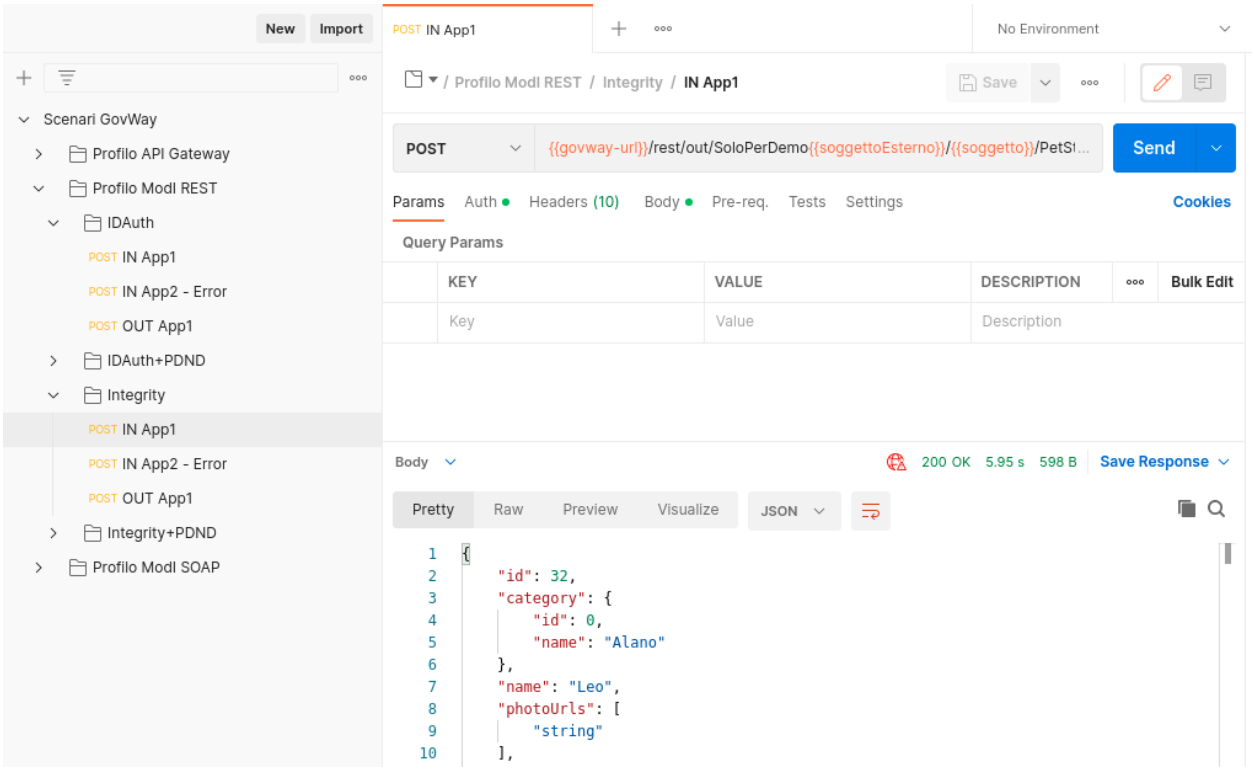


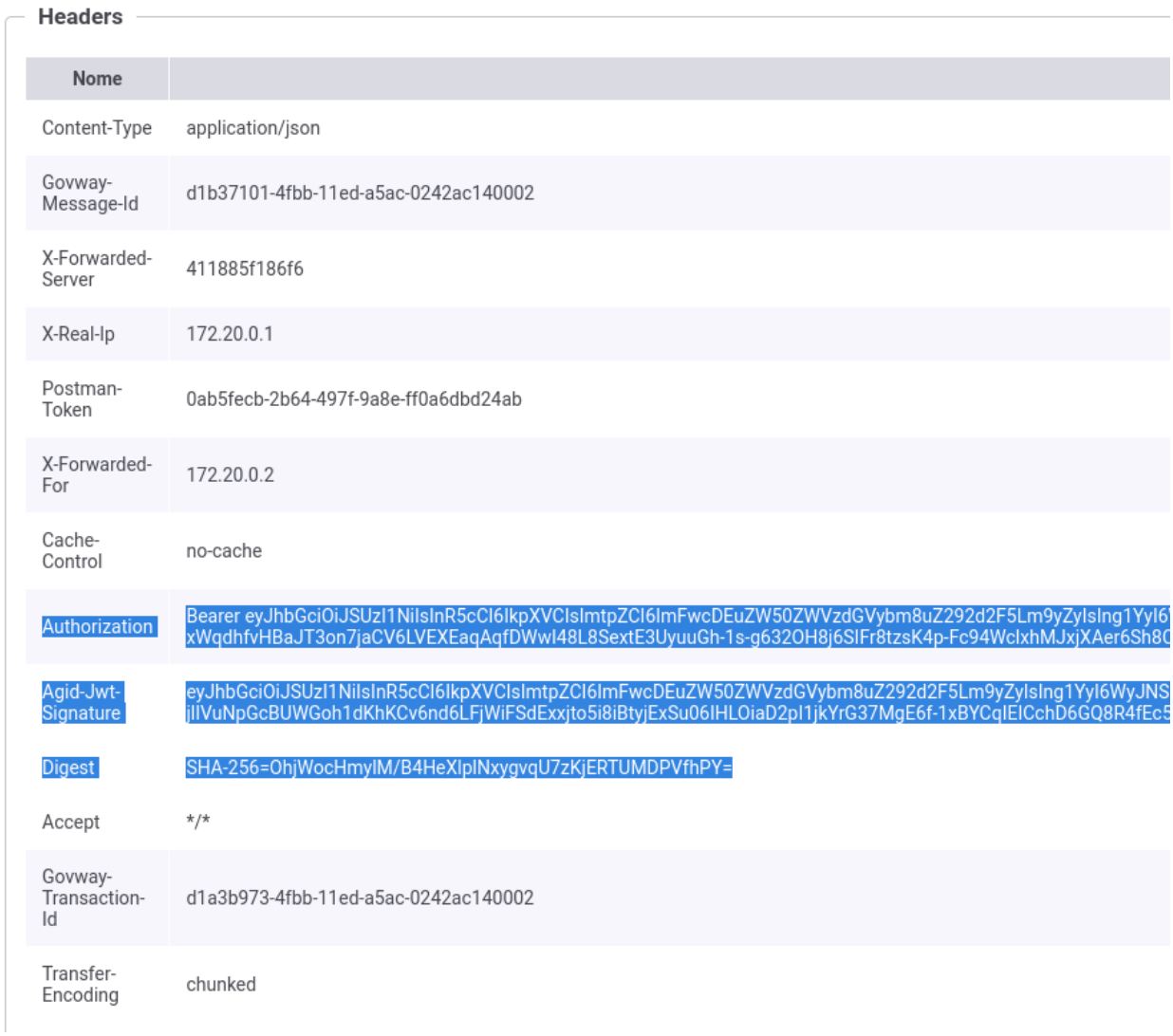
Figure3.48: Pattern Integrity - Erogazione API REST, esecuzione da Postman

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console "govwayMonitor".

Le verifiche da effettuare sono le medesime di quelle descritte nello scenario *Esecuzione*. Di seguito vengono riportati solo i punti salienti in cui emerge una differenza dovuta al pattern di sicurezza diverso utilizzato.

- Dal dettaglio della richiesta si può visualizzare il messaggio che è stato inviato dal fruitore, come in Fig. 3.49.

Come si nota, al payload JSON è associato un insieme di header HTTP tra i quali «Authorization» e «Agid-Jwt-Signature» che contengono rispettivamente il token di sicurezza per l'autenticazione e per l'integrità. È inoltre presente l'header http «Digest» che contiene il valore per la verifica dell'integrità del payload.



Headers

Nome	
Content-Type	application/json
Govway-Message-Id	d1b37101-4fbb-11ed-a5ac-0242ac140002
X-Forwarded-Server	411885f186f6
X-Real-Ip	172.20.0.1
Postman-Token	0ab5fecb-2b64-497f-9a8e-ff0a6dbd24ab
X-Forwarded-For	172.20.0.2
Cache-Control	no-cache
Authorization	Bearer eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6ImFwcDEuZW50ZWVzdGVybm8uZ292d2F5Lm9yZyIsIng1YyI6WyJ xWqdhfvHBaJT3on7jaCV6LVEXEaqAqfDWwI48L8SextE3UyuuGh-1s-g632OH8j6SIFr8tzsK4p-Fc94WclxhMJxjXAer6Sh8C
Agid-Jwt-Signature	eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6ImFwcDEuZW50ZWVzdGVybm8uZ292d2F5Lm9yZyIsIng1YyI6WyJNS jIlVuNpGcBUWGoh1dKhKCv6nd6LFjWiFSdExxjto5i8iBtyjExSu06IHLOiaD2pI1jkYrG37MgE6f-1xBYCqIElCchD6GQ8R4fEc5
Digest	SHA-256=OhjWocHmyIM/B4HeXlpINxygvqU7zKjERTUMDPVfhPY=
Accept	*/*
Govway-Transaction-Id	d1a3b973-4fbb-11ed-a5ac-0242ac140002
Transfer-Encoding	chunked

Figure3.49: Messaggio inviato dal fruitore

- Grazie alle configurazioni presenti nell'erogazione, ed in particolare alla relazione di trust stabilita con il fruitore, Govway è in grado di validare i dati di sicurezza ricevuti andando a decodificare il token. Nella fase di validazione del token si può notare come la sezione header (Fig. 3.50) di entrambi i token «Authorization» e «Agid-Jwt-Signature» riportano l'identità del fruitore e il suo certificato X.509.
- Il messaggio ricevuto dal Govway viene quindi validato, sulla base dei pattern di sicurezza previsti nello scambio, verificando in questo caso l'identità del fruitore, la validità temporale, la corrispondenza dell'audience ricevuto con quello atteso e la corrispondenza del digest con il payload e con il valore interno al token «Agid-Jwt-Signature». Solo in caso di superamento dell'intero processo di validazione, il messaggio viene inoltrato al servizio erogatore. Le evidenze del processo di validazione sono visibili sulla govwayMonitor, andando a consultare la traccia del messaggio di richiesta (Fig. 3.53). Nella sezione «Sicurezza Messaggio» sono riportate le informazioni estratte dai token di sicurezza presenti, tra cui si può notare il digest e gli header http firmati.
- Lo scenario è preconfigurato per autorizzare puntualmente l'applicativo "App1-ModI" identificato grazie al

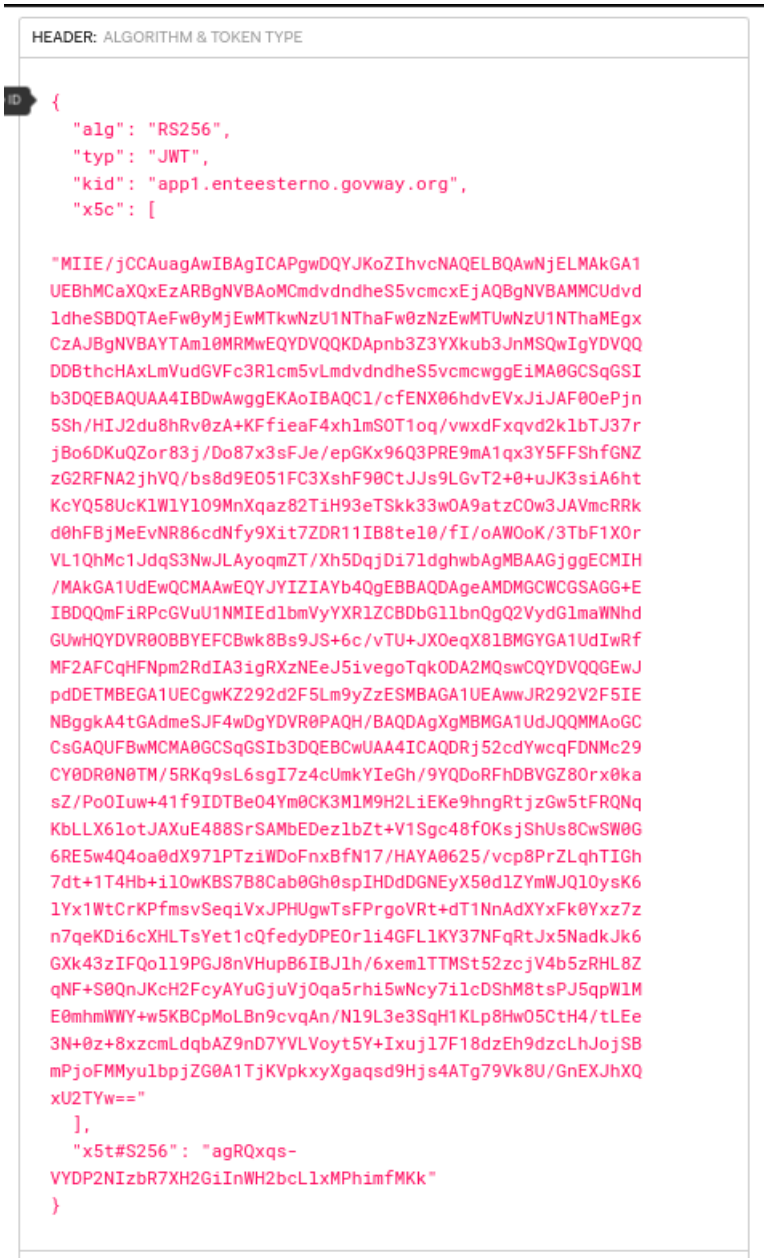


Figure3.50: Sezione «Header» del Token di sicurezza «Authorization» e «Agid-Jwt-Signature»

I payload dei due token invece differiscono (Fig. 3.51 e Fig. 3.52). In entrambi sono presenti i riferimenti temporali (iat, nbf, exp) e l'audience (aud), mentre solamente nel payload del token «Agid-Jwt-Signature» è presente il claim "signed_headers" utilizzato per la verifica dell'integrità.

PAYLOAD: DATA


```
{
  "iat": 1666176318,
  "nbf": 1666176318,
  "exp": 1666176378,
  "jti": "1f46c4b4-4f9b-11ed-a5ac-0242ac140002",
  "aud": "petstore.ente.govway.org",
  "client_id": "app1.enteesterno.govway.org",
  "iss": "SoloPerDemoEnteEsterno",
  "sub": "SoloPerDemoFirmatarioApp1"
}
```


Figure3.51: Sezione «Payload» del Token di sicurezza «Authorization»

PAYLOAD: DATA


```
{
  "iat": 1666190361,
  "nbf": 1666190361,
  "exp": 1666190421,
  "jti": "d1b37101-4fbb-11ed-a5ac-0242ac140002",
  "aud": "petstore.ente.govway.org",
  "client_id": "app1.enteesterno.govway.org",
  "iss": "SoloPerDemoEnteEsterno",
  "sub": "SoloPerDemoFirmatarioApp1",
  "signed_headers": [
    {
      "digest": "SHA-
256=OhjWocHmylM/B4HeXlplNxygvqU7zKjERTUMDPVfhPY="
    },
    {
      "content-type": "application/json"
    }
  ]
}
```


Figure3.52: Sezione «Payload» del Token di sicurezza «Agid-Jwt-Signature»

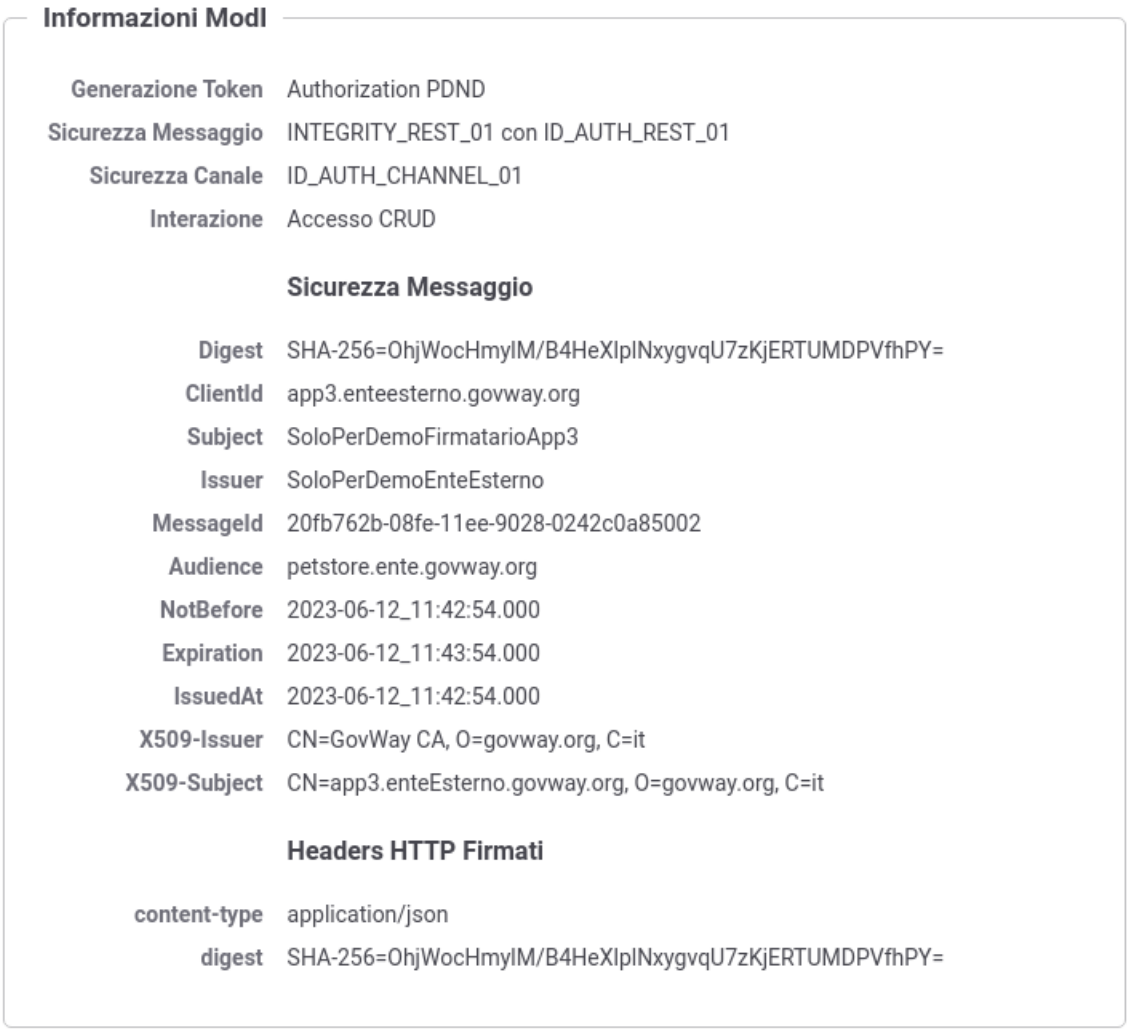


Figure3.53: Traccia della richiesta elaborata dall'erogatore

certificato X.509 presente all'interno del token. È possibile utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - Integrity - IN App2 - Error» per verificare che una richiesta proveniente da un differente applicativo non viene autorizzata.

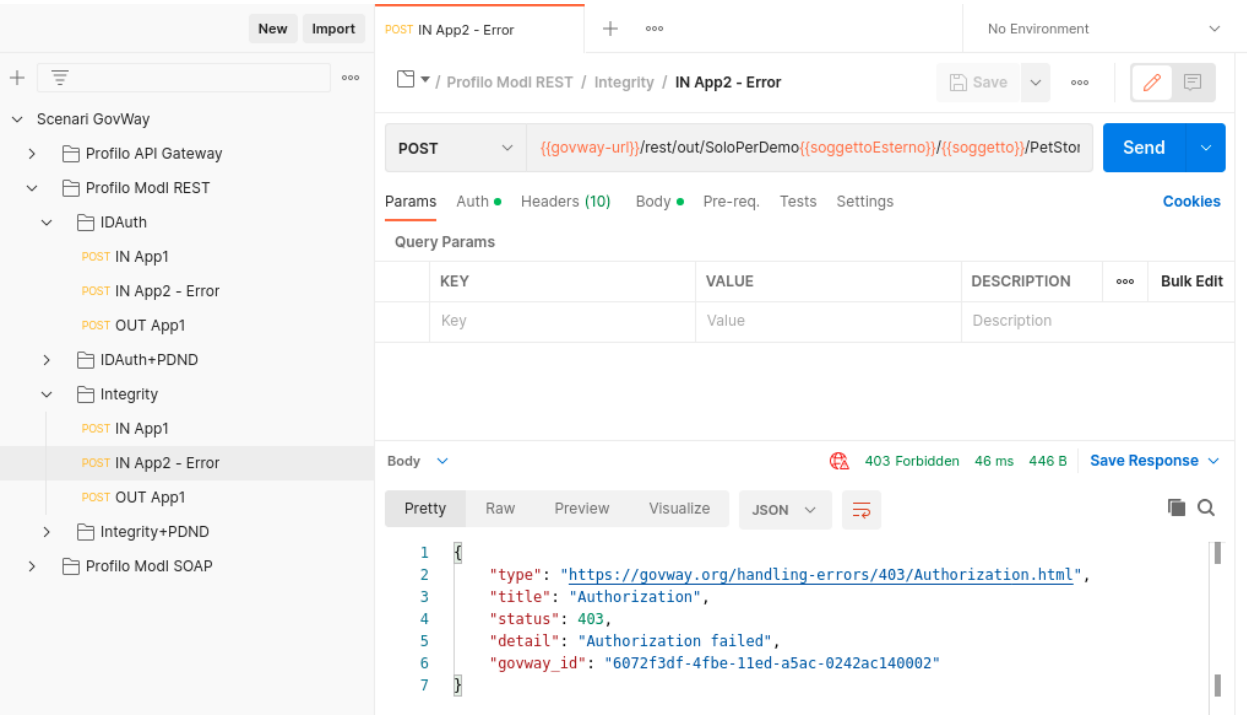


Figure3.54: Pattern Integrity - Erogazione API REST - Autorizzazione negata, esecuzione da Postman

Conformità ai requisiti ModI

I requisiti iniziali, legati alla comunicazione basata su uno scenario ModI, sono verificati dalle seguenti evidenze:

1. la trasmissione è basata sul pattern «ID_AUTH_CHANNEL_02», riguardo la sicurezza canale, come evidenziato nei messaggi diagnostici dalla presenza degli elementi dell'handshake SSL e relativi dati dei certificati scambiati (Fig. 3.5);
2. la sicurezza messaggio applicata è quella dei pattern «ID_AUTH_REST_02» e «INTEGRITY_REST_01» come ampiamente mostrato nelle tracce dei messaggi di richiesta e risposta, dove sono presenti i certificati degli applicativi e le firme dei payload (e le relative validazioni);
3. l'identificazione del fruitore avviene rispetto al certificato X.509 presente all'interno del token. È stato anche mostrato come sia possibile configurare criteri autorizzativi puntuali.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.55: Profilo ModI della govwayConsole

La configurazione dello scenario è del tutto analogo a quello descritto nello scenario *Configurazione* con le sole differenze dovuto al differente pattern di sicurezza utilizzato «INTEGRITY_REST_01 con ID_AUTH_REST_01».

Registrazione API

Viene registrata l'API «PetStoreIntegrity» con il relativo descrittore OpenAPI 3. Vengono selezionati i pattern «ID_AUTH_CHANNEL_02» (sicurezza canale) e «INTEGRITY_REST_01 con ID_AUTH_REST_01» (sicurezza messaggio) nella sezione «ModI» (Fig. 3.56).

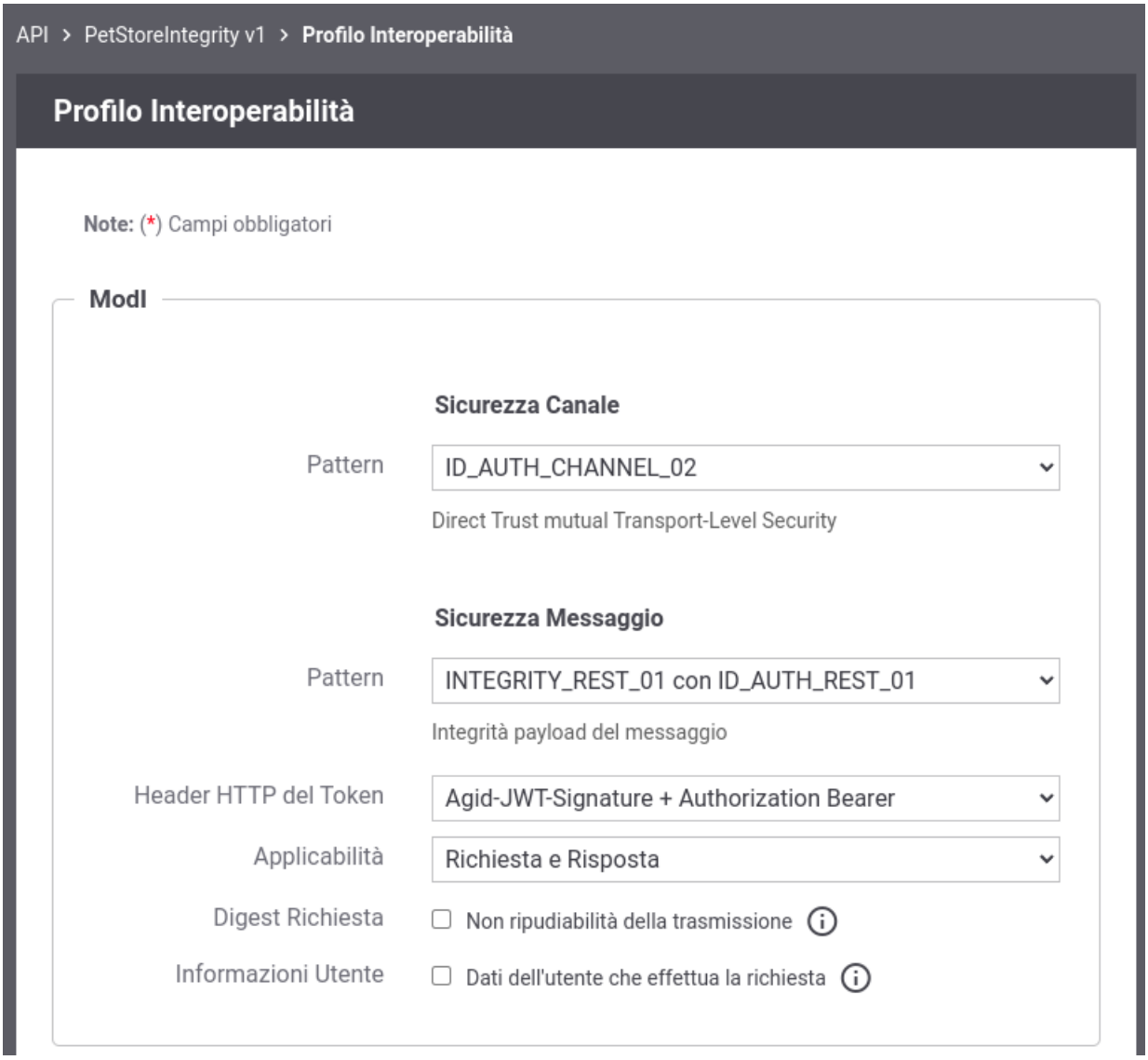


Figure3.56: Configurazione Pattern ModI «INTEGRITY_REST_01 con ID_AUTH_REST_01» sulla API REST

Erogazione

Si registra l'erogazione «PetStoreIntegrity», relativa all'API precedentemente inserita, indicando i dati specifici nella sezione «ModI Richiesta» (Fig. 3.57). In questo contesto vengono inseriti i dati necessari per validare le richieste in ingresso.

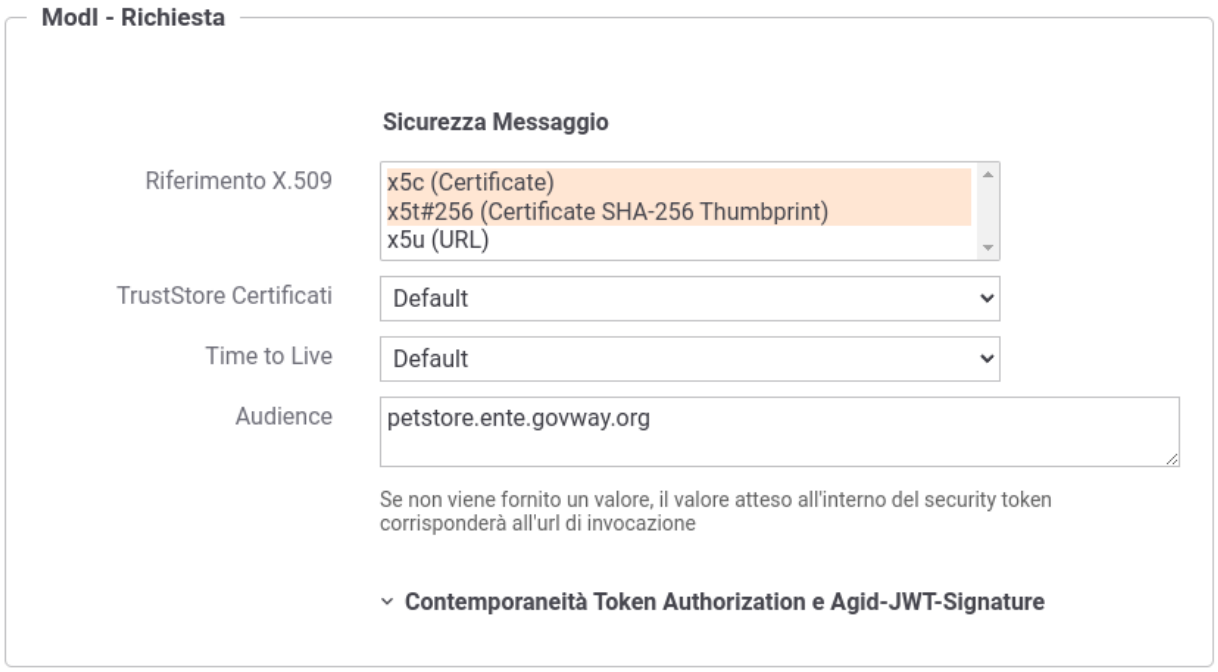


Figure3.57: Configurazione richiesta dell'erogazione

La sezione «ModI Risposta» si utilizza per indicare i parametri per la produzione del token di sicurezza da inserire nel messaggio di risposta (Fig. 3.58).

3.2.2 Fruizione API REST

Obiettivo

Fruire di un servizio REST, definito tramite una API REST (OpenAPI 3.0), accessibile in accordo al pattern di sicurezza "INTEGRITY_REST_01" descritto nella sezione modipa_idar03.

Sintesi

Mostriamo in questa sezione come procedere per l'integrazione di un applicativo con un servizio REST erogato nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario, tra quelli prospettati nel Modello di Interoperabilità di AGID, che prevede oltre a garantire l'autenticazione dell'interlocutore un supporto a garanzia dell'integrità del messaggio.

La figura seguente descrive graficamente questo scenario.

Le caratteristiche principali di questo scenario sono:

1. un applicativo fruitore che dialoga con il servizio erogato in modalità ModI in accordo ad una API condivisa;
2. la comunicazione diretta verso il dominio erogatore veicolata su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_02»;
3. l'autenticità della comunicazione tra fruitore ed erogatore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01»;

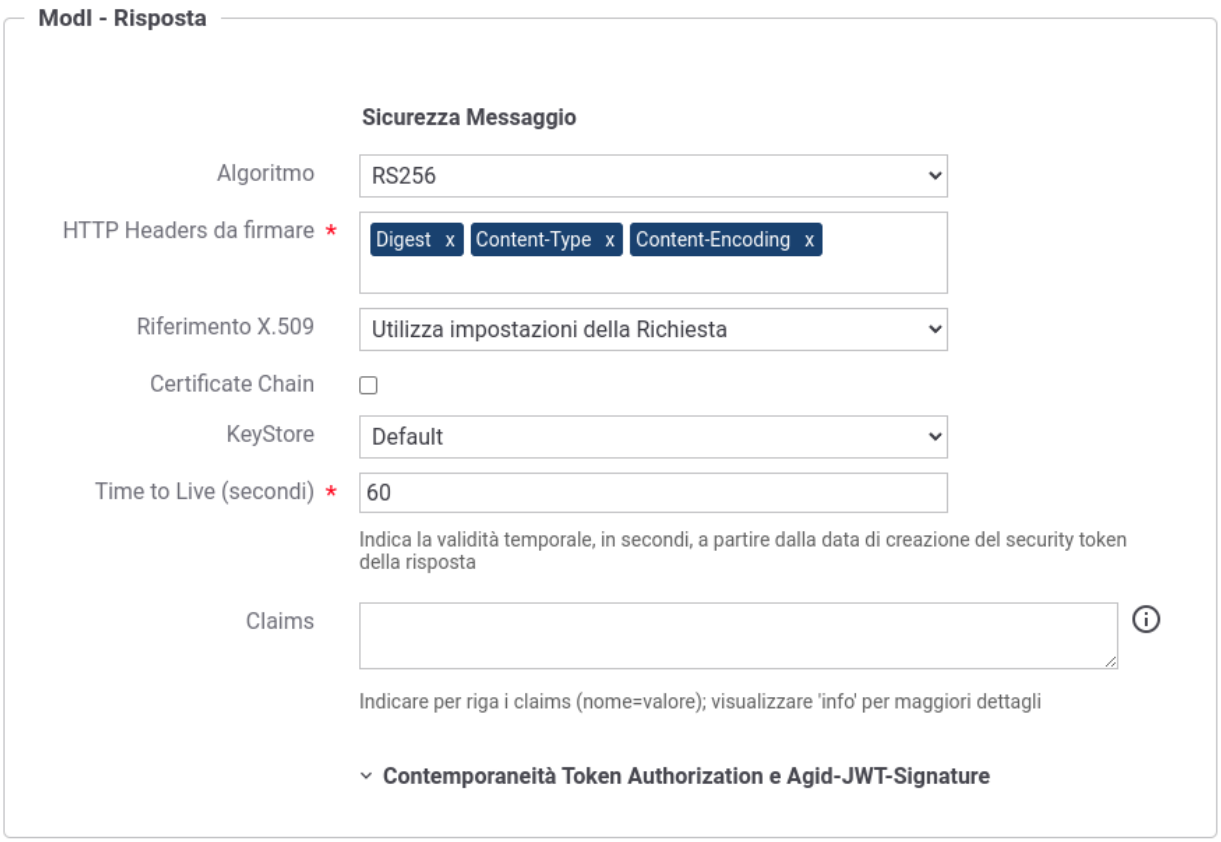


Figure3.58: Configurazione risposta dell'erogazione

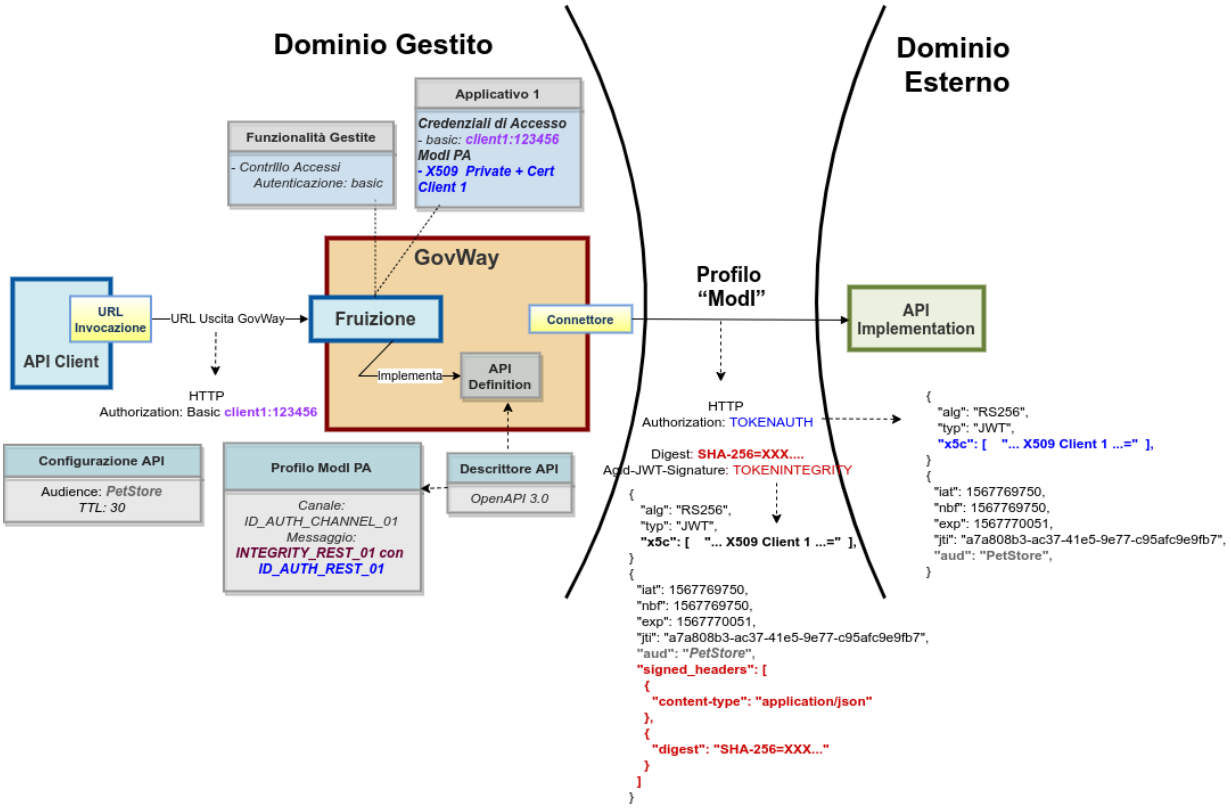


Figure3.59: Fruizione di una API REST con profilo "Modl", pattern INTEGRITY_REST_01 con ID_AUTH_REST_01

4. l'integrità del messaggio scambiato è garantita tramite sicurezza messaggio aggiuntiva prevista nel pattern «INTEGRITY_REST_01».

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.60: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione* con la sola eccezione del pattern di sicurezza utilizzato che in questo scenario è «INTEGRITY_REST_01 con ID_AUTH_REST_01».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - Integrity - OUT App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

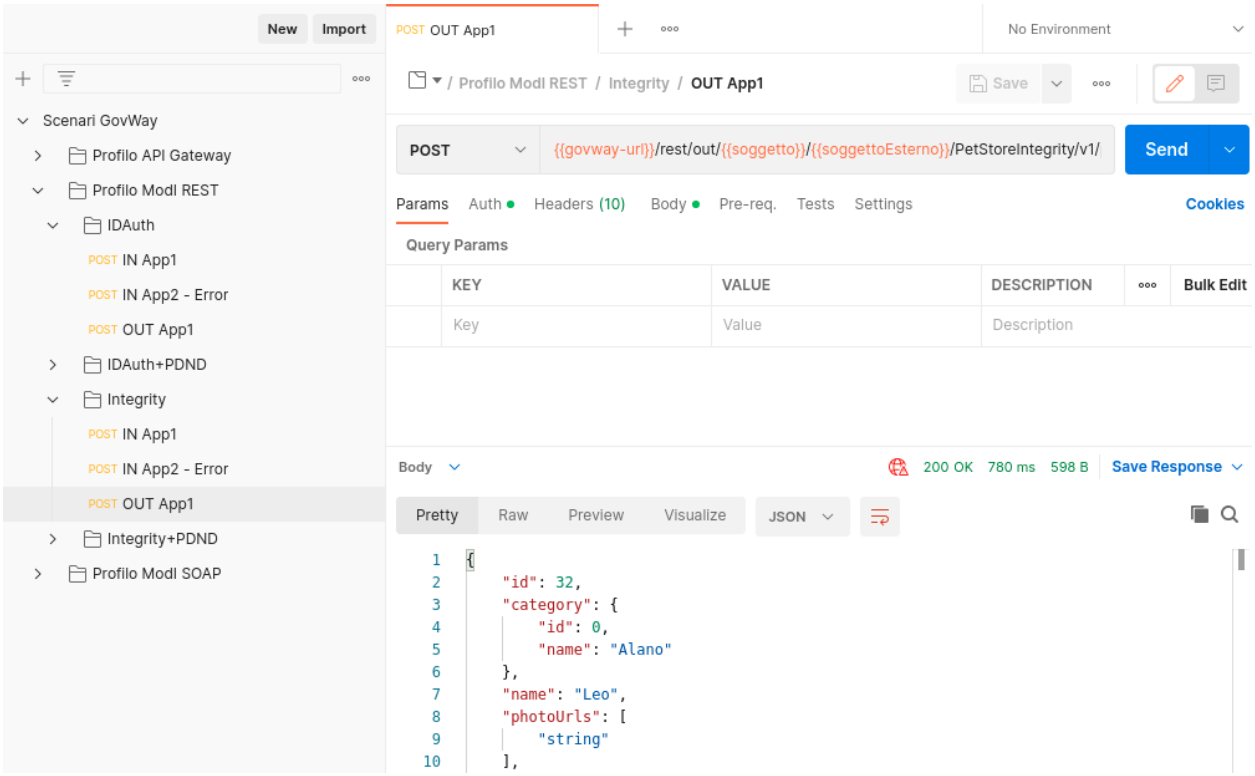


Figure3.61: Pattern Integrity - Fruizione API REST, esecuzione da Postman

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto nelle diverse fasi dell'esecuzione andando a consultare la console "govwayMonitor".

Le verifiche da effettuare sono le medesime di quelle descritte nello scenario *Esecuzione*. Di seguito vengono riportati solo i punti salienti in cui emerge una differenza dovuta al pattern di sicurezza diverso utilizzato.

- Il messaggio di richiesta inviato dal fruitore viene elaborato da Govway che, tramite la configurazione della firma digitale associata all'applicativo mittente, è in grado di produrre il token di sicurezza da inviare con la richiesta all'erogatore. Da govwayMonitor si può visualizzare il messaggio di richiesta in uscita che è il medesimo di quello in entrata con la differenza che sono stati aggiunti gli header HTTP «Authorization» e «Agid-Jwt-Signature» che contengono rispettivamente il token di sicurezza per l'autenticazione e per l'integrità. È inoltre presente l'header http «Digest» che contiene il valore utilizzabile dall'erogatore per la verifica dell'integrità del payload. (Fig. 3.62).

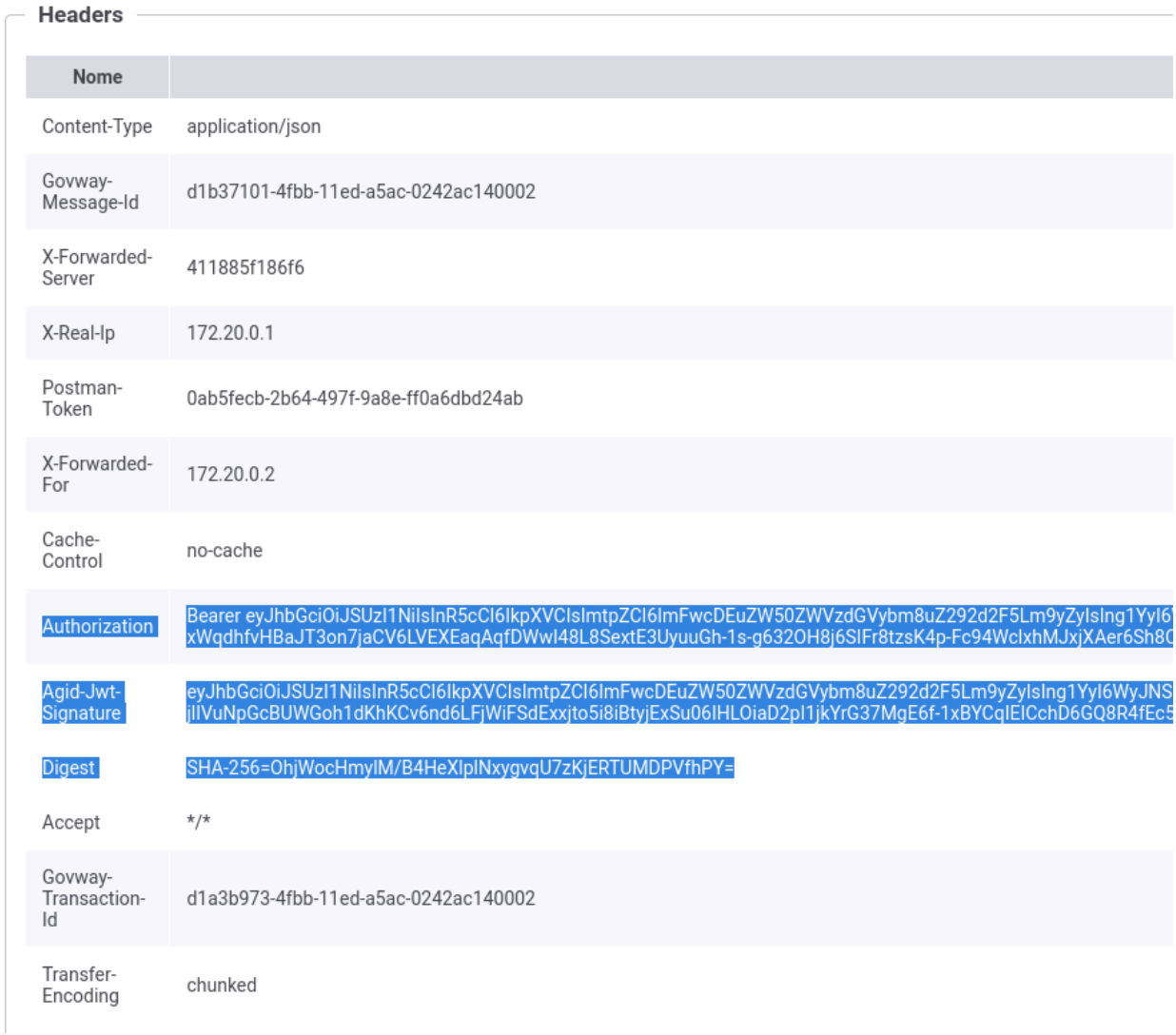


Figure3.62: Messaggio di richiesta in uscita (con token di sicurezza inseriti nell'header HTTP)

- L'header e i payload dei token sono identici a quelli visualizzati nello scenario di erogazione REST, relativamente al messaggio in ingresso (Fig. 3.50, Fig. 3.51 e Fig. 3.52). Le informazioni inserite nel token vengono anche tracciate e sono visibili sulla govwayMonitor, andando a consultare la traccia del messaggio di richiesta (Fig. 3.63). Nella sezione «Sicurezza Messaggio» sono riportate le informazioni estratte dai token di sicurezza, tra cui si può notare il digest e gli header http firmati.

Conformità ai requisiti ModI

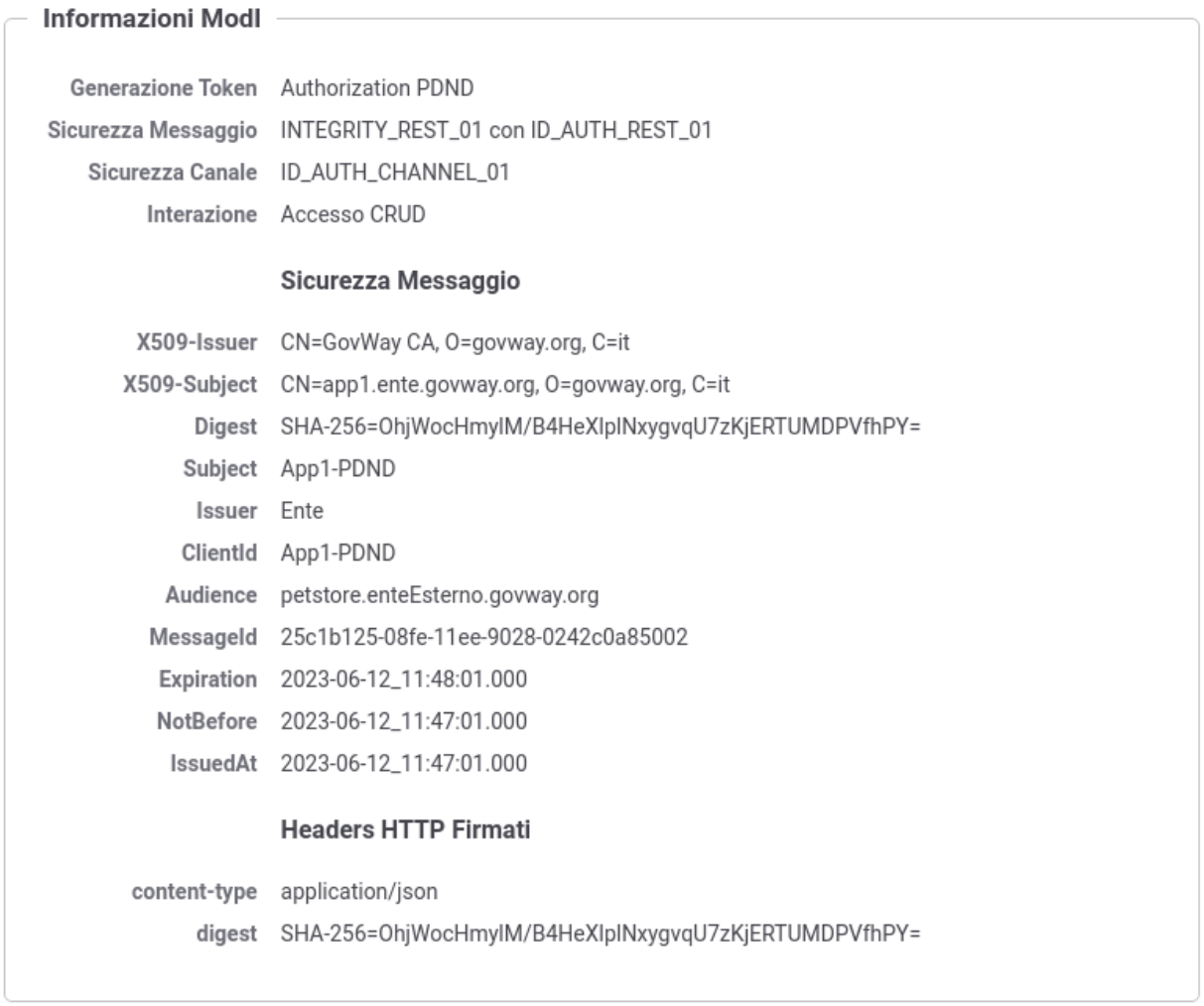


Figure3.63: Traccia della richiesta generata dal fruitore

I requisiti iniziali, legati alla comunicazione basata su uno scenario ModI, sono verificati dalle seguenti evidenze:

1. la trasmissione è basata sul pattern «ID_AUTH_CHANNEL_02», riguardo la sicurezza canale, come evidenziato nei messaggi diangostici dalla presenza degli elementi dell'handshake SSL e relativi dati dei certificati scambiati (Fig. 3.23);
2. la sicurezza messaggio applicata è quella dei pattern «ID_AUTH_REST_02» e «INTEGRITY_REST_01», come ampiamente mostrato nelle tracce dei messaggi di richiesta e risposta, dove sono presenti i certificati degli applicativi e le firme dei payload (e le relative validazioni).

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità «ModI». Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.64: Profilo ModI della govwayConsole

La configurazione dello scenario è del tutto analogo a quello descritto nello scenario *Configurazione* con le sole differenze dovuto al differente pattern di sicurezza utilizzato «INTEGRITY_REST_01 con ID_AUTH_REST_01».

Registrazione API

Viene registrata l'API «PetStoreIntegrity» con il relativo descrittore OpenAPI 3. Vengono selezionati i pattern «ID_AUTH_CHANNEL_02» (sicurezza canale) e «INTEGRITY_REST_01 con ID_AUTH_REST_01» (sicurezza messaggio) nella sezione «ModI» (Fig. 3.65).

Fruizione

Si registra la fruizione «PetStoreIntegrity», relativa all'API precedentemente inserita, indicando i dati specifici nella sezione «ModI Richiesta» (Fig. 3.66). In particolare è possibile specificare l'audience atteso dall'erogatore e il tempo di validità del token.

La sezione «ModI Risposta» definisce i criteri per la validazione dei messaggi di risposta, come la posizione del token di sicurezza e il truststore per l'autenticazione dell'erogatore (Fig. 3.67).

3.2.3 Erogazione API SOAP

Obiettivo

Esporre un servizio SOAP, definito tramite una interfaccia WSDL, accessibile in accordo al pattern di sicurezza "INTEGRITY_SOAP_01" descritto nella sezione modipa_idar03.

Sintesi

Mostriamo in questa sezione come procedere per l'esposizione di un servizio SOAP da erogare nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario, tra quelli prospettati nel Modello di Interoperabilità di AGID, che prevede oltre a garantire l'autenticazione dell'interlocutore un supporto a garanzia dell'integrità del messaggio.

La figura seguente descrive graficamente questo scenario.

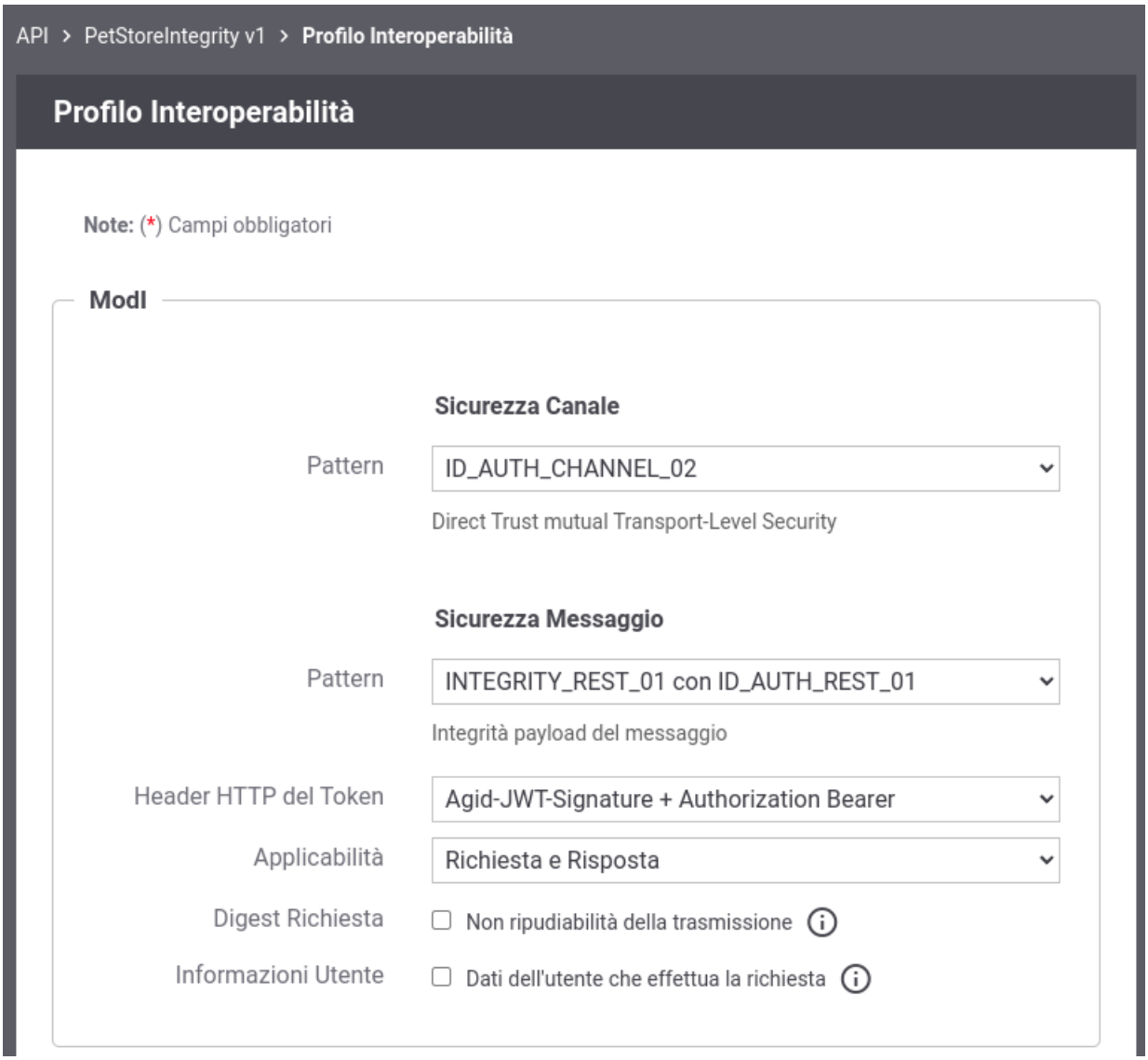


Figure3.65: Configurazione Pattern ModI «INTEGRITY_REST_01 con ID_AUTH_REST_01» sulla API

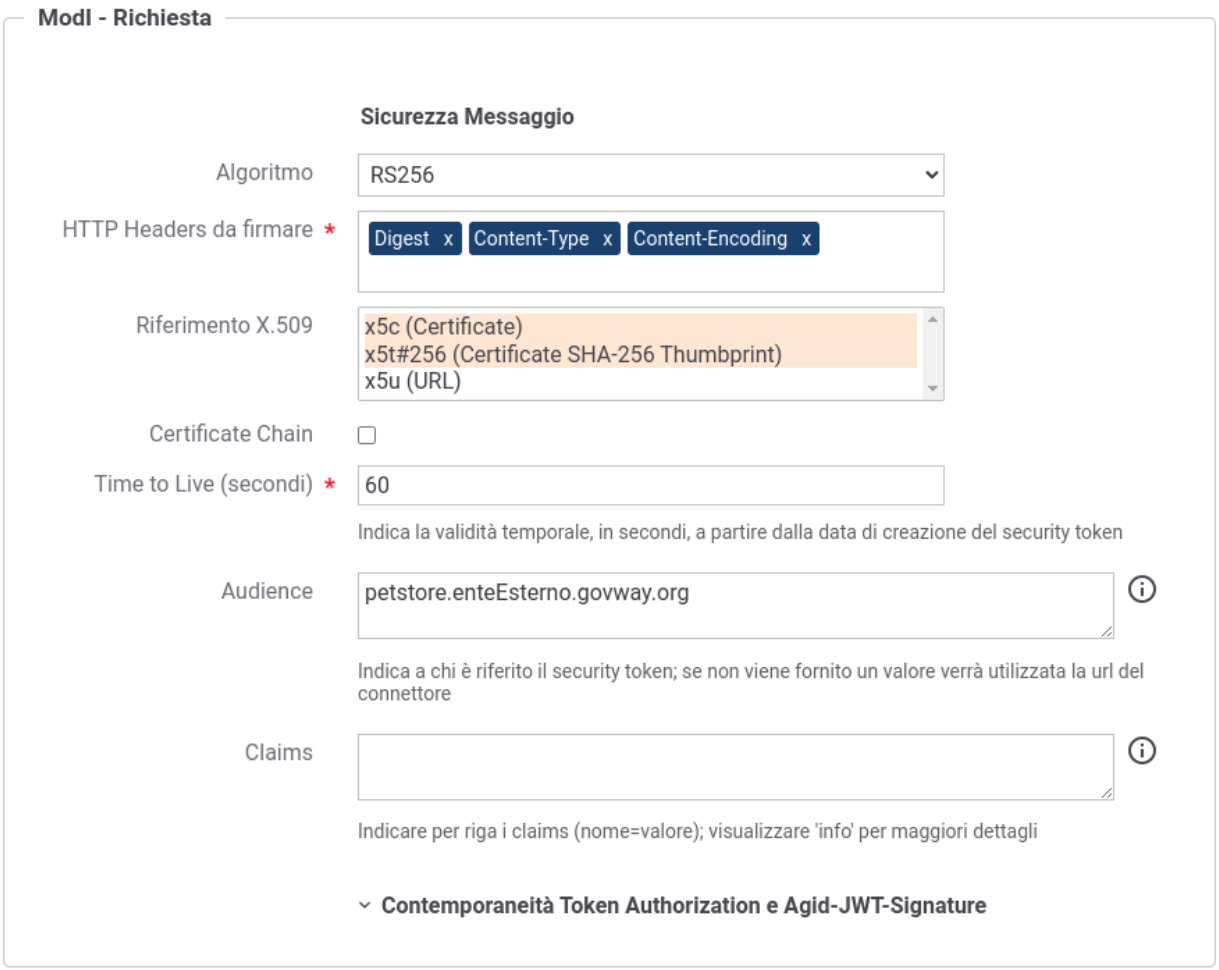


Figure3.66: Configurazione richiesta della fruizione

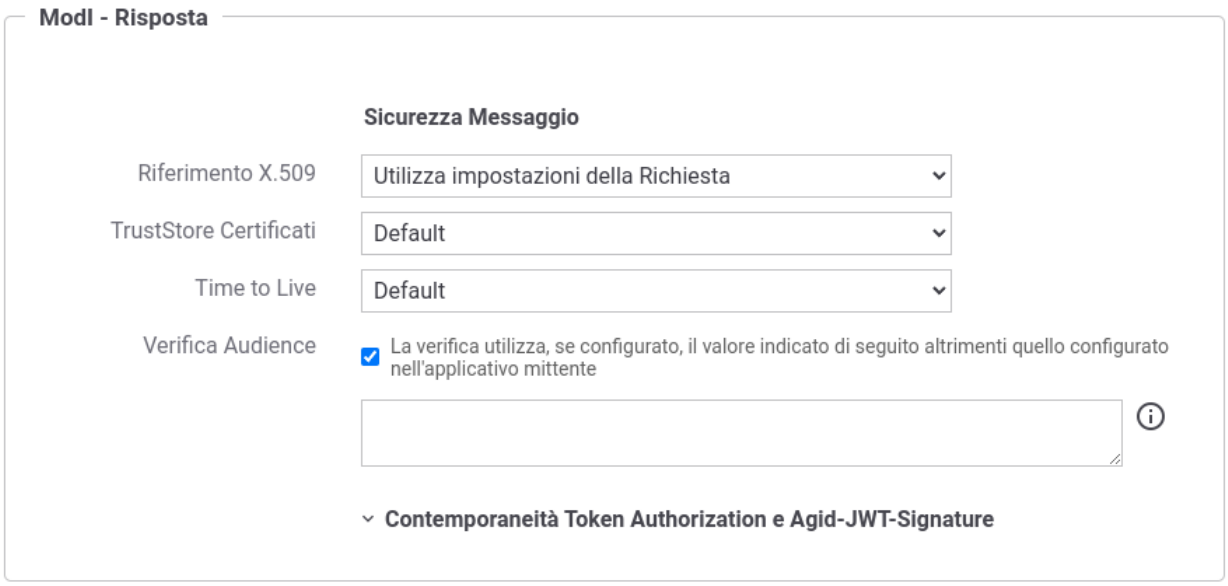


Figure3.67: Configurazione risposta della fruizione

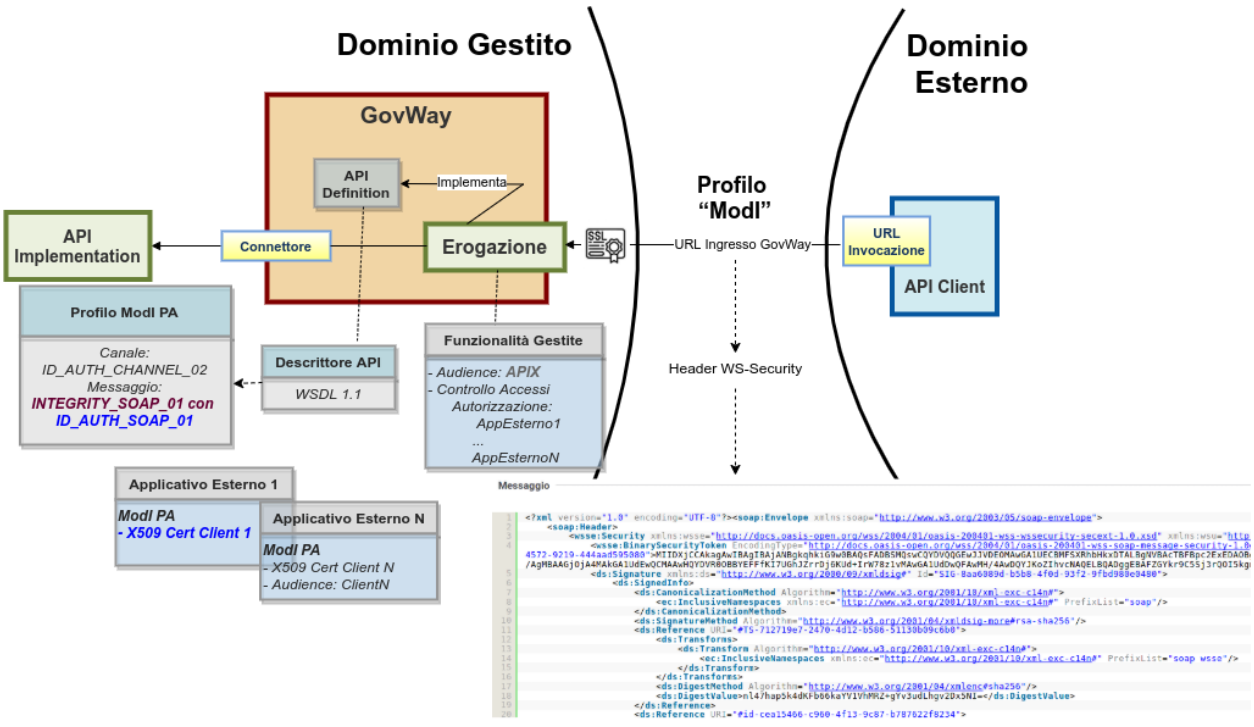


Figure3.68: Erogazione di una API SOAP con profilo "ModI", pattern INTEGRITY_SOAP_01 con ID_AUTH_SOAP_01

Le caratteristiche principali di questo scenario sono:

1. un applicativo eroga un servizio, rivolto a fruitori di domini esterni, in conformità al Modello di Interoperabilità AGID;
2. la comunicazione con i domini esterni avviene su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_02»;
3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_SOAP_01»;
4. l'integrità del messaggio scambiato è garantita tramite sicurezza messaggio aggiuntiva prevista nel pattern «INTEGRITY_SOAP_01».

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.69: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione* con la sola eccezione del pattern di sicurezza utilizzato che in questo scenario è «INTEGRITY_SOAP_01 con ID_AUTH_SOAP_01».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI SOAP - Integrity - IN App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console govwayMonitor.

Le verifiche da effettuare sono le medesime di quelle descritte nello scenario *Esecuzione*. Di seguito vengono riportati solo i punti salienti in cui emerge una differenza dovuta al pattern di sicurezza diverso utilizzato.

- Dal dettaglio della richiesta si può visualizzare il messaggio che è stato inviato dal fruitore, come in Fig. 3.32. Come si nota, il messaggio SOAP contiene nell'header WS-Security sia il token di sicurezza (elemento «BinarySecurityToken») sia l'elemento «WSAddressing - To» e il digest del payload (elemento «DigestValue») prodotti dal fruitore con la relativa firma digitale (elemento «SignatureValue»).
- Il messaggio ricevuto dal Govway viene quindi validato, sulla base dei pattern di sicurezza previsti nello scambio, verificando in questo caso l'identità del fruitore, la validità temporale, la corrispondenza dell'audience ricevuto con quello atteso e la corrispondenza del digest rispetto al payload. Solo in caso di superamento dell'intero processo di validazione, il messaggio viene inoltrato al servizio erogatore. Le evidenze del processo di validazione sono visibili sulla govwayMonitor, andando a consultare la traccia del messaggio di richiesta (Fig. 3.72). Nella sezione «Sicurezza Messaggio» sono riportate le informazioni estratte dal token di sicurezza presente nell'header soap.
- Lo scenario è preconfigurato per autorizzare puntualmente l'applicativo "App1-ModI" identificato grazie al certificato X.509 presente all'interno dell'header WSSecurity. È possibile utilizzare il progetto Postman a corredo con la request «Profilo ModI SOAP - Integrity - IN App2 - Error» per verificare che una richiesta proveniente da un differente applicativo non viene autorizzata.

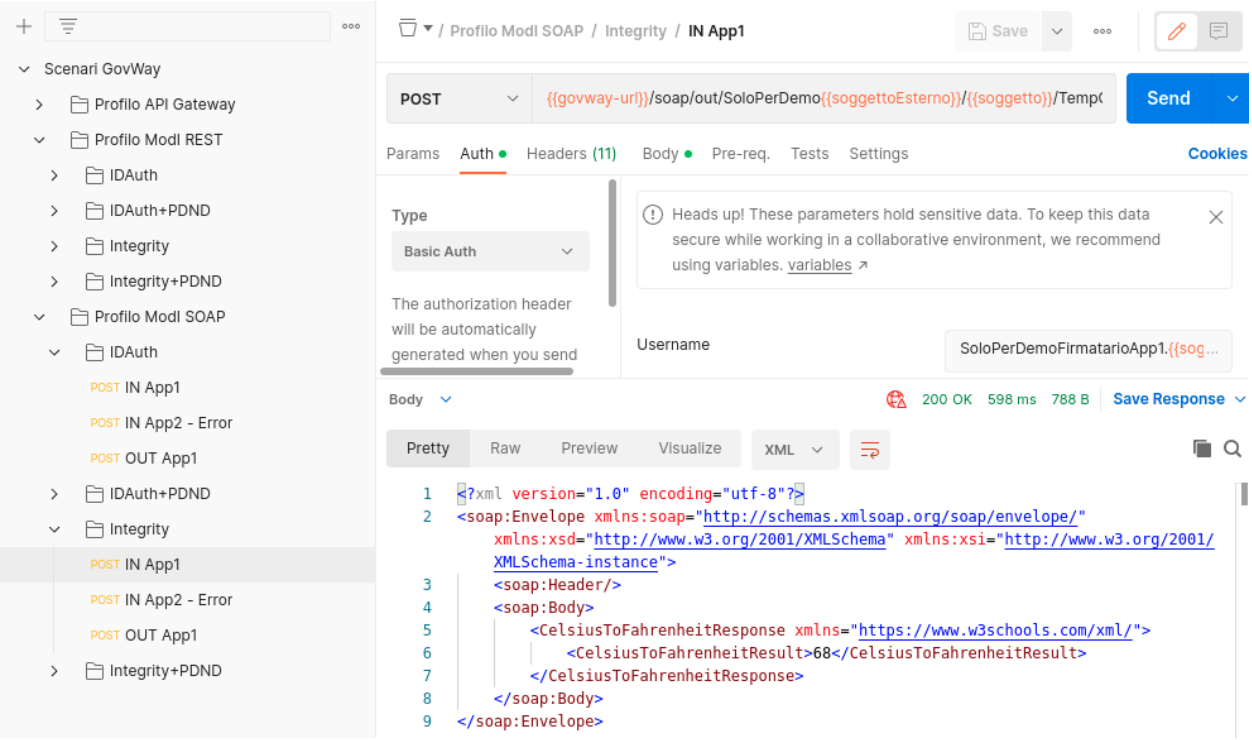


Figure3.70: Pattern Integrity - Erogazione API SOAP, esecuzione da Postman



Figure3.71: Messaggio inviato dal fruitore



Figure3.72: Traccia della richiesta elaborata dall'erogatore

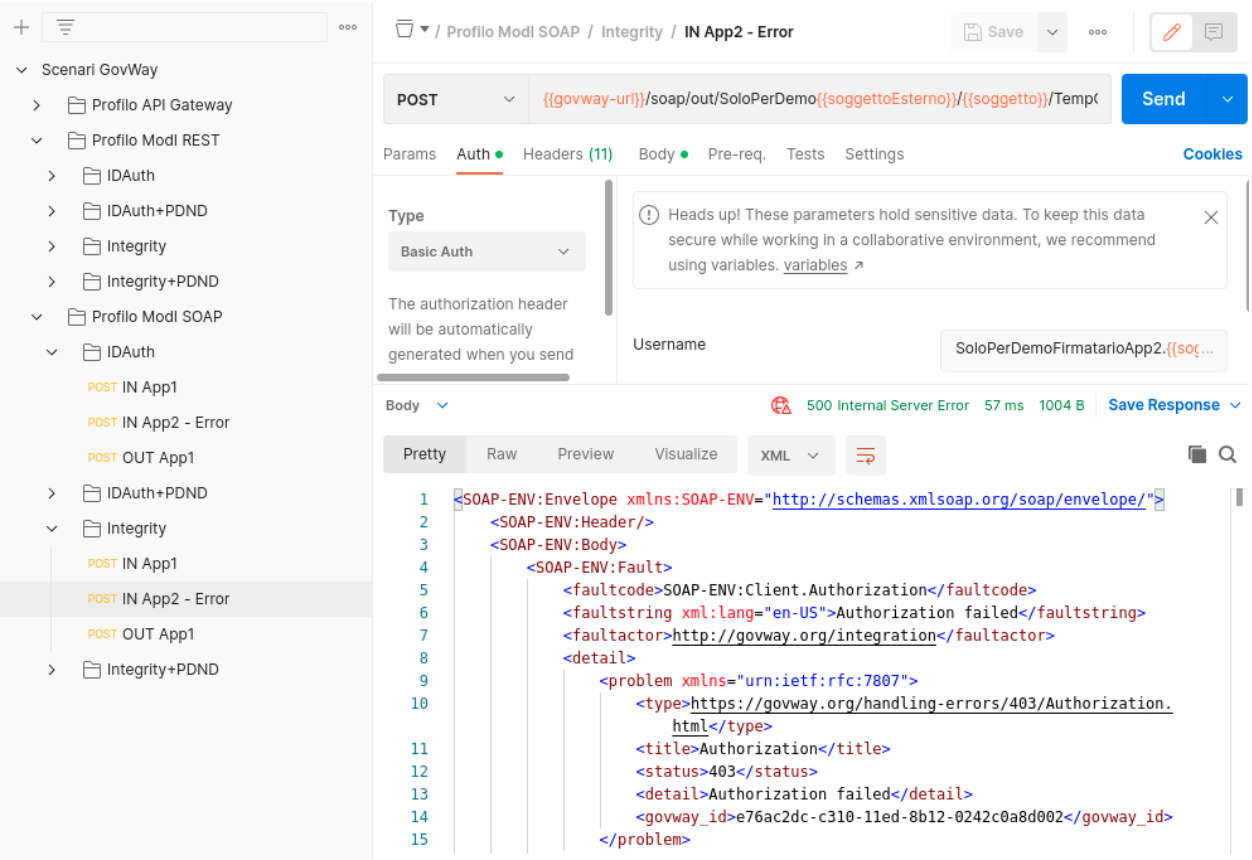


Figure3.73: Pattern Integrity - Erogazione API SOAP - Autorizzazione negata, esecuzione da Postman

Conformità ai requisiti ModI

La verifica dei requisiti ModI per questo scenario non differisce da quanto già descritto in *Esecuzione*.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.74: Profilo ModI della govwayConsole

Il processo di configurazione per questo scenario è del tutto analogo a quello descritto per lo scenario *Configurazione*. Nel seguito sono evidenziate le sole differenze.

L'interfaccia wsdl del servizio soap è ottenibile all'indirizzo "https://www.w3schools.com/xml/tempconvert.asmx?wsdl".

Registrazione API

Viene registrata l'API «TemperatureConversionIntegrity» con il relativo descrittore WSDL. Vengono selezionati i pattern «ID_AUTH_CHANNEL_02» (sicurezza canale) e «INTEGRITY_SOAP_01 con ID_AUTH_SOAP_01» (sicurezza messaggio) nella sezione «ModI» (Fig. 3.75).

Erogazione

Si registra l'erogazione SOAP "TempConvertSoapIntegrity", relativa all'API precedentemente inserita, indicando i dati specifici nella sezione «ModI Richiesta» (Fig. 3.76). In questo contesto vengono inseriti i dati necessari per validare le richieste in ingresso.

La sezione «ModI Risposta» si utilizza per indicare i parametri per la produzione del token di sicurezza da inserire nel messaggio di risposta (Fig. 3.77).

3.2.4 Fruizione API SOAP

Obiettivo

Fruire di un servizio SOAP, definito tramite una interfaccia WSDL, accessibile in accordo al pattern di sicurezza "INTEGRITY_SOAP_01" descritto nella sezione modipa_idar03.

Sintesi

Mostriamo in questa sezione come procedere per l'integrazione di un applicativo con un servizio SOAP erogato nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario, tra quelli prospettati nel Modello di Interoperabilità di AGID, che prevede oltre a garantire l'autenticazione dell'interlocutore un supporto a garanzia dell'integrità del messaggio.

La figura seguente descrive graficamente questo scenario.

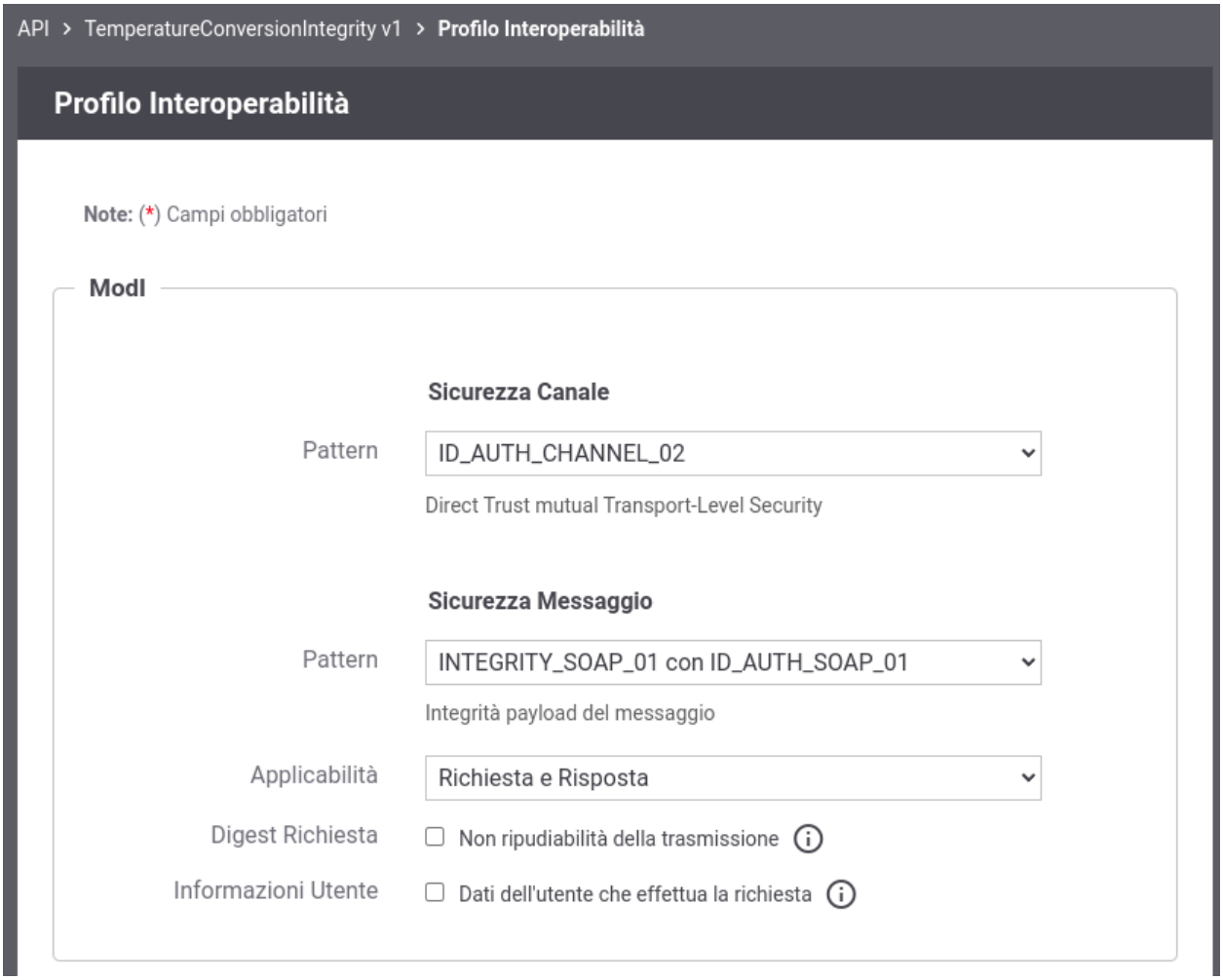


Figure3.75: Configurazione Pattern ModI «INTEGRITY_SOAP_01 con ID_AUTH_SOAP_01» sulla API SOAP



Figure3.76: Configurazione richiesta dell'erogazione

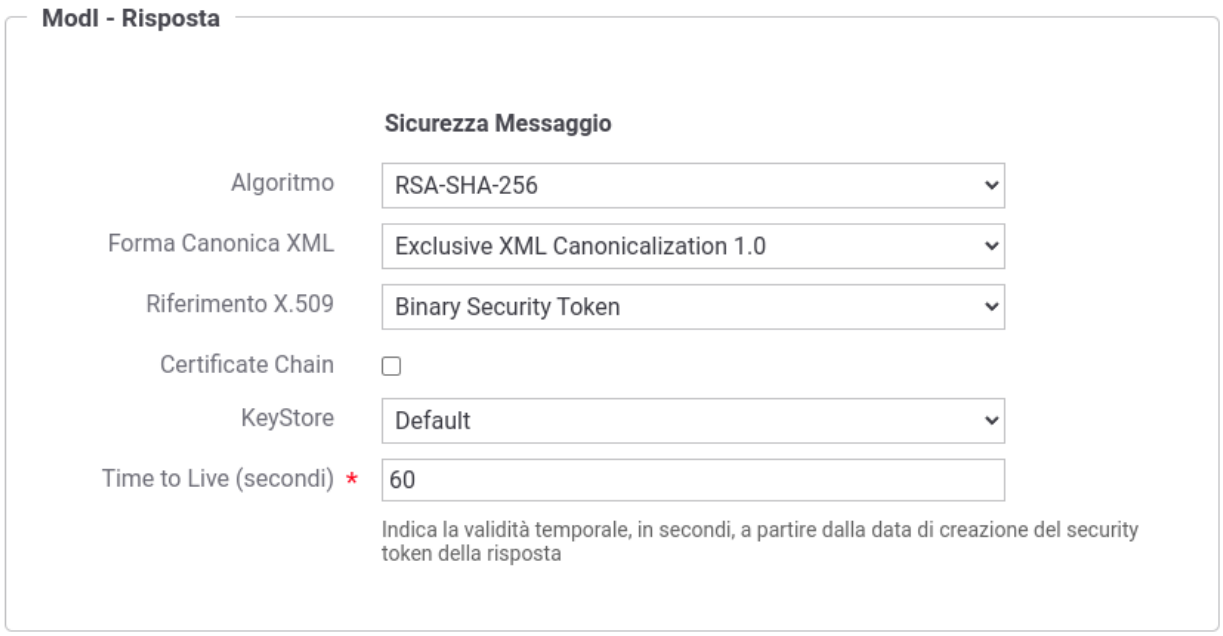


Figure3.77: Configurazione risposta dell'erogazione

Le caratteristiche principali di questo scenario sono:

1. un applicativo fruitore che dialoga con il servizio erogato in modalità ModI in accordo ad una API condivisa;
2. la comunicazione diretta verso il dominio erogatore veicolata su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_02»;
3. l'autenticità della comunicazione tra fruitore ed erogatore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_SOAP_01»;
4. l'integrità del messaggio scambiato è garantita tramite sicurezza messaggio aggiuntiva prevista nel pattern «INTEGRITY_SOAP_01».

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.79: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione* con la sola eccezione del pattern di sicurezza utilizzato che in questo scenario è «INTEGRITY_SOAP_01 con ID_AUTH_SOAP_01».

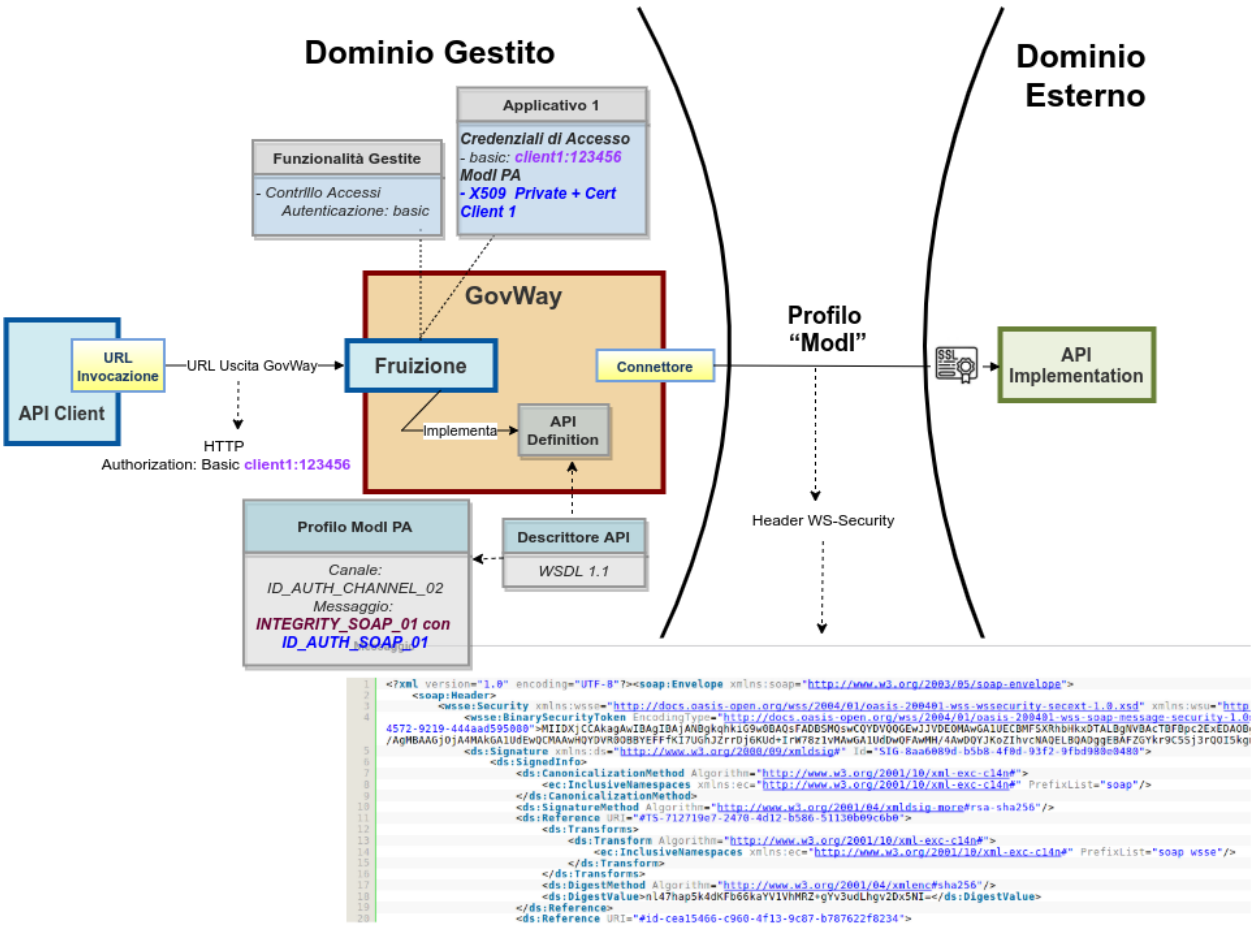


Figure3.78: Fruizione di una API SOAP con profilo "ModI", pattern INTEGRITY_SOAP_01 con ID_AUTH_SOAP_01

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI SOAP - Integrity - OUT App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

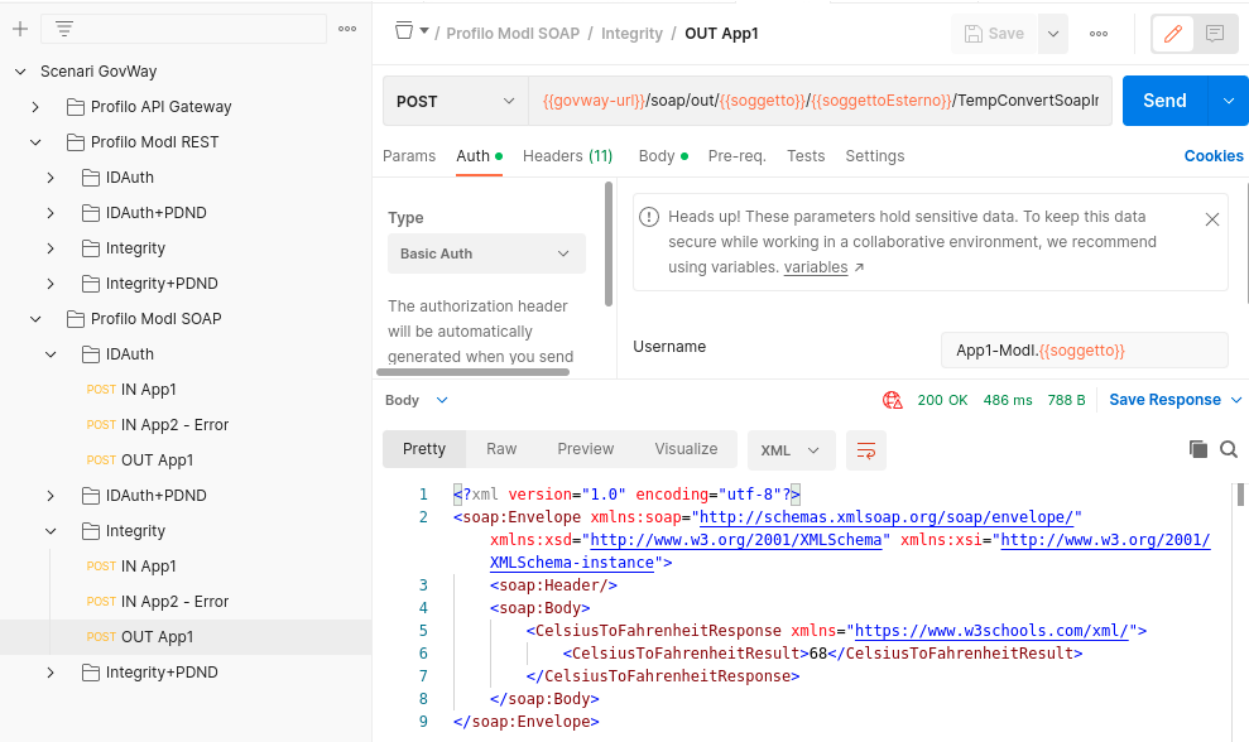


Figure3.80: Pattern Integrity - Fruizione API SOAP, esecuzione da Postman

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console "govwayMonitor".

Le verifiche da effettuare sono le medesime di quelle descritte nello scenario *Esecuzione*.

Conformità ai requisiti ModI

La verifica dei requisiti ModI per questo scenario non differisce da quanto già descritto in *Esecuzione*.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità «ModI». Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.81: Profilo ModI della govwayConsole

La configurazione dello scenario è del tutto analogo a quello descritto nello scenario *Configurazione* con le sole differenze dovuto al differente pattern di sicurezza utilizzato «INTEGRITY_SOAP_01 con ID_AUTH_SOAP_01».

Registrazione API

Viene registrata l'API «TemperatureConversionIntegrity» con il relativo descrittore WSDL. Vengono selezionati i pattern «ID_AUTH_CHANNEL_02» (sicurezza canale) e «INTEGRITY_SOAP_01 con ID_AUTH_SOAP_01» (sicurezza messaggio) nella sezione «ModI» (Fig. 3.82).

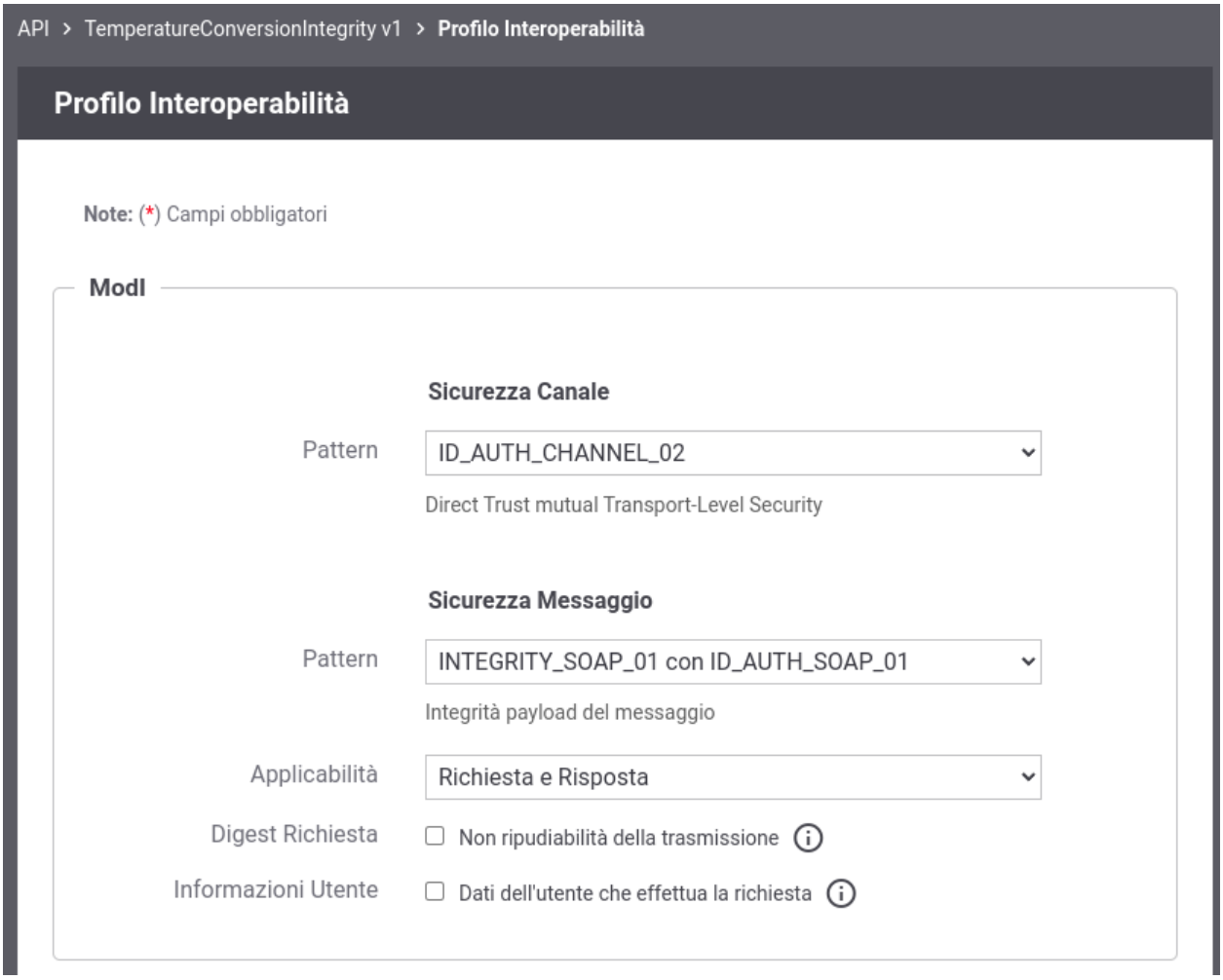


Figure3.82: Configurazione Pattern ModI «INTEGRITY_SOAP_01 con ID_AUTH_SOAP_01» sulla API SOAP

Fruizione

Si registra la fruizione SOAP "TempConvertSoapIntegrity", relativa all'API precedentemente inserita, indicando i dati specifici nella sezione «ModI Richiesta» (Fig. 3.83).

La sezione «ModI Risposta» definisce i criteri per la validazione dei messaggi di risposta (Fig. 3.84).

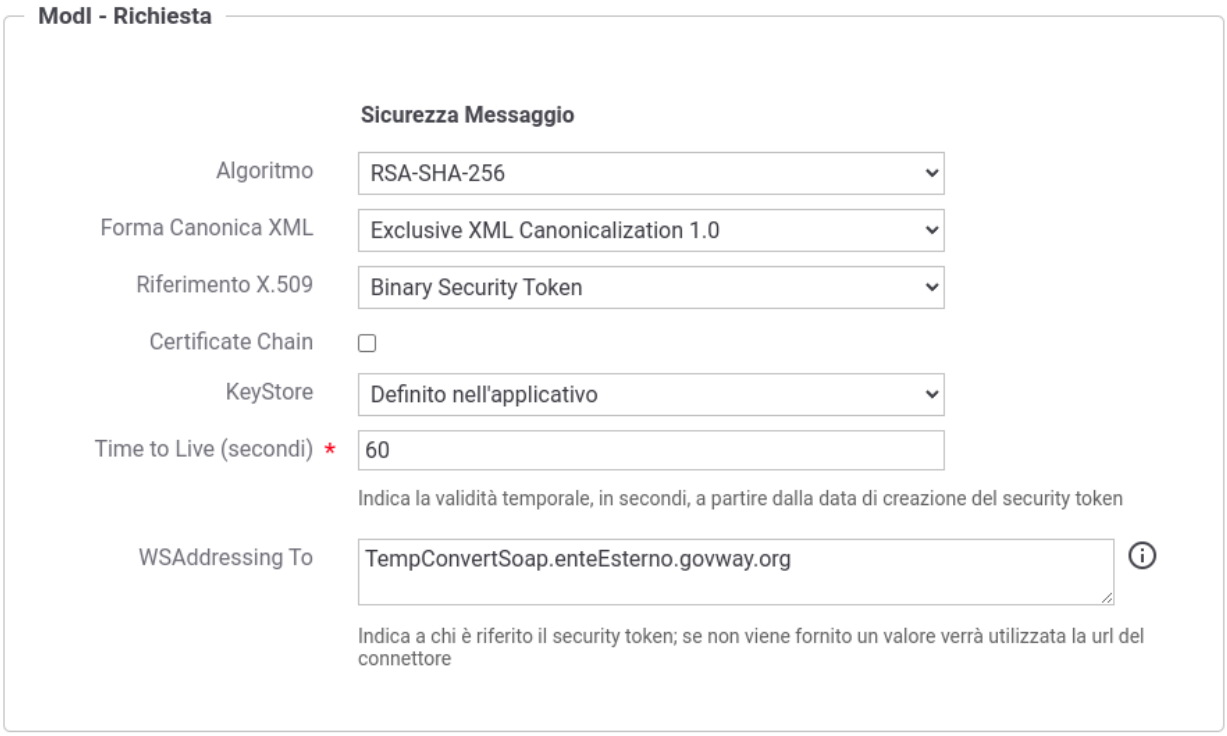


Figure3.83: Configurazione richiesta della fruizione



Figure3.84: Configurazione risposta della fruizione

3.3 Pattern “ID_AUTH” via PDND

Gli scenari riportati in questa sezione riguardano API configurate con pattern modipa_pdnd.

3.3.1 Erogazione API REST

Obiettivo

Esporre un servizio, definito tramite una API REST (OpenAPI 3.0), accessibile in accordo al pattern di sicurezza descritto nella sezione modipa_pdnd.

Sintesi

Mostriamo in questa sezione come procedere per l’esposizione di un servizio REST da erogare nel rispetto della normativa italiana alla base dell’interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui un servizio è stato registrato sulla PDND, e i fruitori per poterlo fruire devono ottenere un voucher dalla PDND che successivamente devono inviare all’erogatore insieme alla normale richiesta di servizio.

La figura seguente descrive graficamente questo scenario.

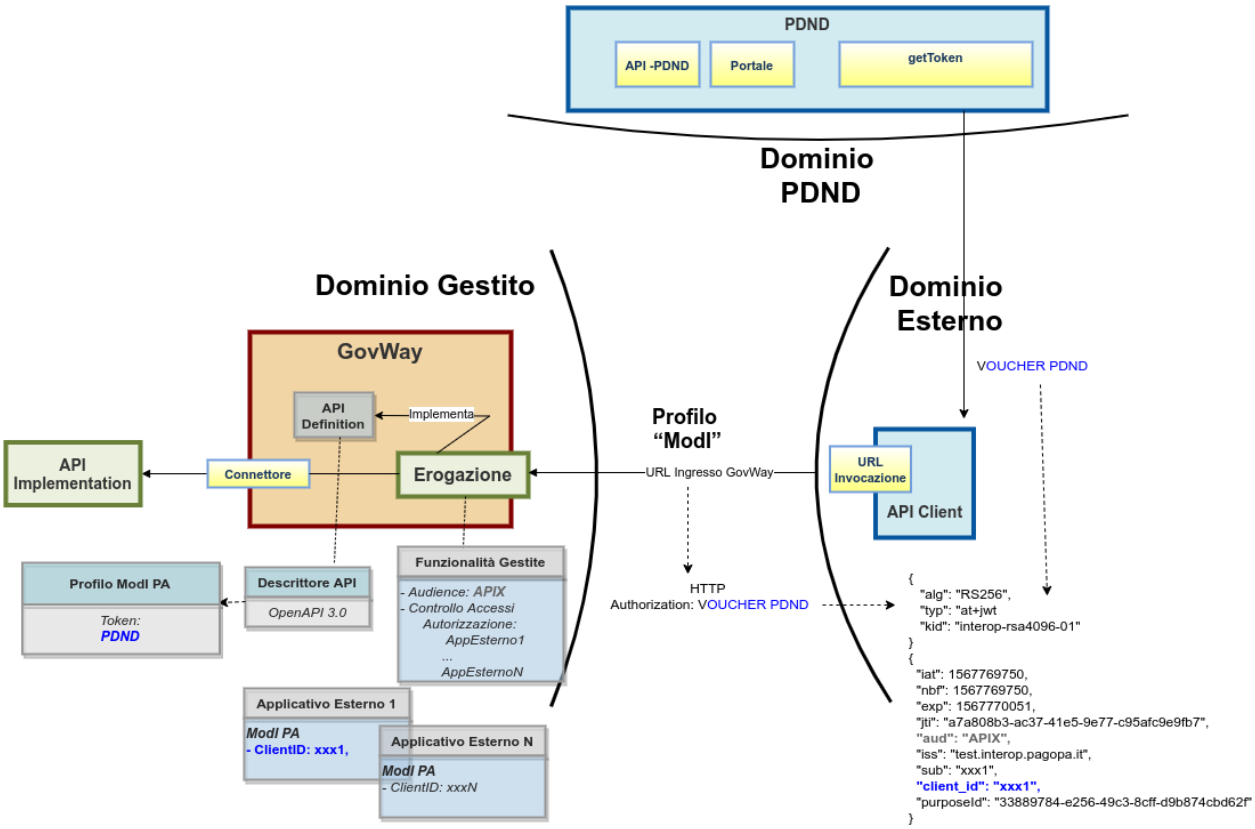


Figure3.85: Erogazione di una API REST con profilo “ModI”, pattern ID_AUTH_REST_01 via PDND

Le caratteristiche principali di questo scenario sono:

1. un applicativo eroga un servizio, rivolto a fruitori di domini esterni, registrandolo sulla PDND;
2. la comunicazione con i domini esterni avviene su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;
3. l’autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND».

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.86: Profilo ModI della govwayMonitor

L'esecuzione dello scenario si basa sui seguenti elementi:

- una API REST di esempio (PetStore) definita con pattern di interazione "CRUD" e pattern di sicurezza «ID_AUTH_CHANNEL_01» e «ID_AUTH_REST_01 via PDND»;
- un'istanza Govway per la gestione del profilo ModI nel dominio dell'erogatore;
- un'authorization server che simula la PDND;
- un client del dominio esterno che invoca la risorsa «POST /pet» dell'erogazione esposta da Govway;
- il server PetStore di esempio che riceve le richieste inoltrate dal Govway e produce le relative risposte. Per questo scenario viene utilizzato il server disponibile on line all'indirizzo "https://petstore.swagger.io/".

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - IDAuth+PDND - IN App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console "govwayMonitor".

1. Dal dettaglio della richiesta si può visualizzare il messaggio che è stato inviato dal fruitore, come in Fig. 3.88. Come si nota, al payload JSON è associato un insieme di header HTTP tra i quali «Authorization», che contiene il token di sicurezza che il fruitore ha ottenuto dalla PDND.
2. Grazie alle configurazioni presenti nell'erogazione, ed in particolare all'indicazione che il token ricevuto deve essere validato tramite Token Policy PDND, GovWay è in grado di validare i dati di sicurezza ricevuti (Fig. 3.89) e decodificare il token.
3. Analizzando il token ricevuto nella sezione header (Fig. 3.90) si può notare che non viene riportata l'identità del fruitore tramite certificato X.509 come avveniva per il pattern ID_AUTH_REST_01 descritto nella scenario *Esecuzione*. L'identità del fruitore è presente nella sezione payload (Fig. 3.91) all'interno del claim *client_id*, insieme ai riferimenti temporali (iat, nbf, exp) e all'audience (aud). Da notare inoltre la presenza del claim "purposeId" che indica la finalità per cui il fruitore sta fruendo del servizio.

Nota

Il token ritornato dall'authorization server demo che simula la PDND contiene ulteriori claims che possono essere ignorati poiché non utili alla descrizione dello scenario e non presenti in un token PDND reale.

4. Il messaggio ricevuto dal Govway viene quindi validato, sulla base della configurazione realizzata, verificando in questo caso l'identità del fruitore, la validità temporale, la corrispondenza dell'audience ricevuto con quello atteso. Solo in caso di superamento dell'intero processo di validazione, il messaggio viene inoltrato al servizio erogatore. Se

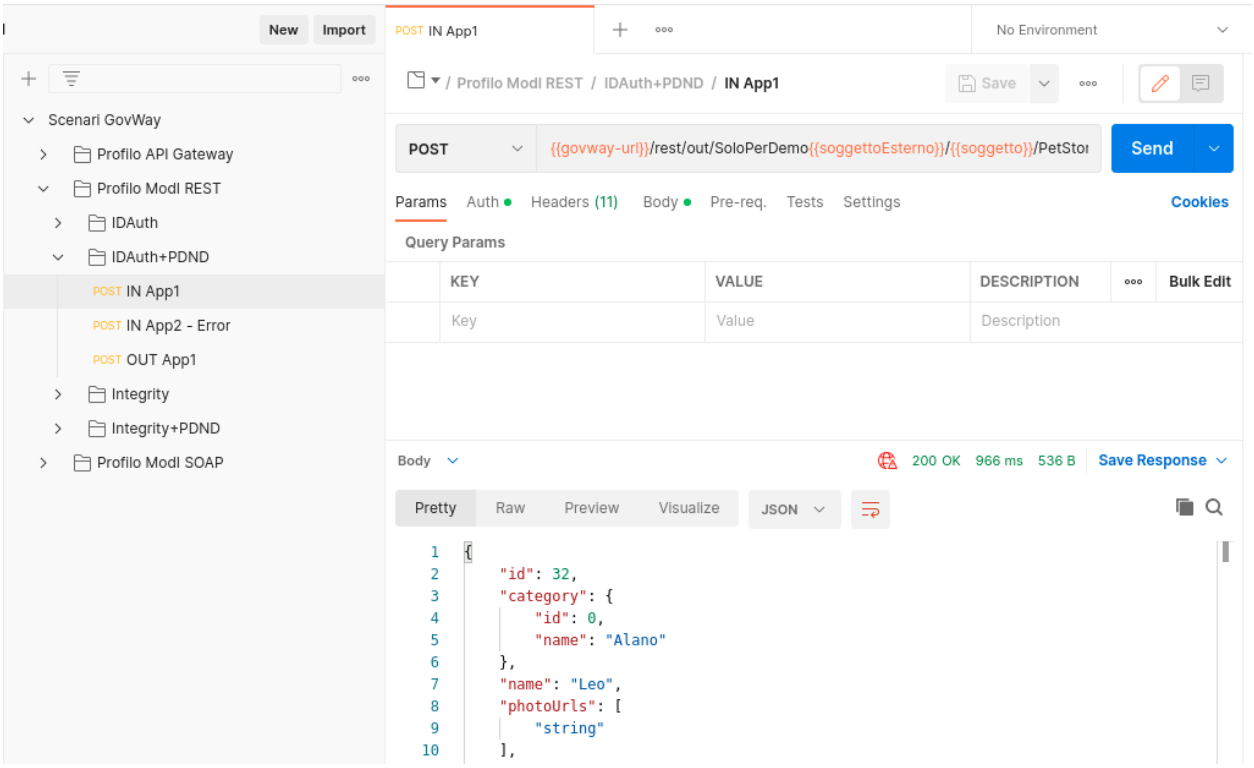


Figure3.87: Pattern IDAuth+PDND - Erogazione API REST, esecuzione da Postman

il processo di validazione del token ha successo è possibile consultare i dati interni al token ricevuto tramite la console come mostrato nelle figure Fig. 3.92 e Fig. 3.93.

5. Esaminando il messaggio inoltrato al backend è possibile vedere come tra gli header HTTP inoltrati vi sia l'header "GovWay-Token-PurposeId" contenente il valore del claim "purposeId" presente nel token ricevuto dalla PDND (Fig. 3.94).

6. Lo scenario è preconfigurato per autorizzare puntualmente l'applicativo "App1-ModI" identificato grazie al claim "client_id" presente all'interno del token. È possibile utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - IDAuth+PDND - IN App2 - Error» per verificare che una richiesta proveniente da un differente applicativo non viene autorizzata.

Conformità ai requisiti ModI

I requisiti iniziali, legati alla comunicazione basata su uno scenario ModI, sono verificati dalle seguenti evidenze:

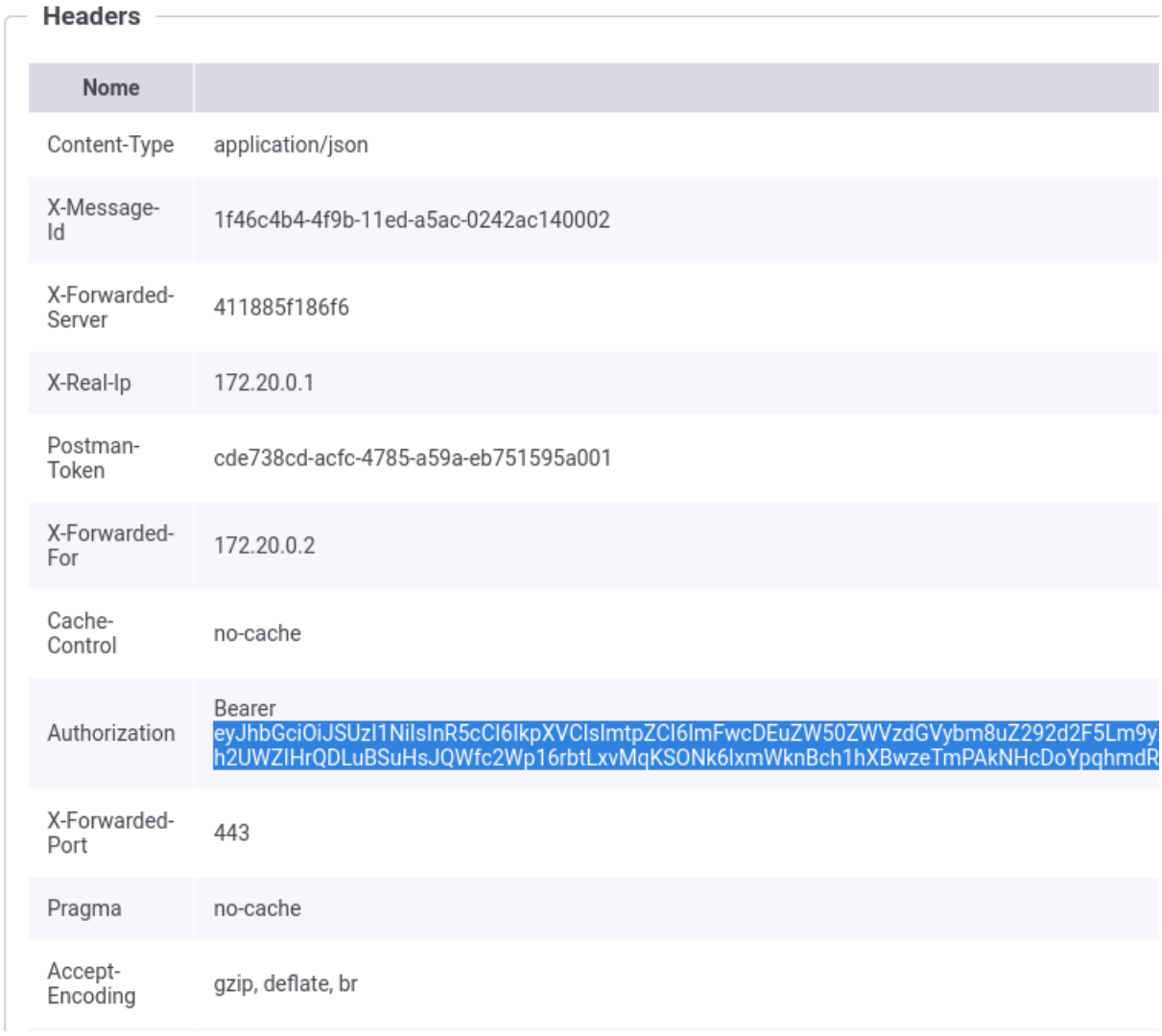
1. la sicurezza messaggio applicata è quella dei pattern «ID_AUTH_REST_01 via PDND» come ampiamente mostrato precedentemente dove sono stati mostrati i token validati e i criteri autorizzativi;

2. l'identificazione del fruitore avviene rispetto al claim "client_id" presente all'interno del token. È stato anche mostrato come sia possibile configurare criteri autorizzativi puntuali.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità "ModI". Si suggerisce



Headers

Nome	
Content-Type	application/json
X-Message-Id	1f46c4b4-4f9b-11ed-a5ac-0242ac140002
X-Forwarded-Server	411885f186f6
X-Real-Ip	172.20.0.1
Postman-Token	cde738cd-acfc-4785-a59a-eb751595a001
X-Forwarded-For	172.20.0.2
Cache-Control	no-cache
Authorization	Bearer eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6ImFwcDEuZW50ZWVzdGVybm8uZ292d2F5Lm9y h2UWZIHrQDLuBSuHsJQWfc2Wp16rbtLxvMqKSONk6lxmWknBch1hXBwzeTmPAkNHcDoYpqhmdR
X-Forwarded-Port	443
Pragma	no-cache
Accept-Encoding	gzip, deflate, br

Figure3.88: Messaggio inviato dal fruitore

2022-10-20 11:06:27.473	infoIntegration	RicezioneBuste	Gestione Token [PDND] (Validazione JWT) in corso ...
2022-10-20 11:06:27.474	infoIntegration	RicezioneBuste	Gestione Token [PDND] (Validazione JWT) completata con successo

Figure3.89: Evidenza diagnostica della validazione del token

HEADER: ALGORITHM & TOKEN TYPE

```
{
  "typ": "at+jwt",
  "alg": "RS256",
  "use": "sig",
  "kid": "interop-rsa4096-01"
}
```

Figure3.90: Sezione «Header» del Token PDND

PAYLOAD: DATA


```
{
  "aud": "PetStore",
  "sub": "App1-Esterno-PDND",
  "client_id": "App1-Esterno-PDND",
  "purposeId": "54806042-5e7f-4c70-9ee0-a4f100a079f7",
  "iss": "test.interop.pagopa.it",
  "exp": 1666258251,
  "iat": 1666257651,
  "nbf": 1666257651,
  "jti": "32c30a37-ed2e-4a50-a42e-0093b50773dc"
}
```


Figure3.91: Sezione «Payload» del Token PDND

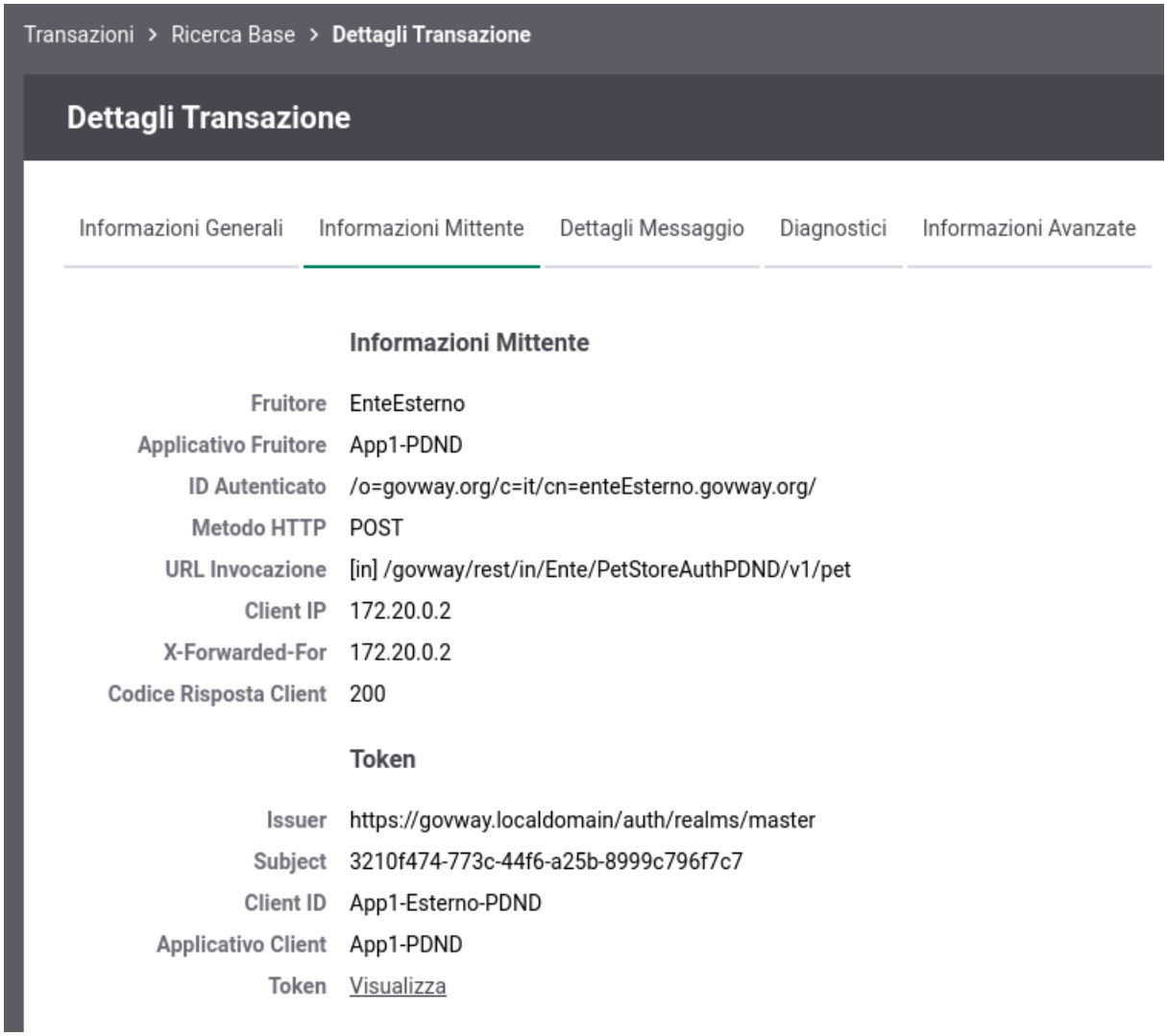


Figure3.92: Dati principali presenti nel Token PDND

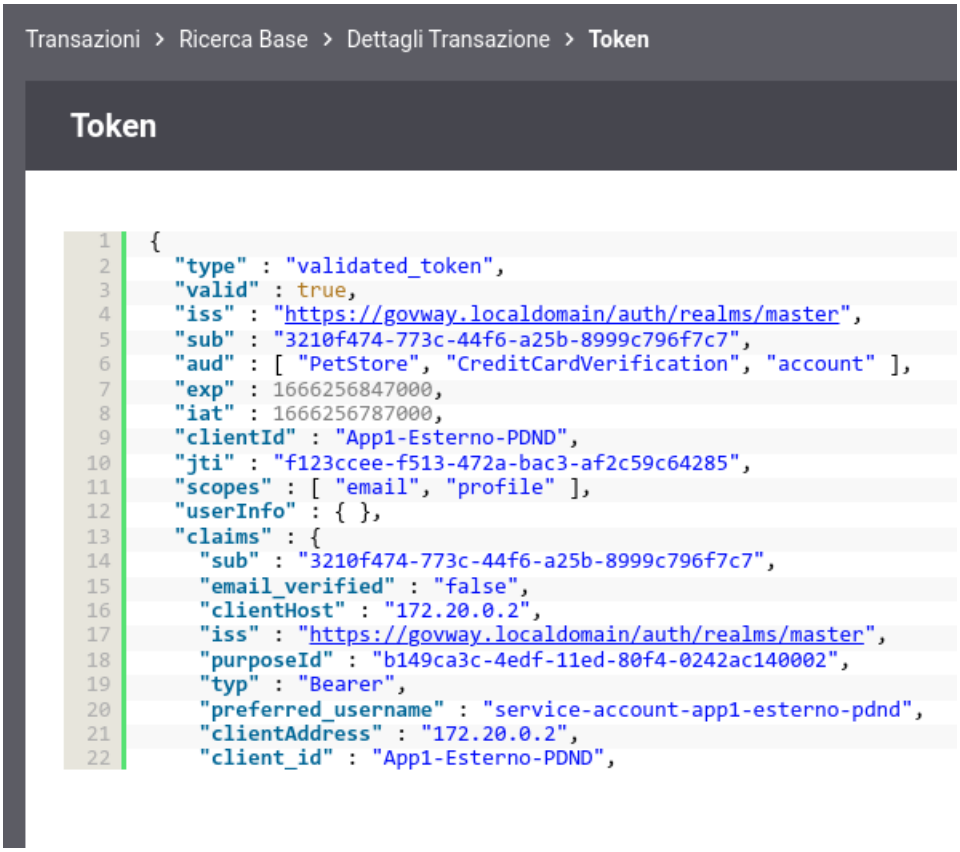


Figure3.93: Claim presenti nel Token PDND

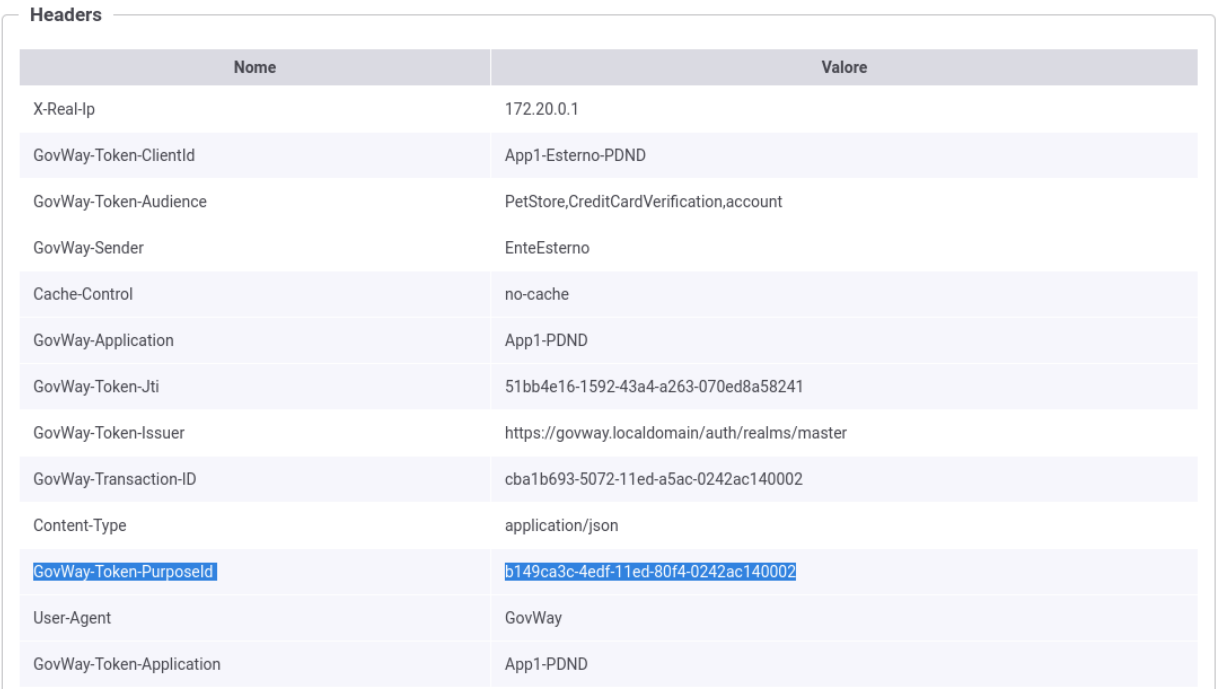


Figure3.94: Header HTTP "GovWay-Token-PurposeId" inoltrato al backend

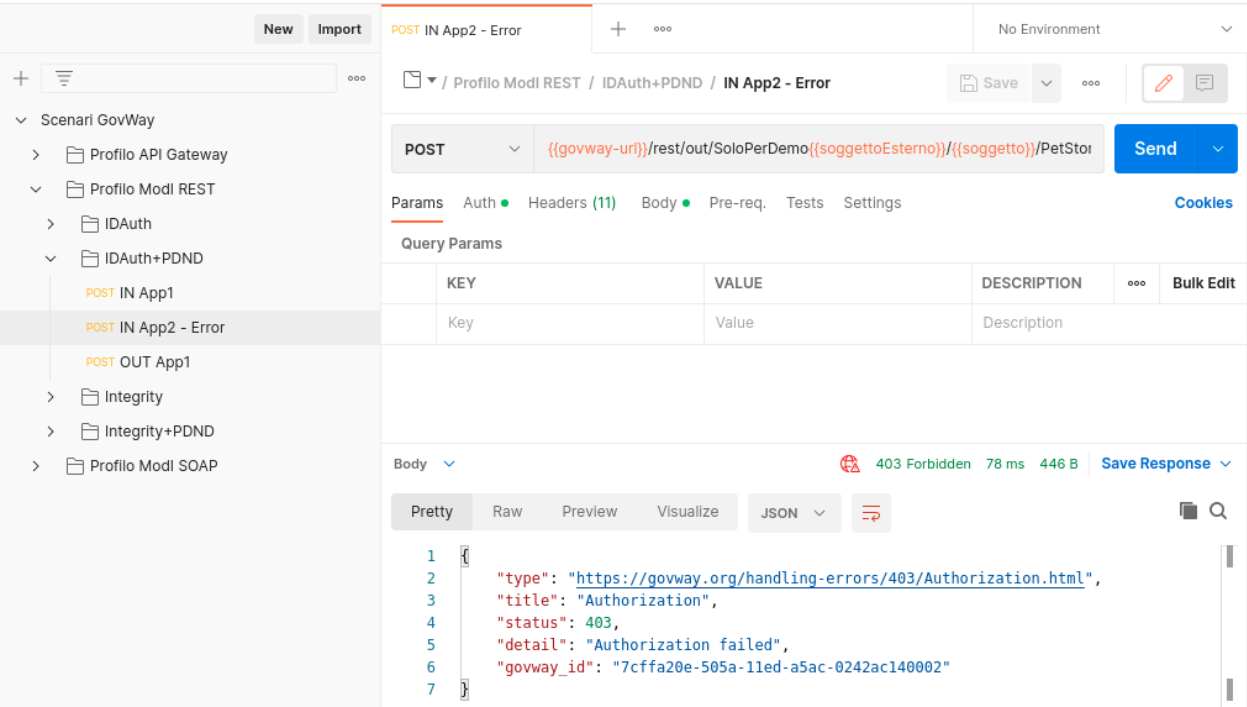


Figure3.95: Pattern IDAuth+PDND - Erogazione API REST - Autorizzazione negata, esecuzione da Postman

inoltre di selezionare il soggetto “Ente” per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.96: Profilo ModI della govwayConsole

Registrazione API

Viene registrata l’API «PetStoreAuthPDND» con il relativo descrittore OpenAPI 3. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «ID_AUTH_REST_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND» (Fig. 3.97).

Applicativo Esterno

È opzionalmente possibile registrare l’applicativo esterno che corrisponde al fruitore del servizio. Questa scelta può essere fatta in base al tipo di autorizzazione che si è impostata sui fruitori. Vediamo i seguenti casi:

- Se si desidera autorizzare qualsiasi fruitore proveniente dalla PDND, questo passo può anche essere omesso. La validazione del token è sufficiente a stabilire che il fruitore ha ottenuto un voucher dalla PDND valido per il servizio invocato.
- In alternativa è possibile configurare una autorizzazione puntuale procedendo alla registrazione degli applicativi fornendo i singoli “client_id” necessari all’identificazione (Fig. 3.98). Questo scenario è quello preconfigurato.

Token Policy PDND

Con il prodotto viene fornita built-in la token policy “PDND” (Fig. 3.99) da finalizzare nella sezione “TrustStore”,

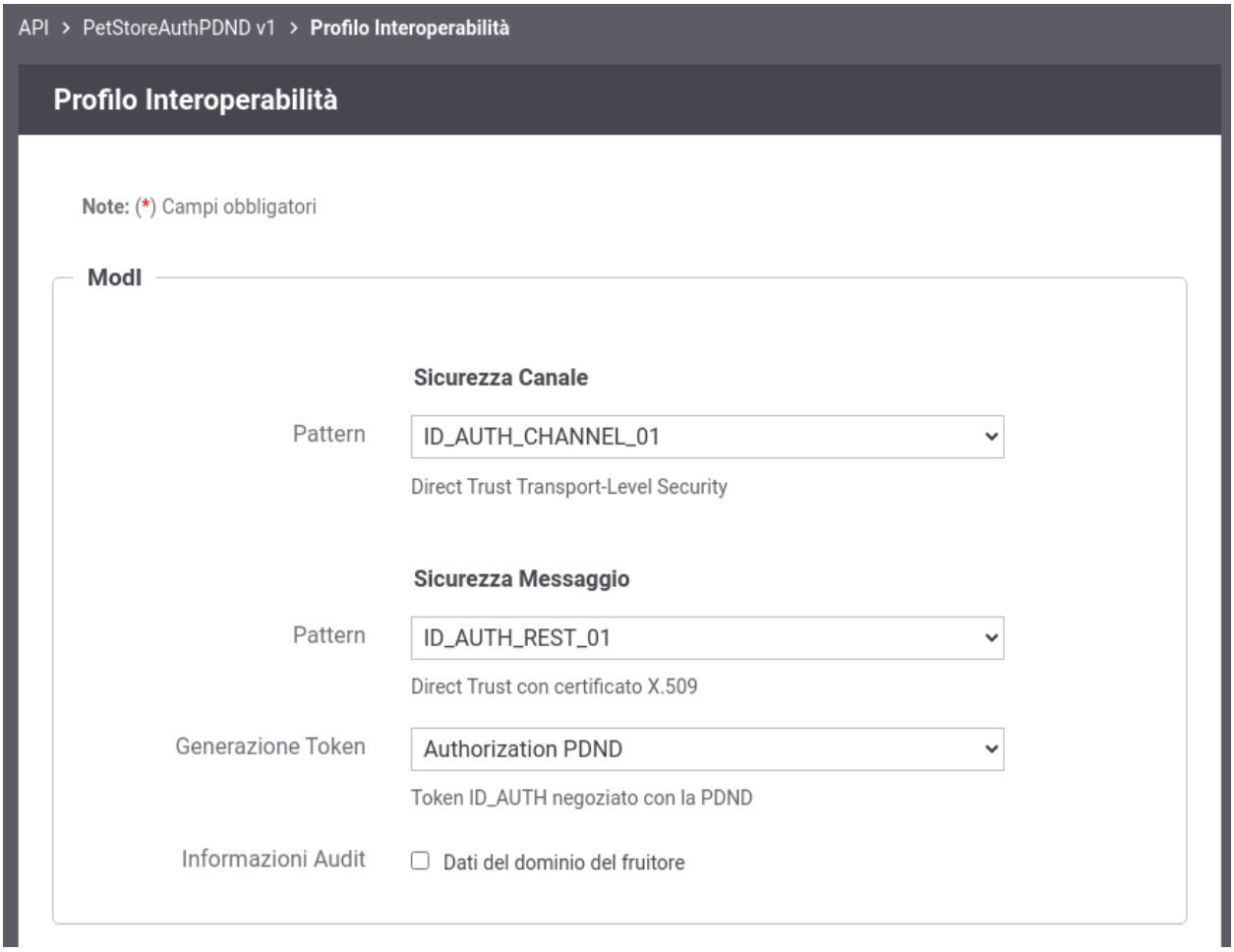


Figure3.97: Configurazione Pattern ModI con «ID_AUTH_CHANNEL_01» senza sicurezza messaggio

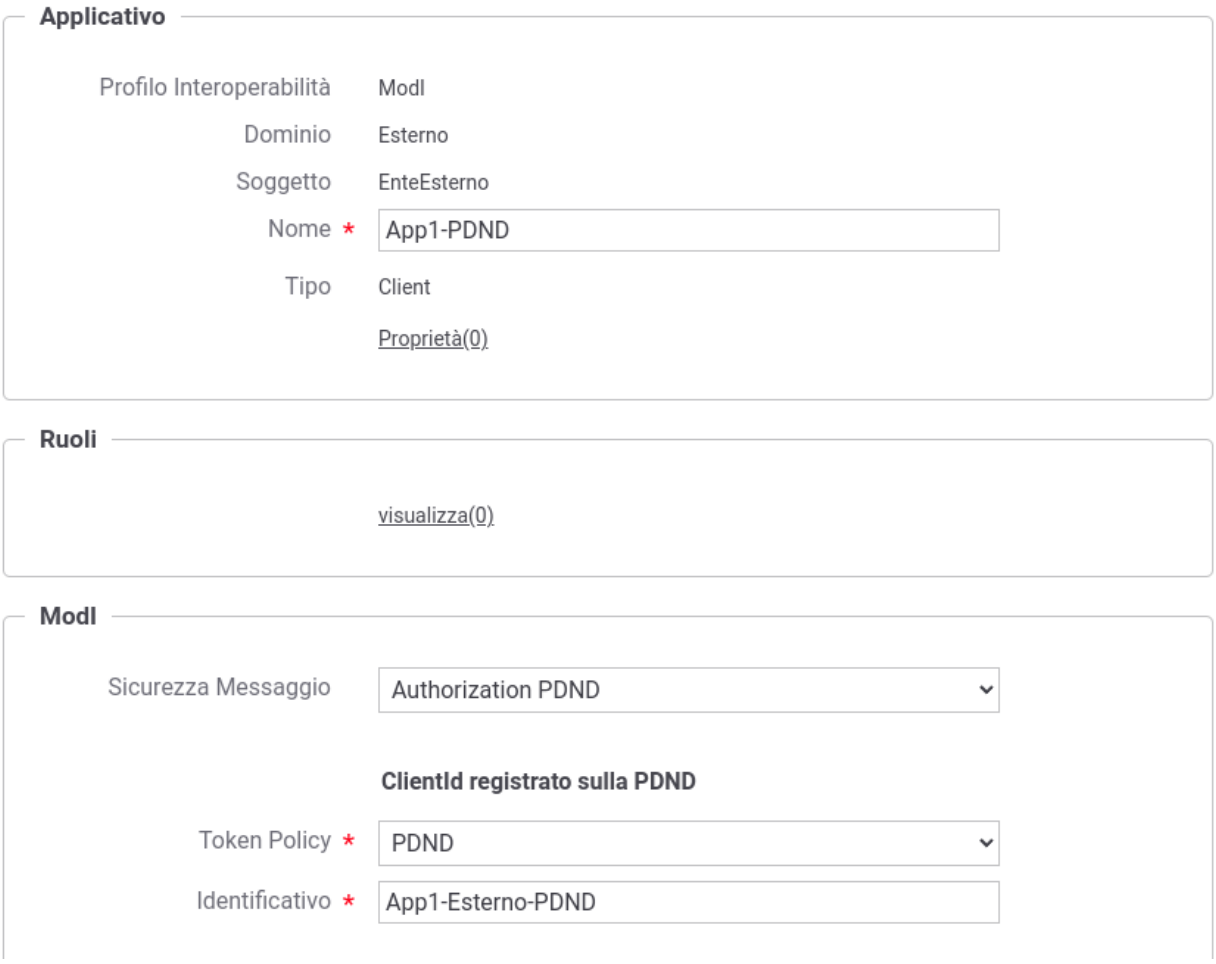


Figure3.98: Configurazione applicativo esterno (fruitore)

come descritto nel manuale “Console di Gestione” nella sezione modipa_passiPreliminari_trustStore_pdnd. La configurazione utilizzata per gli scenari (Fig. 3.100) simula la PDND tramite i certificati predisposti su “Keycloak”:

- File: deve essere indicato un path su file system che contiene il certificato di firma della PDND ottenibile tramite la url “…/.well-known/jwks.json” fornita dalla PDND stessa;
- Alias Certificato: deve contenere l’alias (il kid) della chiave pubblica utilizzata dalla PDND per firmare i token rilasciati, corrispondente al valore del claim “kid” presente nel JWKSet configurato al punto precedente;
- Token Forward: deve essere eventualmente configurata la modalità di forward delle informazioni presenti nel token verso il backend, utile nel nostro scenario per far arrivare il valore del claim “purposeId” al backend nell’header HTTP “GovWay-Token-PurposeId”.

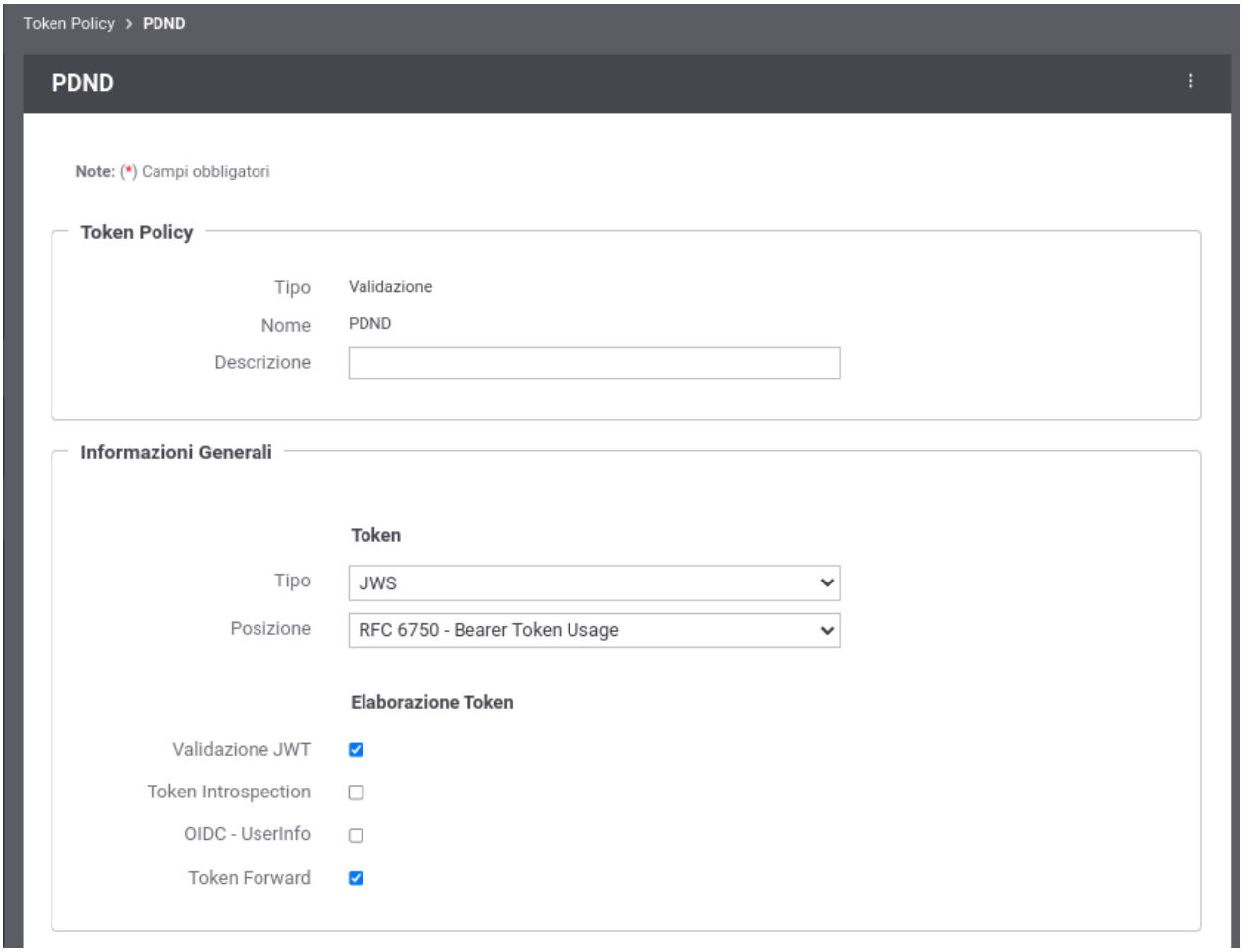


Figure3.99: Token Policy PDND (Dati Generali)

Erogazione

Si registra l’erogazione «PetStoreAuthPDND», relativa all’API precedentemente inserita, abilitando la validazione del token ricevuto dalla PDND tramite la omonima policy (Fig. 3.101).

Si può notare nella sezione “Autenticazione Canale” del Controllo degli Accessi come l’autenticazione https sia opzionale per essere aderenti al pattern di sicurezza canale «ID_AUTH_CHANNEL_01» (Fig. 3.102).

Nella sezione “Autorizzazione” si può invece vedere come nella voce “Autorizzazione per Token Claims” vi sia configurato il valore del claim “aud” atteso.

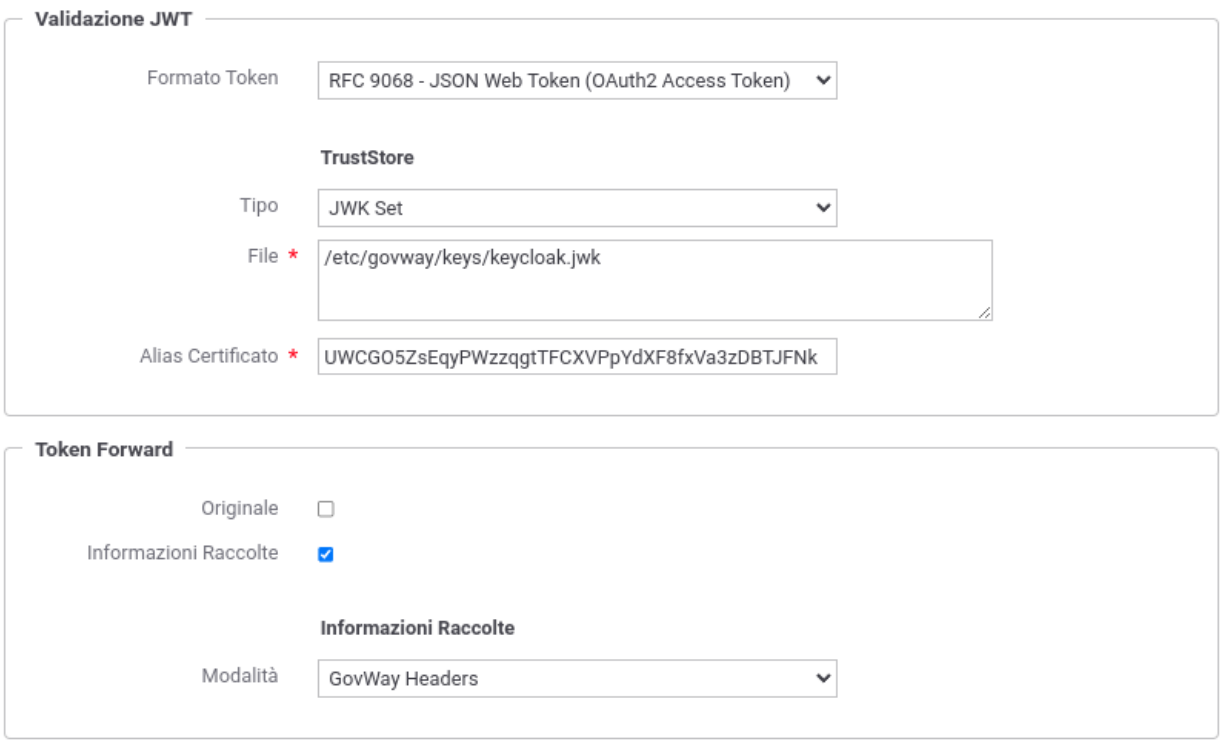


Figure3.100: Token Policy PDND (Aspetti da Configurare)

Se si è scelto inoltre di registrare gli applicativi esterni, fruitori del servizio, saranno specificati i singoli applicativi fruitori autorizzati ad effettuare richieste al servizio erogato. Questo scenario è quello preconfigurato come mostrato nelle figure Fig. 3.103 e Fig. 3.104.

3.3.2 Fruizione API REST

Obiettivo

Fruire di un servizio REST, definito tramite una API REST (OpenAPI 3.0), accessibile in accordo al pattern di sicurezza descritto nella sezione modipa_pdnd.

Sintesi

Mostriamo in questa sezione come procedere per l'integrazione di un applicativo con un servizio REST erogato nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui il servizio è stato registrato sulla PDND, e il fruitore per poterlo fruire deve ottenere un voucher dalla PDND che successivamente deve inviare all'erogatore insieme alla normale richiesta di servizio.

La figura seguente descrive graficamente questo scenario.

Le caratteristiche principali di questo scenario sono:

1. un applicativo fruitore che dialoga con il servizio erogato in modalità ModI in accordo ad una API condivisa registrata su PDND;
2. la comunicazione diretta verso il dominio erogatore veicolata su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;
3. l'autenticità della comunicazione tra fruitore ed erogatore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND».

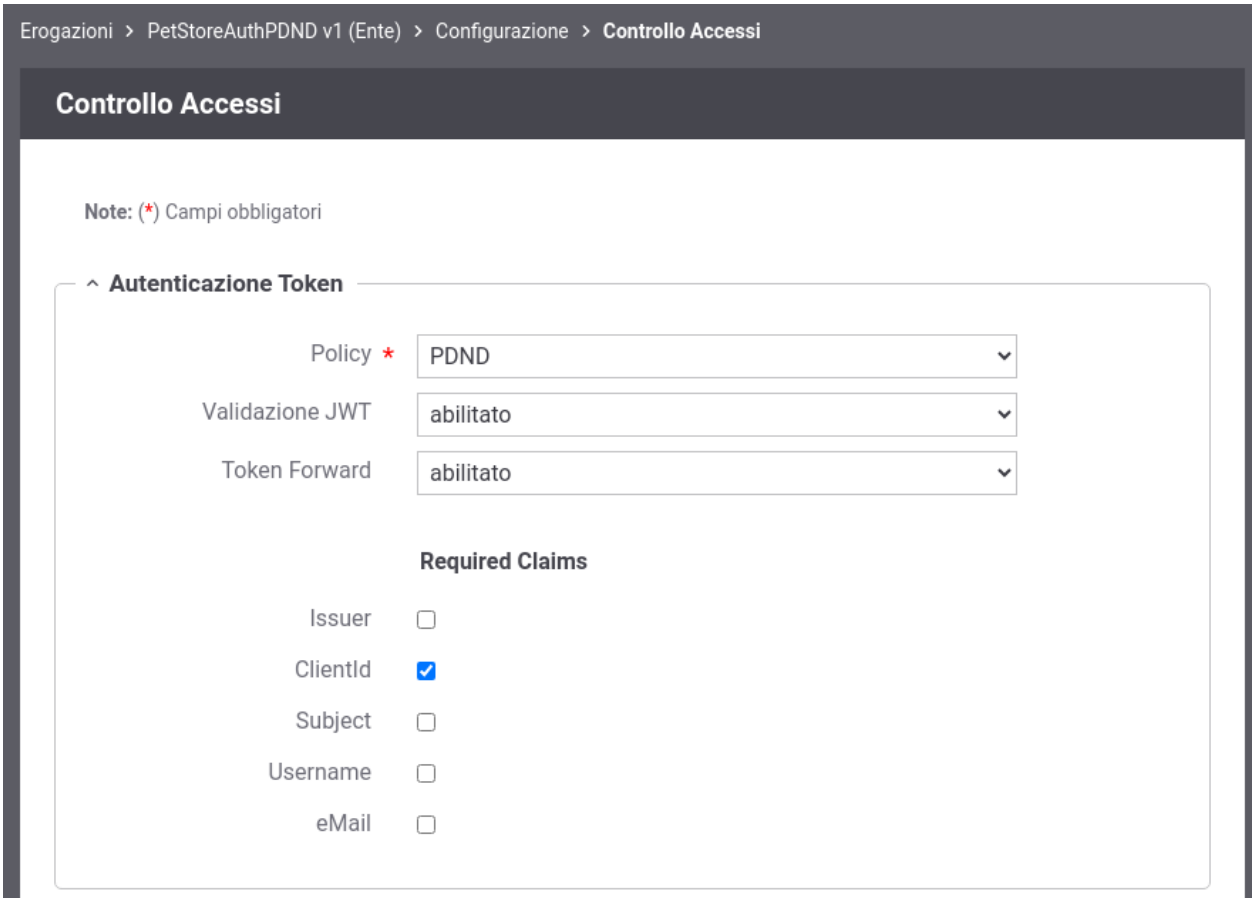


Figure3.101: Controllo degli Accessi - Autenticazione Token

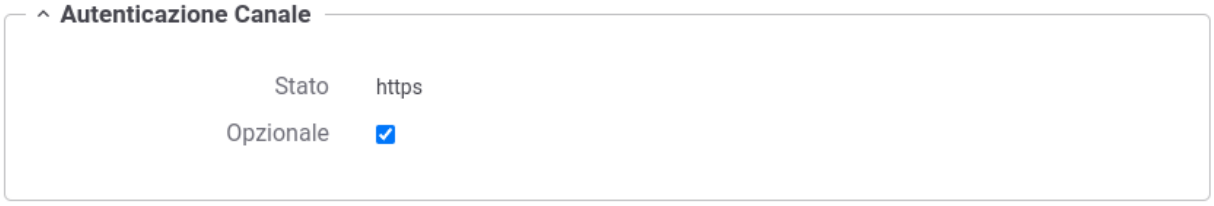


Figure3.102: Controllo degli Accessi - Autenticazione Canale

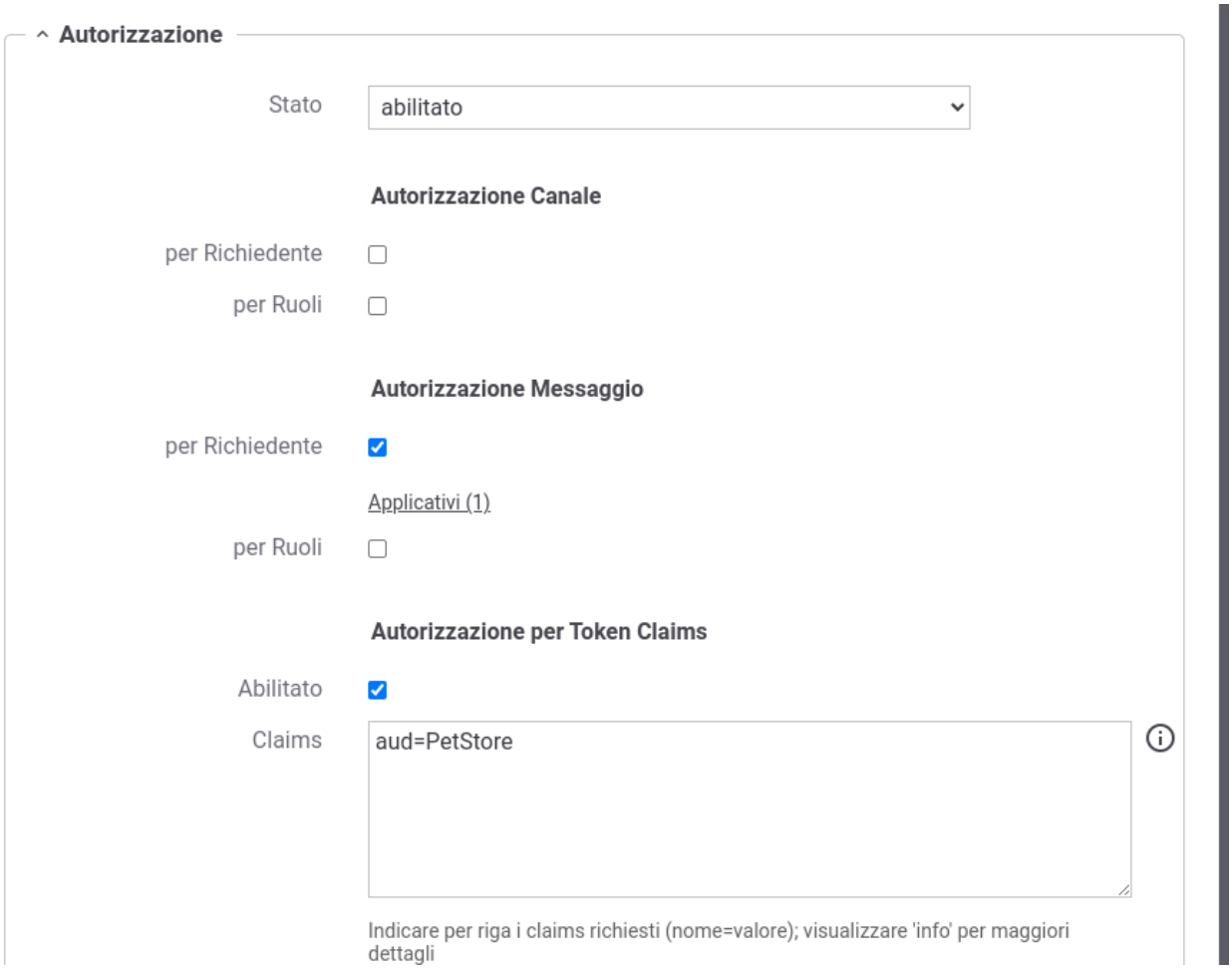


Figure3.103: Controllo accessi con autorizzazione dell'audience e degli applicativi esterni

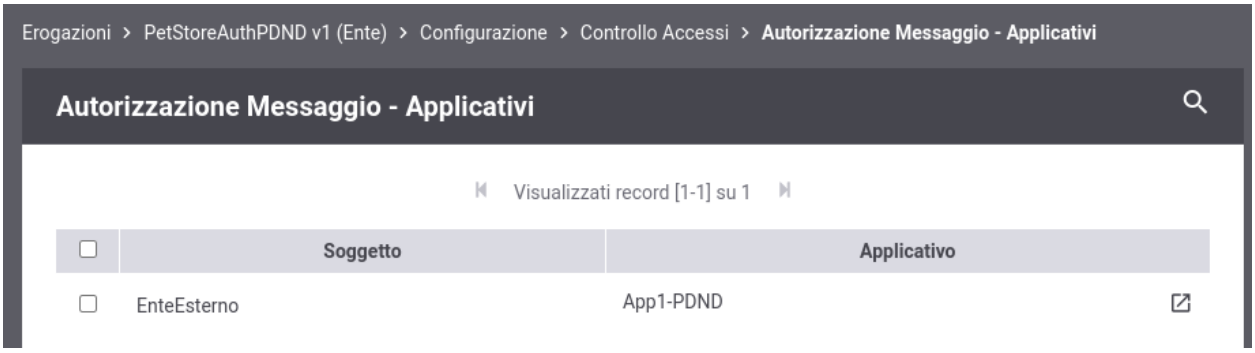


Figure3.104: Lista degli applicativi esterni autorizzati

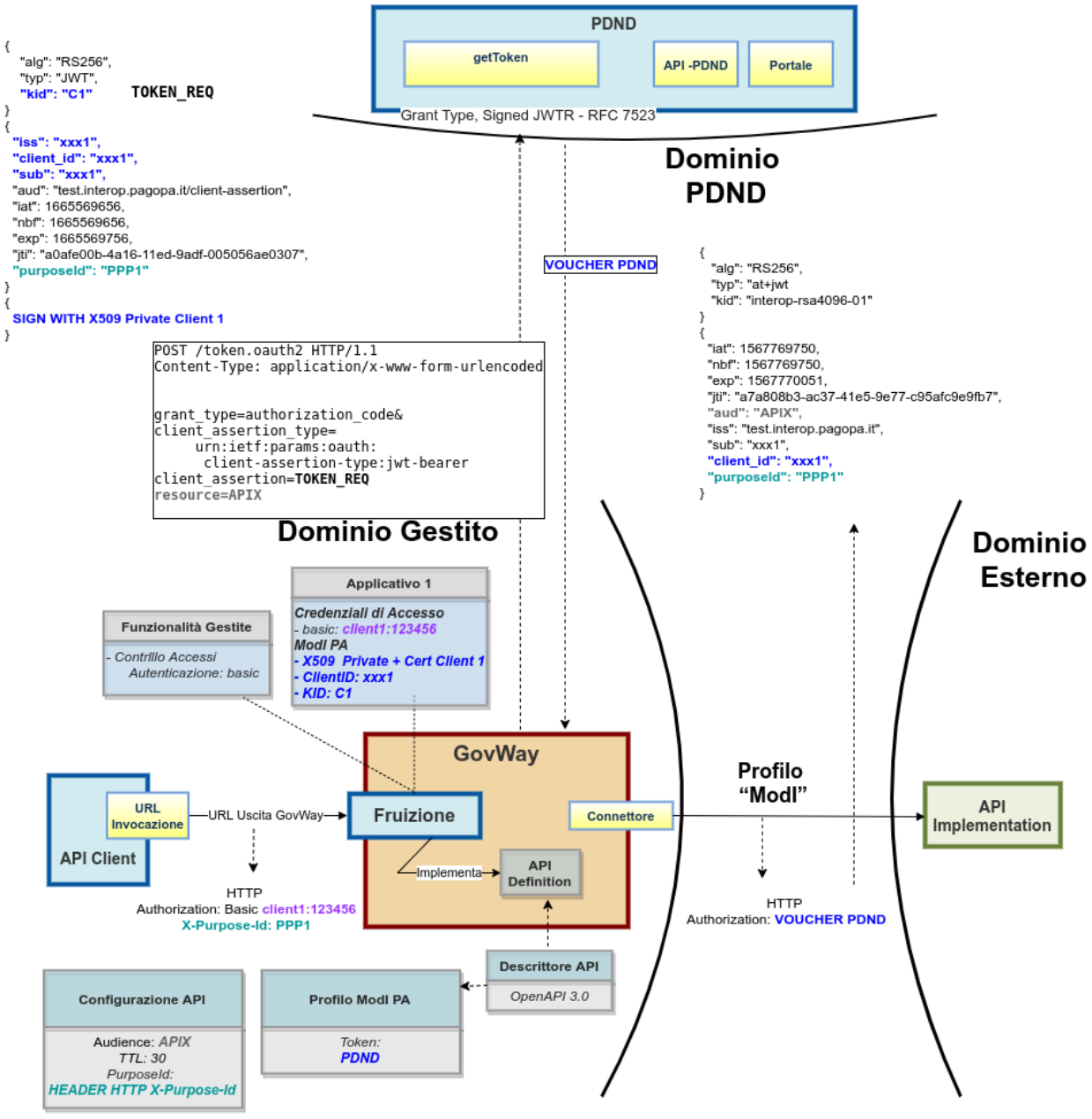


Figure3.105: Fruizione di una API REST con profilo "ModI", pattern ID_AUTH_REST_01 via PDND

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.106: Profilo ModI della govwayMonitor

L'esecuzione dello scenario si basa sui seguenti elementi:

- una API REST di esempio (PetStore) definita con pattern di interazione "CRUD" e pattern di sicurezza «ID_AUTH_CHANNEL_01» e «ID_AUTH_REST_01 via PDND»;
- un'istanza Govway per la gestione del profilo ModI nel dominio del fruitore;
- un'authorization server che simula la PDND;
- un client che invoca la risorsa «POST /pet» con un messaggio di esempio diretto alla fruizione configurata su Govway.

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - IDAuth+PDND - OUT App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

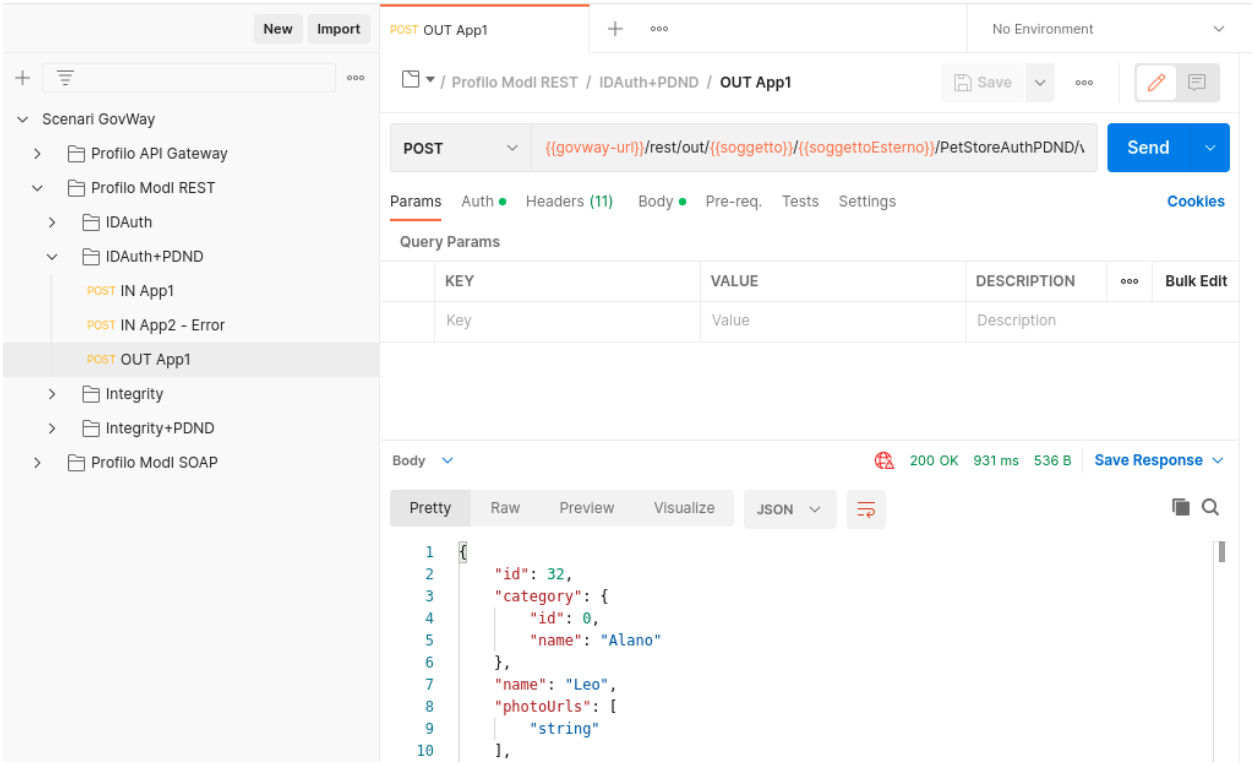


Figure3.107: Pattern IDAuth+PDND - Fruizione API REST, esecuzione da Postman

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto nelle diverse fasi dell'esecuzione andando a consultare la console "govwayMonitor".

1. Il messaggio di richiesta inviato dal fruitore viene elaborato da Govway che, tramite la configurazione della firma digitale associata all'applicativo mittente, è in grado di produrre un token di sicurezza da inviare alla PDND con il quale ottenere indietro un voucher spendibile per il servizio desiderato. Tramite la console è possibile esaminare sia l'asserzione JWT inviata alla PDND (Fig. 3.108) che l'access token ottenuto dalla PDND (Fig. 3.109).

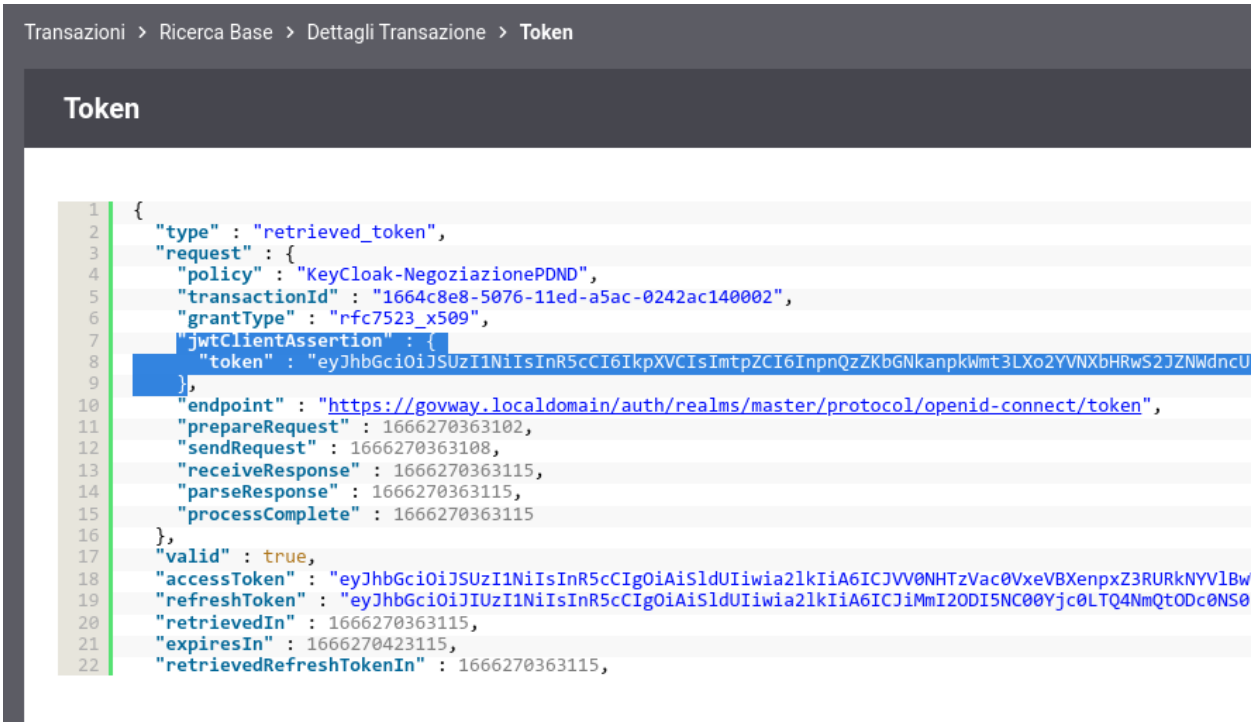


Figure3.108: Evidenza dell'asserzione JWT inviata alla PDND

2. Esaminando l'header e il payload dell'asserzione JWT inviata alla PDND (Fig. 3.110) si può notare:

- Valore del claim "kid" associato all'applicativo mittente in configurazione
- Valore del claim "client_id" (uguale per i claim "sub" e "iss") associato all'applicativo mittente in configurazione
- Valore del claim "purposeId" indicato dal client (nell'esempio Postman) tramite un header http "X-Purpose-Id"

3. Analizzando l'access token ricevuto dalla PDND, nella sezione header (Fig. 3.111) si può notare che non viene riportata l'identità del fruitore tramite certificato X.509 come avveniva per il pattern ID_AUTH_REST_01 descritto nella scenario *Esecuzione*. L'identità del fruitore è presente nella sezione payload (Fig. 3.112) all'interno del claim *client_id*, insieme ai riferimenti temporali (iat, nbf, exp) e all'audience (aud) del servizio per cui si è richiesto il voucher. Da notare inoltre la presenza del claim "purposeId" che servirà ad indicare la finalità per cui il fruitore sta fruendo del servizio all'erogatore.

Nota

Il token ritornato dall'authorization server demo che simula la PDND contiene ulteriori claims che possono essere ignorati poiché non utili alla descrizione dello scenario e non presenti in un token PDND reale.

4. Tramite la console govwayMonitor si può visualizzare il messaggio di richiesta in uscita che è il medesimo di quello in entrata con la differenza che è stato aggiunto l'access token ottenuto dalla PDND tra gli header HTTP all'interno dell'header «Authorization» (Fig. 3.113).

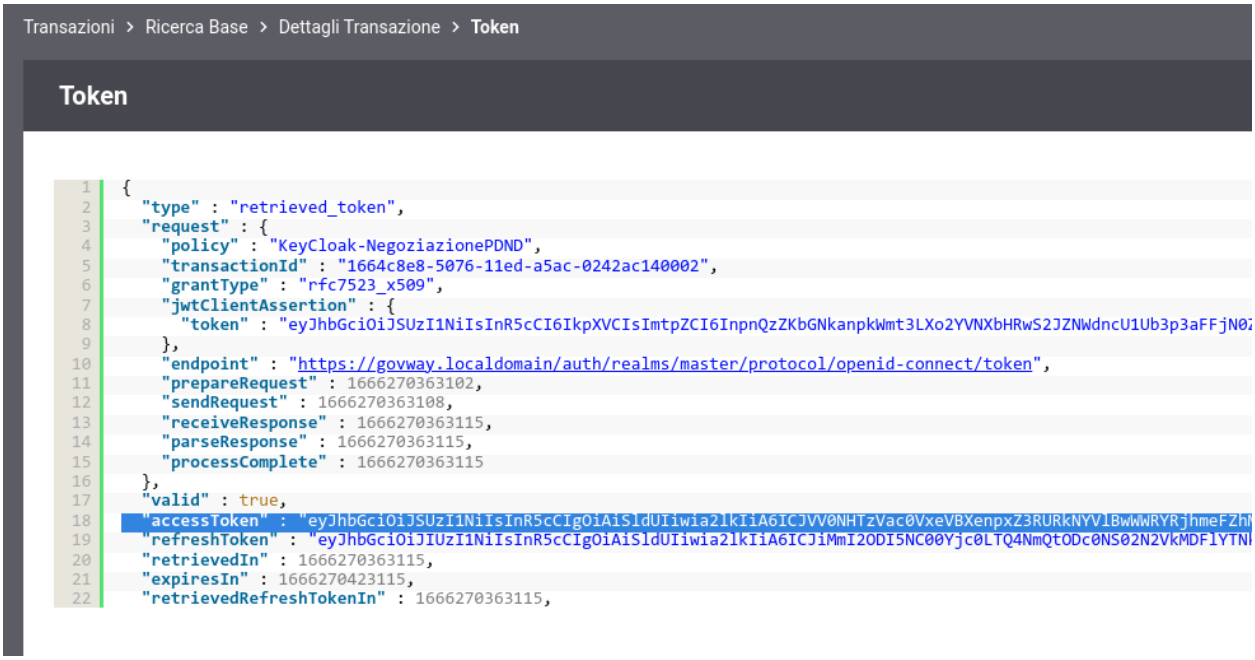


Figure3.109: Evidenza dell'access token ottenuto dalla PDND

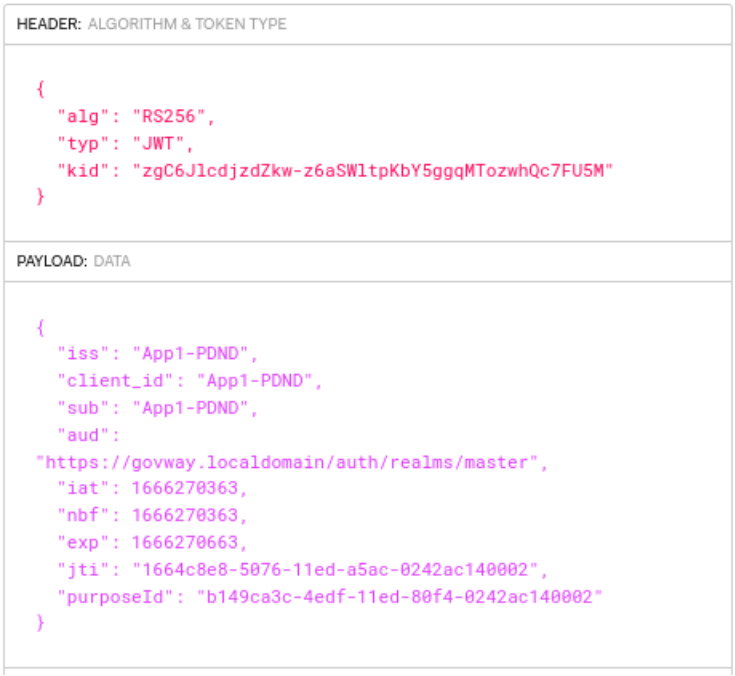


Figure3.110: Header e Payload dell'asserzione JWT inviata alla PDND



Figure3.111: Sezione «Header» del Token PDND



Figure3.112: Sezione «Payload» del Token PDND

5. Govway riceve la risposta dell'erogatore grazie al fatto che ha inviato un voucher PDND correttamente validato dall'erogatore.

Conformità ai requisiti ModI

I requisiti iniziali, legati alla comunicazione basata su uno scenario ModI, sono verificati dalle seguenti evidenze:

1. viene effettuata una negoziazione del voucher PDND come mostrato nelle tracce relative ai token scambiati con la PDND;
2. l'invocazione del servizio avviene fornendo il voucher della PDND precedentemente negoziato.

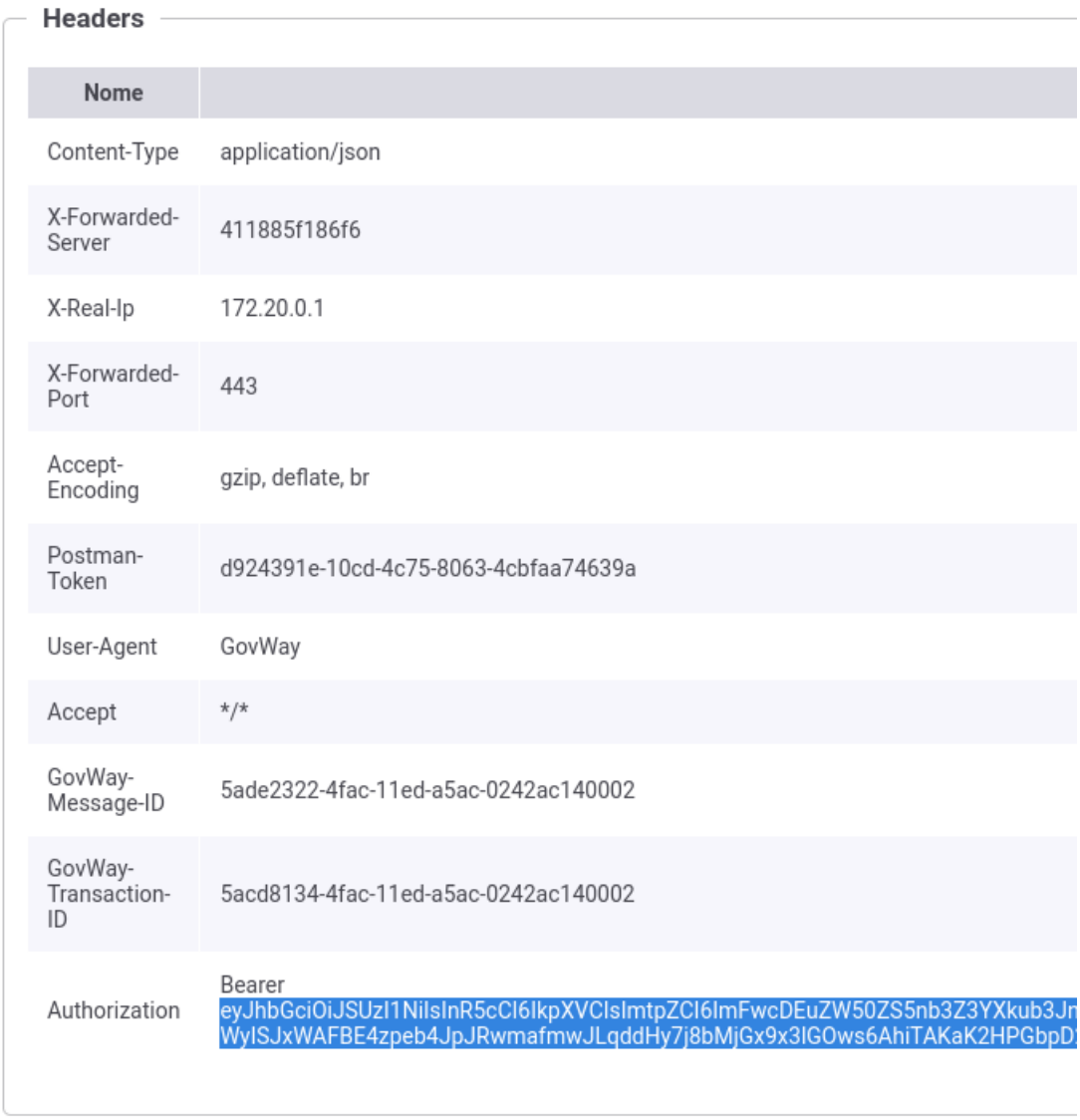
Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità «ModI». Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.114: Profilo ModI della govwayConsole



Headers

Nome	
Content-Type	application/json
X-Forwarded-Server	411885f186f6
X-Real-Ip	172.20.0.1
X-Forwarded-Port	443
Accept-Encoding	gzip, deflate, br
Postman-Token	d924391e-10cd-4c75-8063-4cbfaa74639a
User-Agent	GovWay
Accept	*/*
GovWay-Message-ID	5ade2322-4fac-11ed-a5ac-0242ac140002
GovWay-Transaction-ID	5acd8134-4fac-11ed-a5ac-0242ac140002
Authorization	Bearer eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6ImFwcDEuZW50ZS5nb3Z3YXkub3Jn WyISJxWAFBE4zpeb4JpJRwmafmwJLqddHy7j8bMjGx9x3lGOws6AhiTAKaK2HPGbpD

Figure3.113: Messaggio di richiesta in uscita (con voucher PDND inserito nell'header HTTP)

Registrazione API

Viene registrata l'API «PetStoreAuthPDND» con il relativo descrittore OpenAPI 3. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «ID_AUTH_REST_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND» (Fig. 3.97).

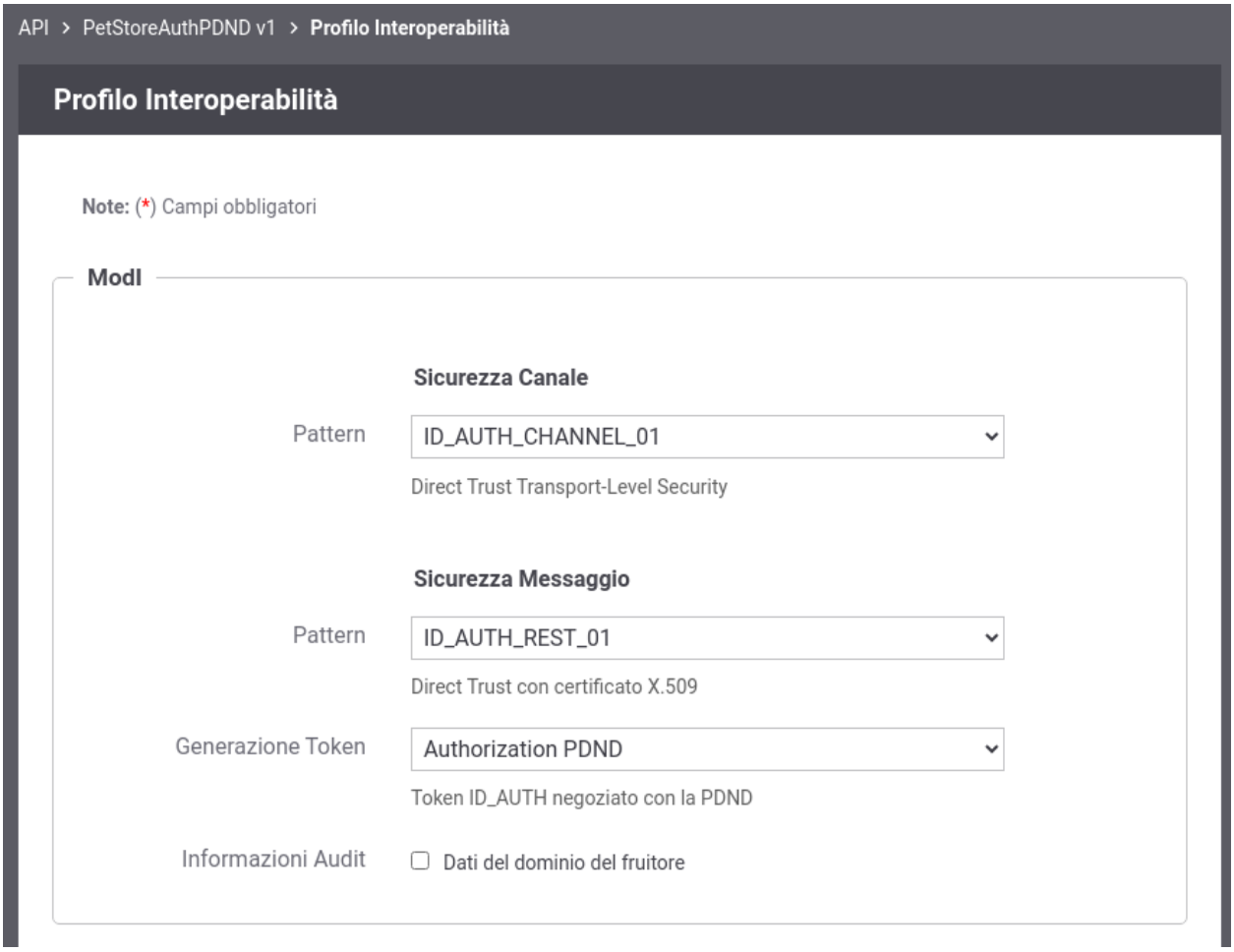


Figure3.115: Configurazione Pattern ModI con «ID_AUTH_CHANNEL_01» senza sicurezza messaggio

Applicativo

Si configura l'applicativo mittente indicando, nella sezione ModI, i parametri del keystore e i parametri di identificazione sulla PDND necessari affinché Govway possa produrre il token di sicurezza firmando per conto dell'applicativo (Fig. 3.116 e Fig. 3.117). Alla registrazione dell'applicativo vengono associate credenziali "basic" che consentono a GovWay di identificarlo.

Token Policy PDND

Per la configurazione delle fruizioni con un pattern di sicurezza via PDND è necessario registrare una Token Policy di Negoziazione del tipo descritto nella sezione "tokenNegoziazionePolicy_pdnd".

Una volta effettuata la registrazione della Token Policy, per utilizzarla in una fruizione è sufficiente associarla al connettore della fruizione come descritto nella sezione avanzate_connettori_tokenPolicy.

Di seguito vengono riportate tutte le informazioni più importanti della policy:

- Tipo: SignedJWT;

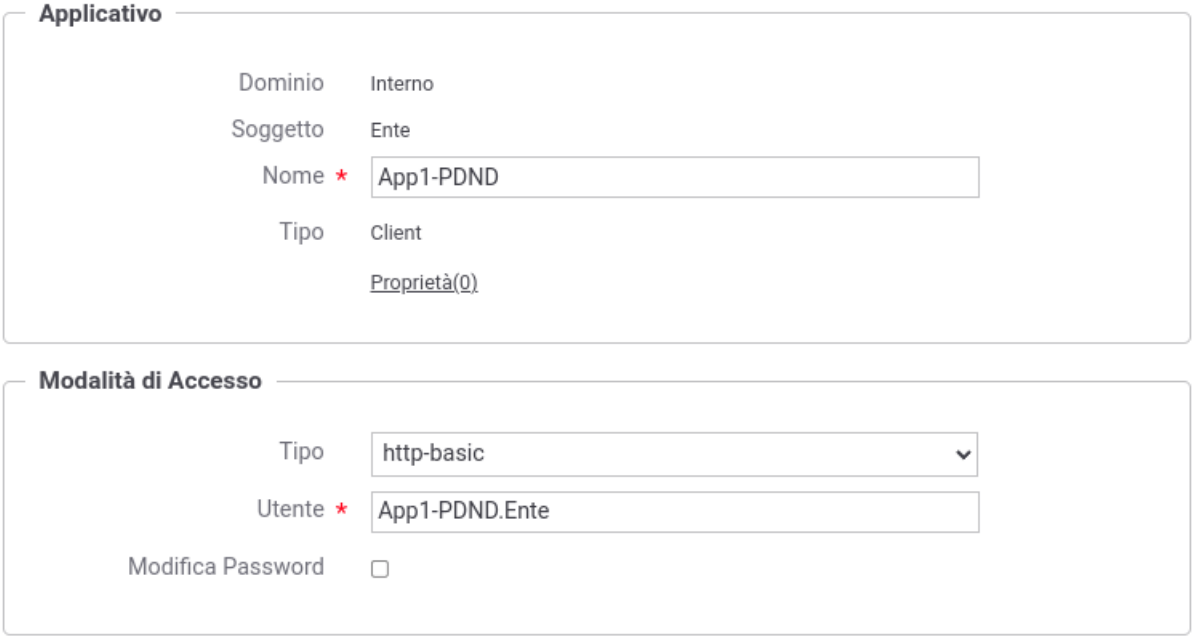


Figure3.116: Configurazione applicativo fruitore (Dati Generali)

- PDND: flag attivato;
- URL: endpoint esposto dalla PDND su cui è possibile richiedere lo stacco del voucher;
- JWT Keystore: parametri di accesso al keystore contenente la chiave privata corrispondente alla chiave pubblica caricata sulla PDND durante la registrazione dell'applicativo client. I parametri variano in funzione del tipo di keystore selezionato e nello scenario preconfigurato è stata scelta la modalità "Definito nell'applicativo ModI" nella quale il keystore utilizzato per firmare l'asserzione JWT inviata alla PDND sarà quello definito nell'applicativo ModI richiedente (Fig. 3.119).

Nota

Questa modalità consente di definire un'unica TokenPolicy di negoziazione utilizzabile da più applicativi richiedenti ognuno configurato con la propria coppia di chiavi di firma e i relativi identificativi "client_id" e "kid".

- JWT Signature: algoritmo di firma
- JWT Header:
  - Type (typ): lasciare il valore "JWT";
  - Key Id (kid): deve essere indicato l'identificativo univoco (KID) associato al certificato caricato sulla PDND e ottenuto al termine della registrazione dell'applicativo client. Può essere fornito tramite differenti modalità e nello scenario preconfigurato è stata scelta la modalità "Definito nell'applicativo ModI" nella quale il valore del KID viene configurato sull'applicativo richiedente (Fig. 3.119).
- JWT Payload:

  l'identificativo univoco dell'applicativo client ("*client_id*" o "*sub*") ottenuto al termine della registrazione dell'applicativo sulla PDND deve essere indicato nei seguenti campi:

  - Client ID

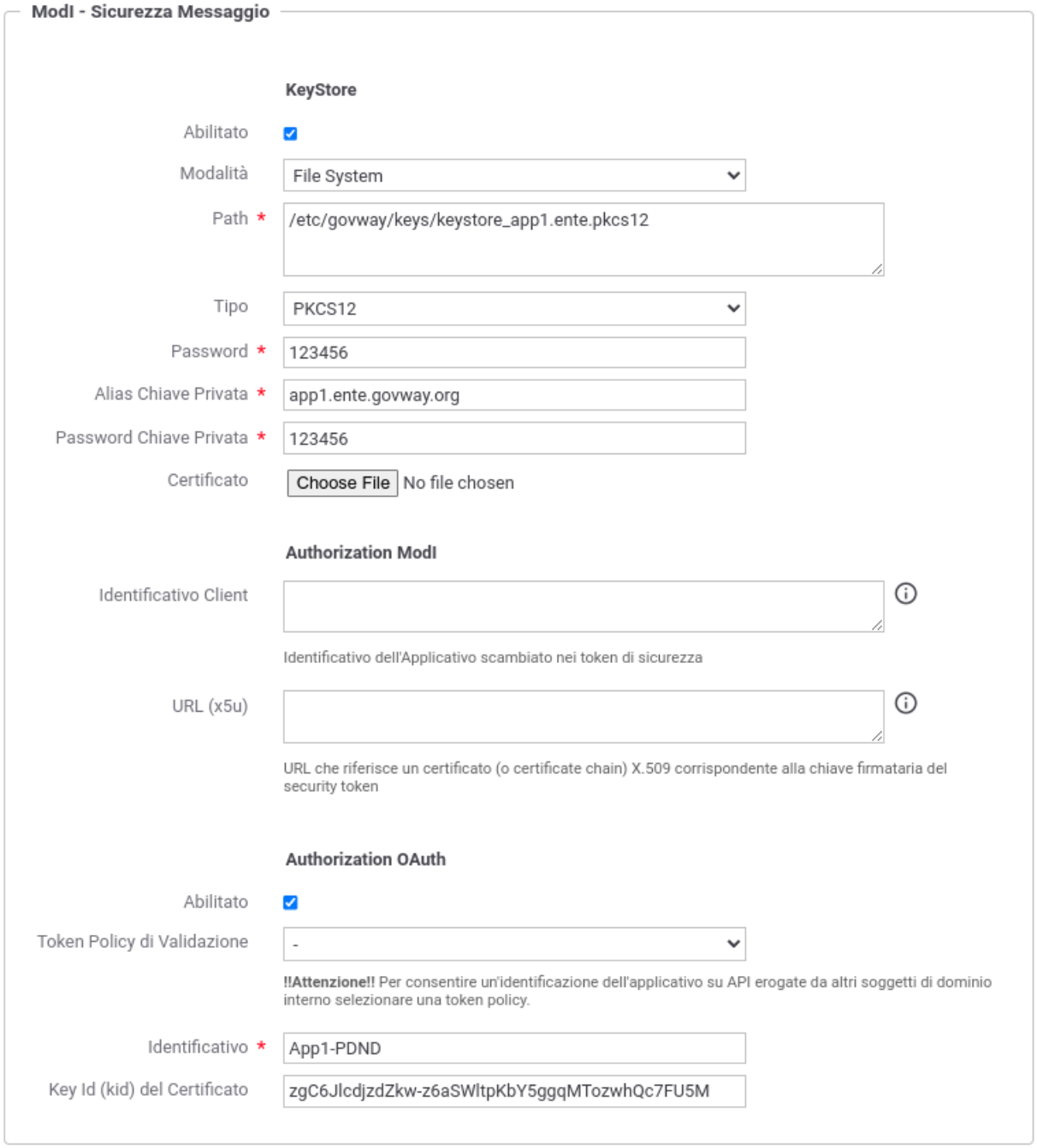


Figure3.117: Configurazione applicativo fruitore (Configurazione ModI)

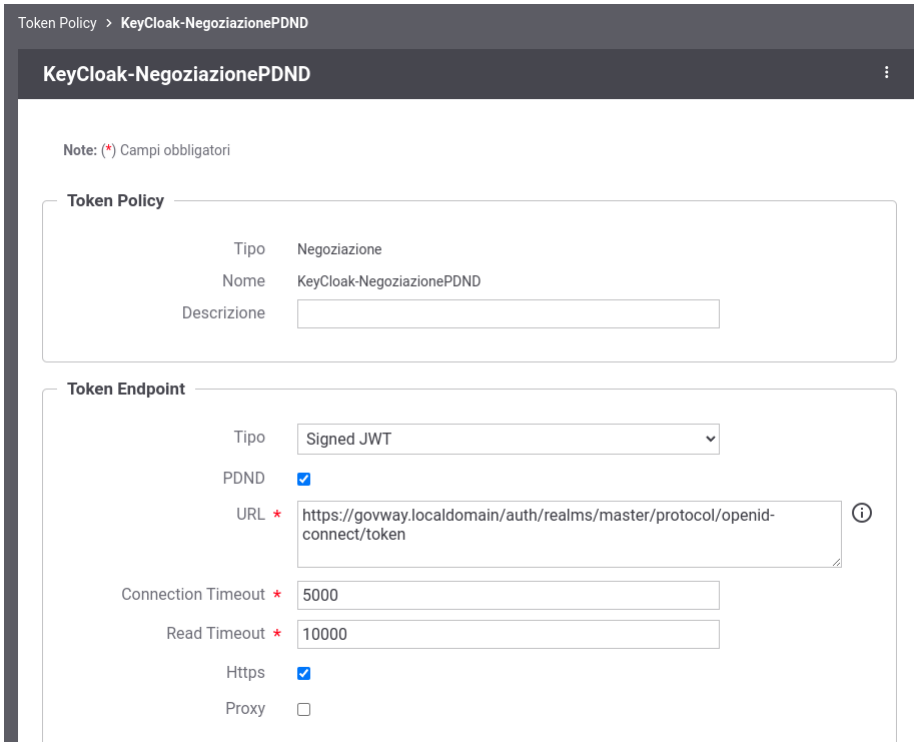


Figure3.118: Token Policy di Negoziazione PDND (Endpoint)

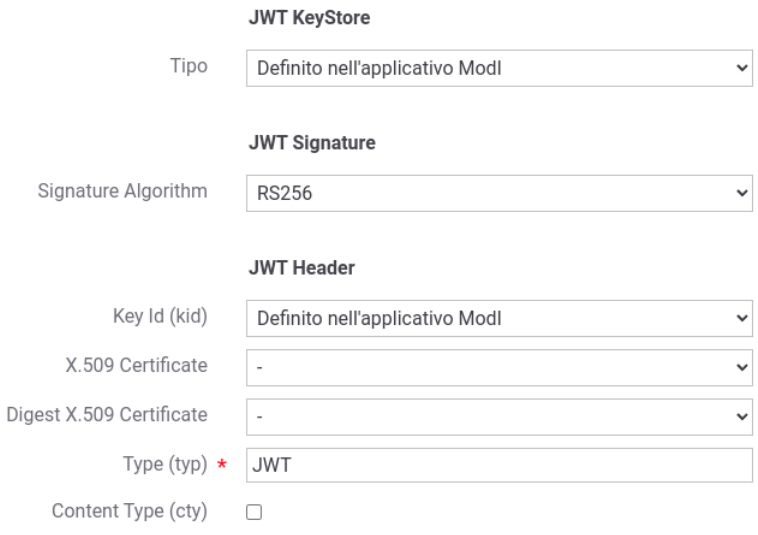


Figure3.119: Token Policy di Negoziazione PDND (Keystore definito nell'applicativo ModI)

- Issuer
- Subject

Nello scenario preconfigurato è stato però scelta la modalità alternativa in cui il ClientID ottenuto dalla PDND deve essere configurato sull'applicativo richiedente e la token policy viene configurata per utilizzare tale valore (Fig. 3.120).

Gli altri campi presenti nella sezione "JWT Payload" rappresentano (Fig. 3.120):

- Audience: indica il servizio di stacco del voucher della PDND. Il valore, fornito dalla PDND, è indipendente dal servizio per cui si vuole richiedere un voucher e varia solamente in funzione dell'ambiente di validazione o produzione della PDND stessa;
- Identifier: consente di configurare la modalità di valorizzazione del claim "jti" presente all'interno del token di richiesta inviato alla PDND. Si suggerisce di valorizzare il campo con la keyword "${transaction:id}" al fine di utilizzare l'identificativo di transazione della richiesta;
- Time to Live (secondi): consente di indicare la durate del token di richiesta inviato alla PDND (es. 100 sec);
- Purpose ID: identificativo univoco della finalità per cui si intende fruire di un servizio. Il valore può essere fornito staticamente o può contenere una keyword risolta a runtime in modo da valorizzare il claim purposeId con un valore prelevato dai dati della richiesta o dalla configurazione della fruizione. Nello scenario preconfigurato il purposeId viene indicato dall'applicativo richiedente tramite l'header HTTP "X-Purpose-Id".
- Informazioni Sessione: consente di valorizzare il claim "sessionInfo" previsto dalla PDND. La valorizzazione può essere statica o formata da parti dinamiche risolte a runtime dal Gateway (per maggiori dettagli valoriDinamici).

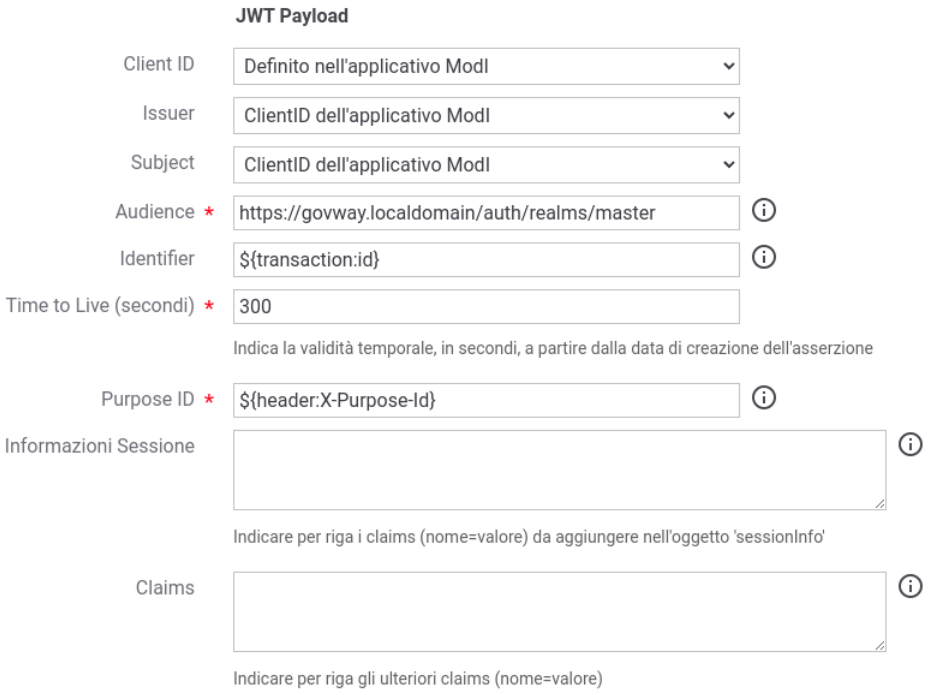


Figure3.120: Token Policy di Negoziazione PDND (JWT Payload)

- Dati Richiesta:

- Resource: indica l'audience/url del servizio per cui si vuole richiedere un voucher; nello scenario preconfigurato il valore viene preso dalla proprietà "PDND-resource" della fruizione configurata.
- Client ID: deve essere indicato il medesimo valore inserito nel campo "Client ID" della sezione "JWT Payload"; nello scenario preconfigurato viene infatti utilizzato il valore configurato sull'applicativo richiedente.

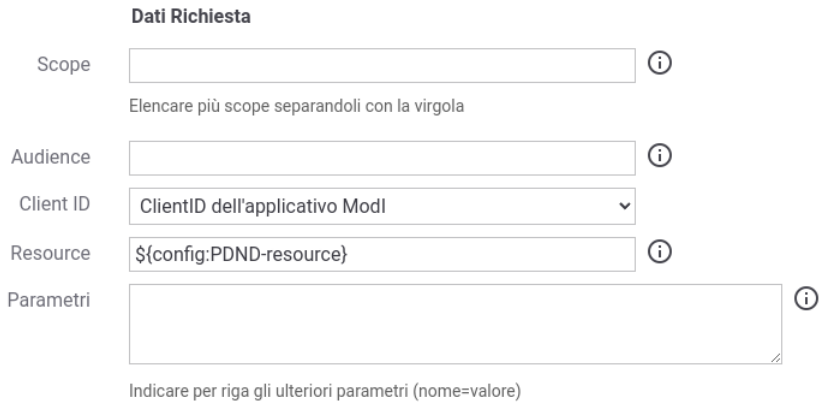


Figure3.121: Token Policy di Negoziazione PDND (Dati Richiesta)

Fruizione

Si registra la fruizione «PetStoreAuthPDND», relativa all'API precedentemente inserita, indicando l'utilizzo della token policy di negoziazione sul connettore (Fig. 3.122).

Tra le proprietà della fruizione viene definita la proprietà "PDND-resource" contenente il valore da inserire nella richiesta di voucher effettuata alla PDND che identifica il servizio per cui si sta richiedendo il token (Fig. 3.123).

3.3.3 Erogazione API SOAP

Obiettivo

Esporre un servizio SOAP, definito tramite una interfaccia WSDL, accessibile in accordo al pattern di sicurezza descritto nella sezione modipa_pdnd.

Sintesi

Mostriamo in questa sezione come procedere per l'esposizione di un servizio SOAP da erogare nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui un servizio è stato registrato sulla PDND, e i fruitori per poterlo fruire devono ottenere un voucher dalla PDND che successivamente devono inviare all'erogatore insieme alla normale richiesta di servizio.

La figura seguente descrive graficamente questo scenario.

Le caratteristiche principali di questo scenario sono:

1. un applicativo eroga un servizio, rivolto a fruitori di domini esterni, registrandolo sulla PDND;
2. la comunicazione con i domini esterni avviene su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;
3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND».

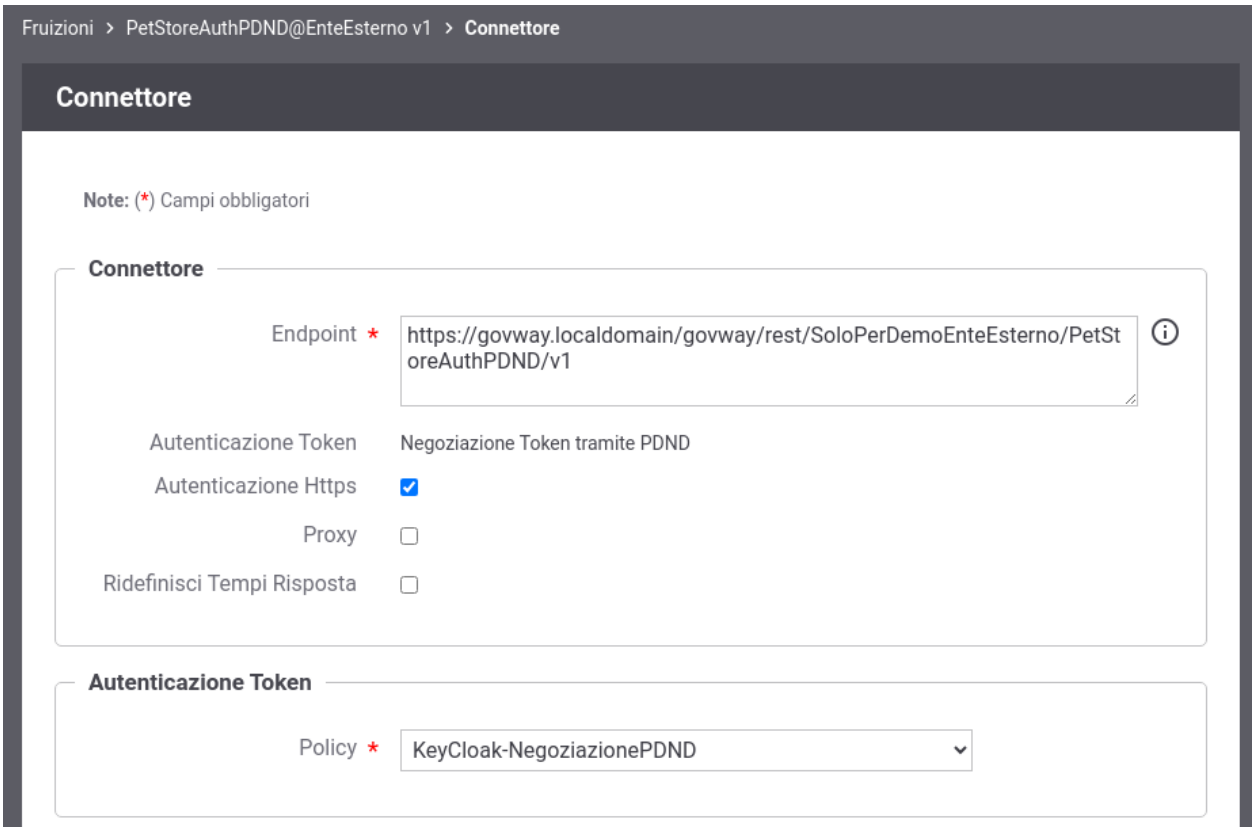


Figure3.122: Associazione della Token Policy di Negoziazione al connettore

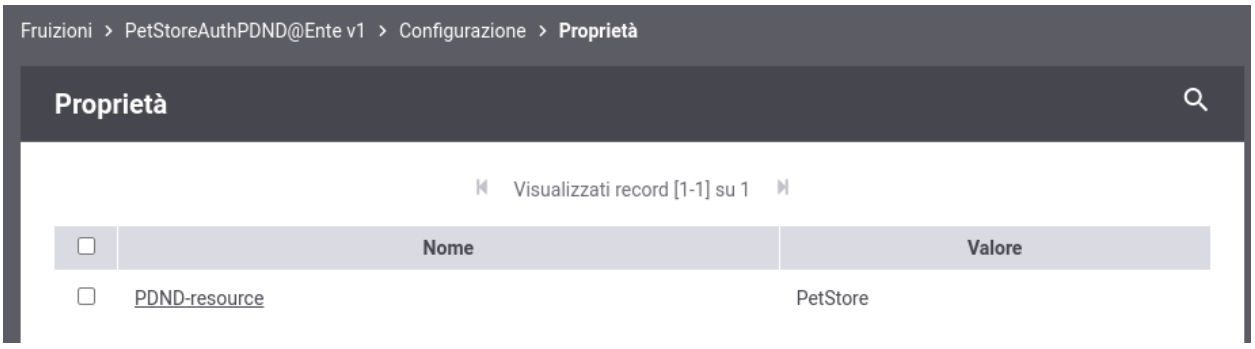


Figure3.123: Proprietà “PDND-resource”

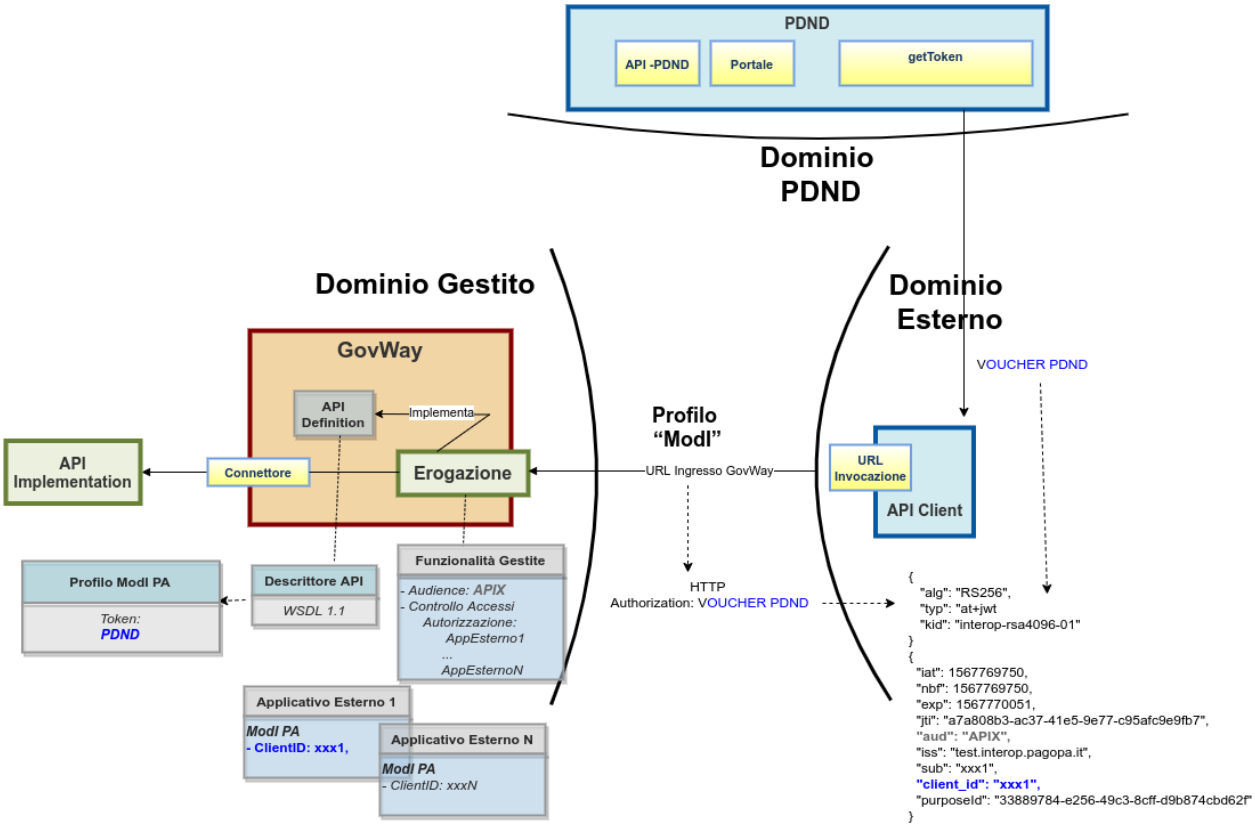


Figure3.124: Erogazione di una API SOAP con profilo "ModI", pattern ID_AUTH_REST_01 via PDND

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.125: Profilo ModI della govwayMonitor

L'esecuzione dello scenario si basa sui seguenti elementi:

- una API SOAP di esempio (Temperature Conversion) definita con pattern di interazione Bloccante e pattern di sicurezza «ID_AUTH_CHANNEL_01» e «ID_AUTH_REST_01 via PDND»;
- un'istanza Govway per la gestione del profilo ModI nel dominio dell'erogatore;
- un'authorization server che simula la PDND;
- un client del dominio esterno che invoca l'azione di esempio «CelsiusToFahrenheit» dell'erogazione esposta da Govway;
- il server "Temperature Conversion" di esempio che riceve le richieste inoltrate dal Govway e produce le relative risposte. Per questo scenario viene utilizzato il server disponibile on line all'indirizzo "https://www.w3schools.com/xml/tempconvert.asmx".

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI SOAP - IDAuth+PDND - IN App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console govwayMonitor.

Le verifiche da effettuare sono le medesime di quelle descritte nello scenario *Esecuzione*.

Lo scenario è preconfigurato per autorizzare puntualmente l'applicativo "App1-ModI" identificato grazie al claim "client_id" presente all'interno del token. È possibile utilizzare il progetto Postman a corredo con la request «Profilo ModI SOAP - IDAuth+PDND - IN App2 - Error» per verificare che una richiesta proveniente da un differente applicativo non viene autorizzata.

Conformità ai requisiti ModI

La verifica dei requisiti ModI per questo scenario non differisce da quanto già descritto in *Esecuzione*.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.

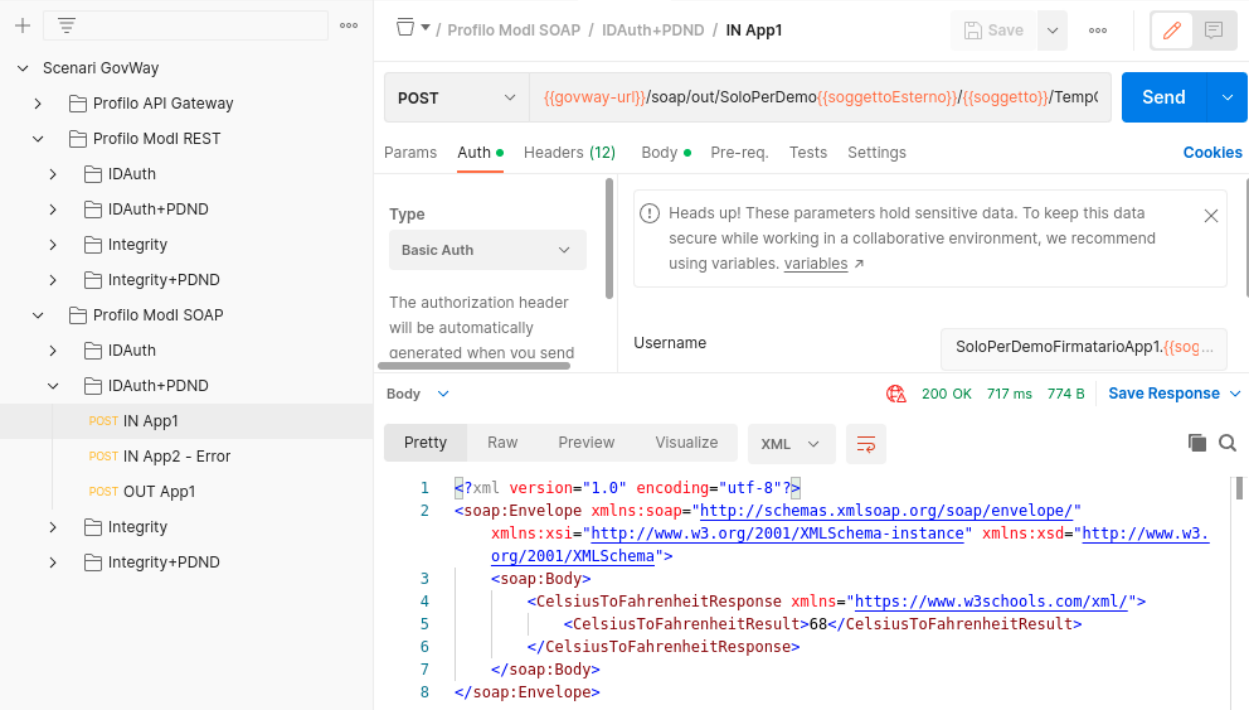


Figure3.126: Pattern IDAuth+PDND - Erogazione API SOAP, esecuzione da Postman



Figure3.127: Profilo ModI della govwayConsole

Il processo di configurazione per questo scenario è del tutto analogo a quello descritto per lo scenario *Esecuzione*. Nel seguito viene riporta solamente la differenza relativa alla registrazione dell'API.

Registrazione API

Viene registrata l'API «TemperatureConversionAuthPDND» con il relativo descrittore WSDL. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «ID_AUTH_SOAP_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND» (Fig. 3.128).

3.3.4 Fruizione API SOAP

Obiettivo

Fruire di un servizio SOAP, definito tramite una interfaccia WSDL, accessibile in accordo al pattern di sicurezza descritto nella sezione modipa_pdnd.

Sintesi

Mostriamo in questa sezione come procedere per l'integrazione di un applicativo con un servizio SOAP erogato nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui il servizio è stato registrato sulla PDND, e il fruitore per poterlo fruire deve ottenere un voucher dalla PDND che successivamente deve inviare all'erogatore insieme alla normale richiesta di servizio.

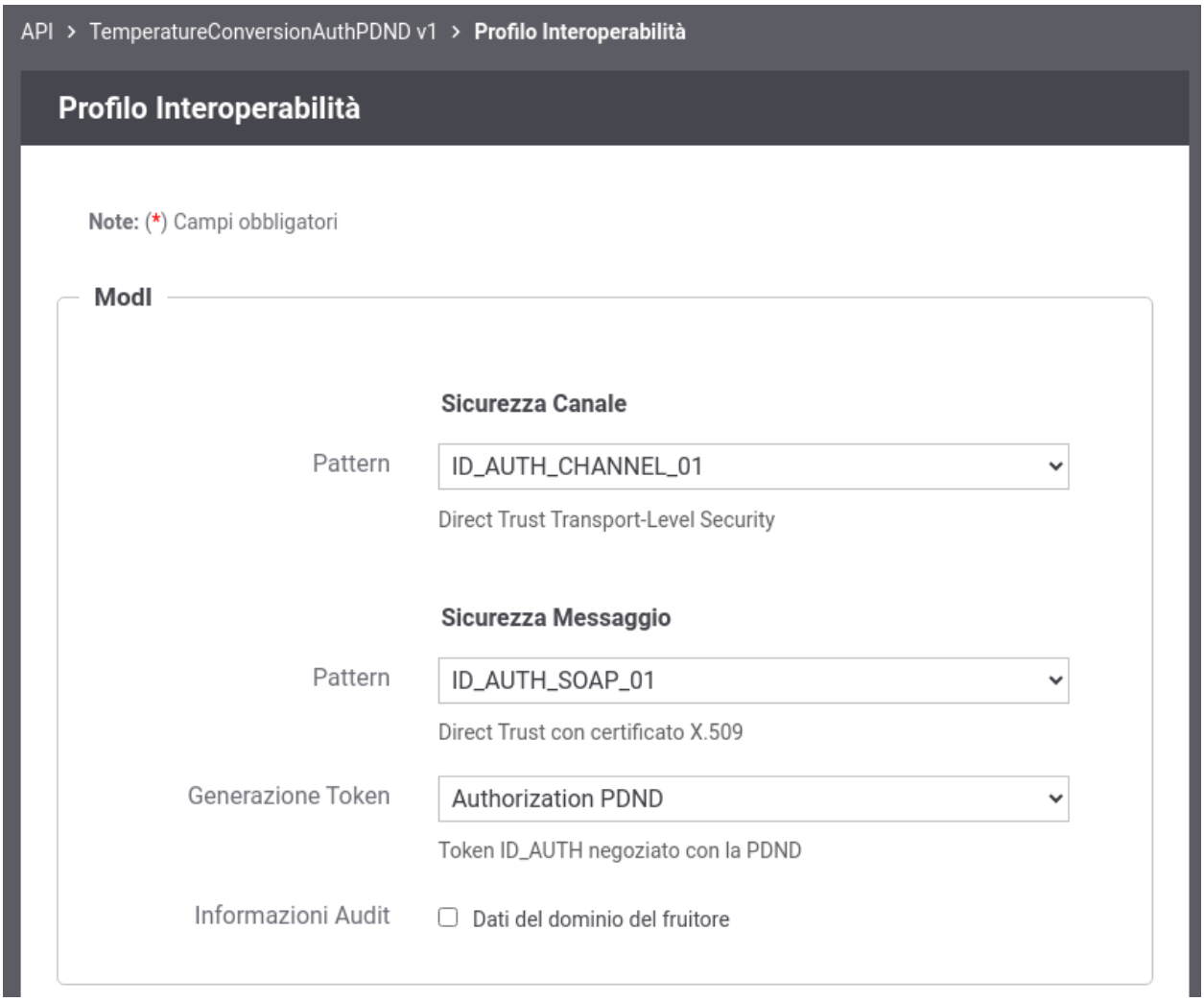


Figure3.128: Configurazione Pattern ModI con «ID_AUTH_CHANNEL_01» senza sicurezza messaggio

La figura seguente descrive graficamente questo scenario.

Le caratteristiche principali di questo scenario sono:

1. un applicativo fruitore che dialoga con il servizio erogato in modalità ModI in accordo ad una API condivisa registrata su PDND;
2. la comunicazione diretta verso il dominio erogatore veicolata su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;
3. l'autenticità della comunicazione tra fruitore ed erogatore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND».

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.130: Profilo ModI della govwayMonitor

L'esecuzione dello scenario si basa sui seguenti elementi:

- una API SOAP di esempio (Temperature Conversion) definita con pattern di interazione Bloccante e pattern di sicurezza «ID_AUTH_CHANNEL_01» e «ID_AUTH_REST_01 via PDND»;
- un'istanza Govway per la gestione del profilo ModI nel dominio del fruitore;
- un'authorization server che simula la PDND;
- un client del dominio gestito che invoca l'azione di esempio «CelsiusToFahrenheit» sulla fruzione configurata su Govway.

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI SOAP - IDAuth+PDND - OUT App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console "govwayMonitor".

Le verifiche da effettuare sono le medesime di quelle descritte nello scenario *Esecuzione*.

Conformità ai requisiti ModI

La verifica dei requisiti ModI per questo scenario non differisce da quanto già descritto in *Esecuzione*.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità «ModI». Si suggerisce

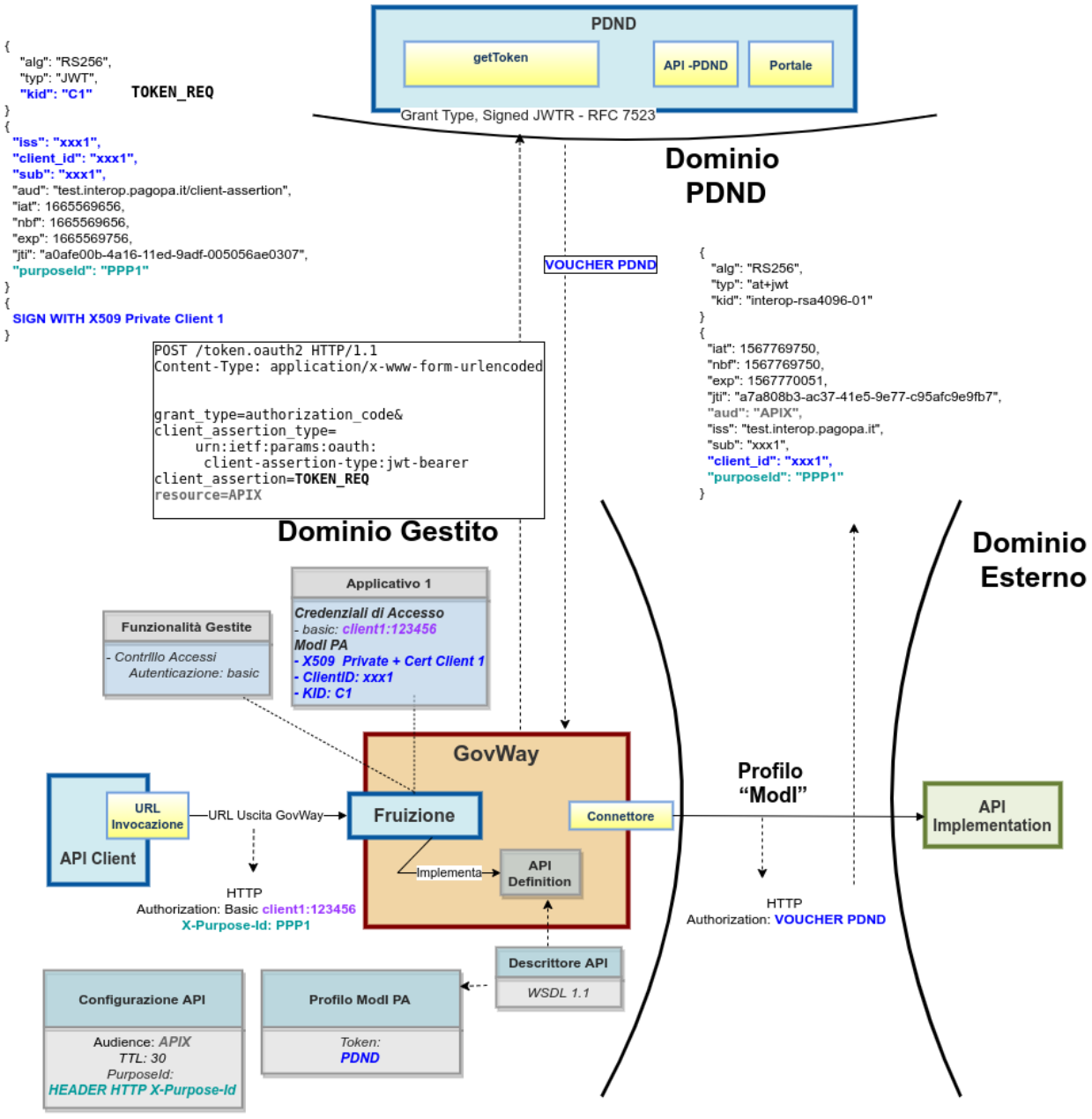


Figure3.129: Fruizione di una API SOAP con profilo "ModI", pattern ID_AUTH_REST_01 via PDND

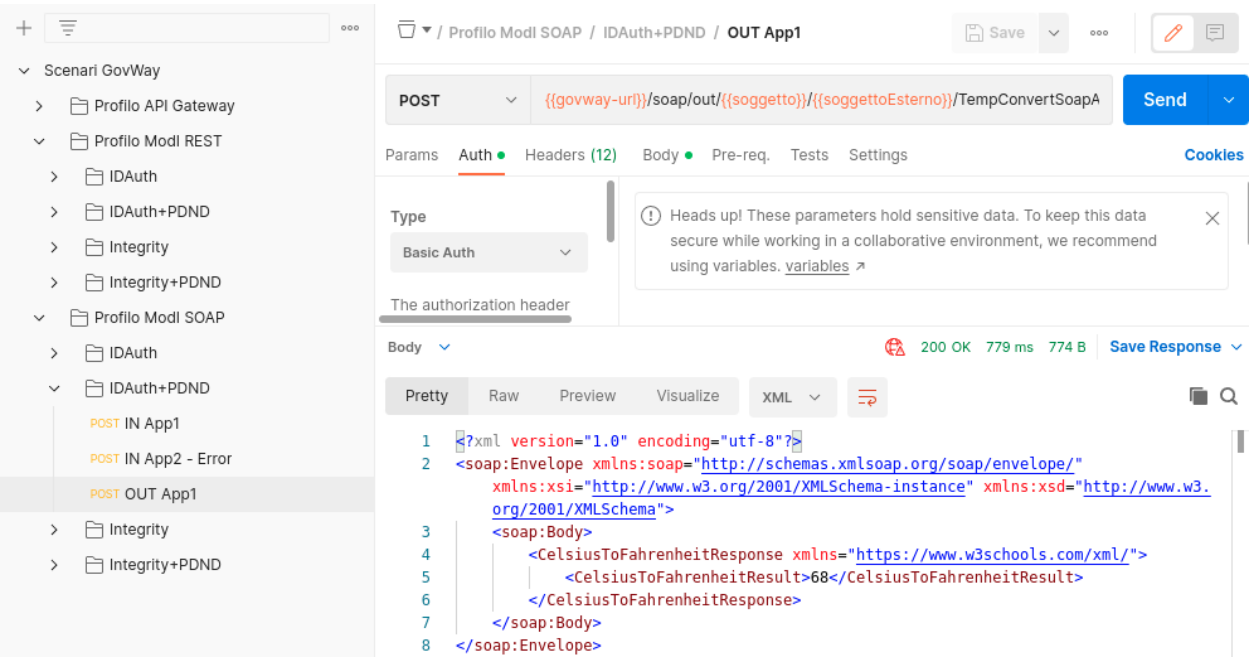


Figure3.131: Pattern IDAuth+PDND - Fruizione API SOAP, esecuzione da Postman

inoltre di selezionare il soggetto “Ente” per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.132: Profilo ModI della govwayConsole

Il processo di configurazione per questo scenario è del tutto analogo a quello descritto per lo scenario *Configurazione*. Nel seguito viene riporta solamente la differenza relativa alla registrazione dell’API.

Registrazione API

Viene registrata l’API «TemperatureConversionAuthPDND» con il relativo descrittore WSDL. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «ID_AUTH_SOAP_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND» (Fig. 3.133).

3.4 Pattern “ID_AUTH” via PDND + “INTEGRITY_01”

Gli scenari riportati in questa sezione riguardano API configurate con pattern modipa_pdnd_integrity.

3.4.1 Erogazione API REST

Obiettivo

Esporre un servizio, definito tramite una API REST (OpenAPI 3.0), accessibile in accordo al pattern di sicurezza descritto nella sezione modipa_pdnd_integrity.

Sintesi

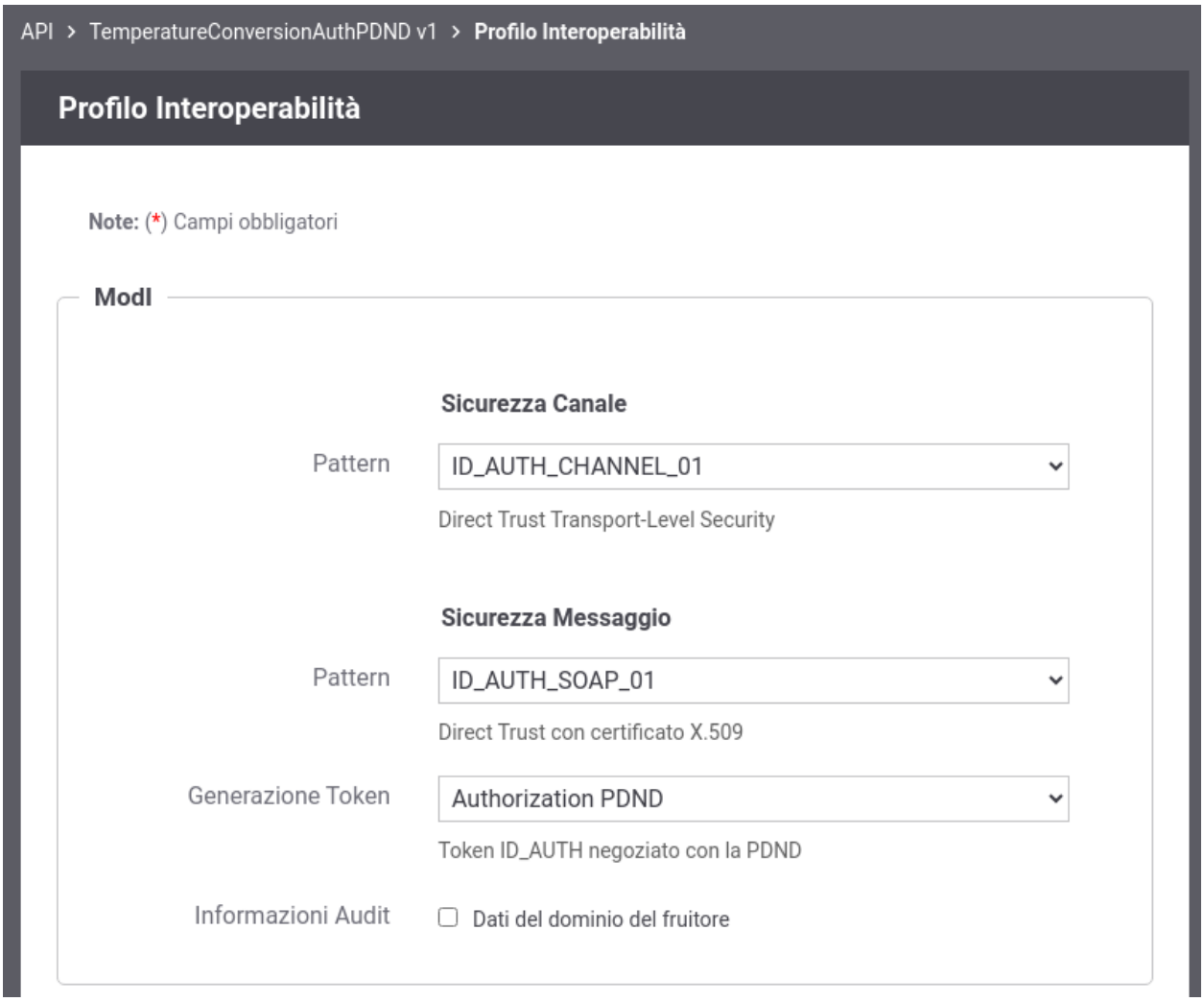


Figure3.133: Configurazione Pattern ModI con «ID_AUTH_CHANNEL_01» senza sicurezza messaggio

Mostriamo in questa sezione come procedere per l'esposizione di un servizio REST da erogare nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui un servizio è stato registrato sulla PDND, e i fruitori per poterlo fruire devono ottenere un voucher dalla PDND che successivamente devono inviare all'erogatore insieme alla normale richiesta di servizio. Oltre al voucher devono anche presentare il token di sicurezza «Agid-JWT-Signature» previsto dal pattern «INTEGRITY_REST_01» a garanzia dell'integrità del messaggio.

La figura seguente descrive graficamente questo scenario.

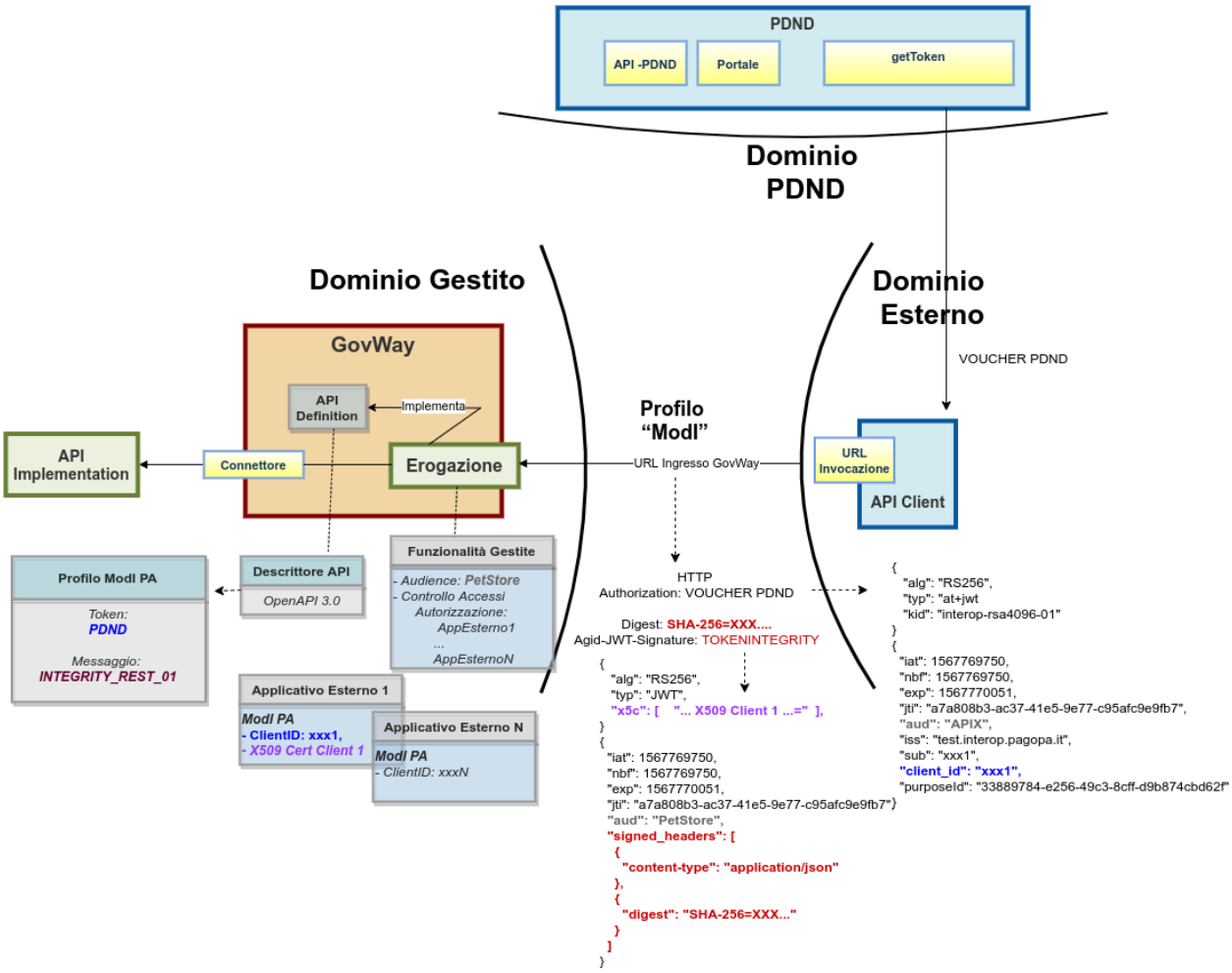


Figure3.134: Erogazione di una API REST con profilo "ModI", pattern INTEGRITY_REST_01 e pattern ID_AUTH_REST_01 via PDND

Le caratteristiche principali di questo scenario sono:

1. un applicativo eroga un servizio, rivolto a fruitori di domini esterni, in conformità al Modello di Interoperabilità AGID e il servizio viene registrato sulla PDND;
2. la comunicazione con i domini esterni avviene su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;
3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND»;
4. l'integrità del messaggio scambiato è garantita tramite sicurezza messaggio aggiuntiva prevista nel pattern «INTEGRITY_REST_01».

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.135: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «INTEGRITY_REST_01».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - Integrity+PDND - IN App3» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

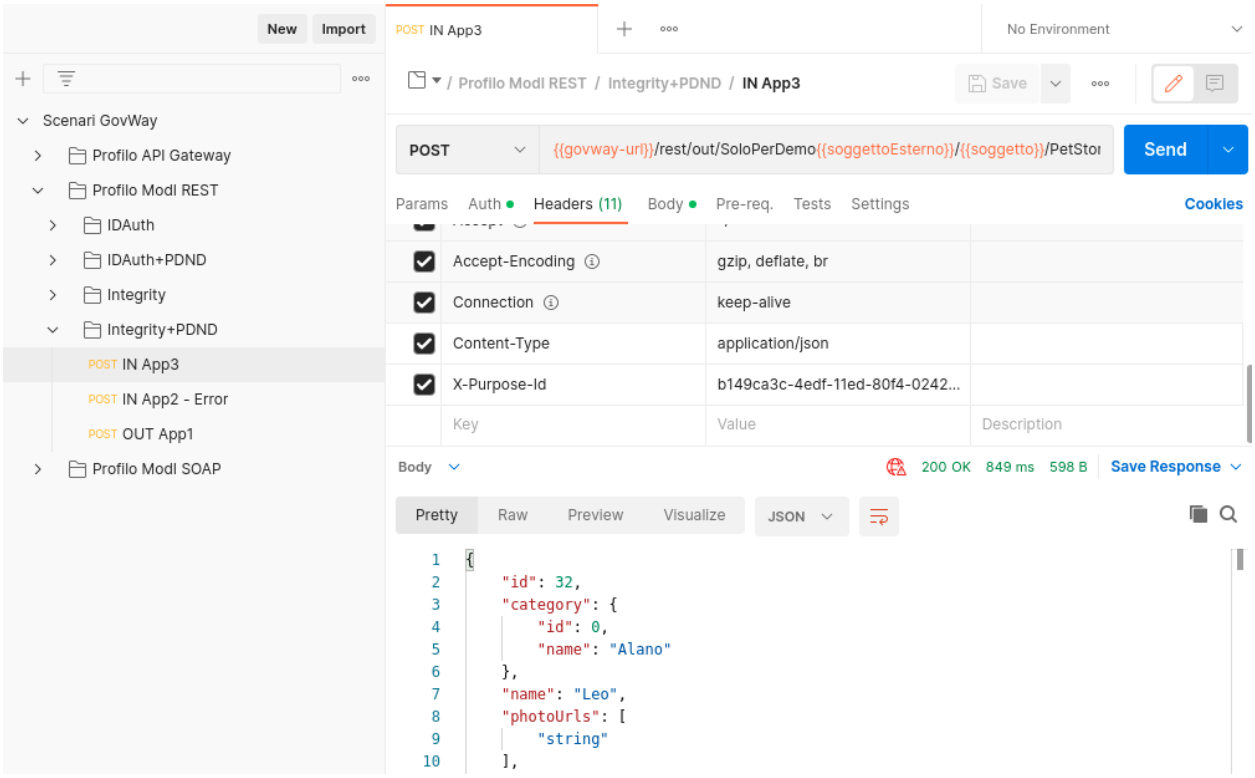


Figure3.136: Pattern Integrity+PDND - Erogazione API REST, esecuzione da Postman

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console "govwayMonitor".

Le verifiche da effettuare sono le medesime di quelle descritte nello scenario *Esecuzione*. Di seguito vengono riportati solo i punti salienti in cui emerge una differenza dovuta al pattern di sicurezza diverso utilizzato.

- Dal dettaglio della richiesta si può visualizzare il messaggio che è stato inviato dal fruitore, come in Fig. 3.137.

Come si nota, al payload JSON è associato un insieme di header HTTP tra i quali «Authorization» e «Agid-Jwt-Signature» che contengono rispettivamente il token di sicurezza che il fruitore ha ottenuto dalla PDND e il token di integrità. È inoltre presente l'header http «Digest» che contiene il valore per la verifica dell'integrità del payload.

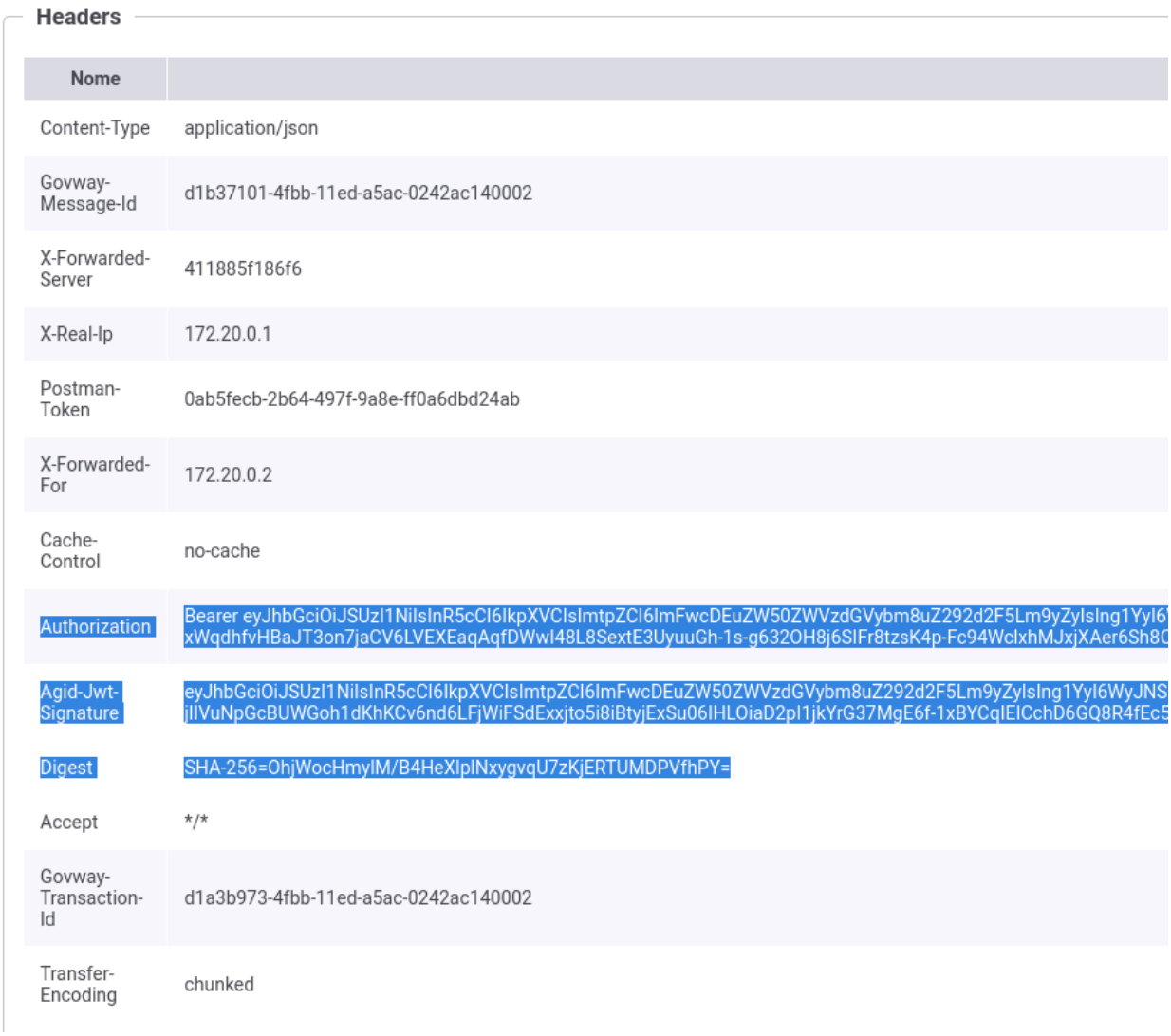


Figure3.137: Messaggio inviato dal fruitore

- Tutte le analisi che riguardano il token di autenticazione generato dalla PDND sono le medesime descritte nello scenario *Esecuzione*.
- Inoltre grazie alle configurazioni presenti nell'erogazione, ed in particolare alla relazione di trust stabilita con il fruitore, Govway è in grado di validare i dati di sicurezza ricevuti nel token «Agid-JWT-Signature». Nella fase di validazione del token si può notare come nella sezione header (Fig. 3.138) viene riportata l'identità del fruitore sotto forma di certificato X.509 a differenza di quello ottenuto dalla PDND.
- Il messaggio ricevuto dal Govway viene quindi validato, sulla base dei pattern di sicurezza previsti nello scambio, verificando in questo caso l'identità del fruitore, la validità temporale, la corrispondenza dell'audience ricevuto con quello atteso e la corrispondenza del digest con il payload e con il valore interno al token «Agid-Jwt-Signature». Solo in caso di superamento dell'intero processo di validazione, il messaggio viene inoltrato al servizio erogatore.

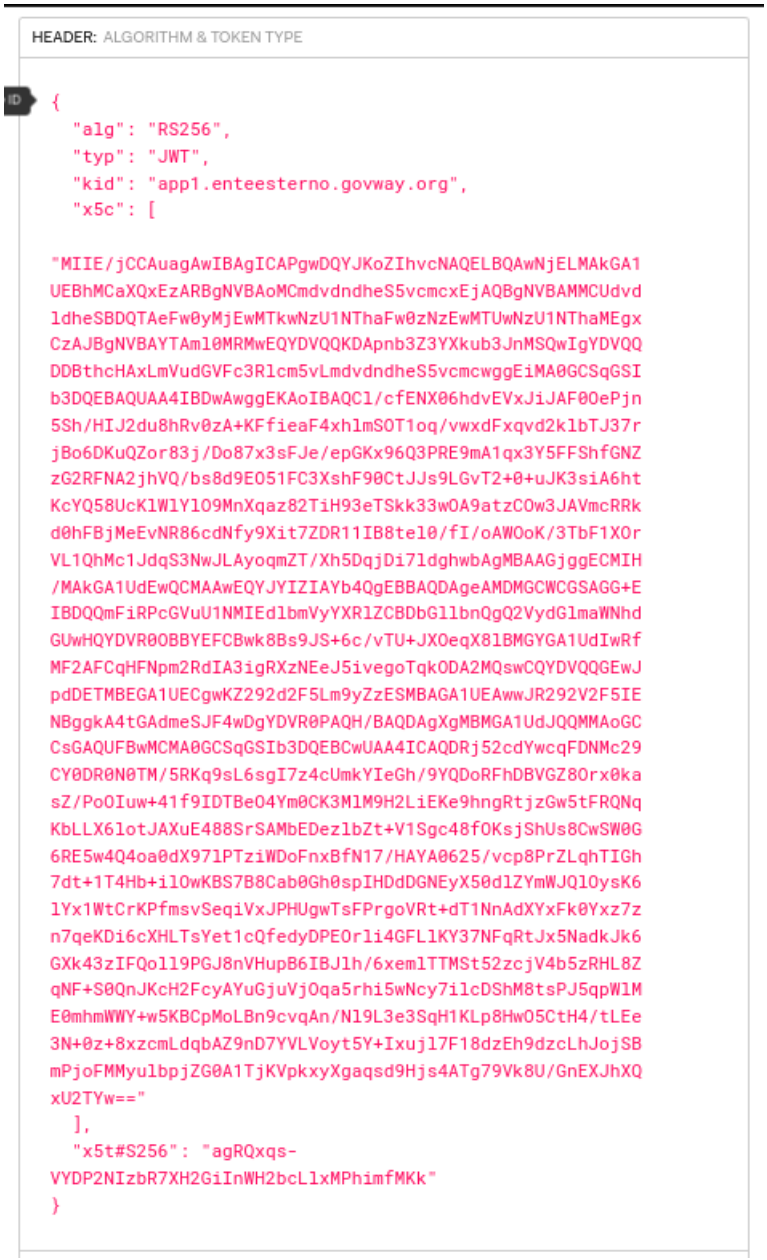


Figure3.138: Sezione «Header» del Token di sicurezza «Agid-Jwt-Signature»

Nel payload del token «Agid-JWT-Signature» (Fig. 3.139) sono invece presenti i riferimenti temporali (iat, nbf, exp), l'audience (aud) e il claim "signed_headers" utilizzato per la verifica dell'integrità.



Figure3.139: Sezione «Payload» del Token di sicurezza «Agid-Jwt-Signature»

Le evidenze del processo di validazione relative al token PDND sono le medesime descritte nella scenario *Esecuzione*.

Le evidenze del processo di validazione relativo al pattern «INTEGRITY_REST_01» sono visibili sulla govwayMonitor, andando a consultare la traccia del messaggio di richiesta (Fig. 3.140). Nella sezione «Sicurezza Messaggio» sono riportate le informazioni estratte dai token di sicurezza presenti, tra cui si può notare il digest e gli header http firmati.

- Lo scenario è preconfigurato per autorizzare puntualmente l'applicativo "App3-ModI" identificato grazie al claim "client_id" presente all'interno del token della PDND. È possibile utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - Integrity+PDND - IN App2 - Error» per verificare che una richiesta proveniente da un differente applicativo non viene autorizzata.

Conformità ai requisiti ModI

I requisiti iniziali, legati alla comunicazione basata su uno scenario ModI, sono verificati dalle seguenti evidenze:

1. la sicurezza messaggio applicata è quella dei pattern «ID_AUTH_REST_01 via PDND» + «INTEGRITY_REST_01» come ampiamente mostrato precedentemente dove sono stati mostrati i token validati e i criteri autorizzativi;
2. l'identificazione del fruitore avviene rispetto al claim "client_id" presente all'interno del token. È stato anche mostrato come sia possibile configurare criteri autorizzativi puntuali.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.

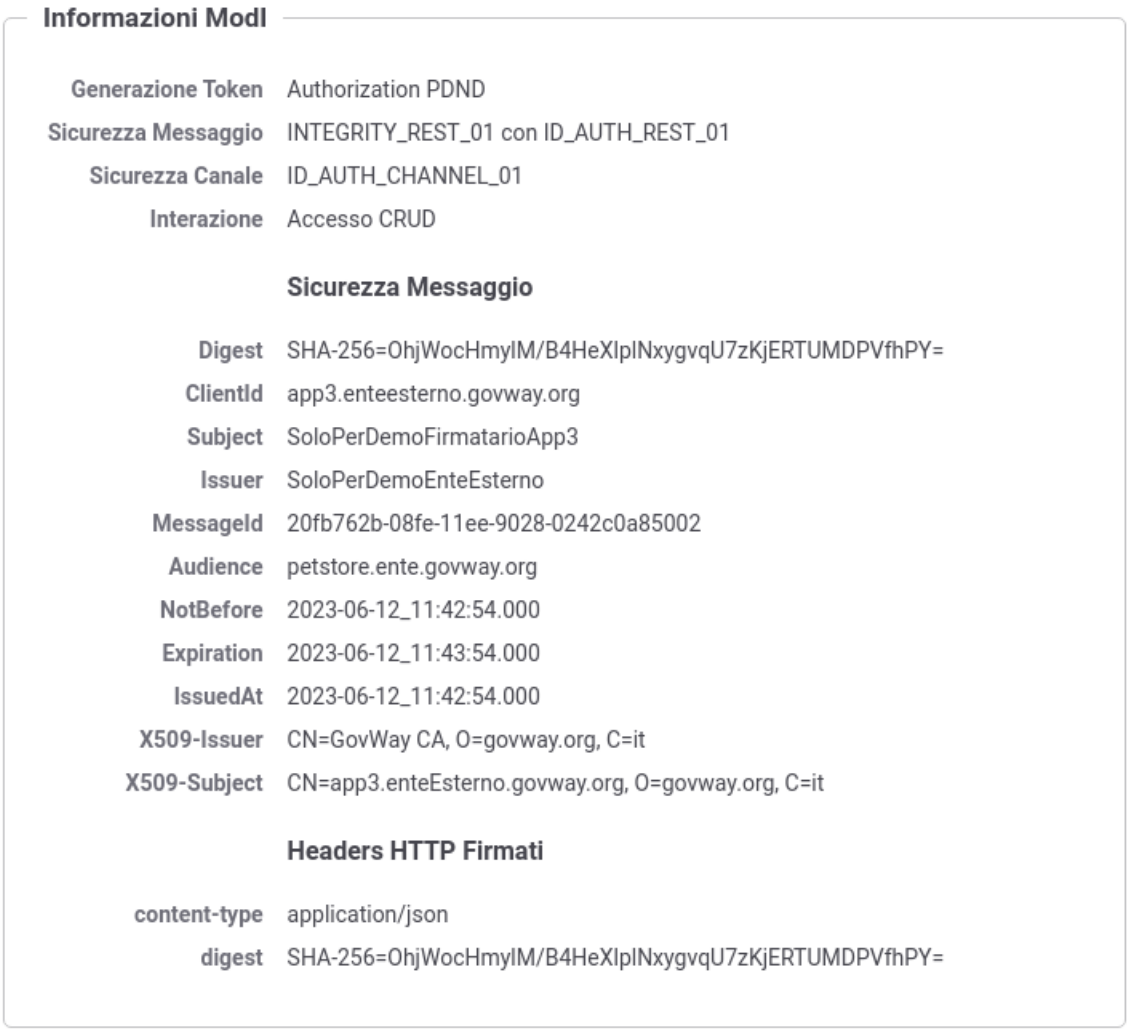


Figure3.140: Traccia della richiesta elaborata dall'erogatore

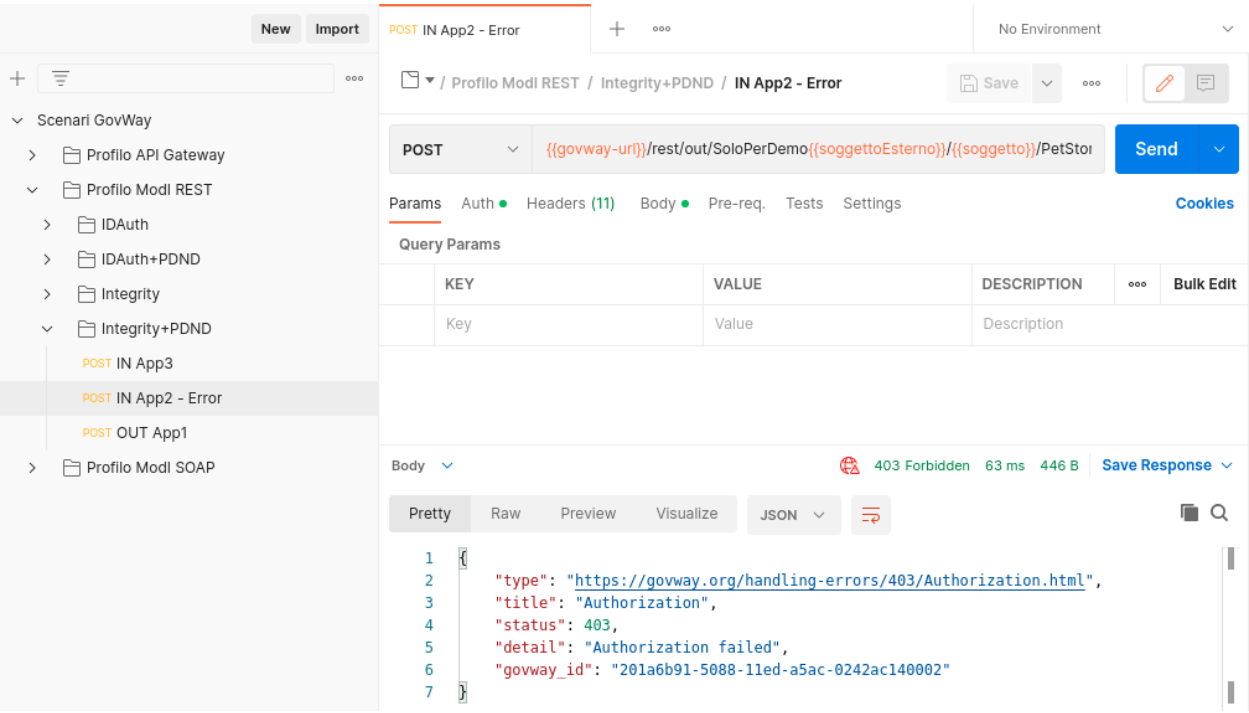


Figure3.141: Pattern Integrity+PDND - Erogazione API REST - Autorizzazione negata, esecuzione da Postman



Figure3.142: Profilo ModI della govwayConsole

La configurazione dello scenario è del tutto analogo a quello descritto nello scenario *Configurazione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «INTEGRITY_REST_01».

Registrazione API

Viene registrata l'API «PetStoreIntegrityPDND» con il relativo descrittore OpenAPI 3. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «INTEGRITY_REST_01 con ID_AUTH_REST_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND» (Fig. 3.56).

Applicativo Esterno

È opzionalmente possibile registrare l'applicativo esterno che corrisponde al fruitore del servizio come descritto nello scenario nello scenario *Configurazione*.

La registrazione comporta l'associazione all'applicativo sia del "client_id" necessario all'identificazione che del certificato di firma che verrà atteso nell'header HTTP "Agid-JWT-Signature" (Fig. 3.144). Questo scenario è quello preconfigurato.

Erogazione

Nell'erogazione «PetStoreIntegrityPDND», relativa all'API precedentemente inserita, vanno indicati i dati specifici nella sezione «ModI Richiesta» (Fig. 3.145) necessari per validare le richieste in ingresso relativamente al token "Agid-JWT-Signature".

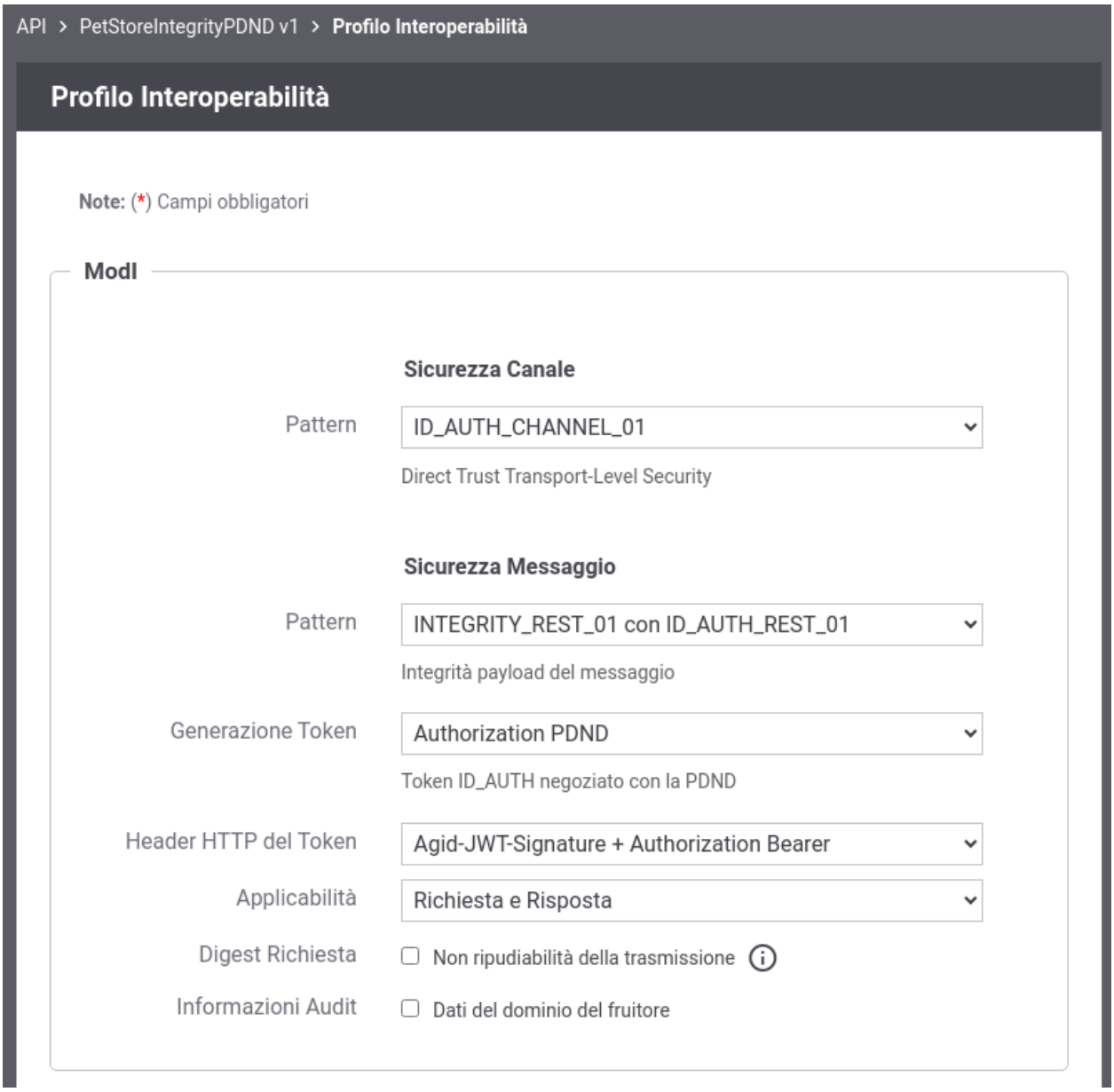


Figure3.143: Configurazione Pattern ModI «INTEGRITY_REST_01 con ID_AUTH_REST_01» sulla API REST

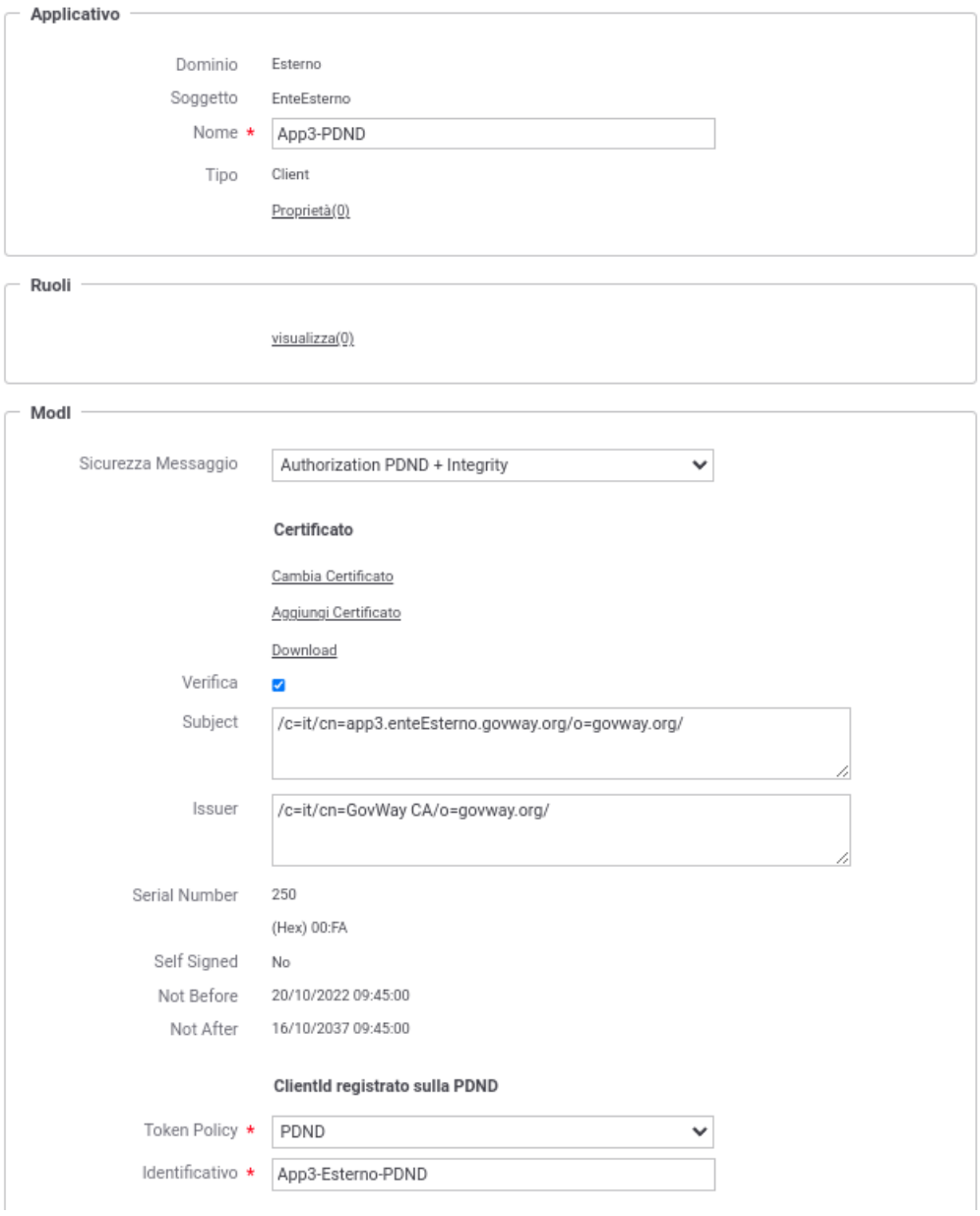


Figure3.144: Configurazione applicativo esterno (fruitore)

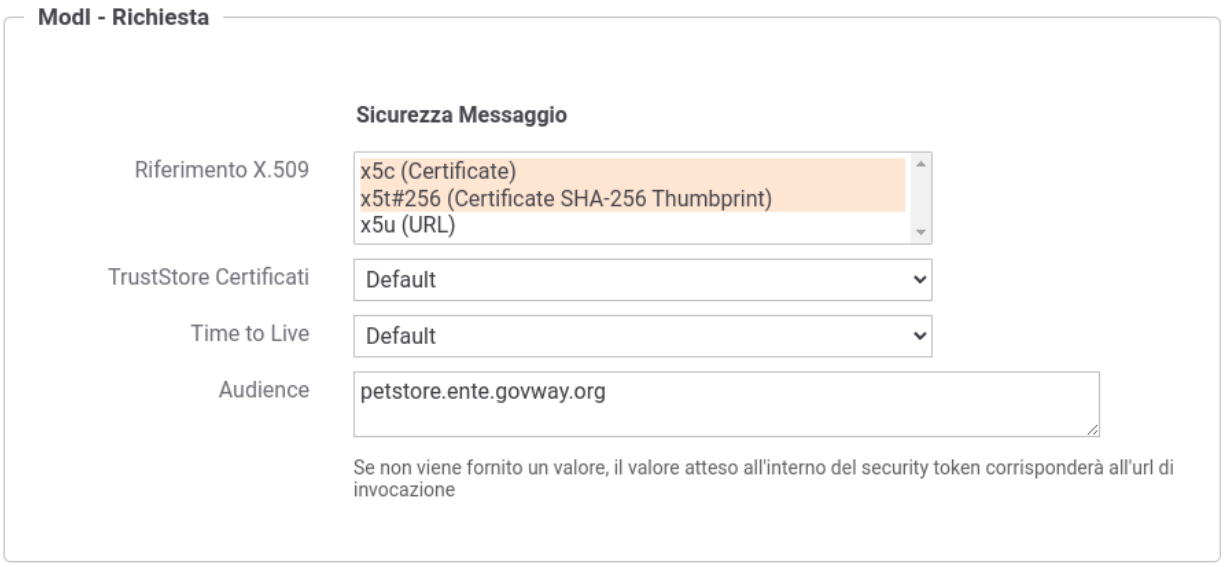


Figure3.145: Configurazione richiesta dell'erogazione

La sezione «ModI Risposta» si utilizza per indicare i parametri per la produzione del token di sicurezza "Agid-JWT-Signature" da inserire nel messaggio di risposta (Fig. 3.146).

3.4.2 Fruizione API REST

Obiettivo

Fruire di un servizio REST, definito tramite una API REST (OpenAPI 3.0), accessibile in accordo al pattern di sicurezza descritto nella sezione modipa_pdnd_integrity.

Sintesi

Mostriamo in questa sezione come procedere per l'integrazione di un applicativo con un servizio REST erogato nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui il servizio è stato registrato sulla PDND, e il fruitore per poterlo fruire deve ottenere un voucher dalla PDND che successivamente deve inviare all'erogatore insieme alla normale richiesta di servizio. Oltre al voucher il fruitore devo anche presentare il token di sicurezza «Agid-JWT-Signature» previsto dal pattern «INTEGRITY_REST_01» a garanzia dell'integrità del messaggio.

La figura seguente descrive graficamente questo scenario.

Le caratteristiche principali di questo scenario sono:

1. un applicativo fruitore che dialoga con il servizio erogato in modalità ModI in accordo ad una API condivisa e pubblicata su PDND;
2. la comunicazione diretta verso il dominio erogatore veicolata su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;
3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND»;
4. l'integrità del messaggio scambiato è garantita tramite sicurezza messaggio aggiuntiva prevista nel pattern «INTEGRITY_REST_01».

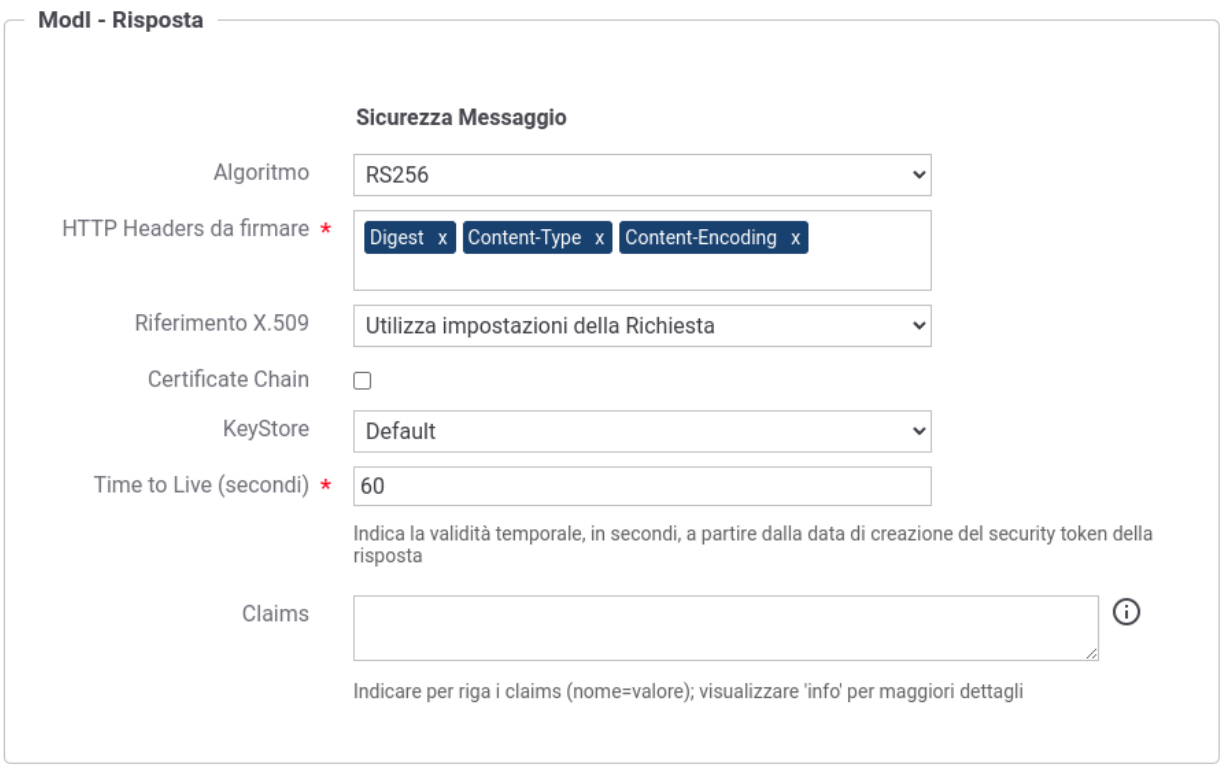


Figure3.146: Configurazione risposta dell'erogazione

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.148: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «INTEGRITY_REST_01».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - Integrity+PDND - OUT App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto nelle diverse fasi dell'esecuzione andando a consultare la console "govwayMonitor".

Le verifiche da effettuare sono le medesime di quelle descritte nello scenario *Esecuzione*. Di seguito vengono riportati solo i punti salienti in cui emerge una differenza dovuta al pattern di sicurezza diverso utilizzato.

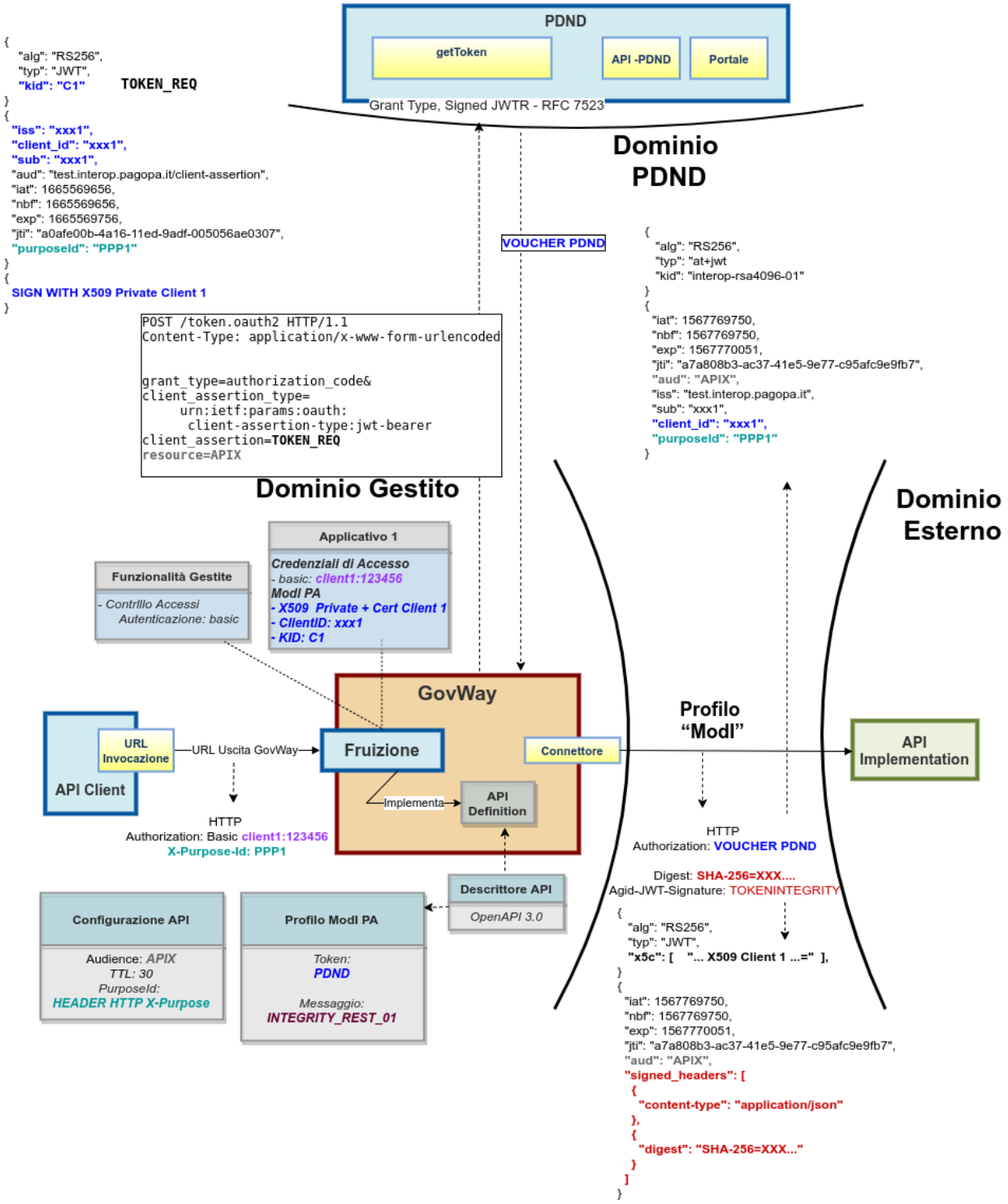


Figure3.147: Fruizione di una API REST con profilo "Modl", pattern INTEGRITY_REST_01 e pattern ID_AUTH_REST_01 via PDND

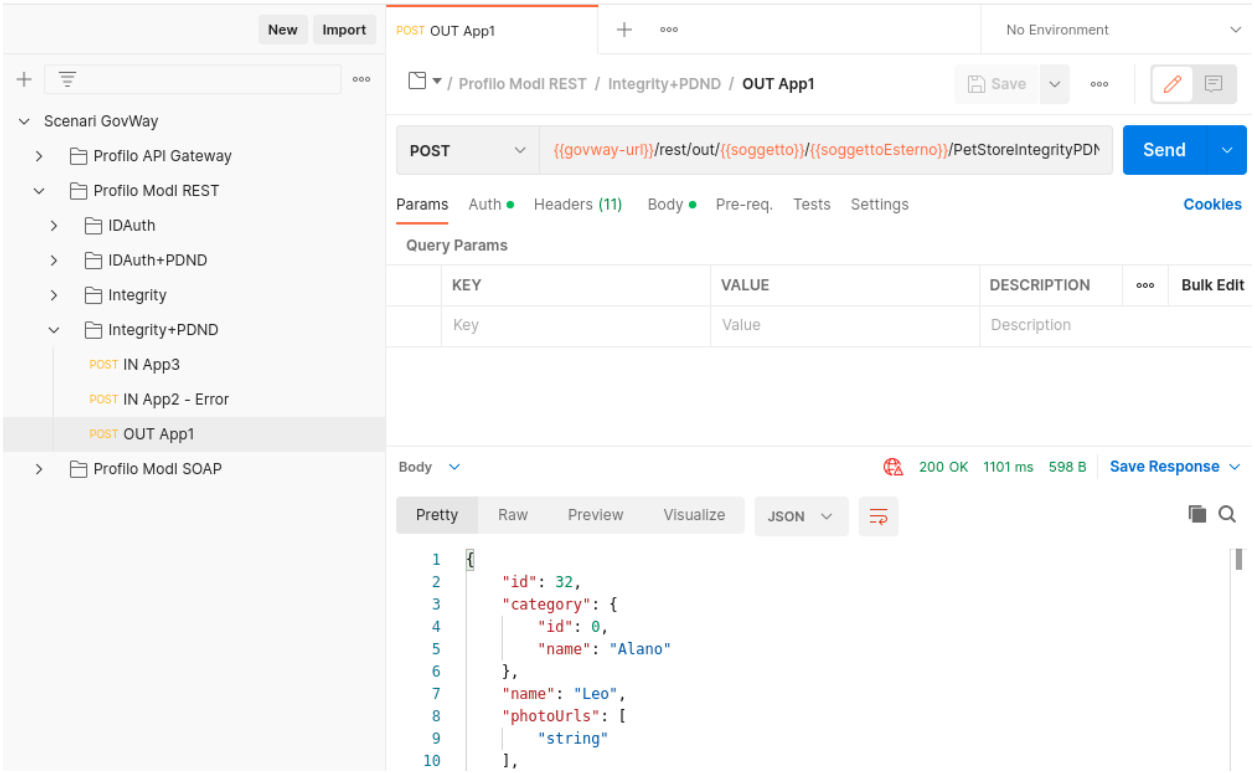


Figure3.149: Pattern Integrity+PDND - Fruizione API REST, esecuzione da Postman

- Il messaggio di richiesta inviato dal fruitore viene elaborato da Govway che, tramite la configurazione della firma digitale associata all'applicativo mittente, è in grado di produrre un token di sicurezza da inviare alla PDND con il quale ottenere indietro un voucher spendibile per il servizio desiderato. Questa parte è stata ampiamente mostrata nella scenario *Esecuzione*.

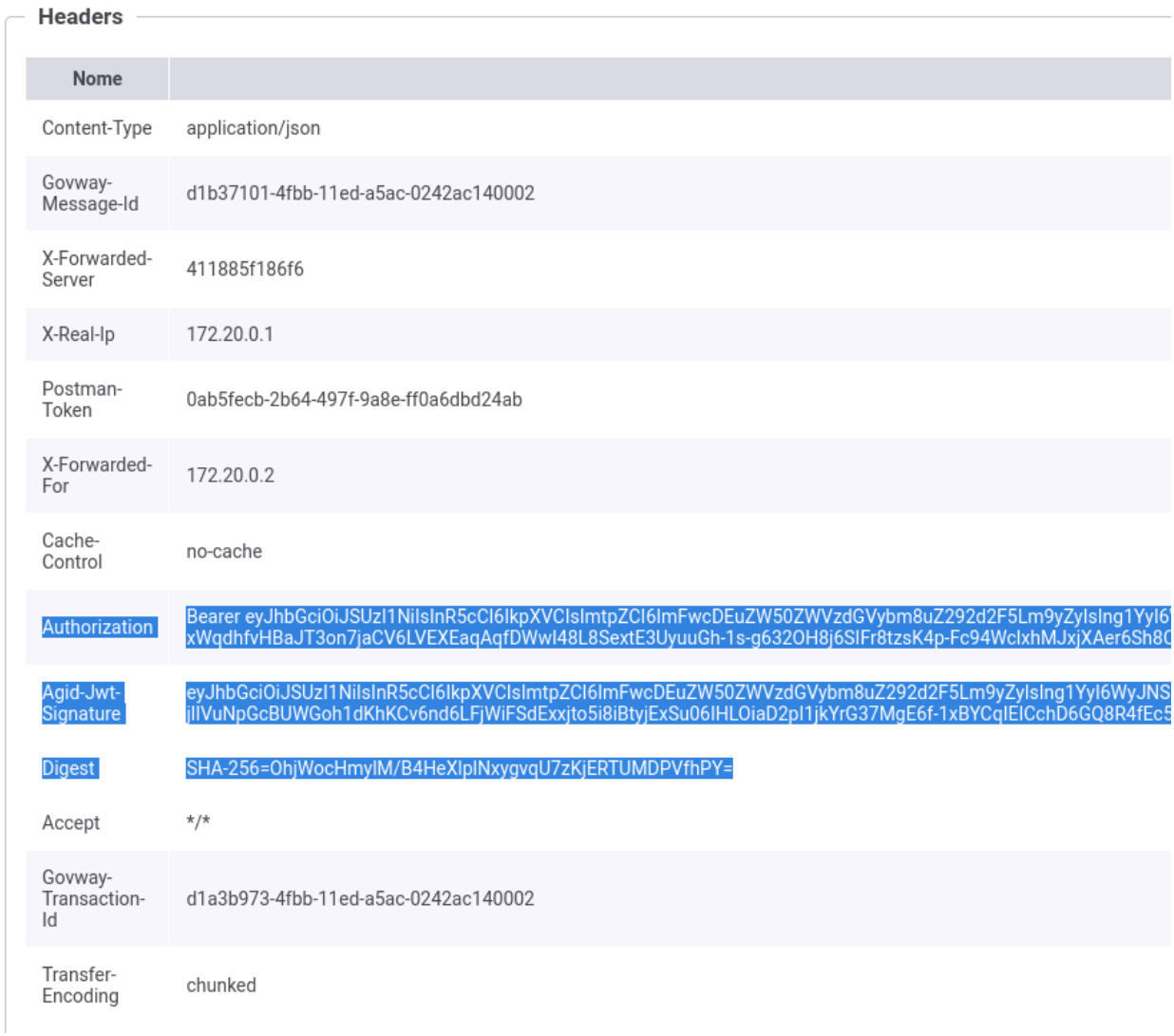
  Oltre al token della PDND, GovWay produce un ulteriore token di sicurezza «Agid-JWT-Signature» previsto dal pattern «INTEGRITY_REST_01». Da govwayMonitor si può visualizzare il messaggio di richiesta in uscita che è il medesimo di quello in entrata con la differenza che sono stati aggiunti gli header HTTP «Authorization» e «Agid-Jwt-Signature» che contengono rispettivamente il token ottenuto dalla PDND e il token dell'integrità. È inoltre presente l'header http «Digest» che contiene il valore utilizzabile dall'erogatore per la verifica dell'integrità del payload. (Fig. 3.150).

- L'header e i payload del token «Agid-JWT-Signature» sono identici a quelli già visualizzati nello scenario di erogazione REST, relativamente al messaggio in ingresso (Fig. 3.138 e Fig. 3.139). Le informazioni inserite nel token vengono anche tracciate e sono visibili sulla govwayMonitor, andando a consultare la traccia del messaggio di richiesta (Fig. 3.151). Nella sezione «Sicurezza Messaggio» sono riportate le informazioni estratte dai token di sicurezza, tra cui si può notare il digest e gli header http firmati.

Conformità ai requisiti ModI

I requisiti iniziali, legati alla comunicazione basata su uno scenario ModI, sono verificati dalle seguenti evidenze:

1. viene effettuata una negoziazione del voucher PDND come mostrato nelle tracce relative ai token scambiati con la PDND;
2. l'invocazione del servizio avviene fornendo il voucher della PDND precedentemente negoziato;
3. vengono inoltre prodotti gli header http «Agid-Jwt-Signature» e «Digest» previsti dal pattern di sicurezza «INTEGRITY_REST_01».



Headers

Nome	
Content-Type	application/json
Govway-Message-Id	d1b37101-4fbb-11ed-a5ac-0242ac140002
X-Forwarded-Server	411885f186f6
X-Real-Ip	172.20.0.1
Postman-Token	0ab5fecb-2b64-497f-9a8e-ff0a6dbd24ab
X-Forwarded-For	172.20.0.2
Cache-Control	no-cache
Authorization	Bearer eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6ImFwcDEuZW50ZWVzdGVybm8uZ292d2F5Lm9yZyIsIng1YyI6[illegible] xWqdhfvHBaJT3on7jaCV6LVEXEaqAqfDWwI48L8SextE3UyuuGh-1s-g632OH8j6SIFr8tzsK4p-Fc94WclxhMJxjXAer6Sh8[illegible]
Agid-Jwt-Signature	eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6ImFwcDEuZW50ZWVzdGVybm8uZ292d2F5Lm9yZyIsIng1YyI6WyJNS[illegible] jIlVuNpGcBUWGoh1dKhKCv6nd6LFjWiFSdExxjto5i8iBtyjExSu06IHLOiaD2pI1jkYrG37MgE6f-1xBYCqIElCchD6GQ8R4fEc5[illegible]
Digest	SHA-256=OhjWocHmyIM/B4HeXlpINxygvqU7zKjERTUMDPVfhPY=
Accept	*/*
Govway-Transaction-Id	d1a3b973-4fbb-11ed-a5ac-0242ac140002
Transfer-Encoding	chunked

Figure3.150: Messaggio di richiesta in uscita (con token di sicurezza inseriti nell'header HTTP)

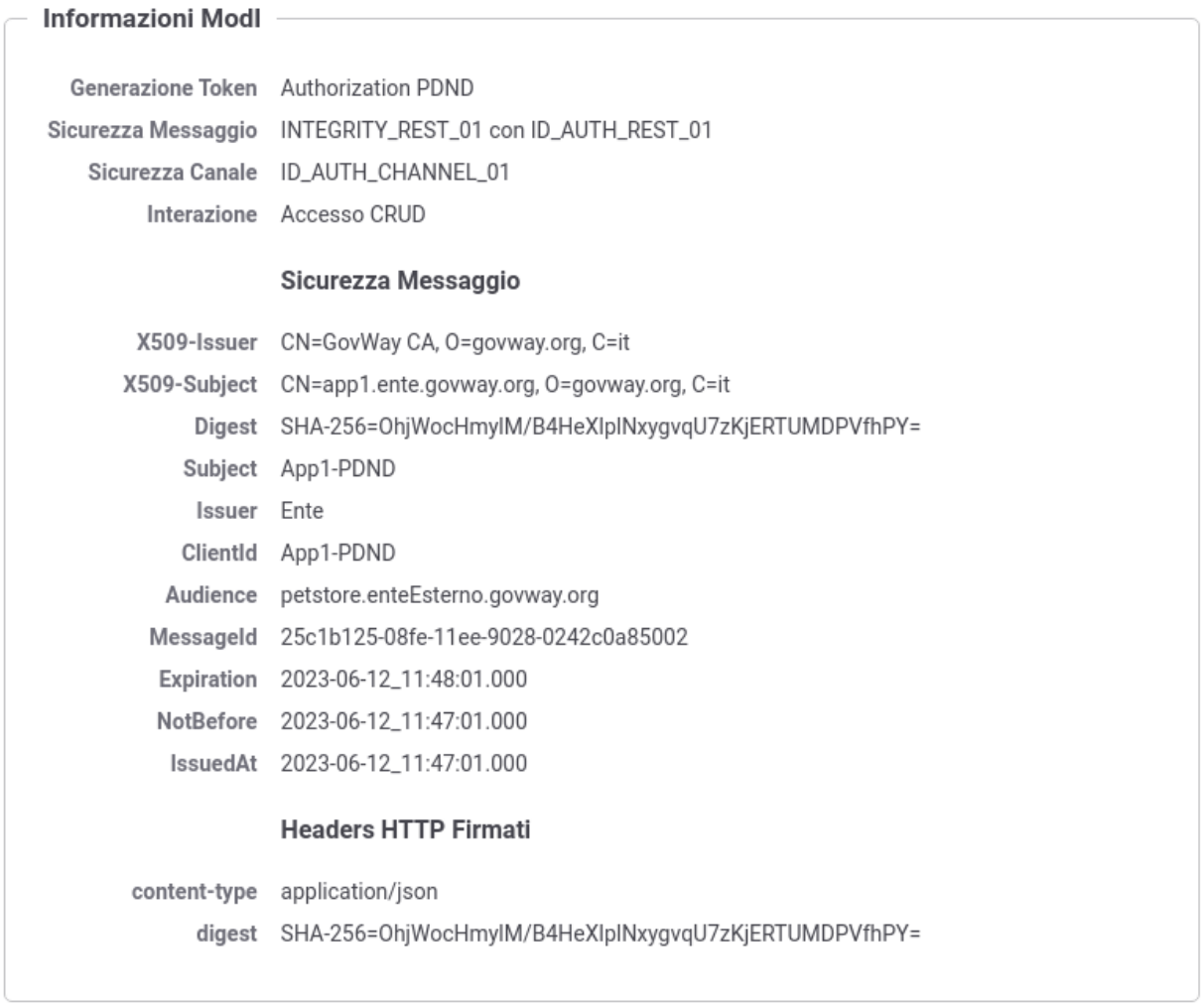


Figure3.151: Traccia della richiesta generata dal fruitore

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità «ModI». Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.152: Profilo ModI della govwayConsole

La configurazione dello scenario è del tutto analogo a quello descritto nello scenario *Configurazione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «INTEGRITY_REST_01».

Registrazione API

Viene registrata l'API «PetStoreIntegrityPDND» con il relativo descrittore OpenAPI 3. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «INTEGRITY_REST_01 con ID_AUTH_REST_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND» (Fig. 3.153).

Fruizione

Nella fruizione «PetStoreIntegrityPDND», relativa all'API precedentemente inserita, vanno indicati i dati specifici nella sezione «ModI Richiesta» (Fig. 3.154) necessari a generare il token "Agid-JWT-Signature". In particolare è possibile specificare l'audience atteso dall'erogatore e il tempo di validità del token.

La sezione «ModI Risposta» definisce i criteri per la validazione del token di sicurezza "Agid-JWT-Signature" presente nel messaggio di risposta, come il truststore per l'autenticazione dell'erogatore (Fig. 3.155).

3.4.3 Erogazione API SOAP

Obiettivo

Esporre un servizio SOAP, definito tramite una interfaccia WSDL, accessibile in accordo al pattern di sicurezza descritto nella sezione modipa_pdnd_integrity.

Sintesi

Mostriamo in questa sezione come procedere per l'esposizione di un servizio SOAP da erogare nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui un servizio è stato registrato sulla PDND, e i fruitori per poterlo fruire devono ottenere un voucher dalla PDND che successivamente devono inviare all'erogatore insieme alla normale richiesta di servizio. Oltre al voucher devono anche presentare il token di sicurezza «Agid-JWT-Signature» previsto dal pattern «INTEGRITY_SOAP_01» a garanzia dell'integrità del messaggio.

La figura seguente descrive graficamente questo scenario.

Le caratteristiche principali di questo scenario sono:

1. un applicativo eroga un servizio, rivolto a fruitori di domini esterni, in conformità al Modello di Interoperabilità AGID e il servizio viene registrato sulla PDND;
2. la comunicazione con i domini esterni avviene su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;

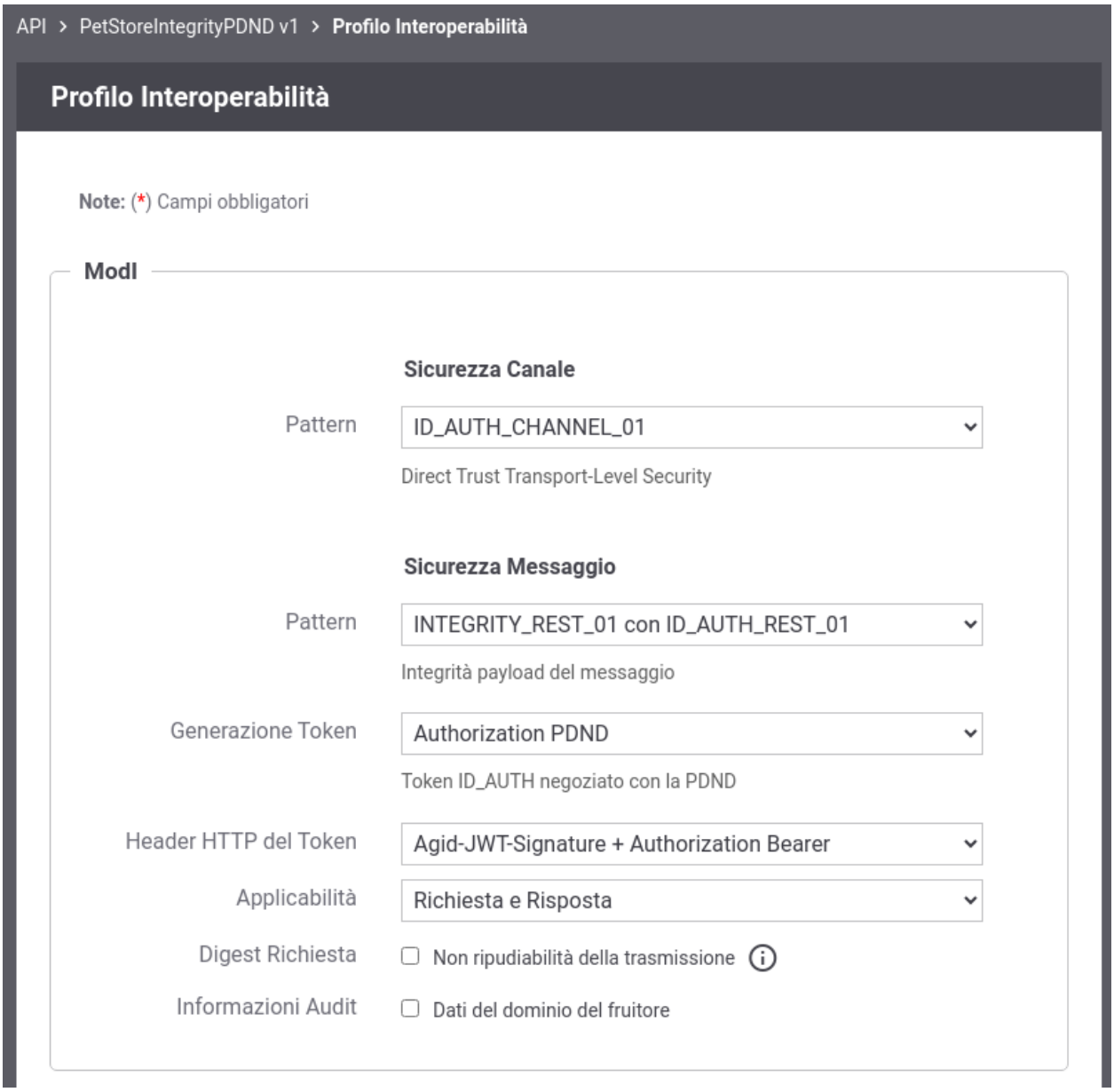


Figure3.153: Configurazione Pattern ModI «INTEGRITY_REST_01 con ID_AUTH_REST_01» sulla API REST

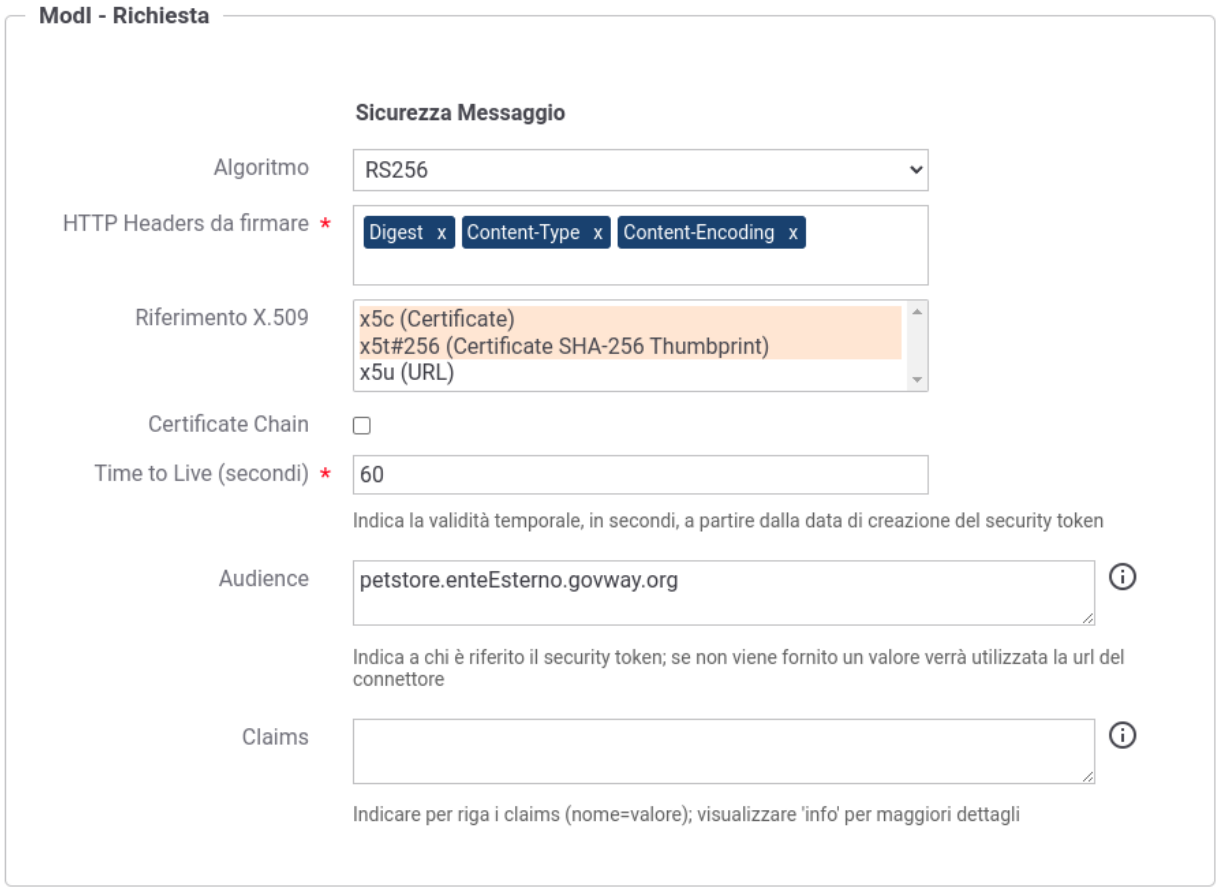


Figure3.154: Configurazione richiesta della fruizione

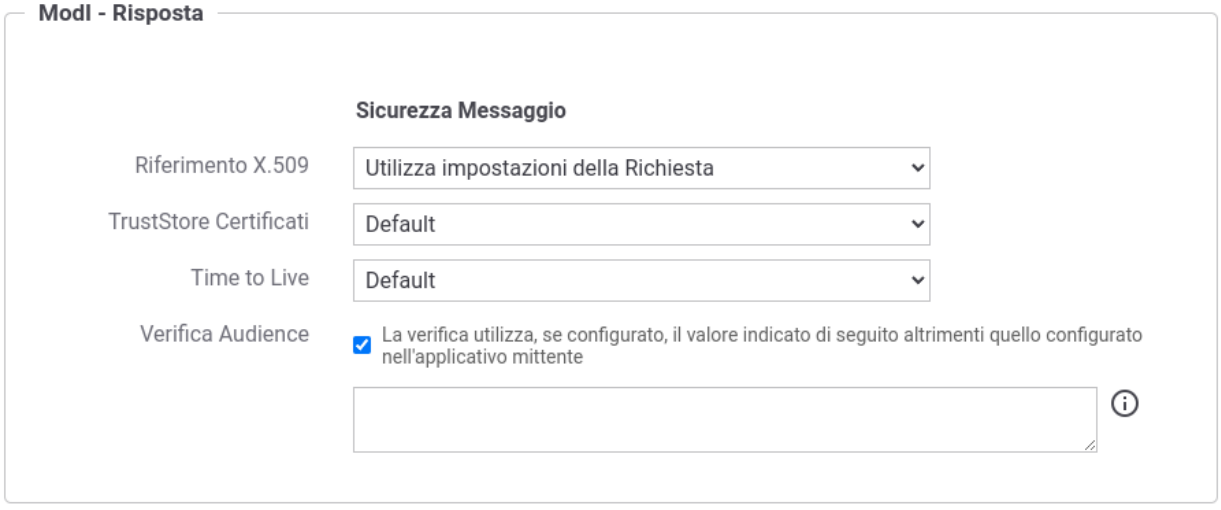


Figure3.155: Configurazione risposta della fruizione

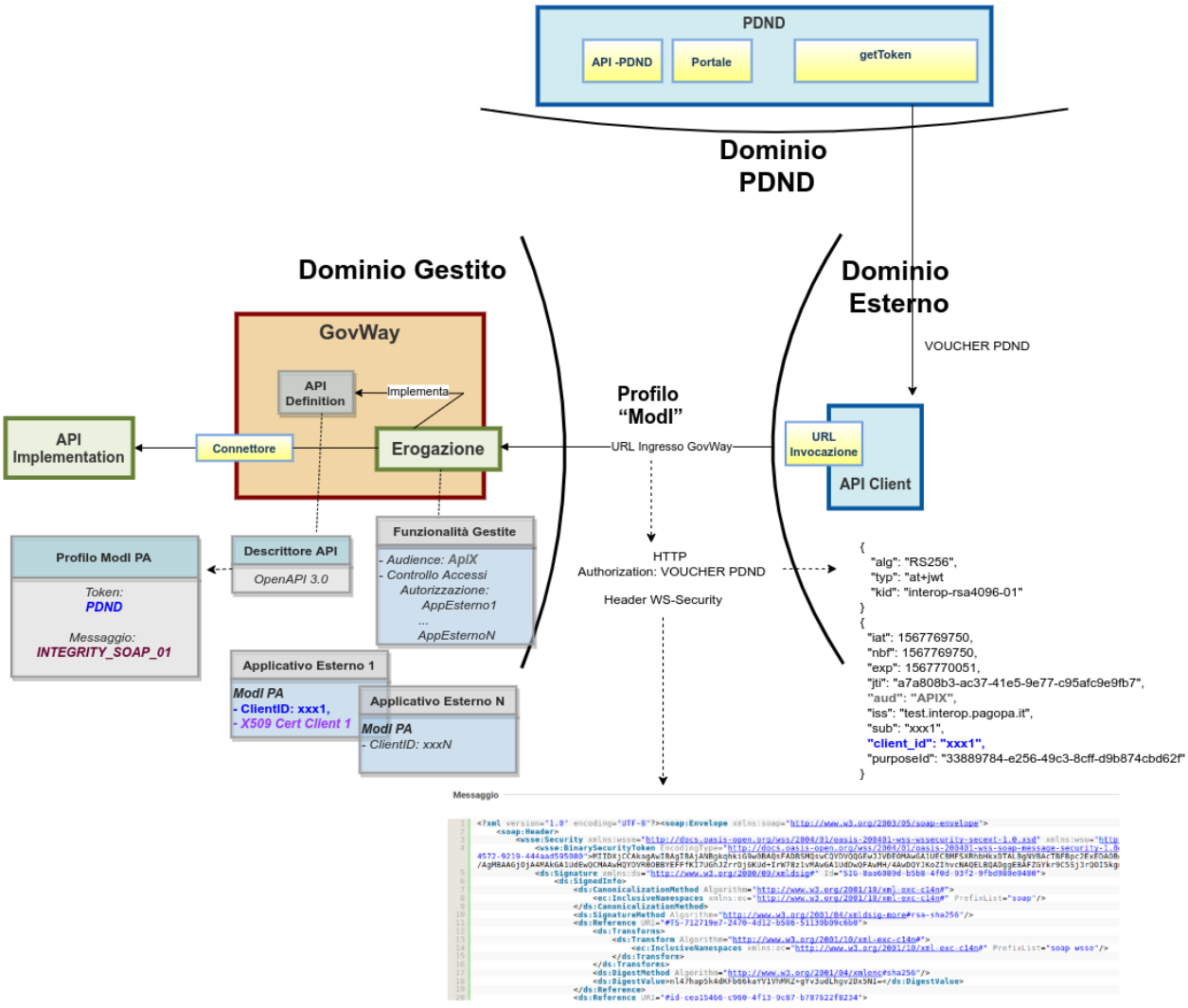


Figure3.156: Erogazione di una API SOAP con profilo "ModI", pattern INTEGRITY_SOAP_01 e pattern ID_AUTH_REST_01 via PDND

3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND»;
4. l'integrità del messaggio scambiato è garantita tramite sicurezza messaggio aggiuntiva prevista nel pattern «INTEGRITY_SOAP_01».

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.157: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «INTEGRITY_SOAP_01».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI SOAP - Integrity+PDND - IN App3» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

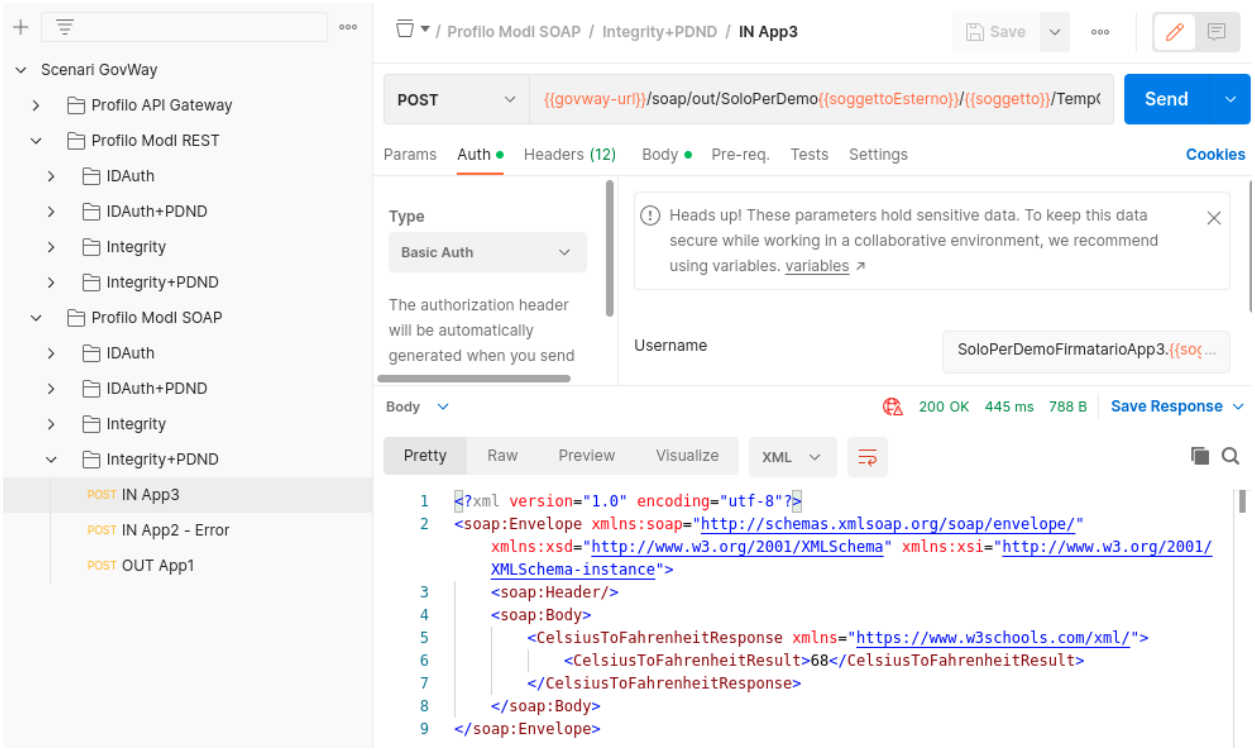


Figure3.158: Pattern Integrity+PDND - Erogazione API SOAP, esecuzione da Postman

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto,

nel corso dell'elaborazione della richiesta, andando a consultare la console govwayMonitor.

Le verifiche da effettuare sono le medesime di quelle descritte nello scenario *Esecuzione*. Di seguito vengono riportati solo i punti salienti in cui emerge una differenza dovuta al pattern di sicurezza diverso utilizzato.

- Dal dettaglio della richiesta si può visualizzare il messaggio che è stato inviato dal fruitore, come in Fig. 3.32. Come si nota, il messaggio SOAP contiene nell'header WS-Security sia il token di sicurezza (elemento «BinarySecurityToken») sia l'elemento «WSAddressing - To» e il digest del payload (elemento «DigestValue») prodotti dal fruitore con la relativa firma digitale (elemento «SignatureValue») come previsto dal pattern «INTEGRITY_SOAP_01».

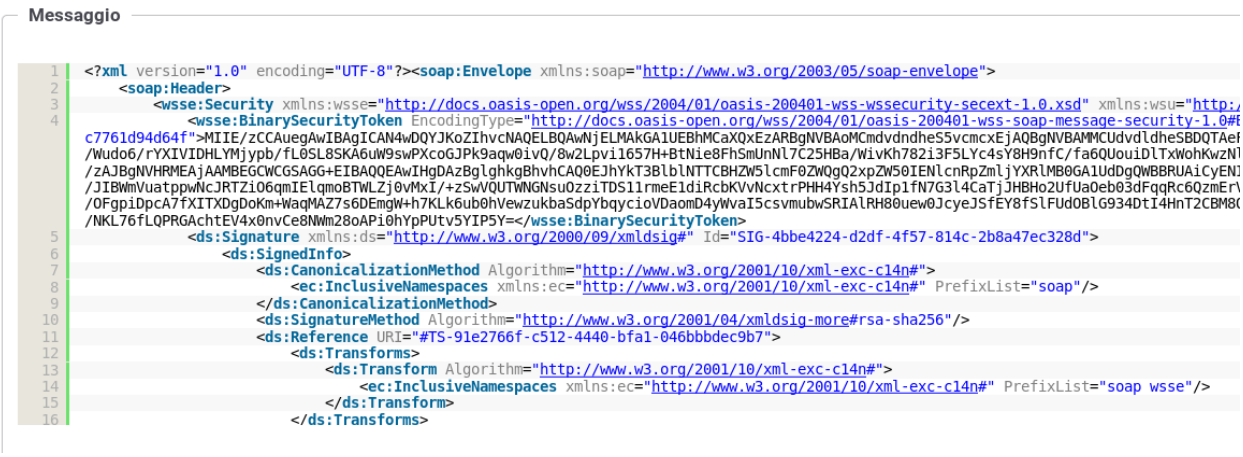


Figure3.159: Messaggio inviato dal fruitore

- Tutte le analisi che riguardano il token di autenticazione generato dalla PDND sono le medesime descritte nello scenario *Esecuzione*.
- Il messaggio ricevuto dal Govway viene quindi validato, sulla base dei pattern di sicurezza previsti nello scambio, verificando in questo caso l'identità del fruitore, la validità temporale, la corrispondenza dell'audience ricevuto con quello atteso e la corrispondenza del digest rispetto al payload. Solo in caso di superamento dell'intero processo di validazione, il messaggio viene inoltrato al servizio erogatore. Le evidenze del processo di validazione sono visibili sulla govwayMonitor, andando a consultare la traccia del messaggio di richiesta (Fig. 3.160). Nella sezione «Sicurezza Messaggio» sono riportate le informazioni estratte dal token di sicurezza presente nell'header soap.
- Lo scenario è preconfigurato per autorizzare puntualmente l'applicativo "App3-ModI" identificato grazie al claim "client_id" presente all'interno del token della PDND. È possibile utilizzare il progetto Postman a corredo con la request «Profilo ModI SOAP - Integrity+PDND - IN App2 - Error» per verificare che una richiesta proveniente da un differente applicativo non viene autorizzata.

Conformità ai requisiti ModI

La verifica dei requisiti ModI per questo scenario non differisce da quanto già descritto in *Esecuzione*.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.160: Traccia della richiesta elaborata dall'erogatore

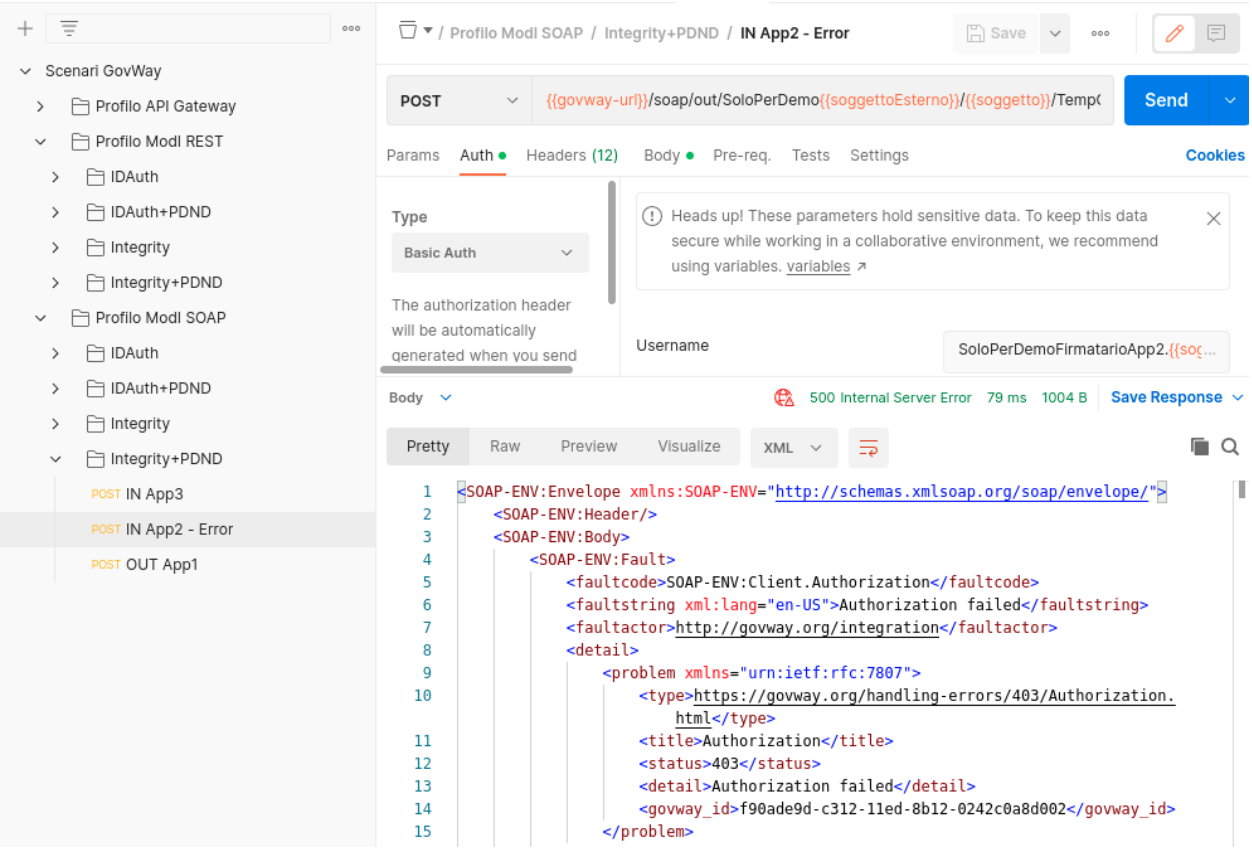


Figure3.161: Pattern Integrity+PDND - Erogazione API SOAP - Autorizzazione negata, esecuzione da Postman



Figure3.162: Profilo ModI della govwayConsole

Il processo di configurazione per questo scenario è del tutto analogo a quello descritto per lo scenario *Configurazione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «INTEGRITY_SOAP_01».

Registrazione API

Viene registrata l'API «TemperatureConversionIntegrityPDND» con il relativo descrittore WSDL. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «INTEGRITY_SOAP_01 con ID_AUTH_SOAP_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND» (Fig. 3.163).

Erogazione

Nell'erogazione SOAP "TempConvertSoapIntegrityPDND", relativa all'API precedentemente inserita, vanno indicati i dati specifici nella sezione «ModI Richiesta» (Fig. 3.76) necessari per validare l'header WSSecurity previsto dal pattern «INTEGRITY_SOAP_01».

La sezione «ModI Risposta» si utilizza per indicare i parametri per la produzione del token di sicurezza da inserire nel messaggio di risposta (Fig. 3.165).

3.4.4 Fruizione API SOAP

Obiettivo

Fruire di un servizio SOAP, definito tramite una interfaccia WSDL, accessibile in accordo al pattern di sicurezza descritto nella sezione modipa_pdnd_integrity.

Sintesi

Mostriamo in questa sezione come procedere per l'integrazione di un applicativo con un servizio SOAP erogato nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui il servizio è stato registrato sulla PDND, e il fruitore per poterlo fruire deve ottenere un voucher dalla PDND che successivamente deve inviare all'erogatore insieme alla normale richiesta di servizio. Oltre al voucher il fruitore devo anche presentare il token di sicurezza WSSecurity previsto dal pattern «INTEGRITY_SOAP_01» a garanzia dell'integrità del messaggio.

La figura seguente descrive graficamente questo scenario.

Le caratteristiche principali di questo scenario sono:

1. un applicativo fruitore che dialoga con il servizio erogato in modalità ModI in accordo ad una API condivisa e pubblicata su PDND;
2. la comunicazione diretta verso il dominio erogatore veicolata su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;
3. l'autenticità della comunicazione tra fruitore ed erogatore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND»;
4. l'integrità del messaggio scambiato è garantita tramite sicurezza messaggio aggiuntiva prevista nel pattern «INTEGRITY_SOAP_01».

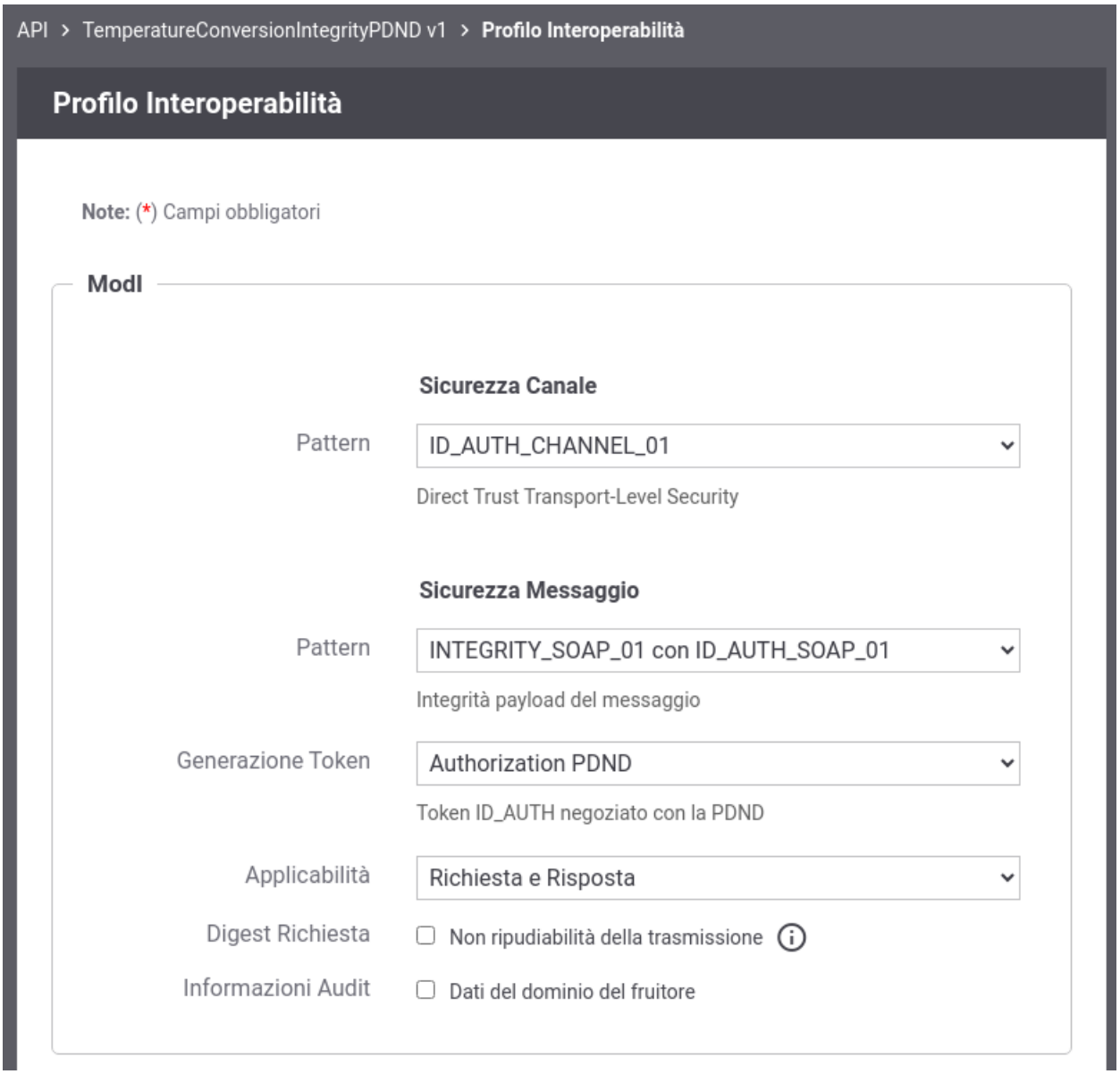


Figure3.163: Configurazione Pattern ModI «INTEGRITY_SOAP_01 con ID_AUTH_SOAP_01» sulla API SOAP



Figure3.164: Configurazione richiesta dell'erogazione

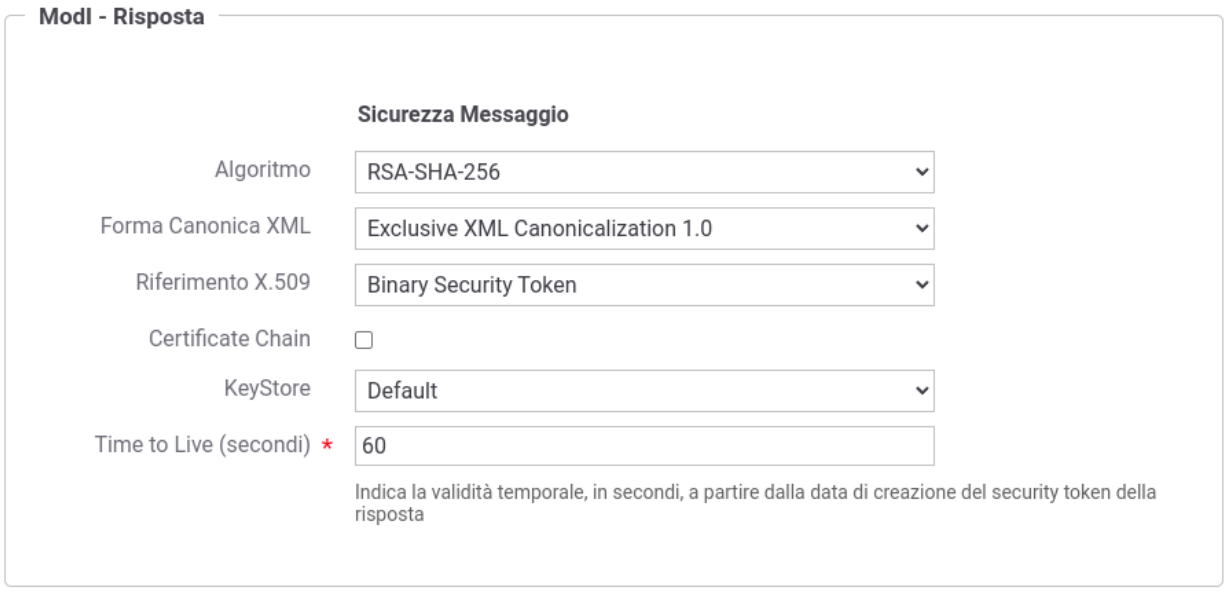


Figure3.165: Configurazione risposta dell'erogazione

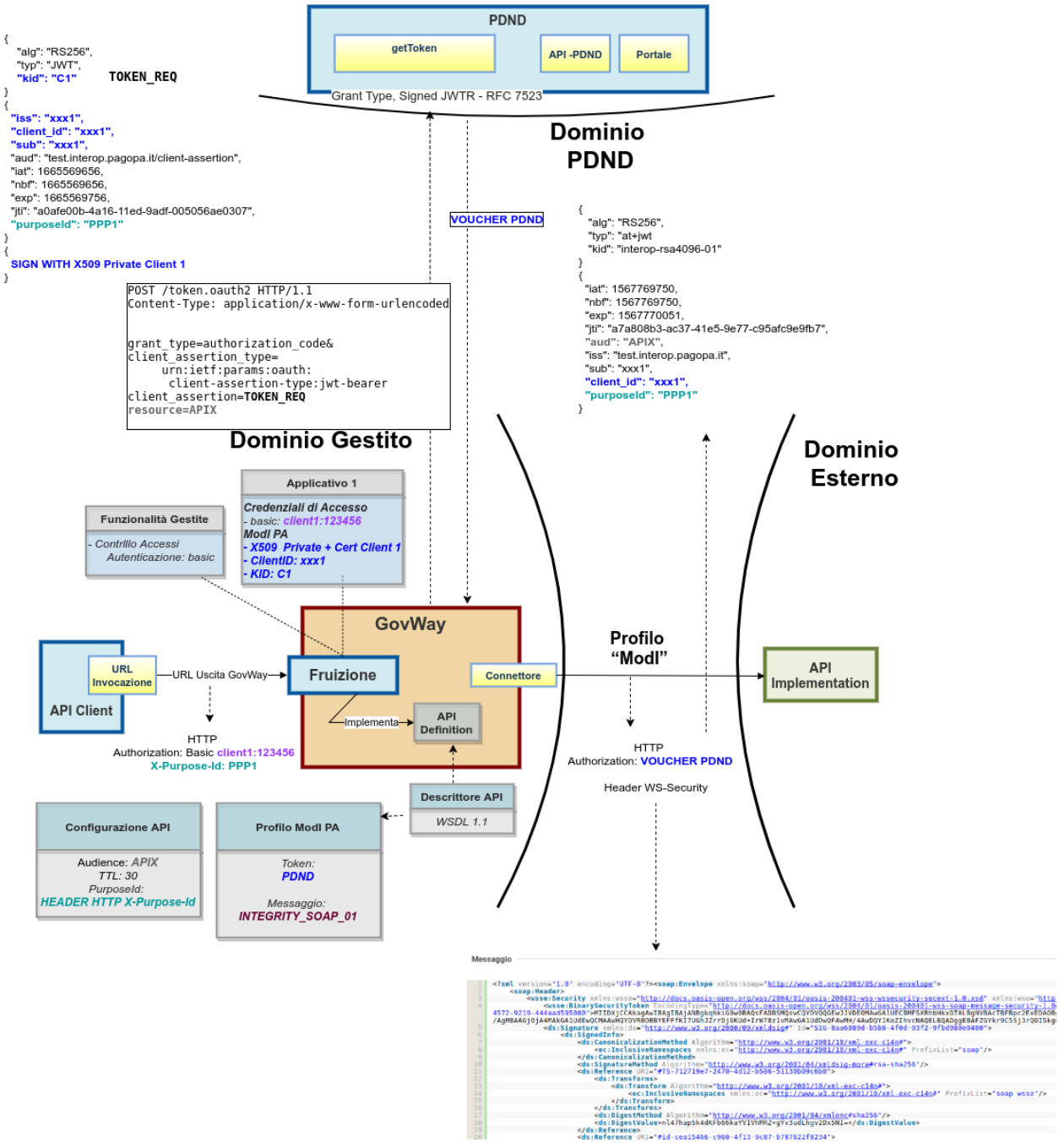


Figure3.166: Fruizione di una API SOAP con profilo "ModI", pattern INTEGRITY_SOAP_01 e pattern ID_AUTH_REST_01 via PDND

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.167: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «INTEGRITY_SOAP_01».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI SOAP - Integrity+PDND - OUT App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

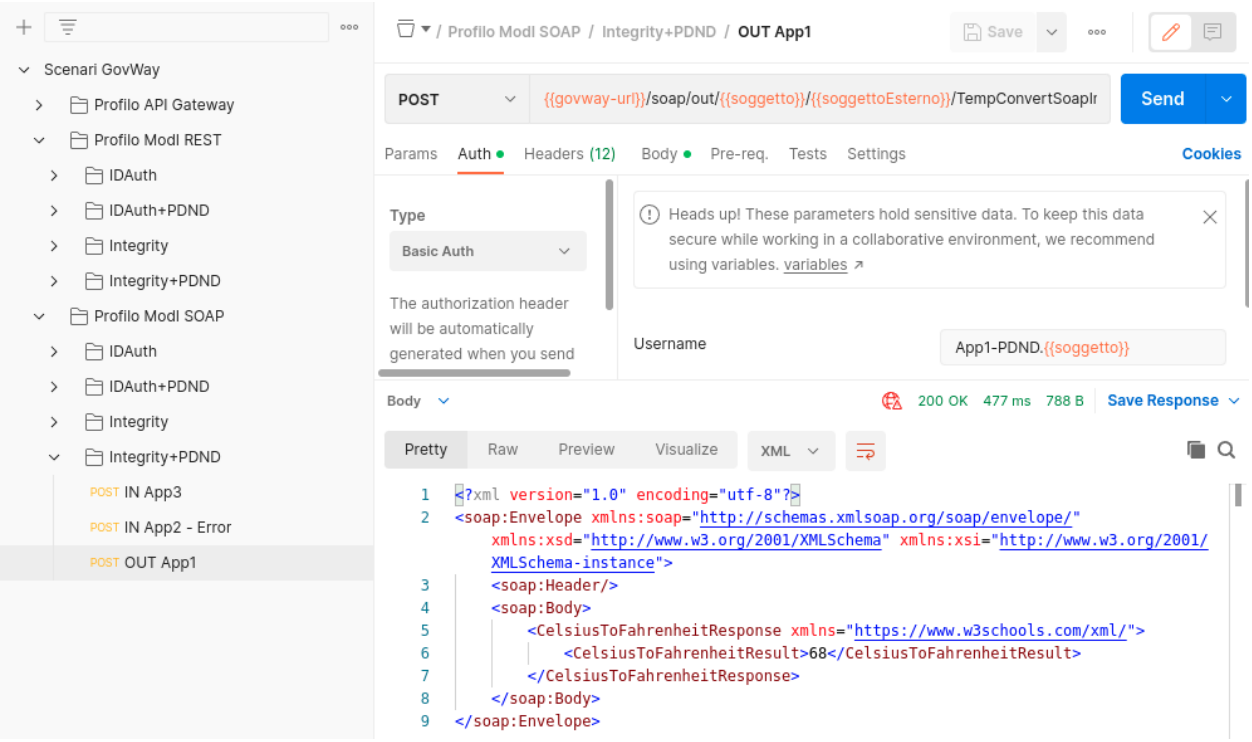


Figure3.168: Pattern Integrity+PDND - Fruizione API SOAP, esecuzione da Postman

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console "govwayMonitor".

Le verifiche da effettuare sono le medesime di quelle descritte nello scenario *Esecuzione*. Di seguito vengono riportati solo i punti salienti in cui emerge una differenza dovuta al pattern di sicurezza diverso utilizzato.

- Dal dettaglio della richiesta si può visualizzare il messaggio che è stato inviato all'erogatore, come in Fig. 3.169. Come si nota, il messaggio SOAP contiene nell'header WS-Security sia il token di sicurezza (elemento

«BinarySecurityToken») sia l'elemento «WSAddressing - To» e il digest del payload (elemento «DigestValue») prodotti dal fruitore con la relativa firma digitale (elemento «SignatureValue») come previsto dal pattern «INTEGRITY_SOAP_01».

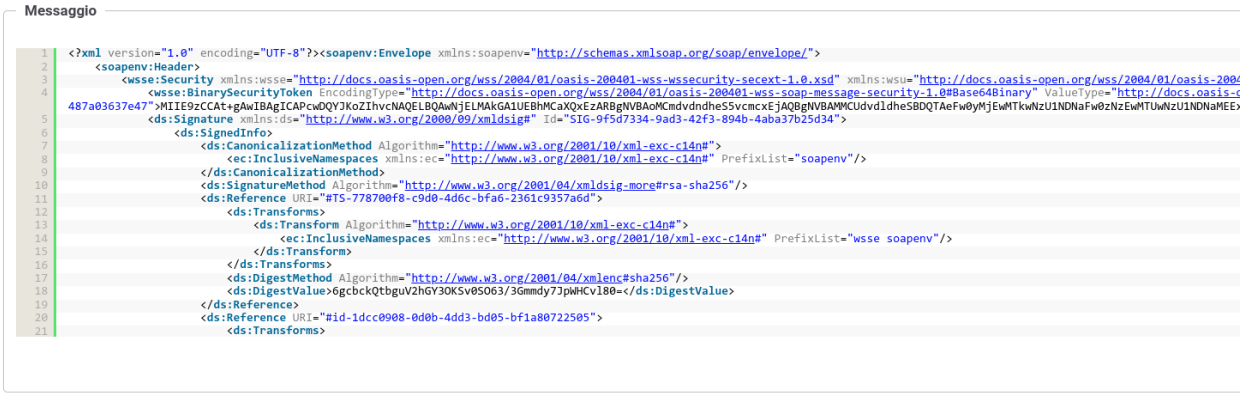


Figure3.169: Messaggio inviato dal fruitore

Conformità ai requisiti ModI

La verifica dei requisiti ModI per questo scenario non differisce da quanto già descritto in *Esecuzione*.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità «ModI». Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.170: Profilo ModI della govwayConsole

La configurazione dello scenario è del tutto analogo a quello descritto nello scenario *Configurazione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «INTEGRITY_SOAP_01».

Registrazione API

Viene registrata l'API «TemperatureConversionIntegrityPDND» con il relativo descrittore WSDL. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «INTEGRITY_SOAP_01 con ID_AUTH_SOAP_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND» (Fig. 3.171).

Fruizione

Nella fruizione SOAP "TempConvertSoapIntegrityPDND", relativa all'API precedentemente inserita, vanno indicati i dati specifici nella sezione «ModI Richiesta» (Fig. 3.83) necessari a generare l'header WSSecurity previsto dal pattern «INTEGRITY_SOAP_01». In particolare è possibile specificare l'audience atteso dall'erogatore e il tempo di validità del token.

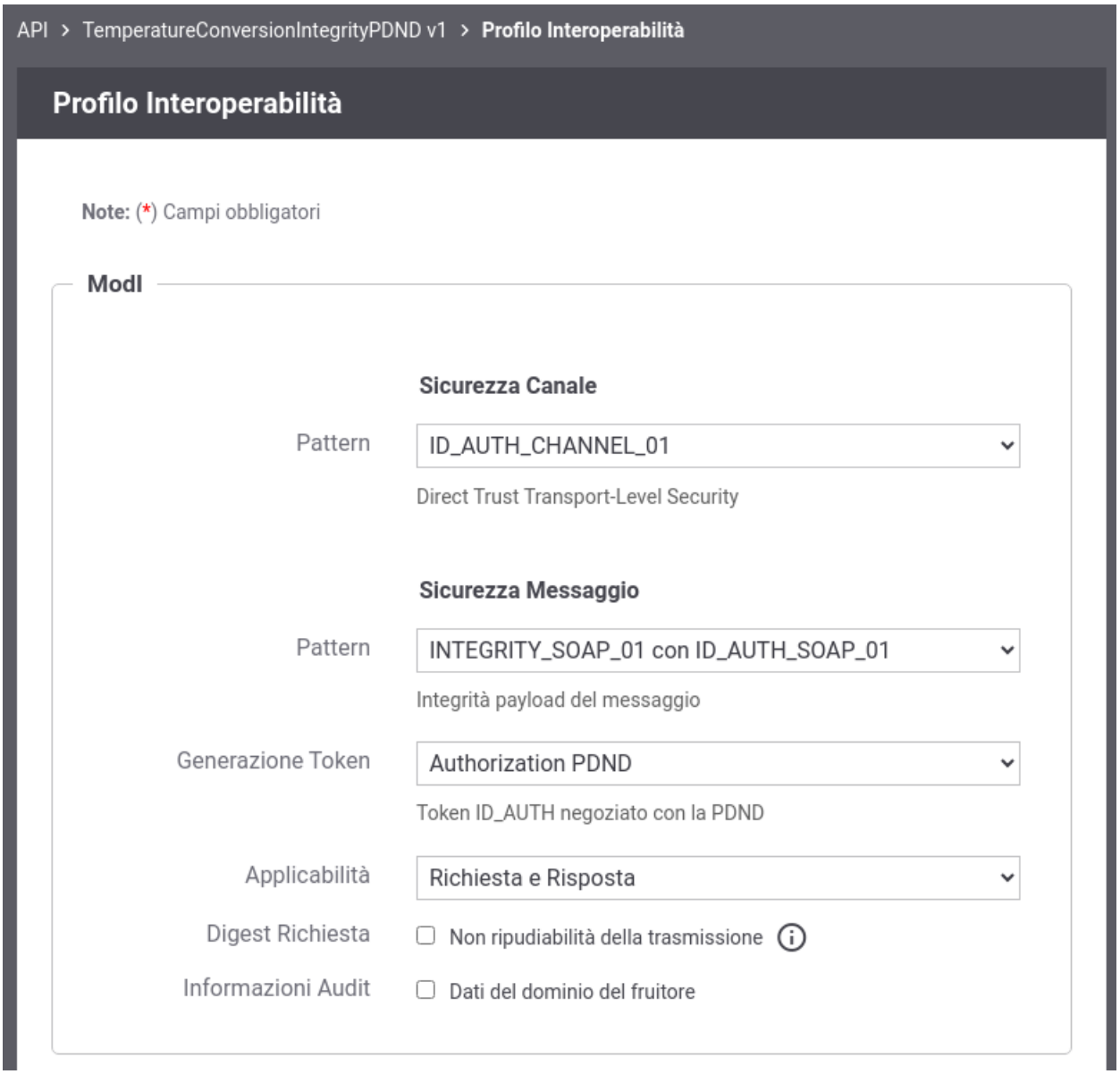


Figure3.171: Configurazione Pattern ModI «INTEGRITY_SOAP_01 con ID_AUTH_SOAP_01» sulla API SOAP

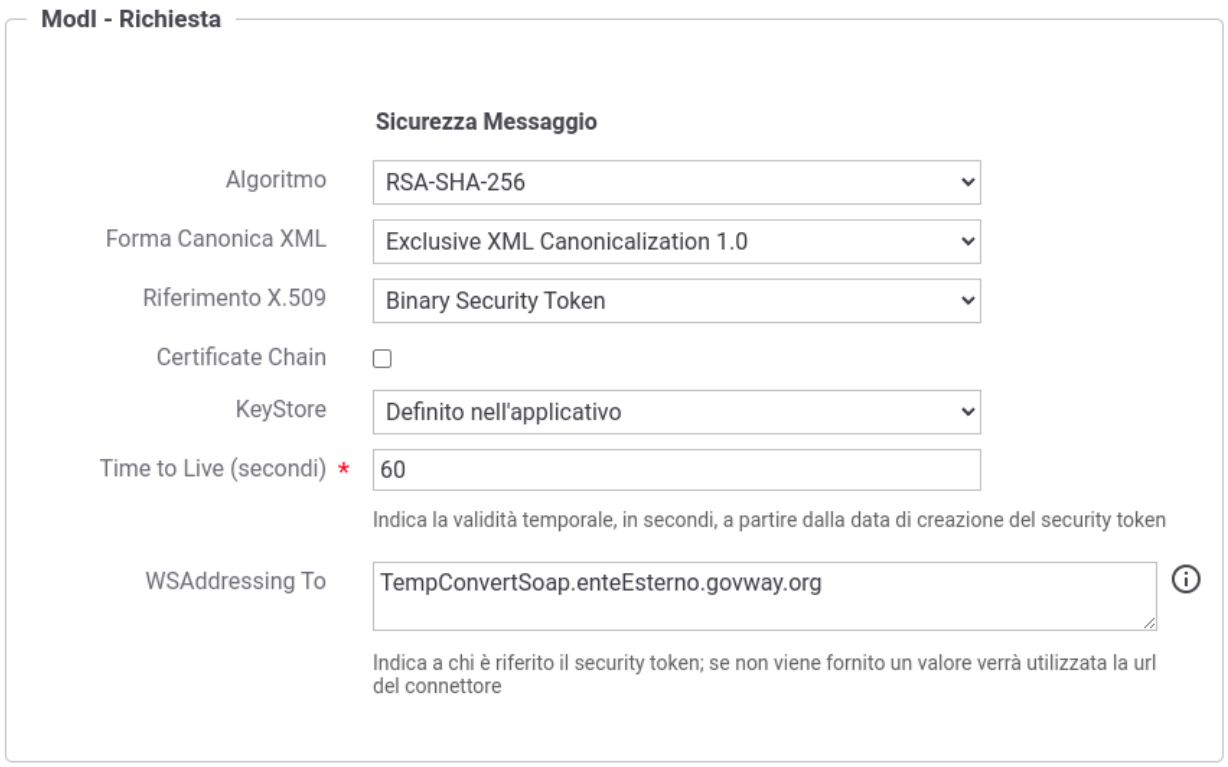


Figure3.172: Configurazione richiesta della fruizione

La sezione «ModI Risposta» definisce i criteri per la validazione dei messaggi di risposta (Fig. 3.84).

3.5 Pattern "ID_AUTH" via PDND + "INTEGRITY_REST_02"

Gli scenari riportati in questa sezione riguardano API configurate con pattern modipa_idar04.

3.5.1 Erogazione API REST

Obiettivo

Esporre un servizio, definito tramite una API REST (OpenAPI 3.0), accessibile in accordo al pattern di sicurezza descritto nella sezione modipa_idar04.

Sintesi

Mostriamo in questa sezione come procedere per l'esposizione di un servizio REST da erogare nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui un servizio è stato registrato sulla PDND, e i fruitori per poterlo fruire devono ottenere un voucher dalla PDND che successivamente devono inviare all'erogatore insieme alla normale richiesta di servizio. Oltre al voucher devono anche presentare il token di sicurezza «Agid-JWT-Signature» previsto dal pattern «INTEGRITY_REST_02» a garanzia dell'integrità del messaggio.

La figura seguente descrive graficamente questo scenario.

Le caratteristiche principali di questo scenario sono:



Figure3.173: Configurazione risposta della fruizione

1. un applicativo eroga un servizio, rivolto a fruitori di domini esterni, in conformità al Modello di Interoperabilità AGID e il servizio viene registrato sulla PDND;
2. la comunicazione con i domini esterni avviene su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;
3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND»;
4. l'integrità del messaggio scambiato è garantita tramite sicurezza messaggio aggiuntiva prevista nel pattern «INTEGRITY_REST_02»;
5. la validazione del token di integrità viene effettuata scaricando la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd;
6. vengono inoltre recuperate e associate alla traccia maggiori informazioni sull'organizzazione afferente al "client-id" presente nel token, sempre attraverso le modipa_passiPreliminari_api_pdnd.

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.175: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «INTEGRITY_REST_02».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - IntegrityRest02+PDND - IN App3» che è stata preconfigurata per il funzionamento con le caratteristiche descritte

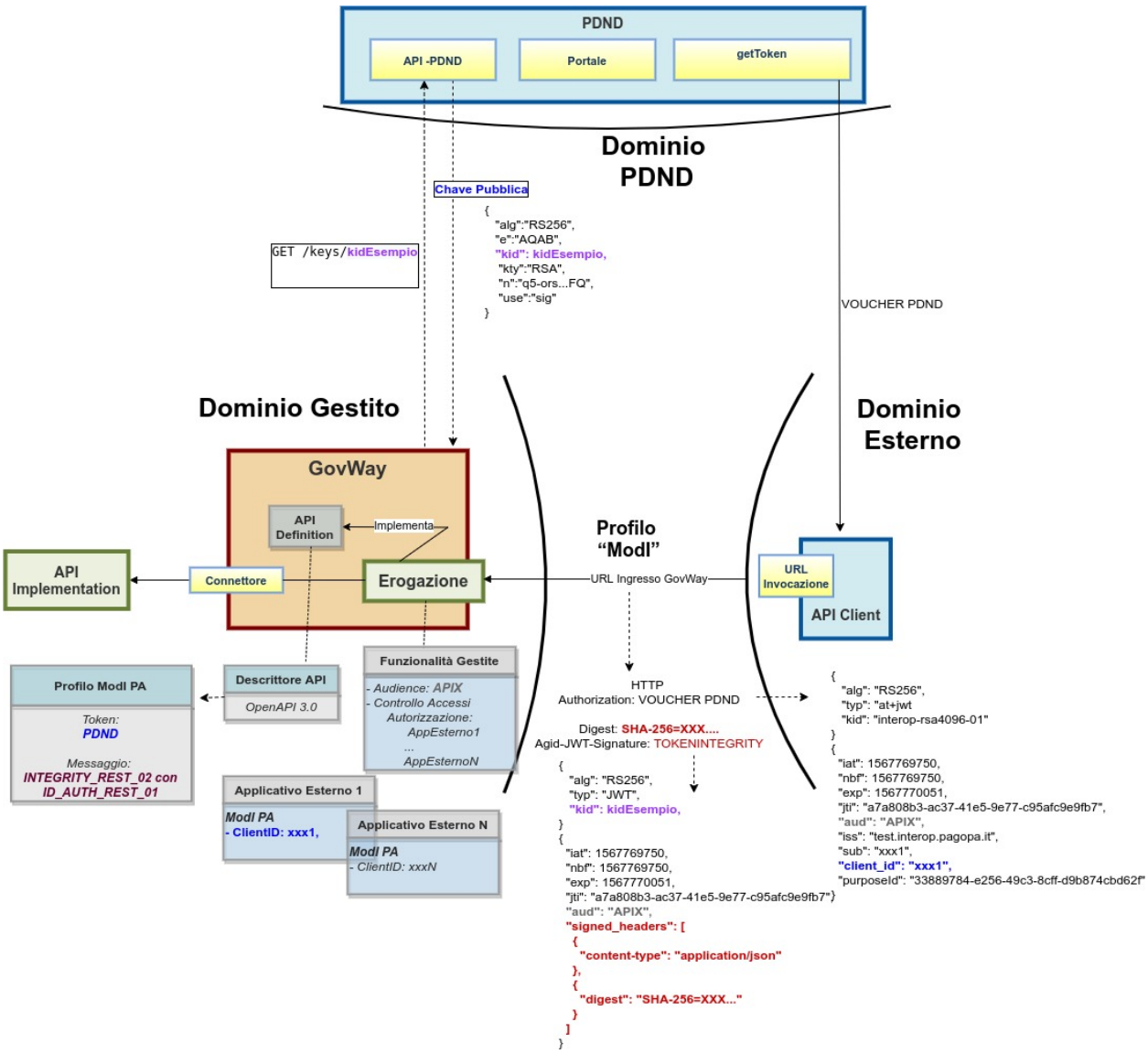


Figure3.174: Erogazione di una API REST con profilo "ModI", pattern INTEGRITY_REST_02 e pattern ID_AUTH_REST_01 via PDND

sopra.

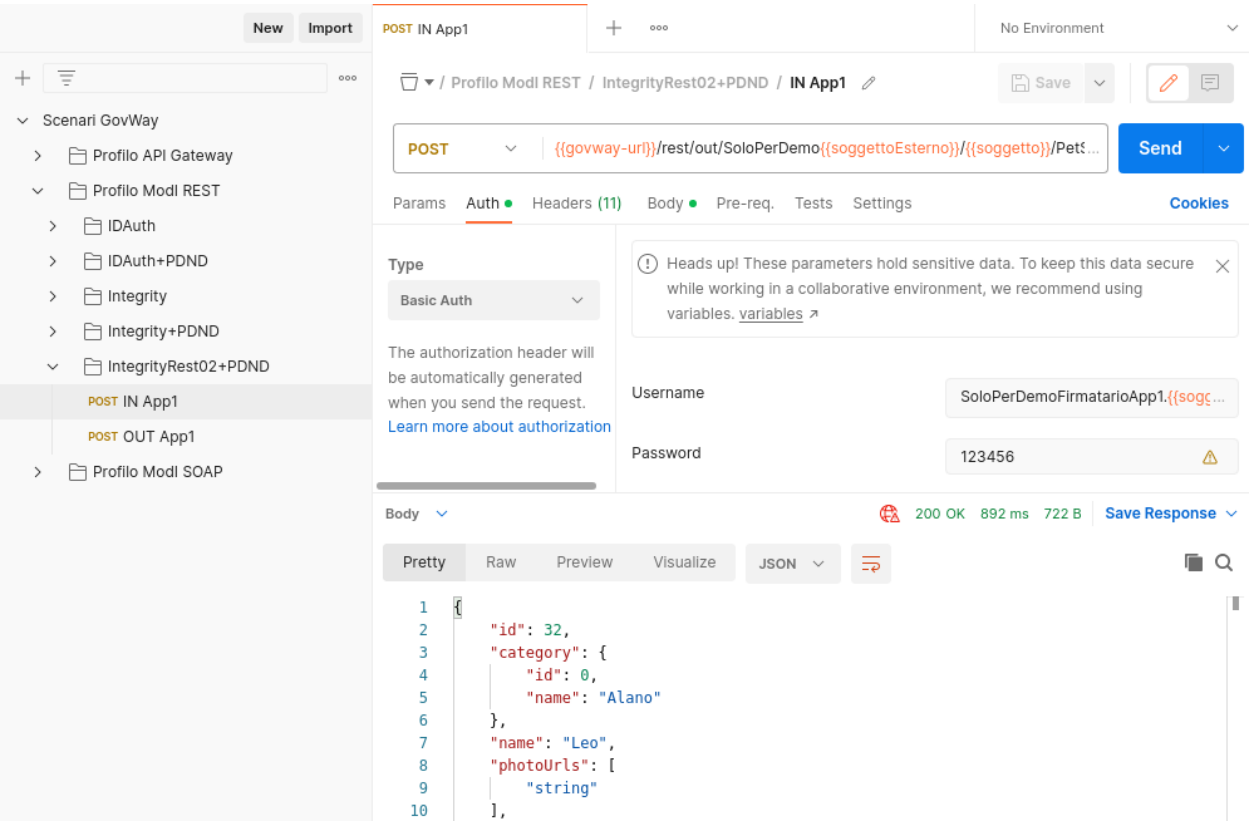


Figure3.176: Pattern IntegrityRest02+PDND - Erogazione API REST, esecuzione da Postman

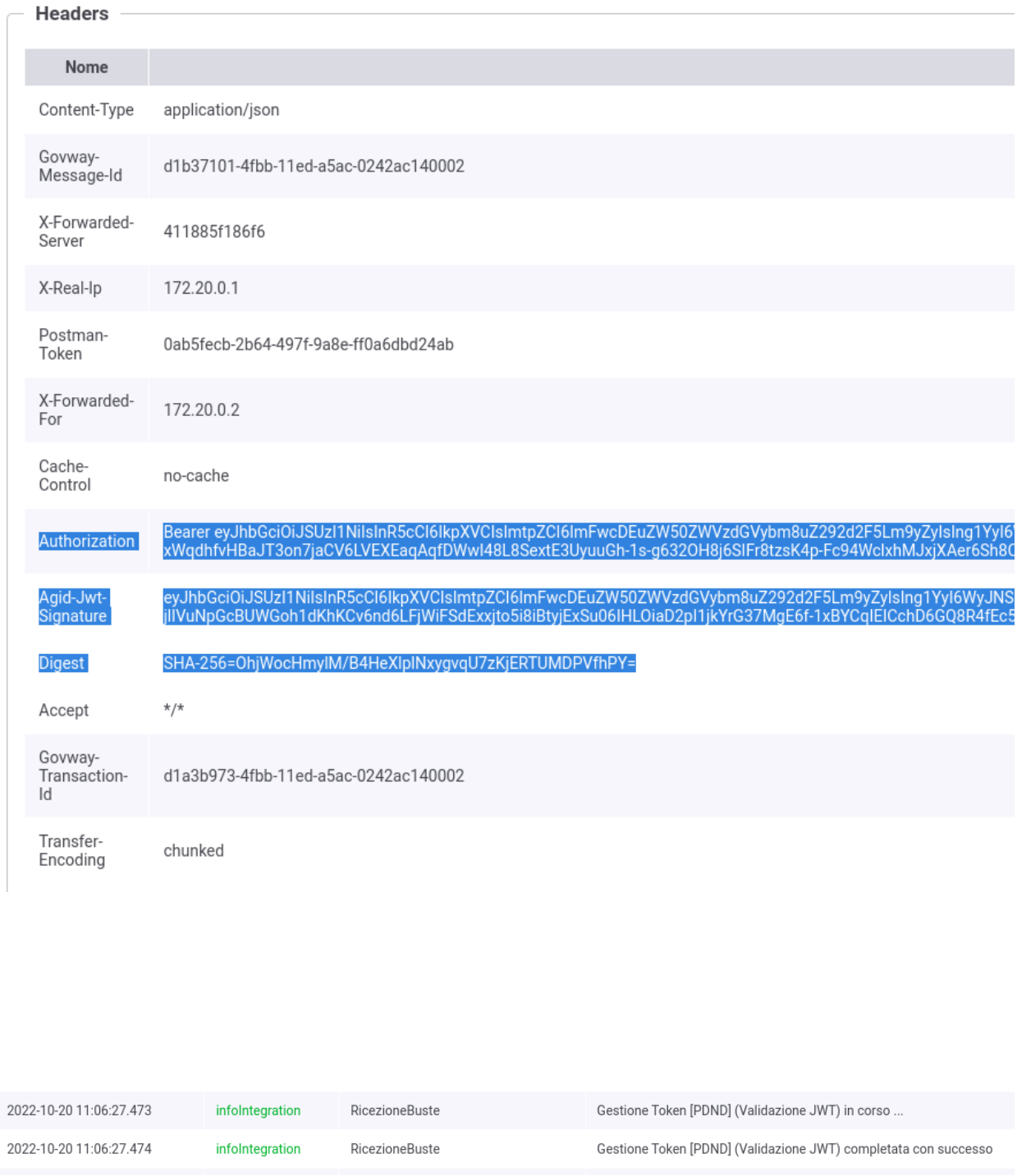
Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console "govwayMonitor".

Nota

Le informazioni ottenute tramite le modipa_passiPreliminari_api_pdnd (chiavi pubbliche JWK e informazioni sui client) vengono salvate su cache locali. Al fine di forzare nuove invocazioni verso la «PDND simulata» è necessario attendere un minuto rispetto a precedenti invocazioni ed effettuare il reset delle cache locali di GovWay accedendo alla sezione strumenti_runtime della console di gestione "*govwayConsole*" e cliccando sul link "*Svuota tutte le Cache*".

Le evidenze del processo di validazione relative al token PDND sono le medesime descritte nella scenario *Esecuzione*.

1. Dal dettaglio della richiesta si può visualizzare il messaggio che è stato inviato dal fruitore, come in Fig. 3.137. Come si nota, al payload JSON è associato un insieme di header HTTP tra i quali «Authorization» e «Agid-Jwt-Signature» che contengono rispettivamente il token di sicurezza che il fruitore ha ottenuto dalla PDND e il token di integrità. È inoltre presente l'header http «Digest» che contiene il valore per la verifica dell'integrità del payload.
2. Grazie alle configurazioni presenti nell'erogazione, ed in particolare all'indicazione che il token ricevuto deve essere validato tramite Token Policy PDND, GovWay è in grado di validare i dati di sicurezza ricevuti (Fig. 3.177) e decodificare il token.
3. Vengono inoltre validati gli ulteriori header «Agid-Jwt-Signature» e «Digest» rispetto al pattern



Headers

Nome	
Content-Type	application/json
Govway-Message-Id	d1b37101-4fbb-11ed-a5ac-0242ac140002
X-Forwarded-Server	411885f186f6
X-Real-Ip	172.20.0.1
Postman-Token	0ab5fecb-2b64-497f-9a8e-ff0a6dbd24ab
X-Forwarded-For	172.20.0.2
Cache-Control	no-cache
Authorization	Bearer eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6ImFwcDEuZW50ZWVzdGVybm8uZ292d2F5Lm9yZyIsIng1YyI6[illegible] xWqdhfvHBaJT3on7jaCV6LVEXEaqAqfDWwI48L8SextE3UyuuGh-1s-g632OH8j6SIFr8tzsK4p-Fc94WclxhMJxjXAer6Sh8[illegible]
Agid-Jwt-Signature	eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6ImFwcDEuZW50ZWVzdGVybm8uZ292d2F5Lm9yZyIsIng1YyI6WyJNS[illegible] iIlVuNpGcBUWGoh1dKhKCv6nd6LFjWiFSdExxjto5i8iBtyjExSu06IHLOiaD2pI1jkYrG37MgE6f-1xBYCqIElCchD6GQ8R4fEc5[illegible]
Digest	SHA-256=OhjWocHmyIM/B4HeXlpINxygvqU7zKjERTUMDPVfhPY=
Accept	*/*
Govway-Transaction-Id	d1a3b973-4fbb-11ed-a5ac-0242ac140002
Transfer-Encoding	chunked

2022-10-20 11:06:27.473	infoIntegration	RicezioneBuste	Gestione Token [PDND] (Validazione JWT) in corso ...
2022-10-20 11:06:27.474	infoIntegration	RicezioneBuste	Gestione Token [PDND] (Validazione JWT) completata con successo

Figure3.177: Evidenza diagnostica della validazione del token

"INTEGRITY_REST_02" indicato nella configurazione dell'API (Fig. 3.178). La validazione del token di integrità viene effettuata scaricando la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd. Nello storico delle transazioni è possibile vedere come GovWay durante la gestione della richiesta di erogazione scaturisca un'ulteriore chiamata verso la PDND per ottenere la chiave pubblica (Fig. 3.179). La chiave pubblica una volta prelevata dalla PDND verrà aggiunta in una cache locale e le successive richieste non provocheranno ulteriori chiamate verso la PDND.

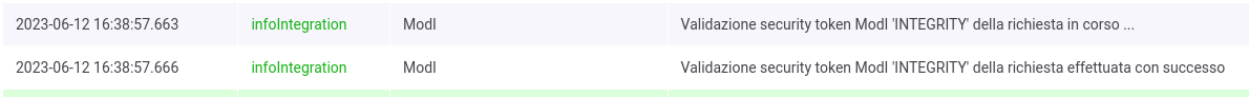


Figure3.178: Evidenza diagnostica della validazione del token di integrità

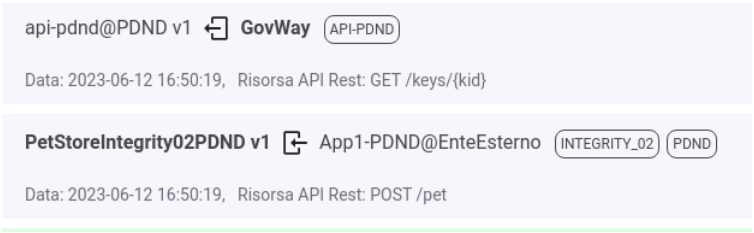


Figure3.179: Evidenza diagnostica della chiamata verso la PDND per ottenere la chiave pubblica

4. Analizzando il token di integrità «Agid-Jwt-Signature» ricevuto nella sezione header (Fig. 3.180) si può notare che non viene riportata l'identità del fruitore tramite certificato X.509 come avveniva per il pattern INTEGRITY_REST_01 descritto nella scenario *Pattern "INTEGRITY_01"* ma bensì tramite il claim "kid" che corrisponde all'identificativo della chiave pubblica registrata sulla PDND. L'identificativo "kid" verrà utilizzato da GovWay per richiedere la chiave pubblica tramite le modipa_passiPreliminari_api_pdnd (Fig. 3.181). Nella sezione payload (Fig. 3.182) sono invece presenti gli header http firmati (tra cui il valore dell'header "Digest") che servono a garantire l'integrità della richiesta, insieme ai riferimenti temporali (iat, nbf, exp) e all'audience (aud).



Figure3.180: Sezione «Header» del Token "Agid-Jwt-Signature" con pattern "INTEGRITY_REST_02"

5. Vengono inoltre recuperate e associate alla traccia maggiori informazioni sull'organizzazione afferente al "client-id" presente nel token, sempre attraverso le modipa_passiPreliminari_api_pdnd (Fig. 3.183). Nello storico delle transazioni è possibile vedere come GovWay durante la gestione della richiesta di erogazione scaturisca due ulteriori chiamate verso la PDND per ottenere maggiori informazioni sul client e sull'organizzazione (Fig. 3.184). Le informazioni recuperate dalla PDND verranno aggiunte in una cache locale e le successive richieste non provocheranno ulteriori chiamate verso la PDND.
6. Le evidenze del processo di validazione relativo al pattern «INTEGRITY_REST_02» sono visibili sulla govwayMonitor, andando a consultare la traccia del messaggio di richiesta (Fig. 3.185). Nella sezione «Sicurezza

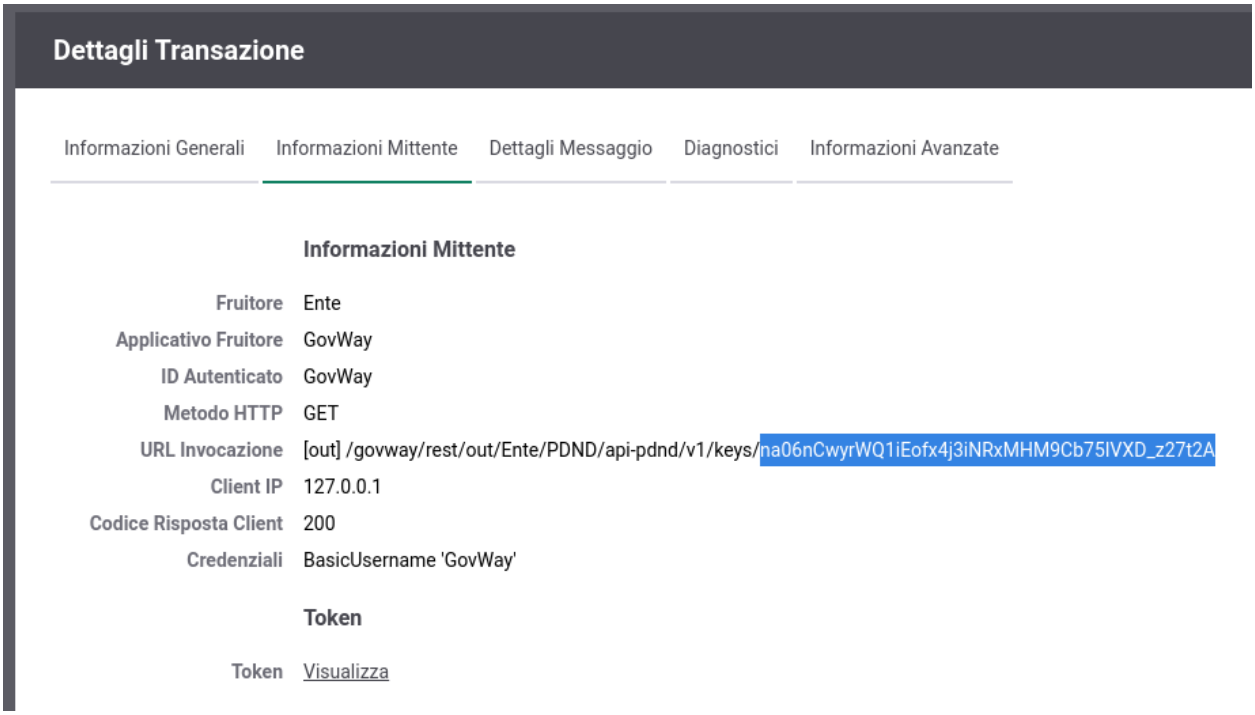


Figure3.181: Dettaglio della url di invocazione utilizzata da GovWay per prelevare la chiave pubblica dalla PDND



Figure3.182: Sezione «Payload» del Token “Agid-Jwt-Signature” con pattern “INTEGRITY_REST_02”

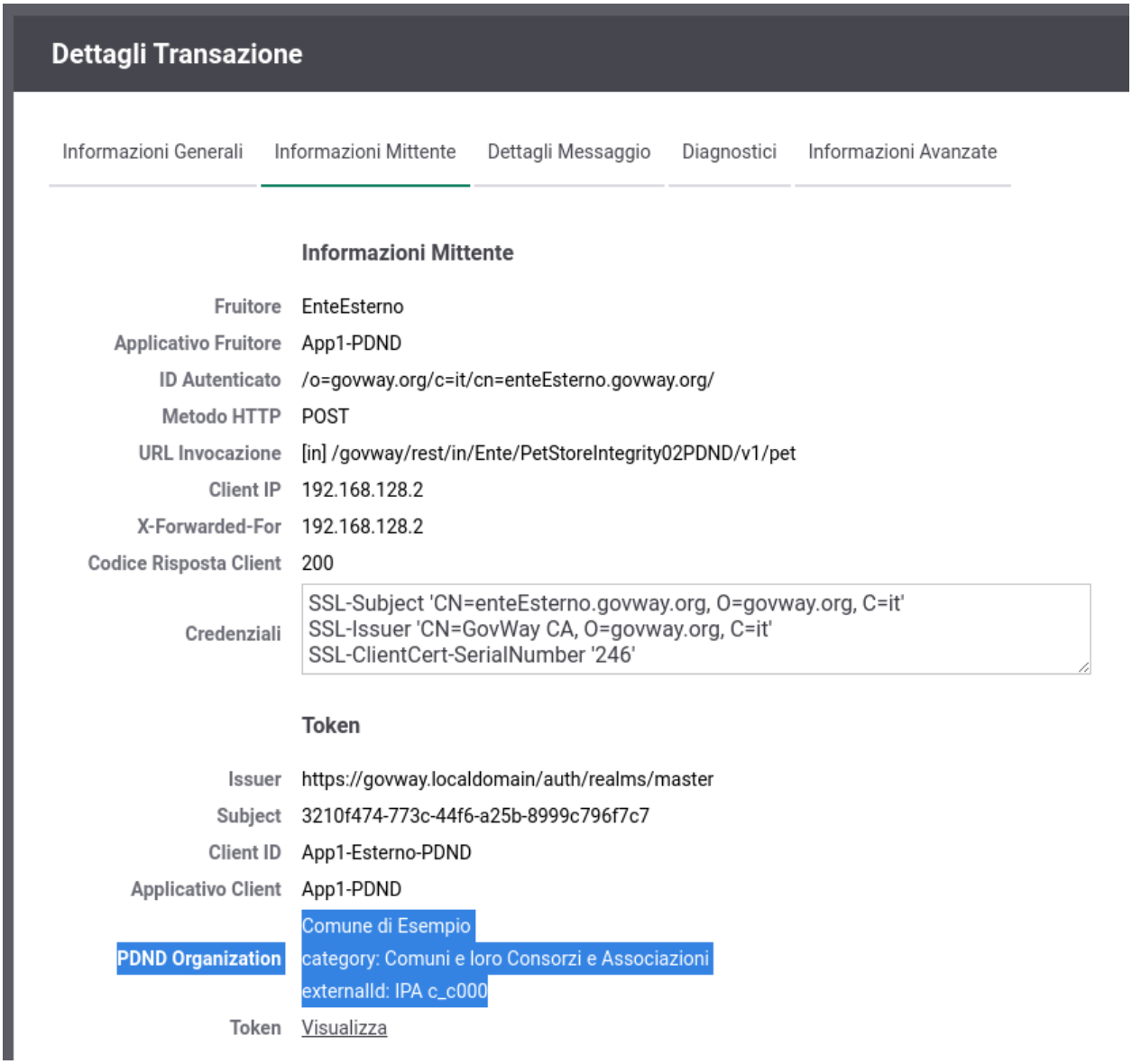


Figure3.183: Informazioni recuperate dalla PDND sull'organizzazione associata al "client-id"

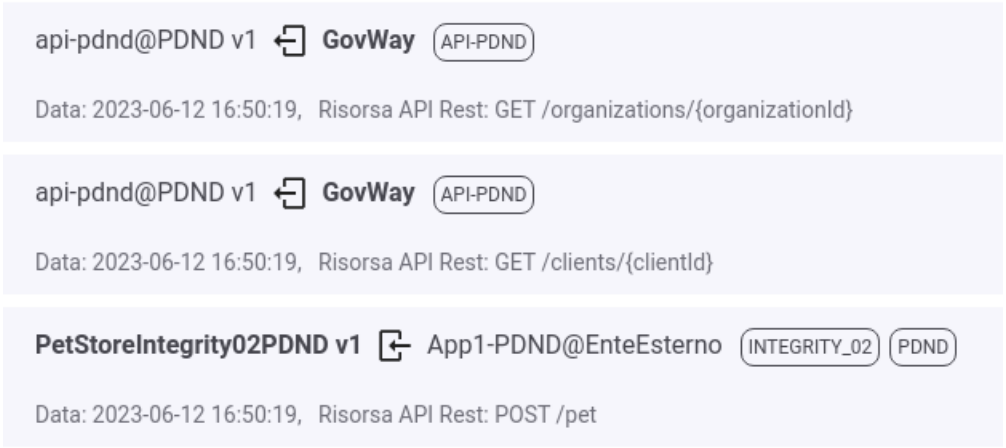


Figure3.184: Evidenza diagnostica delle chiamate verso la PDND per ottenere maggiori informazioni sul "client-id"

Messaggio» sono riportate le informazioni estratte dai token di sicurezza presenti, tra cui si può notare il digest e gli header http firmati.

Conformità ai requisiti ModI

I requisiti iniziali, legati alla comunicazione basata su uno scenario ModI, sono verificati dalle seguenti evidenze:

1. la sicurezza messaggio applicata è quella dei pattern «ID_AUTH_REST_01 via PDND» + «INTEGRITY_REST_02» come ampiamente mostrato precedentemente dove sono stati mostrati i token validati e i criteri autorizzativi;
2. la validazione del token di integrità viene effettuata scaricando la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd;
3. l'identificazione del fruitore avviene rispetto al claim "client_id" presente all'interno del token e ulteriori informazioni sull'organizzazione afferente vengono ottenute invocando le modipa_passiPreliminari_api_pdnd.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.186: Profilo ModI della govwayConsole

La configurazione dello scenario è del tutto analogo a quello descritto nello scenario *Configurazione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «INTEGRITY_REST_02».

Registrazione API

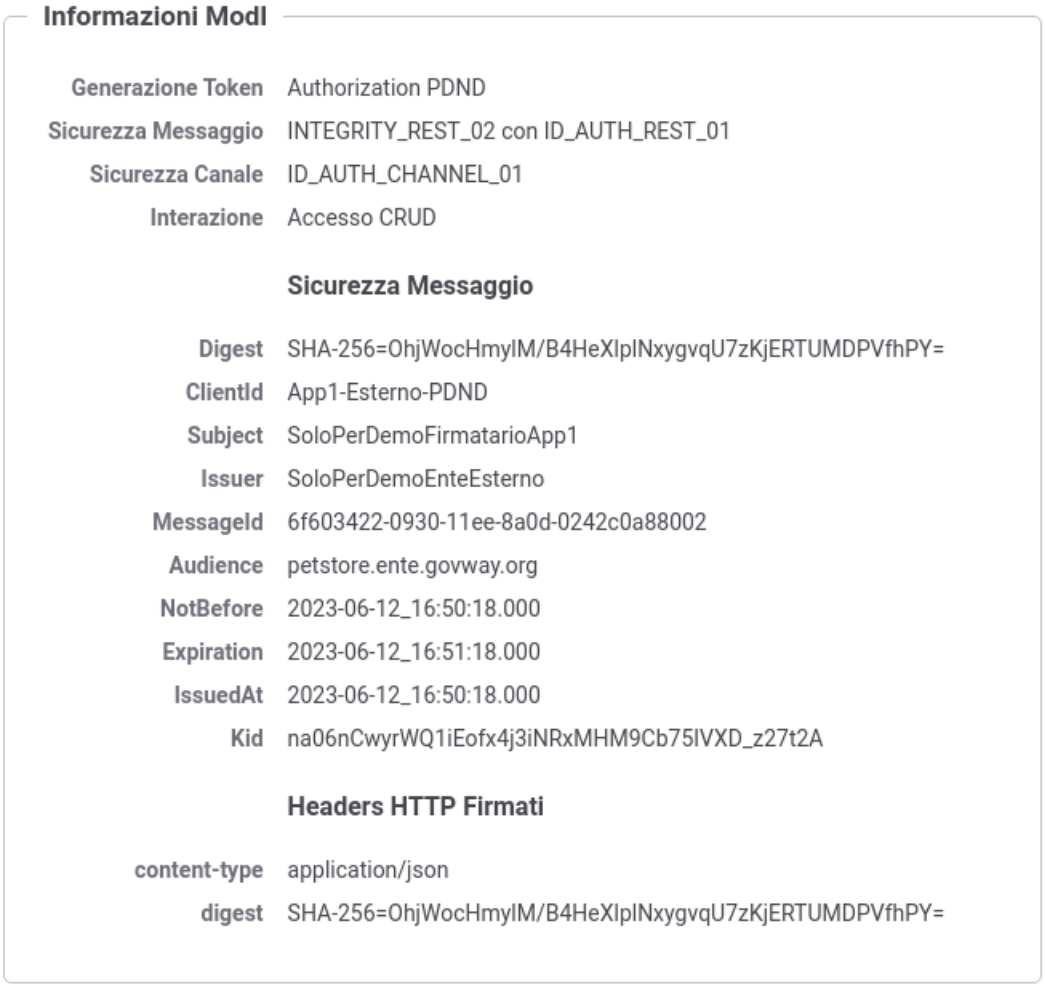


Figure3.185: Traccia della richiesta elaborata dall'erogatore, con pattern "INTEGRITY_REST_02"

Viene registrata l'API «PetStoreIntegrity02PDND» con il relativo descrittore OpenAPI 3. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «INTEGRITY_REST_02 con ID_AUTH_REST_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND» (Fig. 3.187).

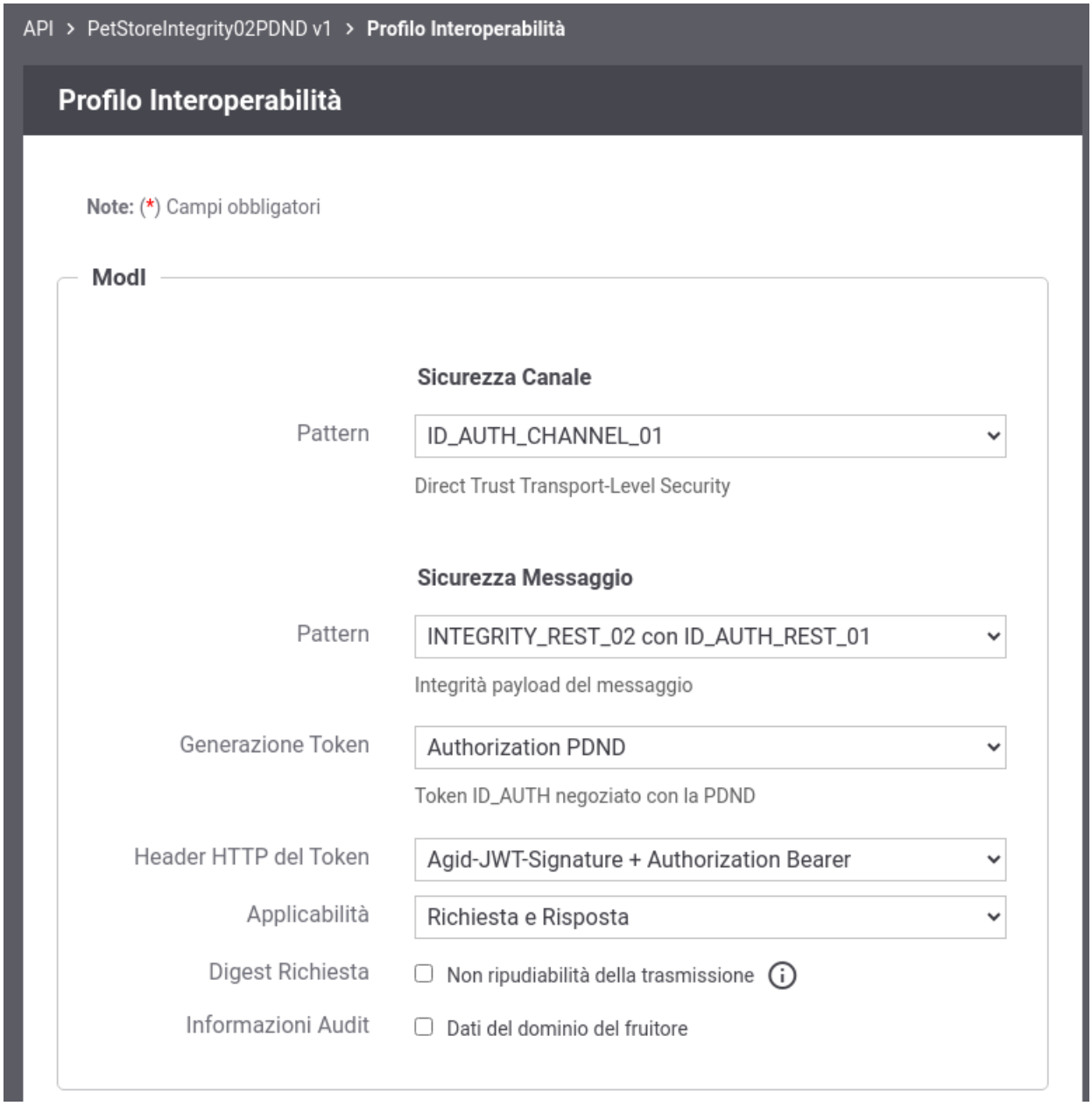


Figure3.187: Configurazione Pattern ModI «INTEGRITY_REST_02 con ID_AUTH_REST_01» sulla API REST

Applicativo Esterno

È opzionalmente possibile registrare l'applicativo esterno che corrisponde al fruitore del servizio. Questa scelta può essere fatta in base al tipo di autorizzazione che si è impostata sui fruitori. Vediamo i seguenti casi:

- Se si desidera autorizzare qualsiasi fruitore proveniente dalla PDND, questo passo può anche essere omesso. La validazione del token è sufficiente a stabilire che il fruitore ha ottenuto un voucher dalla PDND valido per il servizio invocato. Questo scenario è quello preconfigurato.

- In alternativa è possibile configurare una autorizzazione puntuale procedendo alla registrazione degli applicativi fornendo i singoli "client_id" necessari all'identificazione (Fig. 3.188).

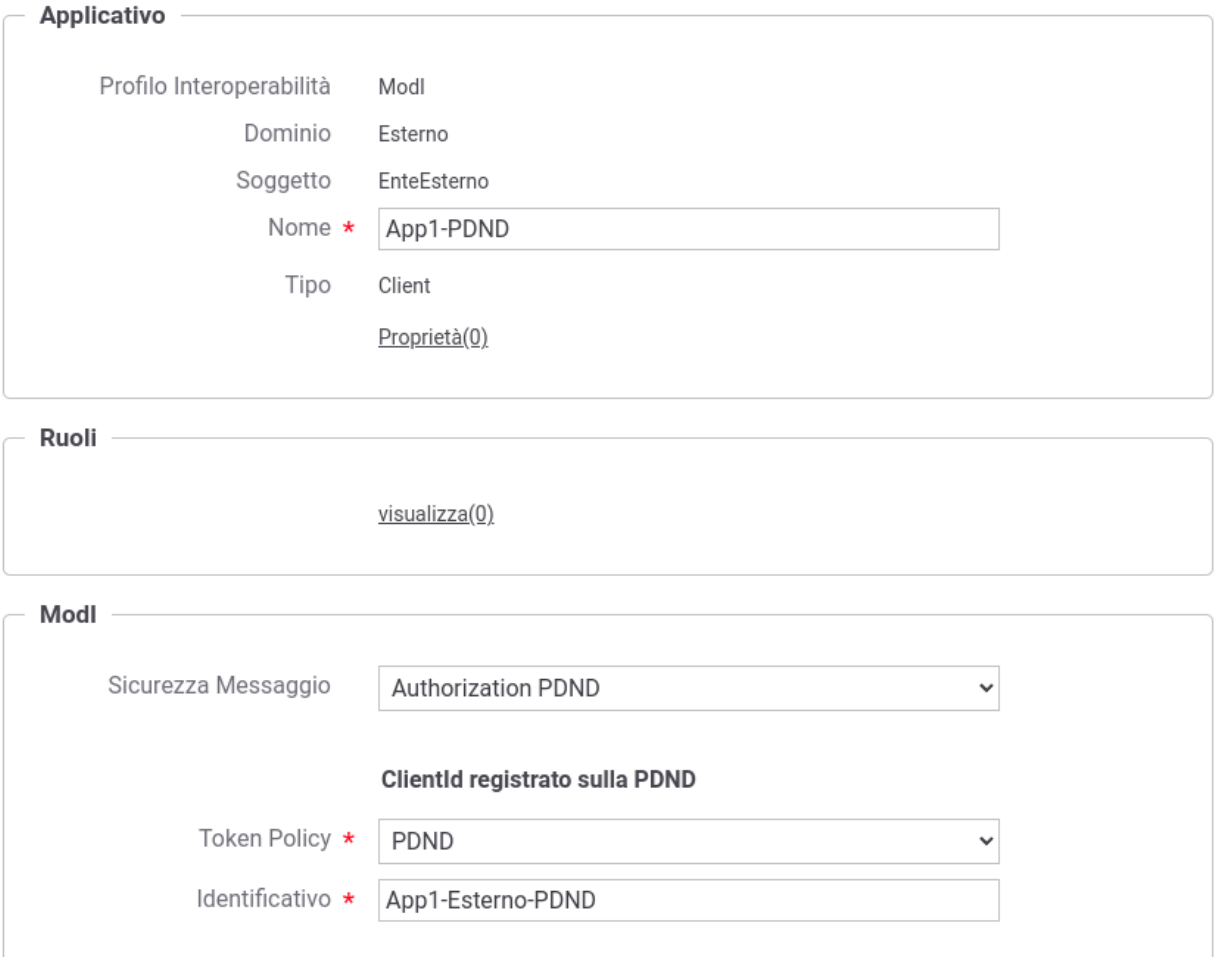


Figure3.188: Configurazione applicativo esterno (fruitore)

Erogazione

Nell'erogazione «PetStoreIntegrity02PDND», relativa all'API precedentemente inserita, vanno indicati i dati specifici nella sezione «ModI Richiesta» (Fig. 3.145) necessari per validare le richieste in ingresso relativamente al token "Agid-JWT-Signature". Si noti come è stato selezionato un truststore basato sulla PDND al fine di scaricare la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd.

La sezione «ModI Risposta» si utilizza per indicare i parametri per la produzione del token di sicurezza "Agid-JWT-Signature" da inserire nel messaggio di risposta (Fig. 3.146). Si noti come è stato indicato nel campo «Key Id (kid) del Certificato» l'identificativo kid associato alla chiave pubblica registrata sulla PDND.

3.5.2 Fruizione API REST

Obiettivo

Fruire di un servizio REST, definito tramite una API REST (OpenAPI 3.0), accessibile in accordo al pattern di sicurezza descritto nella sezione modipa_idar04.

Sintesi

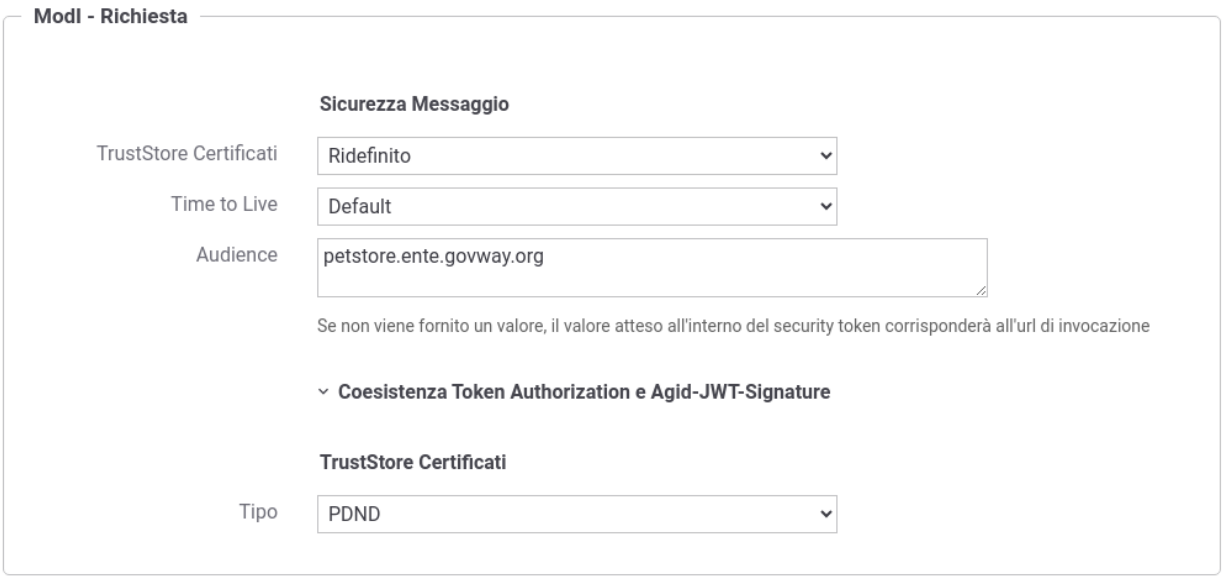


Figure3.189: Configurazione richiesta dell'erogazione

Mostriamo in questa sezione come procedere per l'integrazione di un applicativo con un servizio REST erogato nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui il servizio è stato registrato sulla PDND, e il fruitore per poterlo fruire deve ottenere un voucher dalla PDND che successivamente deve inviare all'erogatore insieme alla normale richiesta di servizio. Oltre al voucher il fruitore devo anche presentare il token di sicurezza «Agid-JWT-Signature» previsto dal pattern «INTEGRITY_REST_02» a garanzia dell'integrità del messaggio.

La figura seguente descrive graficamente questo scenario.

Nella figura "Fig. 3.192" viene raffigurato lo scenario di fruizione durante la fase di validazione del token di risposta tramite un truststore dinamico in cui GovWay utilizza le modipa_passiPreliminari_api_pdnd per ottenere la chiave pubblica necessaria a validare il token di risposta.

Le caratteristiche principali di questo scenario sono:

1. un applicativo fruitore che dialoga con il servizio erogato in modalità ModI in accordo ad una API condivisa e pubblicata su PDND;
2. la comunicazione diretta verso il dominio erogatore veicolata su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;
3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND»;
4. l'integrità del messaggio scambiato è garantita tramite sicurezza messaggio aggiuntiva prevista nel pattern «INTEGRITY_REST_02»;
5. la validazione del token di integrità della risposta viene effettuata scaricando la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd.

Esecuzione

Nota

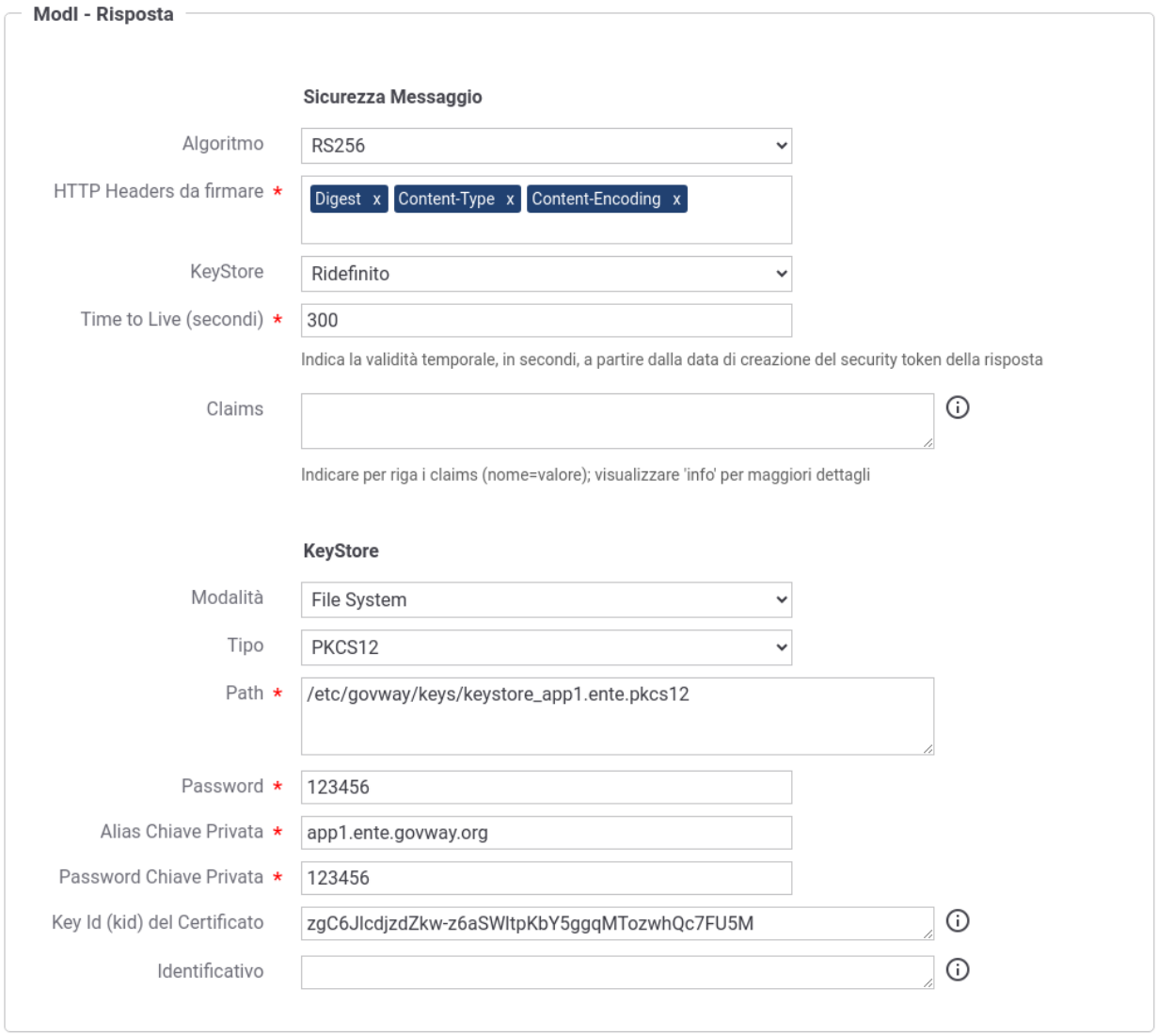


Figure3.190: Configurazione risposta dell'erogazione

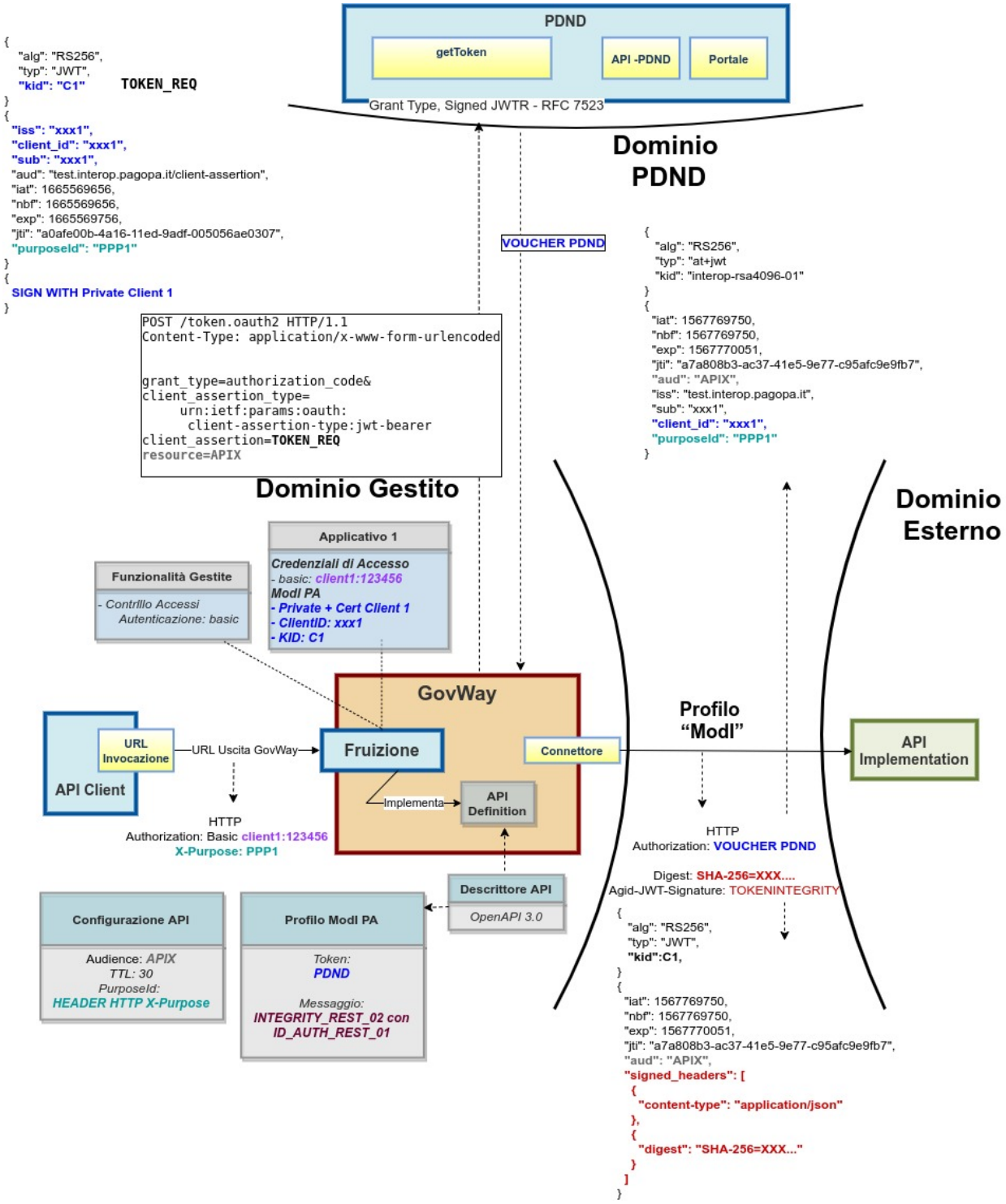


Figure3.191: Fruizione di una API REST con profilo "Modl", pattern INTEGRITY_REST_02 e pattern ID_AUTH_REST_01 via PDND

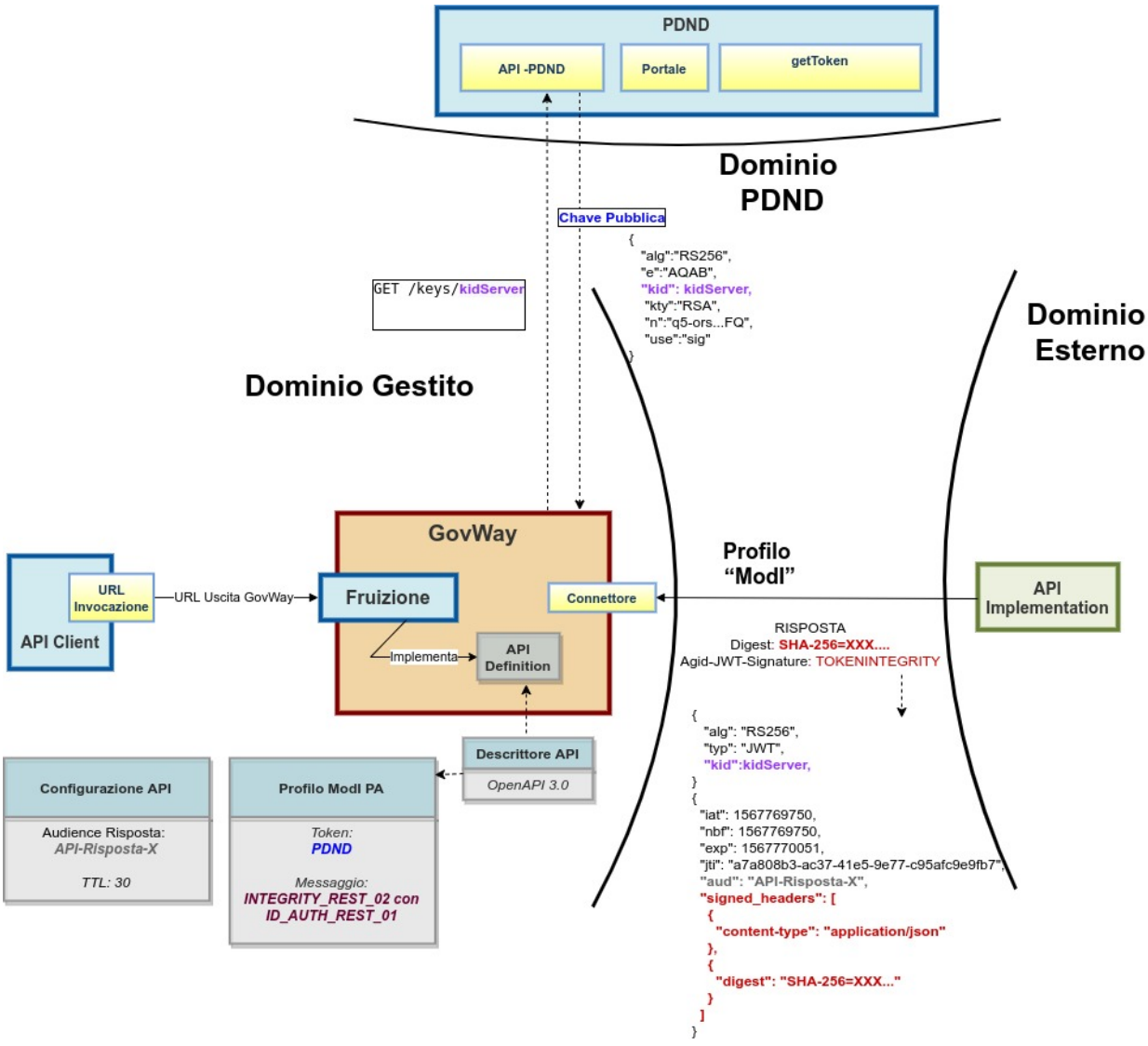


Figure3.192: Fruizione con Profilo di Interoperabilità "ModI", pattern "INTEGRITY_REST_02": utilizzo delle API PDND per ottenere la chiave pubblica per validare la risposta

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.193: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «INTEGRITY_REST_02».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - IntegrityRest02+PDND - OUT App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

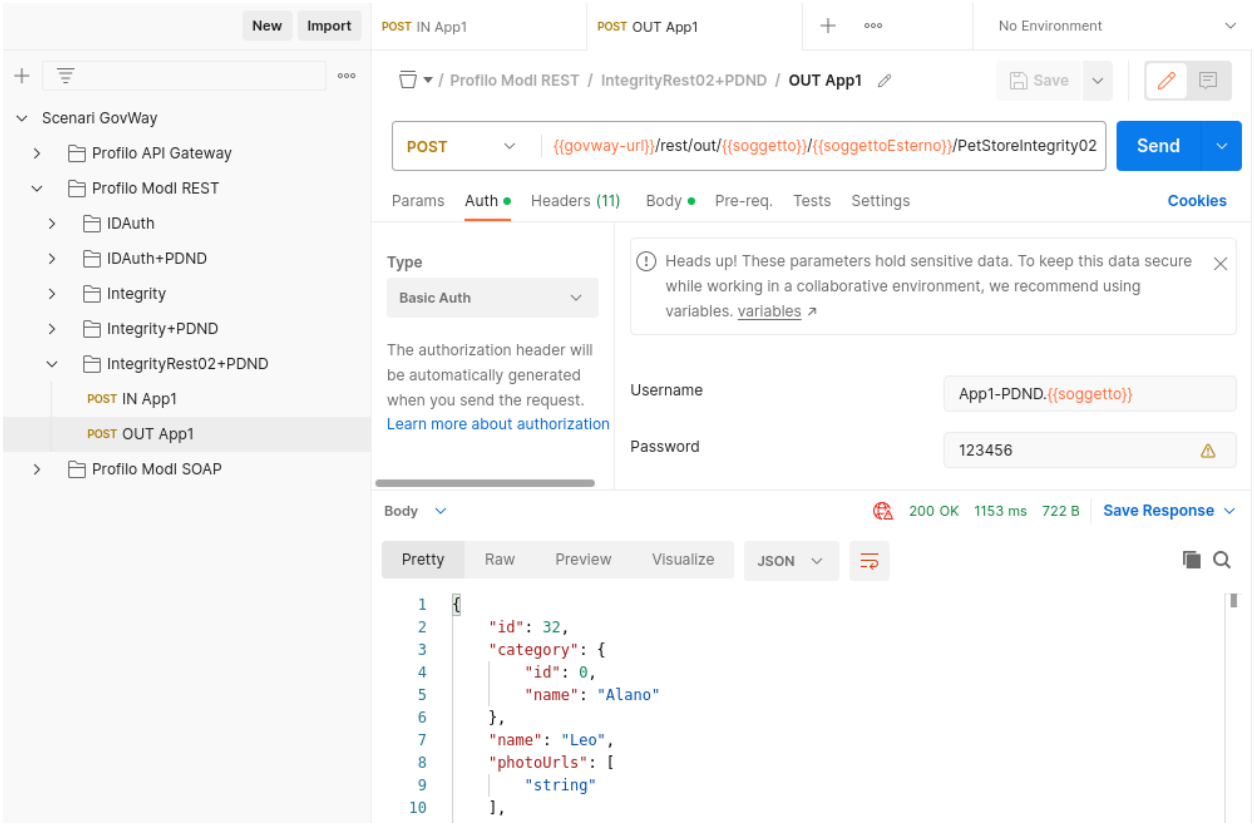


Figure3.194: Pattern IntegrityRest02+PDND - Fruizione API REST, esecuzione da Postman

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto nelle diverse fasi dell'esecuzione andando a consultare la console "govwayMonitor".

Le verifiche da effettuare sono le medesime di quelle descritte nello scenario *Esecuzione*. Di seguito vengono riportati solo i punti salienti in cui emerge una differenza dovuta al pattern di sicurezza diverso utilizzato.

- Il messaggio di richiesta inviato dal fruitore viene elaborato da Govway che, tramite la configurazione della firma digitale associata all'applicativo mittente, è in grado di produrre un token di sicurezza da inviare alla PDND con il

quale ottenere indietro un voucher spendibile per il servizio desiderato. Questa parte è stata ampiamente mostrata nella scenario *Esecuzione*.

Oltre al token della PDND, GovWay produce un ulteriore token di sicurezza «Agid-JWT-Signature» previsto dal pattern «INTEGRITY_REST_02». Da govwayMonitor si può visualizzare il messaggio di richiesta in uscita che è il medesimo di quello in entrata con la differenza che sono stati aggiunti gli header HTTP «Authorization» e «Agid-Jwt-Signature» che contengono rispettivamente il token ottenuto dalla PDND e il token dell'integrità. È inoltre presente l'header http «Digest» che contiene il valore utilizzabile dall'erogatore per la verifica dell'integrità del payload. (Fig. 3.195).

Headers

Nome	
Content-Type	application/json
Govway-Message-Id	d1b37101-4fbb-11ed-a5ac-0242ac140002
X-Forwarded-Server	411885f186f6
X-Real-Ip	172.20.0.1
Postman-Token	0ab5fecb-2b64-497f-9a8e-ff0a6dbd24ab
X-Forwarded-For	172.20.0.2
Cache-Control	no-cache
Authorization	Bearer eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6ImFwcDEuZW50ZWVzdGVybm8uZ292d2F5Lm9yZyIsIng1YyI6 xWqdhfvHBaJT3on7jaCV6LVEXEaqAqfDWwI48L8SextE3UyuuGh-1s-g632OH8j6SlFr8tzsK4p-Fc94WclxhMJxjXAer6Sh8(
Agid-Jwt-Signature	eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6ImFwcDEuZW50ZWVzdGVybm8uZ292d2F5Lm9yZyIsIng1YyI6WyJNS jlIVuNpGcBUWGoh1dKhKCv6nd6LFjWiFSdExxjto5i8iBtyjExSu06IHLOiaD2pI1jkYrG37MgE6f-1xBYCqIElCchD6GQ8R4fEc5
Digest	SHA-256=OhjWocHmyIM/B4HeXIpINxygvqU7zKjERTUMDPVfhPY=
Accept	*/*
Govway-Transaction-Id	d1a3b973-4fbb-11ed-a5ac-0242ac140002
Transfer-Encoding	chunked

Figure3.195: Messaggio di richiesta in uscita (con token di sicurezza inseriti nell'header HTTP)

- L'header e i payload del token «Agid-JWT-Signature» sono identici a quelli già visualizzati nello scenario di erogazione REST, relativamente al messaggio in ingresso (Fig. 3.180 e Fig. 3.182). Le informazioni inserite nel token vengono anche tracciate e sono visibili sulla govwayMonitor, andando a consultare la traccia del messaggio di richiesta (Fig. 3.196). Nella sezione «Sicurezza Messaggio» sono riportate le informazioni estratte dai token di sicurezza, tra cui si può notare il digest e gli header http firmati.
- Vengono inoltre validati anche gli header «Agid-Jwt-Signature» e «Digest» presenti nella risposta rispetto al pattern "INTEGRITY_REST_02" indicato nella configurazione dell'API (Fig. 3.197). La validazione del token



Figure3.196: Traccia della richiesta generata dal fruitore

di integrità della risposta viene effettuata scaricando la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd. Nello storico delle transazioni è possibile vedere come GovWay durante la gestione della richiesta di fruizione scaturisca un'ulteriore chiamata verso la PDND per ottenere la chiave pubblica (Fig. 3.179). La chiave pubblica una volta prelevata dalla PDND verrà aggiunta in una cache locale e le successive richieste non provocheranno ulteriori chiamate verso la PDND.

2023-06-12 18:35:59.105	infoIntegration	ModI	Validazione security token ModI 'INTEGRITY' della risposta in corso ...
2023-06-12 18:35:59.166	infoIntegration	InoltroBuste	Ricezione dati della risposta completata
2023-06-12 18:35:59.167	infoIntegration	ModI	Validazione security token ModI 'INTEGRITY' della risposta effettuata con successo

Figure3.197: Evidenza diagnostica della validazione del token di integrità della risposta

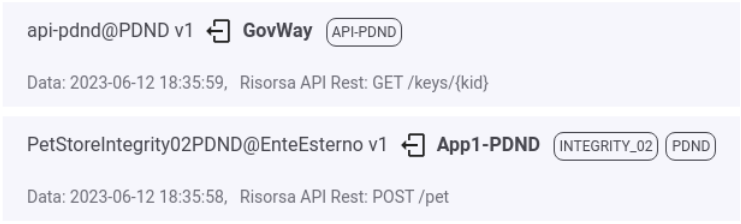


Figure3.198: Evidenza diagnostica della chiamata verso la PDND per ottenere la chiave pubblica con cui è stato firmato il token integrity di risposta

Nota

Le informazioni ottenute tramite le modipa_passiPreliminari_api_pdnd (chiavi pubbliche JWK) vengono salvate su cache locali. Al fine di forzare nuove invocazioni verso la «PDND simulata» è necessario attendere un minuto rispetto a precedenti invocazioni ed effettuare il reset delle cache locali di GovWay accedendo alla sezione strumenti_runtime della console di gestione "*govwayConsole*" e cliccando sul link "*Svuota tutte le Cache*".

Conformità ai requisiti ModI

I requisiti iniziali, legati alla comunicazione basata su uno scenario ModI, sono verificati dalle seguenti evidenze:

1. viene effettuata una negoziazione del voucher PDND come mostrato nelle tracce relative ai token scambiati con la PDND;
2. l'invocazione del servizio avviene fornendo il voucher della PDND precedentemente negoziato;
3. vengono inoltre prodotti gli header http «Agid-Jwt-Signature» e «Digest» previsti dal pattern di sicurezza «INTEGRITY_REST_02»;
4. la validazione del token di integrità della risposta viene effettuata scaricando la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità «ModI». Si suggerisce

inoltre di selezionare il soggetto “Ente” per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.199: Profilo ModI della govwayConsole

La configurazione dello scenario è del tutto analogo a quello descritto nello scenario *Configurazione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «INTEGRITY_REST_02».

Registrazione API

Viene registrata l’API «PetStoreIntegrity02PDND» con il relativo descrittore OpenAPI 3. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «INTEGRITY_REST_02 con ID_AUTH_REST_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND» (Fig. 3.200).

Fruizione

Nella fruizione «PetStoreIntegrity02PDND», relativa all’API precedentemente inserita, vanno indicati i dati specifici nella sezione «ModI Richiesta» (Fig. 3.201) necessari a generare il token “Agid-JWT-Signature”. In particolare è possibile specificare l’audience atteso dall’erogatore e il tempo di validità del token.

La sezione «ModI Risposta» definisce i criteri per la validazione del token di sicurezza “Agid-JWT-Signature” presente nel messaggio di risposta, come il truststore per l’autenticazione dell’erogatore (Fig. 3.202). Si noti come è stato selezionato un truststore basato sulla PDND al fine di scaricare la chiave pubblica, corrispondente al kid presente nel token della risposta, tramite le modipa_passiPreliminari_api_pdnd.

3.6 Pattern “AUDIT_REST_01”

Gli scenari riportati in questa sezione riguardano API configurate con pattern modipa_infoUtente_audit01.

3.6.1 Erogazione API REST

Obiettivo

Esporre un servizio, definito tramite una API REST (OpenAPI 3.0), che richieda per l’accesso oltre ai token di sicurezza descritti nei precedenti scenari anche un token aggiuntivo adibito a contenere informazioni utili all’erogatore a identificare la specifica provenienza di ogni singola richiesta di accesso ai dati effettuta dal fruitore. Il token di audit deve rispettare il pattern di sicurezza descritto nella sezione modipa_infoUtente_audit01.

Nota

Il token descritto nel pattern modipa_infoUtente_audit01 va in aggiunta rispetto agli altri token di sicurezza e quindi può essere utilizzato in combinazione con qualsiasi dei token descritti nei precedenti scenari, anche senza la PDND. In questo scenario verrà utilizzato insieme al token “Authorization” ottenuto tramite la PDND, descritto negli scenari *Pattern “ID_AUTH” via PDND*.

Sintesi

Mostriamo in questa sezione come procedere per l’esposizione di un servizio REST da erogare nel rispetto della normativa italiana alla base dell’interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo

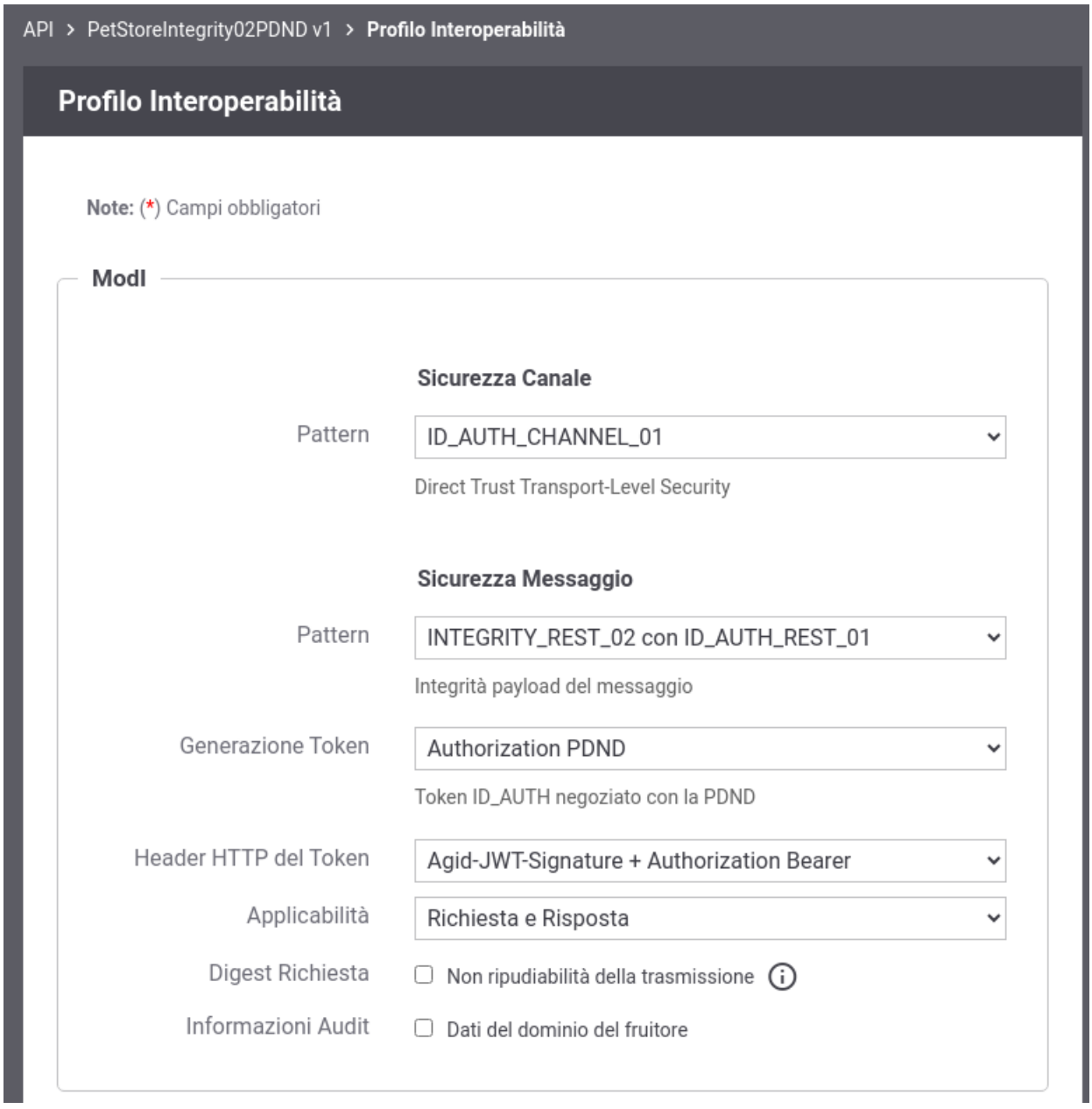


Figure3.200: Configurazione Pattern ModI «INTEGRITY_REST_02 con ID_AUTH_REST_01» sulla API REST

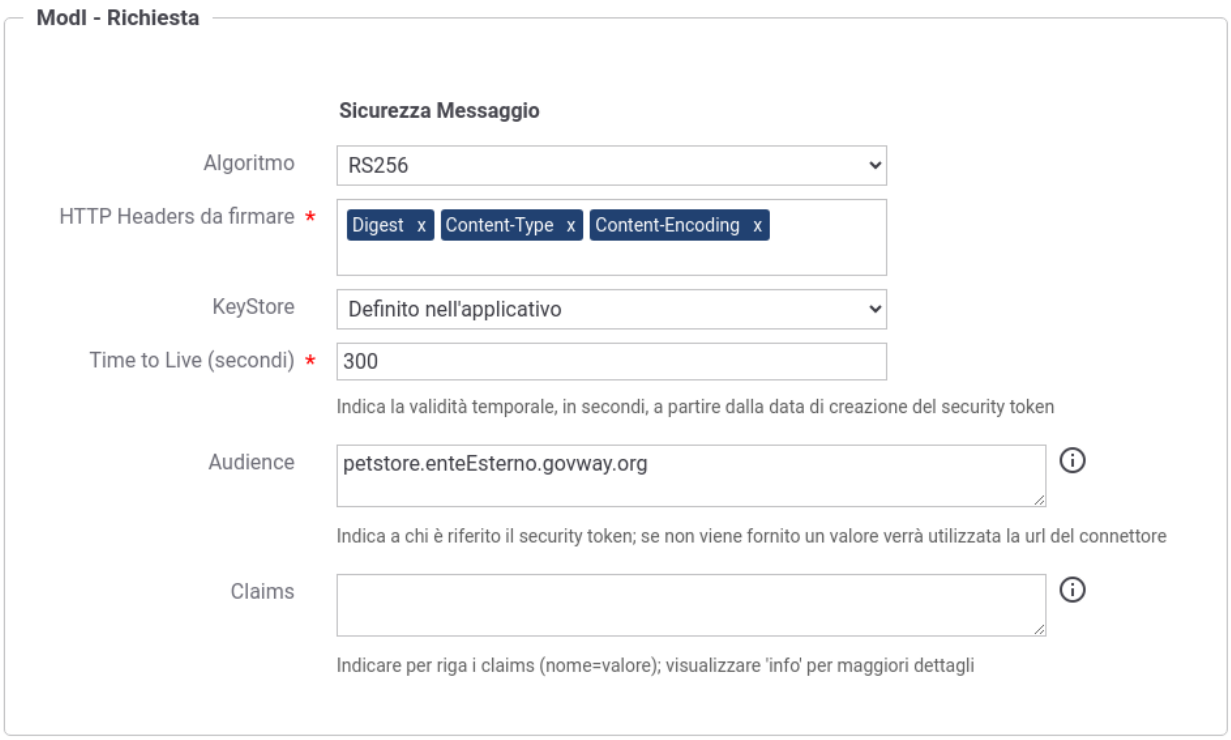


Figure3.201: Configurazione richiesta della fruizione

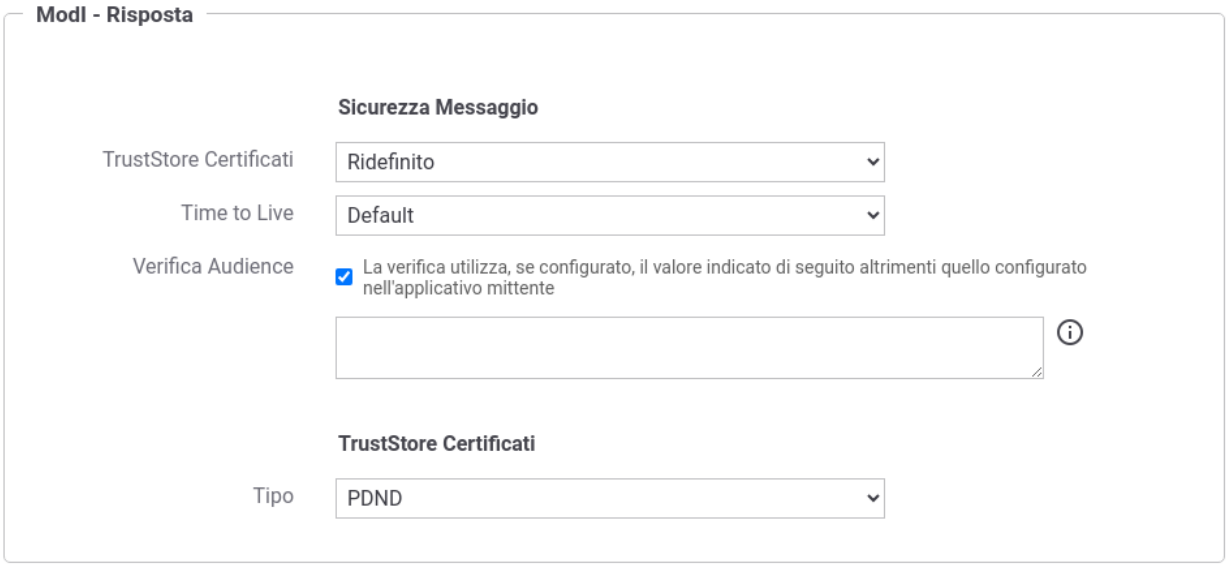


Figure3.202: Configurazione risposta della fruizione

ad illustrare lo scenario in cui un servizio è stato registrato sulla PDND, e i fruitori per poterlo fruire devono ottenere un voucher dalla PDND che successivamente devono inviare all'erogatore insieme alla normale richiesta di servizio. Oltre al voucher devono anche presentare il token di audit «Agid-JWT-TrackingEvidence» previsto dal pattern «AUDIT_REST_01».

La figura seguente descrive graficamente questo scenario.

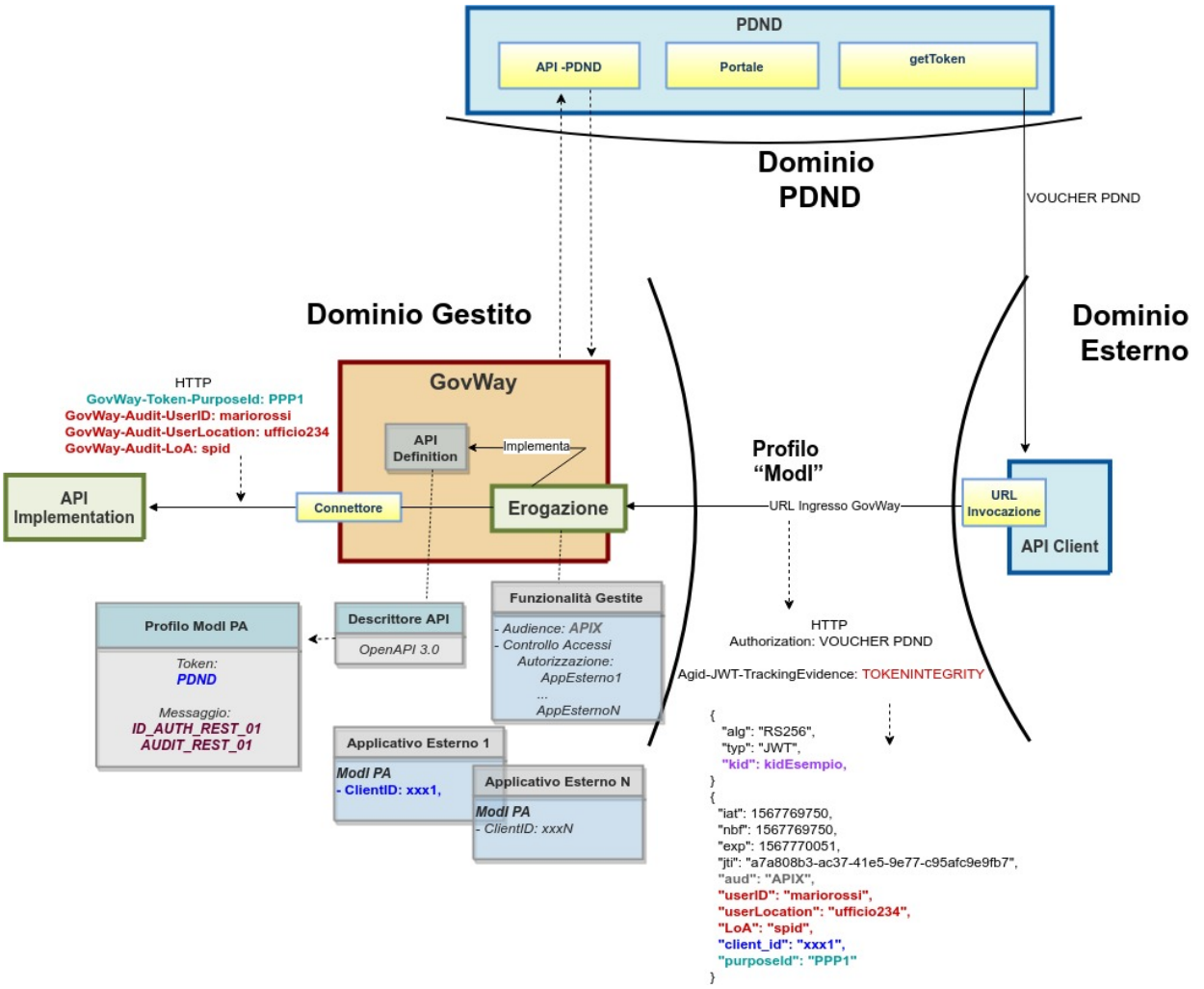


Figure3.203: Erogazione di una API REST con profilo "ModI", pattern AUDIT_REST_01 e pattern ID_AUTH_REST_01 via PDND

Le caratteristiche principali di questo scenario sono:

1. un applicativo eroga un servizio, rivolto a fruitori di domini esterni, in conformità al Modello di Interoperabilità AGID e il servizio viene registrato sulla PDND;
2. la comunicazione con i domini esterni avviene su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;
3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND»;
4. per la fruizione viene richiesto un token aggiuntivo, conforme al pattern «AUDIT_REST_01», adibito a contenere informazioni utili all'erogatore a identificare la specifica provenienza di ogni singola richiesta di accesso ai dati effettuta dal fruitore;

5. la validazione del token di audit viene effettuata scaricando la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd;
6. vengono inoltre recuperate e associate alla traccia maggiori informazioni sull'organizzazione afferente al "client-id" presente nel token, sempre attraverso le modipa_passiPreliminari_api_pdnd.

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.204: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione* con la sola eccezione del pattern di audit aggiuntivo utilizzato in questo scenario: «AUDIT_REST_01».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - Audit+PDND - IN App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

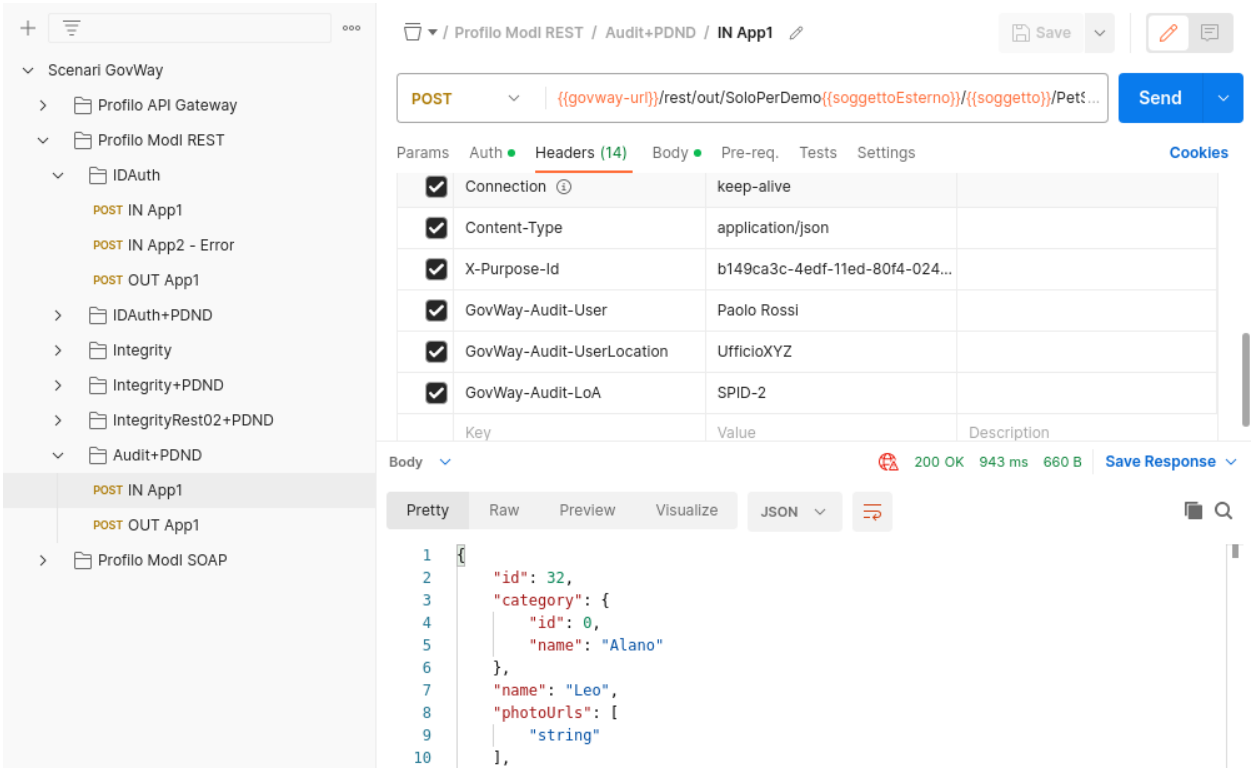


Figure3.205: Pattern Audit+PDND - Erogazione API REST, esecuzione da Postman

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console "govwayMonitor".

Nota

Le informazioni ottenute tramite le modipa_passiPreliminari_api_pdnd (chiavi pubbliche JWK e informazioni sui client) vengono salvate su cache locali. Al fine di forzare nuove invocazioni verso la «PDND simulata» è necessario attendere un minuto rispetto a precedenti invocazioni ed effettuare il reset delle cache locali di GovWay accedendo alla sezione strumenti_runtime della console di gestione "*govwayConsole*" e cliccando sul link "*Svuota tutte le Cache*".

Le evidenze del processo di validazione relative al token PDND sono le medesime descritte nella scenario *Esecuzione*.

1. Dal dettaglio della richiesta si può visualizzare il messaggio che è stato inviato dal fruitore, come in Fig. 3.206. Come si nota, al payload JSON è associato un insieme di header HTTP tra i quali «Authorization» e «Agid-Jwt-TrackingEvidence» che contengono rispettivamente il token di sicurezza che il fruitore ha ottenuto dalla PDND e il token di audit.

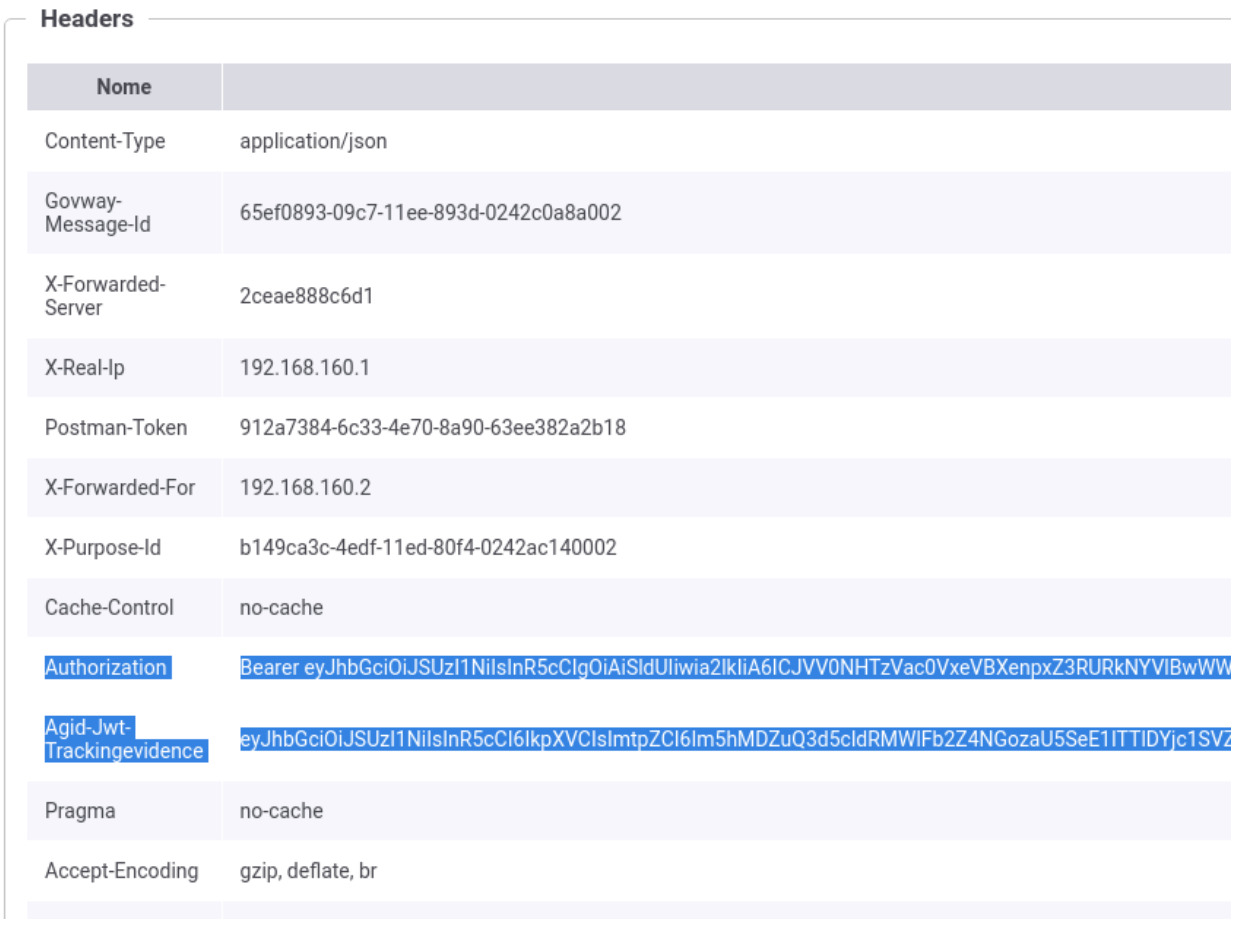


Figure3.206: Evidenza diagnostica degli header «Authorization» e «Agid-Jwt-TrackingEvidence»

2. Grazie alle configurazioni presenti nell'erogazione, ed in particolare all'indicazione che il token ricevuto deve essere validato tramite Token Policy PDND, GovWay è in grado di validare i dati di sicurezza ricevuti (Fig. 3.207) e decodificare il token.



Figure3.207: Evidenza diagnostica della validazione del token

3. Viene inoltre validato l'ulteriore header «Agid-Jwt-TrackingEvidence» rispetto al pattern "AUDIT_REST_01" indicato nella configurazione dell'API (Fig. 3.208). La validazione del token di audit viene effettuata scaricando la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd. Nello storico delle transazioni è possibile vedere come GovWay durante la gestione della richiesta di erogazione scaturisca un'ulteriore chiamata verso la PDND per ottenere la chiave pubblica (Fig. 3.209). La chiave pubblica una volta prelevata dalla PDND verrà aggiunta in una cache locale e le successive richieste non provocheranno ulteriori chiamate verso la PDND.

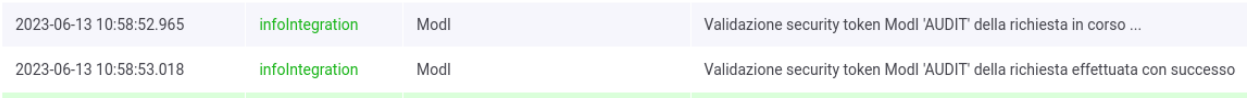


Figure3.208: Evidenza diagnostica della validazione del token di audit

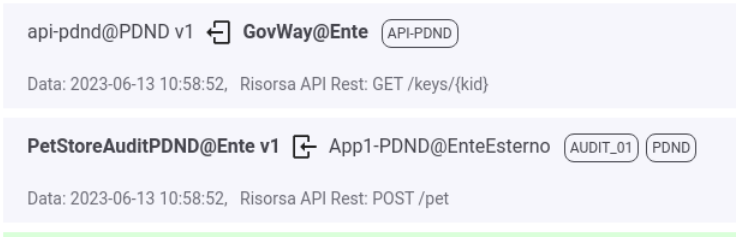


Figure3.209: Evidenza diagnostica della chiamata verso la PDND per ottenere la chiave pubblica

4. Analizzando il token di audit «Agid-Jwt-TrackingEvidence» ricevuto nella sezione header (Fig. 3.210) si può notare la presenza del claim "kid" che corrisponde all'identificativo della chiave pubblica registrata sulla PDND. L'identificativo "kid" verrà utilizzato da GovWay per richiedere la chiave pubblica tramite le modipa_passiPreliminari_api_pdnd (Fig. 3.211). Nella sezione payload (Fig. 3.212) sono invece presenti le informazioni utili all'erogatore a identificare la specifica provenienza di ogni singola richiesta di accesso ai dati effettuta dal fruitore (userId, userLocation, LoA), insieme ai riferimenti temporali (iat, nbf, exp), all'audience (aud) e al "purposeId" utilizzato dal fruitore per richiedere il token di autorizzazione alla PDND.
5. Vengono inoltre recuperate e associate alla traccia maggiori informazioni sull'organizzazione afferente al "client-id" presente nel token, sempre attraverso le modipa_passiPreliminari_api_pdnd (Fig. 3.213). Nello storico delle transazioni è possibile vedere come GovWay durante la gestione della richiesta di erogazione scaturisca due ulteriori chiamate verso la PDND per ottenere maggiori informazioni sul client e sull'organizzazione (Fig. 3.214). Le informazioni recuperate dalla PDND verranno aggiunte in una cache locale e le successive richieste non provocheranno ulteriori chiamate verso la PDND.
6. Le evidenze del processo di validazione relativo al pattern «AUDIT_REST_01» sono visibili sulla govwayMonitor, andando a consultare la traccia del messaggio di richiesta (Fig. 3.215). Nella sezione «Sicurezza Messaggio» sono riportate le informazioni estratte dai token di sicurezza presenti, tra cui si può notare le informazioni sull'utente fruitore.
7. Esaminando il messaggio inoltrato al backend è possibile vedere come tra gli header HTTP inoltrati vi sia l'header "GovWay-Token-PurposeId" contenente il valore del claim "purposeId" presente sia nel token ricevuto dalla PDND che nel token di audit e gli header "GovWay-Audit-UserID", "GovWay-Audit-UserLocation" e "GovWay-Audit-LoA" presenti nel token di audit (Fig. 3.216).

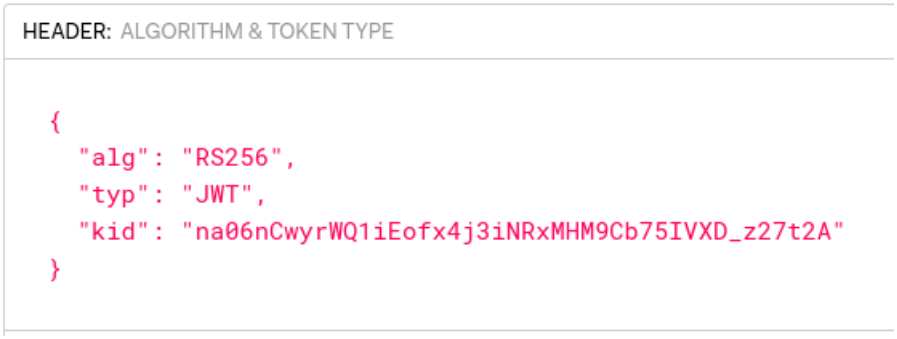


Figure3.210: Sezione «Header» del Token "Agid-Jwt-TrackingEvidence" con pattern "AUDIT_REST_01"

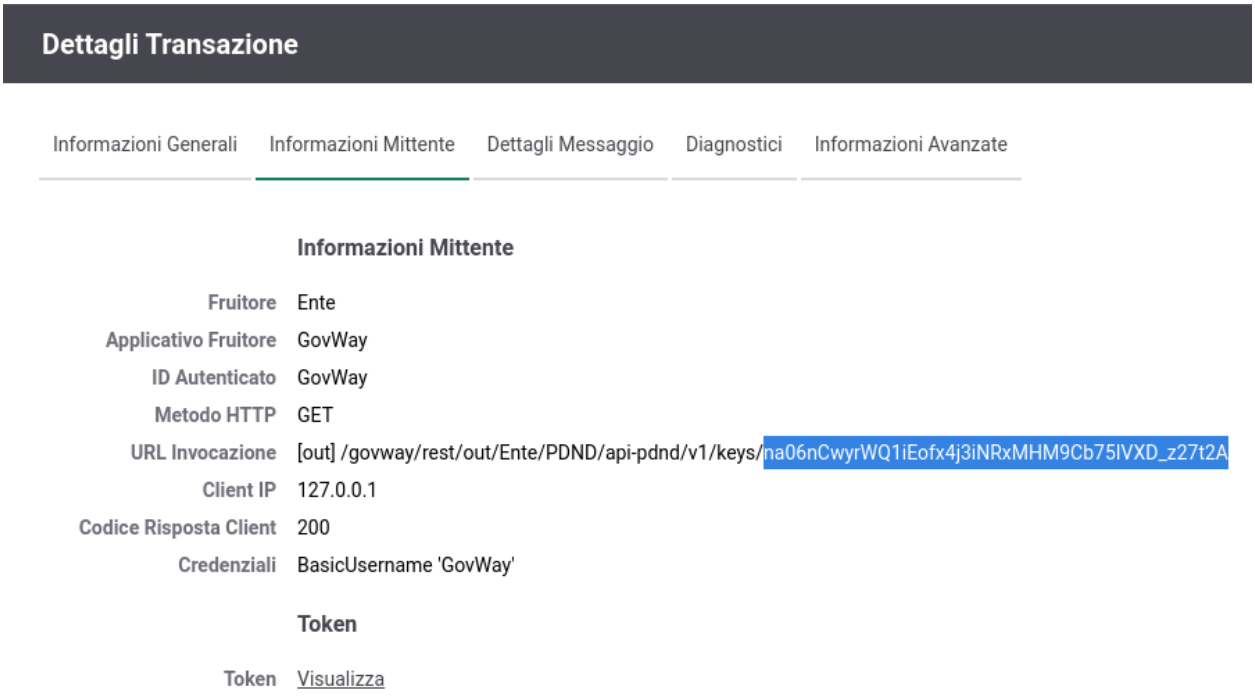


Figure3.211: Dettaglio della url di invocazione utilizzata da GovWay per prelevare la chiave pubblica, utilizzata per firmare il token di audit, dalla PDND



Figure3.212: Sezione «Payload» del Token "Agid-Jwt-TrackingEvidence" con pattern "AUDIT_REST_01"

Conformità ai requisiti ModI

I requisiti iniziali, legati alla comunicazione basata su uno scenario ModI, sono verificati dalle seguenti evidenze:

1. la sicurezza messaggio applicata è quella dei pattern «ID_AUTH_REST_01 via PDND» + «AUDIT_REST_01» come ampiamente mostrato precedentemente dove sono stati mostrati i token validati e i criteri autorizzativi;
2. la validazione del token di audit viene effettuata scaricando la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd;
3. l'identificazione del fruitore avviene rispetto al claim "client_id" presente all'interno del token e ulteriori informazioni sull'organizzazione afferente vengono ottenute invocando le modipa_passiPreliminari_api_pdnd;
4. le informazioni sul fruitore presenti nel token di audit vengono aggiunte alla traccia.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.217: Profilo ModI della govwayConsole

La configurazione dello scenario è del tutto analogo a quello descritto nello scenario *Configurazione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «AUDIT_REST_01».

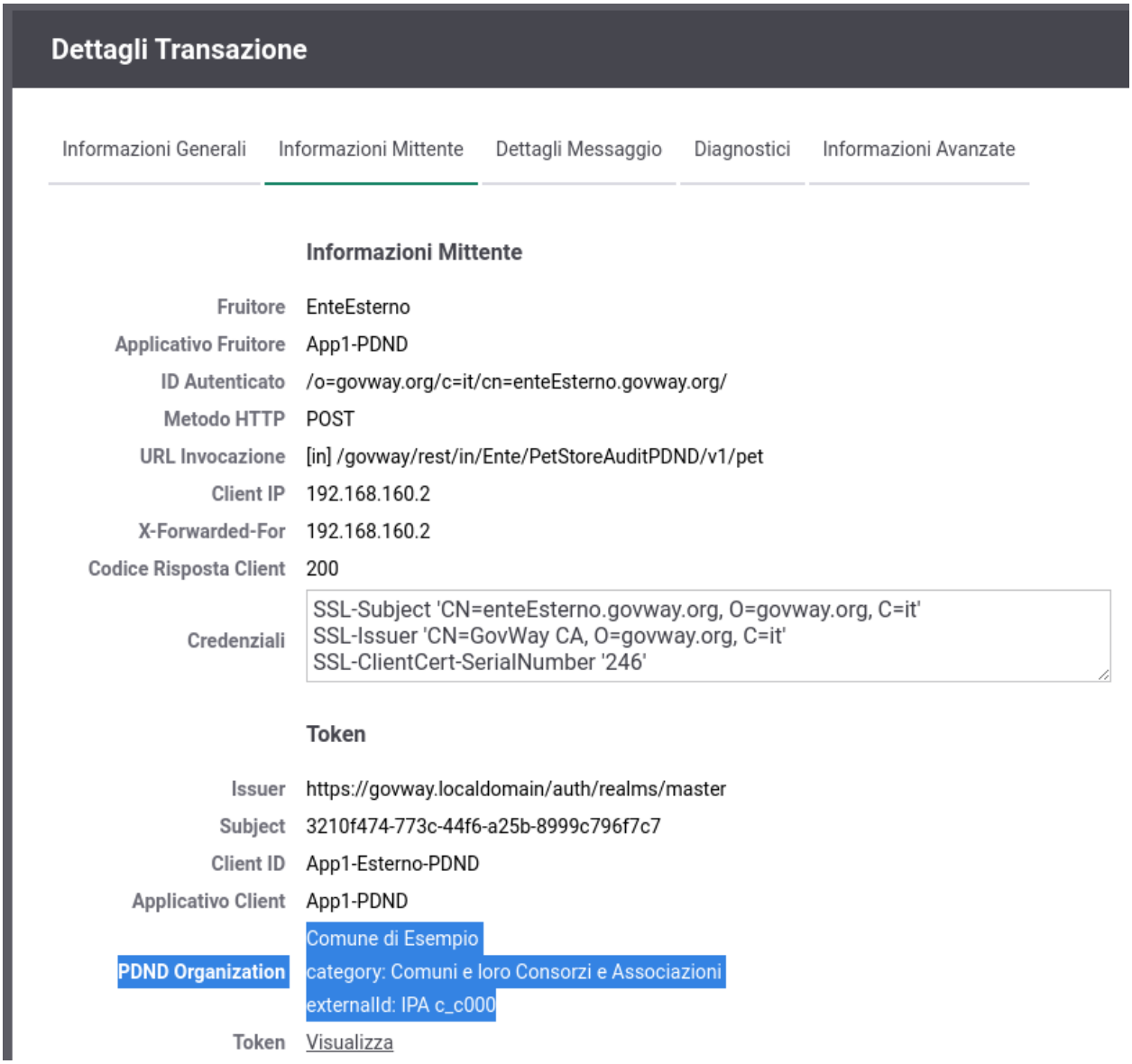


Figure3.213: Informazioni recuperate dalla PDND sull'organizzazione associata al "client-id"



Figure3.214: Evidenza diagnostica delle chiamate verso la PDND per ottenere maggiori informazioni sul "client-id"

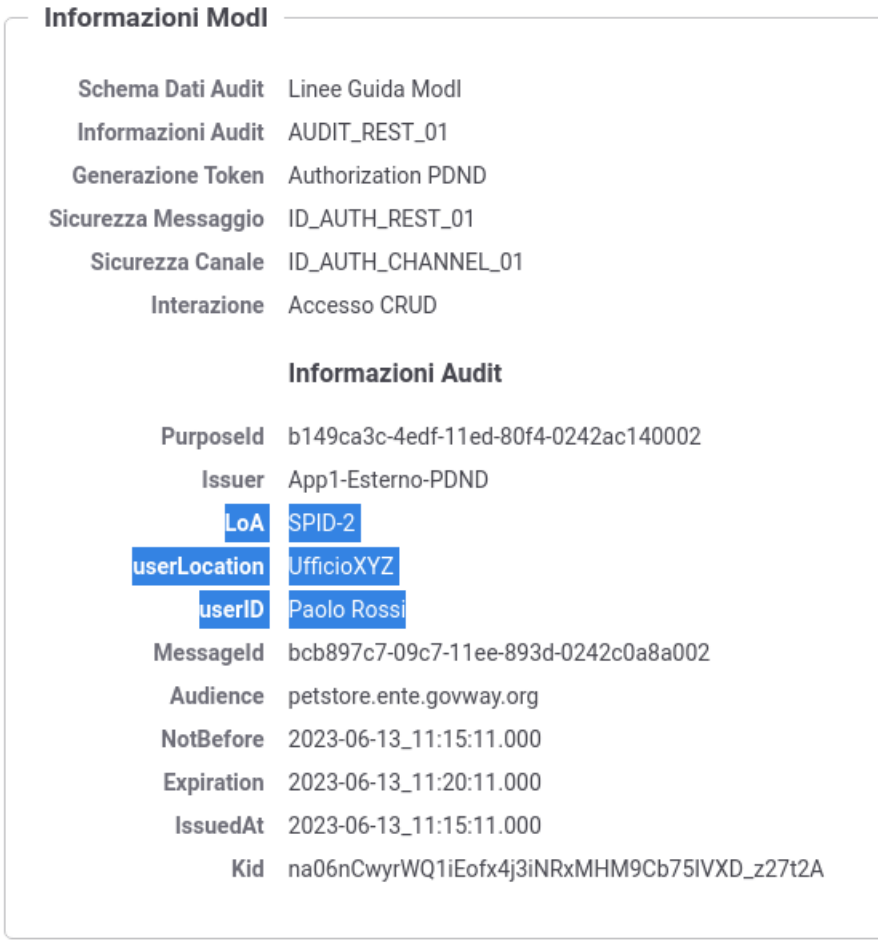


Figure3.215: Traccia della richiesta elaborata dall'erogatore, con pattern "AUDIT_REST_01"

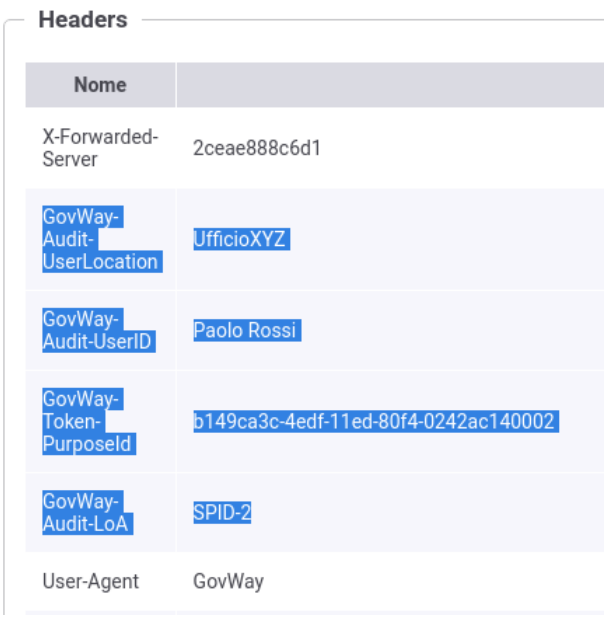


Figure3.216: Header HTTP "GovWay-Token-PurposeId", "GovWay-Audit-UserID", "GovWay-Audit-UserLocation" e "GovWay-Audit-LoA" inoltrati al backend

Registrazione API

Viene registrata l'API «PetStoreAuditPDND» con il relativo descrittore OpenAPI 3. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «ID_AUTH_REST_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND». Viene infine abilitata l'opzione "Informazioni Audit" e selezionato il pattern «AUDIT_REST_01» e lo schema dei dati «Linee Guida ModI» (Fig. 3.218). Per ulteriori dettagli sullo schema dei dati di un token di audit si rimanda alle sezioni modipa_infoUtente_audit01_schema e modipa_infoUtente_audit01_schema_custom.

Applicativo Esterno

È opzionalmente possibile registrare l'applicativo esterno che corrisponde al fruitore del servizio. Questa scelta può essere fatta in base al tipo di autorizzazione che si è impostata sui fruitori. Vediamo i seguenti casi:

- Se si desidera autorizzare qualsiasi fruitore proveniente dalla PDND, questo passo può anche essere omesso. La validazione del token è sufficiente a stabilire che il fruitore ha ottenuto un voucher dalla PDND valido per il servizio invocato. Questo scenario è quello preconfigurato.
- In alternativa è possibile configurare una autorizzazione puntuale procedendo alla registrazione degli applicativi fornendo i singoli "client_id" necessari all'identificazione (Fig. 3.219).

Erogazione

Nell'erogazione «PetStoreAuditPDND», relativa all'API precedentemente inserita, vanno indicati i dati specifici nella sezione «ModI Richiesta» (Fig. 3.220) necessari per validare le richieste in ingresso relativamente al token "Agid-JWT-TrackingEvidence". Si noti come è stato selezionato un truststore basato sulla PDND al fine di scaricare la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd.

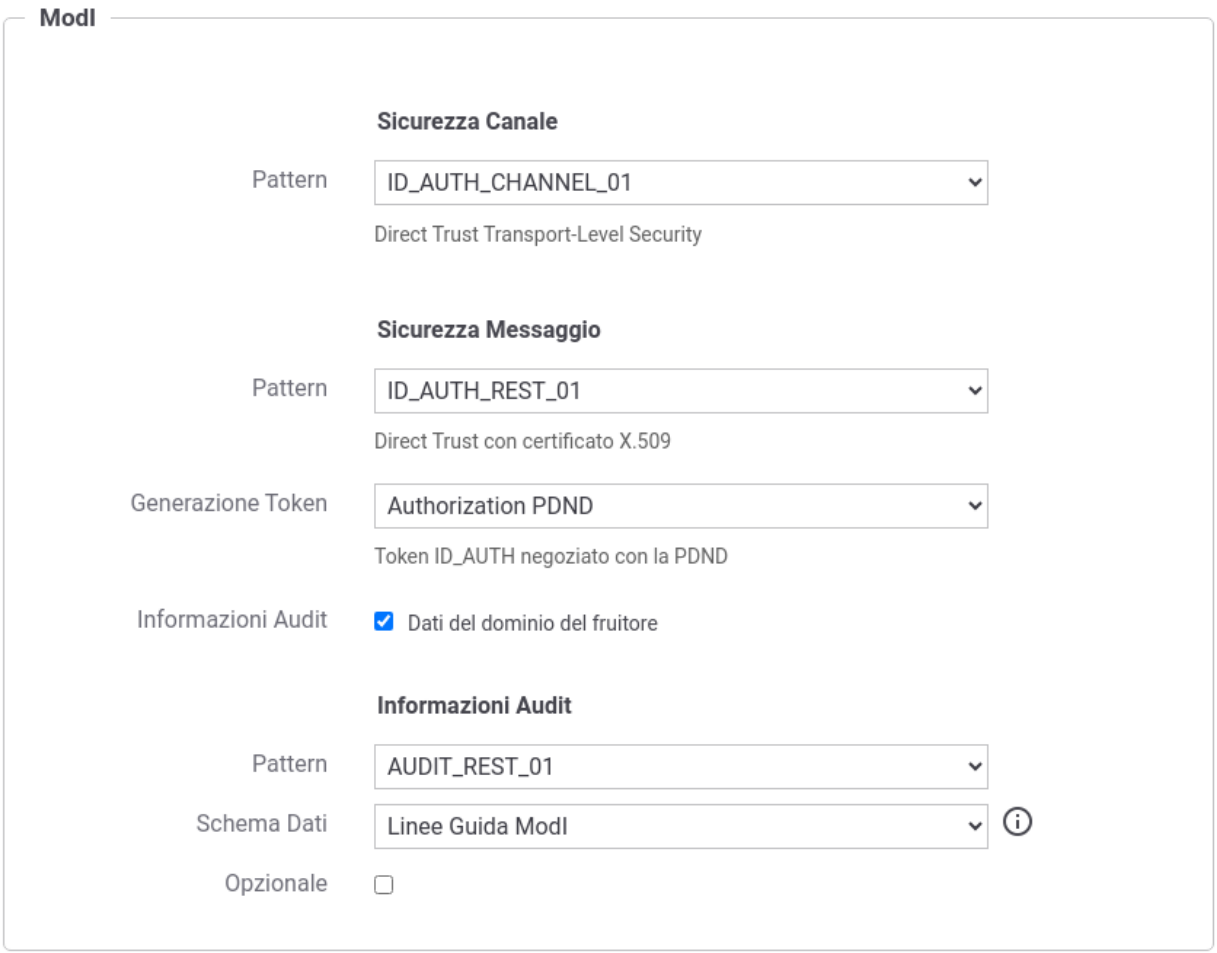


Figure3.218: Configurazione Pattern ModI «AUDIT_REST_01» sulla API REST

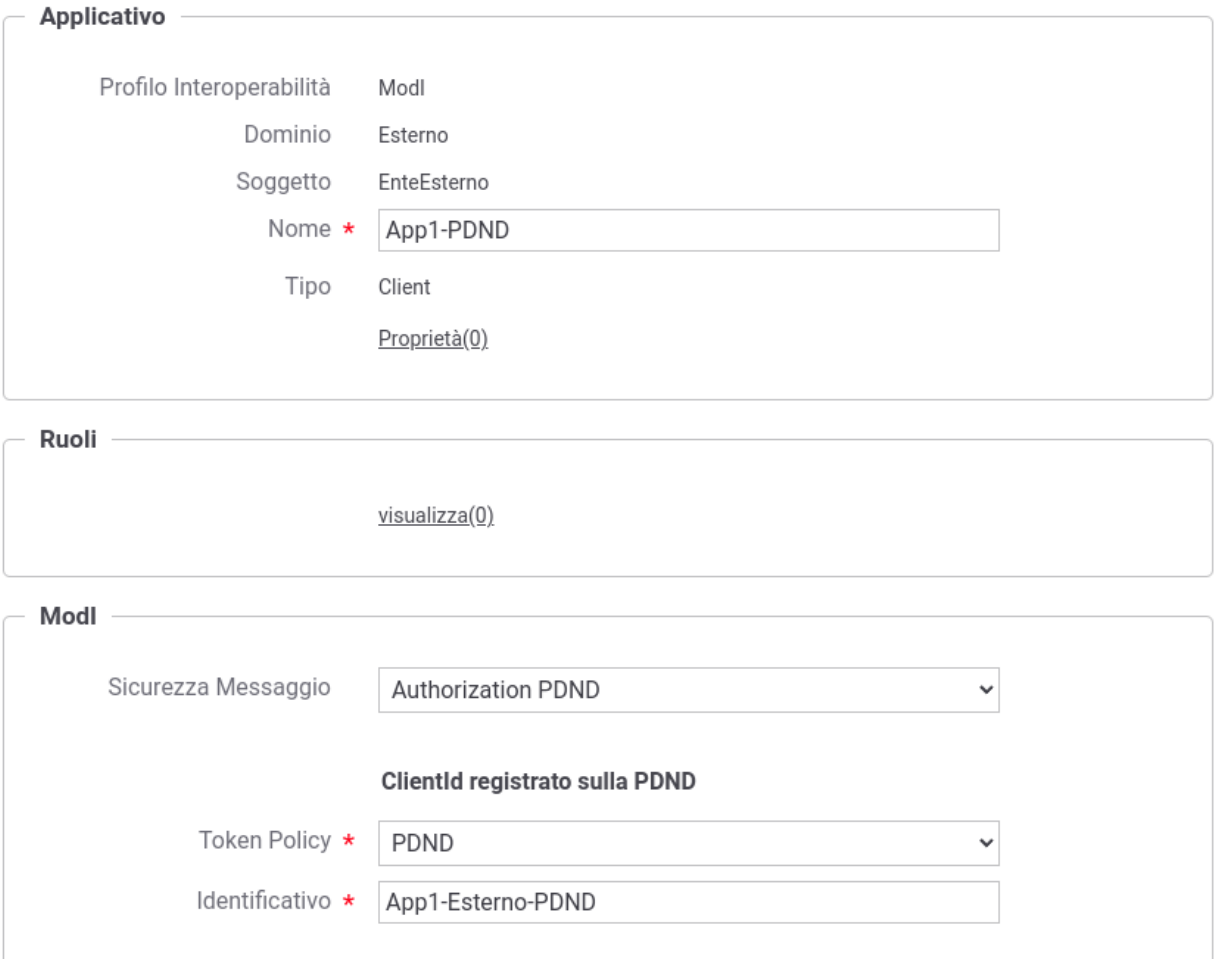


Figure3.219: Configurazione applicativo esterno (fruitore)

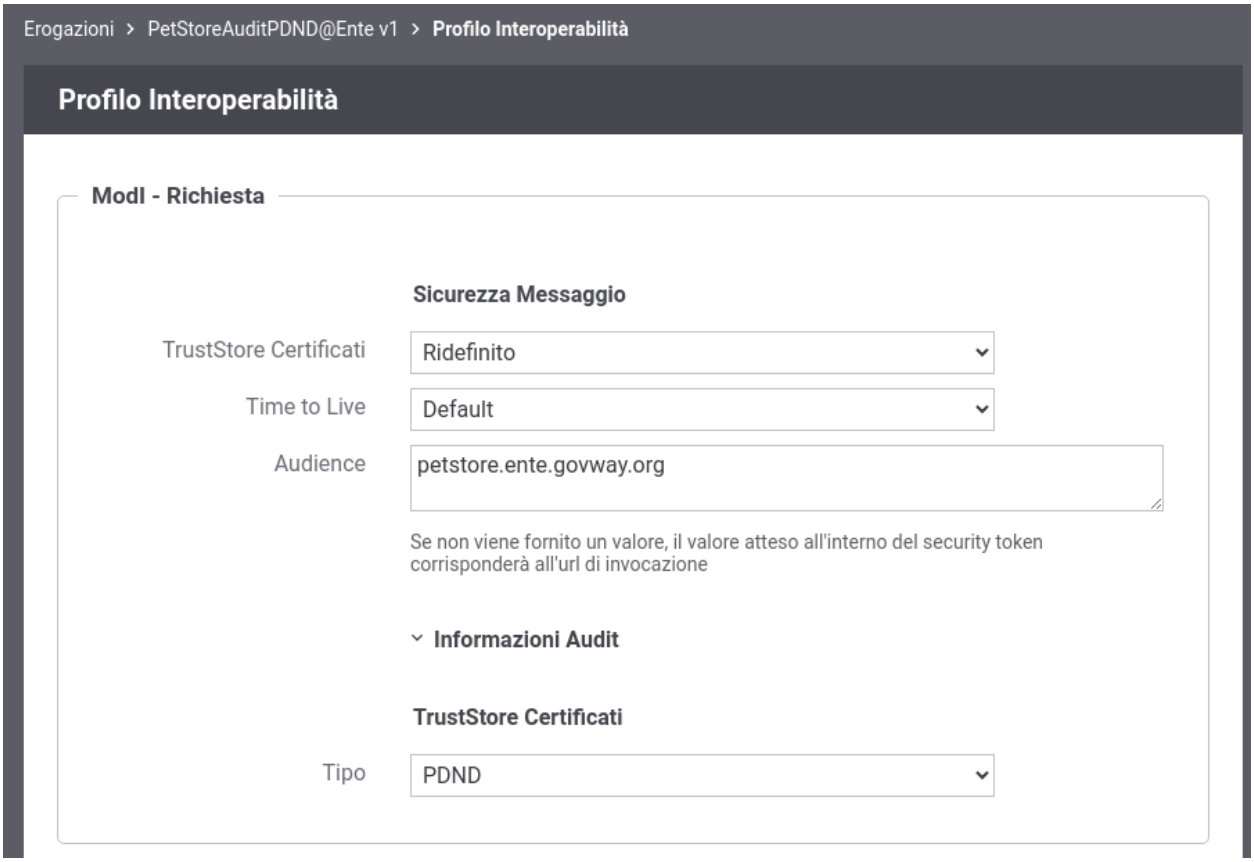


Figure3.220: Configurazione richiesta dell'erogazione

3.6.2 Fruizione API REST

Obiettivo

Fruire di un servizio REST, definito tramite una API REST (OpenAPI 3.0), che richiede per l'accesso oltre ai token di sicurezza descritti nei precedenti scenari anche un token aggiuntivo adibito a contenere informazioni utili all'erogatore a identificare la specifica provenienza di ogni singola richiesta di accesso ai dati effettuta dal fruitore. Il token di audit deve rispettare il pattern di sicurezza descritto nella sezione modipa_infoUtente_audit01.

Sintesi

Mostriamo in questa sezione come procedere per l'integrazione di un applicativo con un servizio REST erogato nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui il servizio è stato registrato sulla PDND, e il fruitore per poterlo fruire deve ottenere un voucher dalla PDND che successivamente deve inviare all'erogatore insieme alla normale richiesta di servizio. Oltre al voucher il fruitore devo anche presentare il token di audit «Agid-JWT-TrackingEvidence» previsto dal pattern «AUDIT_REST_01».

La figura seguente descrive graficamente questo scenario.

Le caratteristiche principali di questo scenario sono:

1. un applicativo fruitore che dialoga con il servizio erogato in modalità ModI in accordo ad una API condivisa e pubblicata su PDND;
2. la comunicazione diretta verso il dominio erogatore veicolata su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;
3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND»;
4. le informazioni di audit, richieste dall'erogatore per identificare la specifica provenienza di ogni singola richiesta di accesso ai dati effettuta dal fruitore, vengono inserite in un token di audit conforme al pattern «AUDIT_REST_01». Le informazioni vengono fornite dall'applicativo fruitore tramite header HTTP.

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.222: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «AUDIT_REST_01».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - Audit+PDND - OUT App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto nelle diverse fasi dell'esecuzione andando a consultare la console "govwayMonitor".

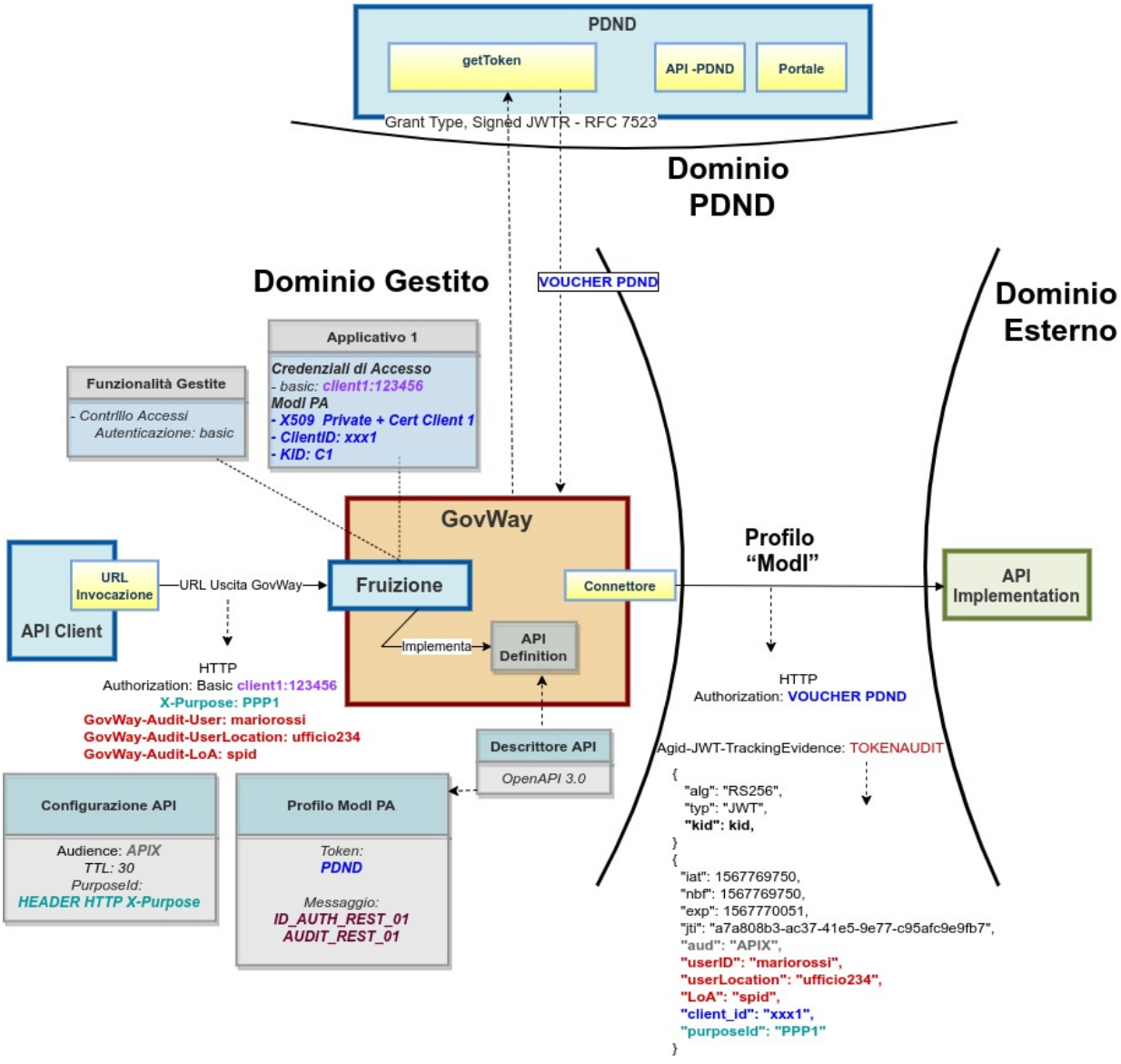


Figure3.221: Fruizione di una API REST con profilo "ModI", pattern AUDIT_REST_01 e pattern ID_AUTH_REST_01 via PDND

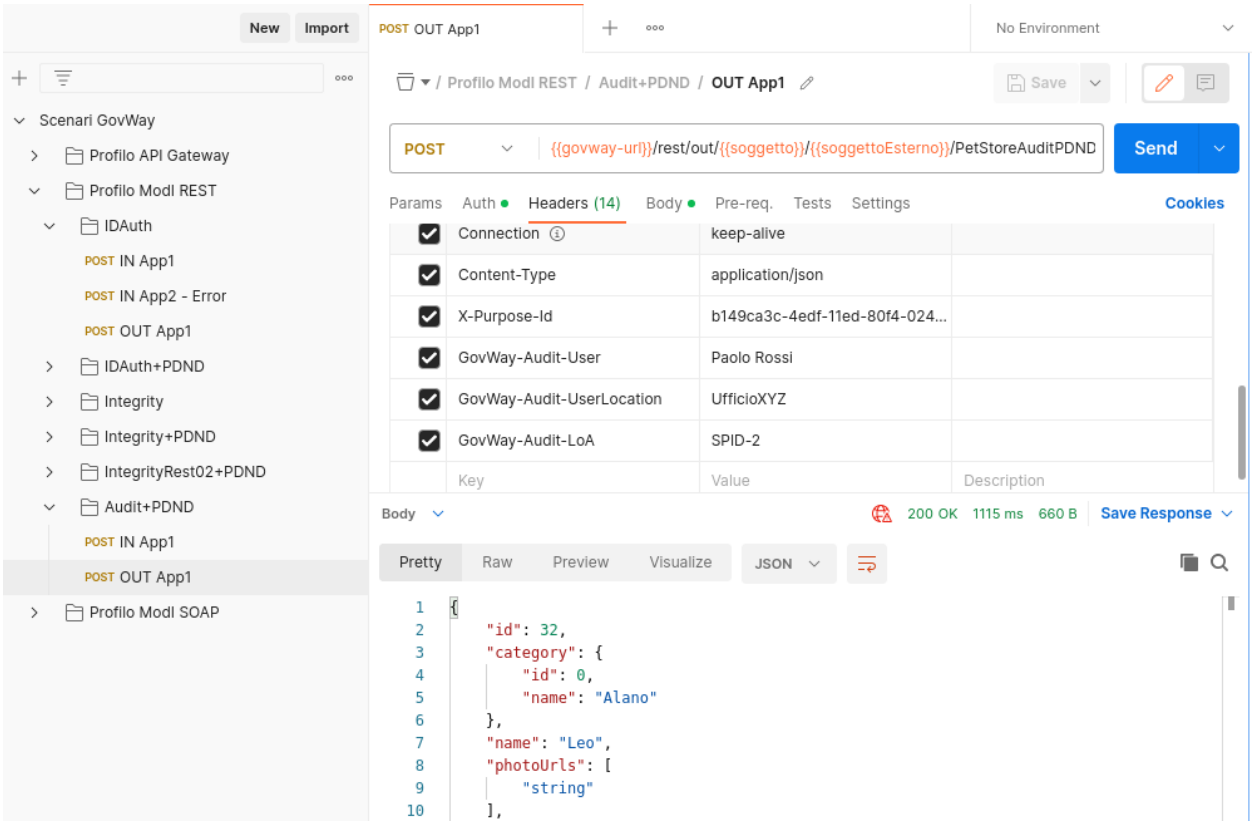
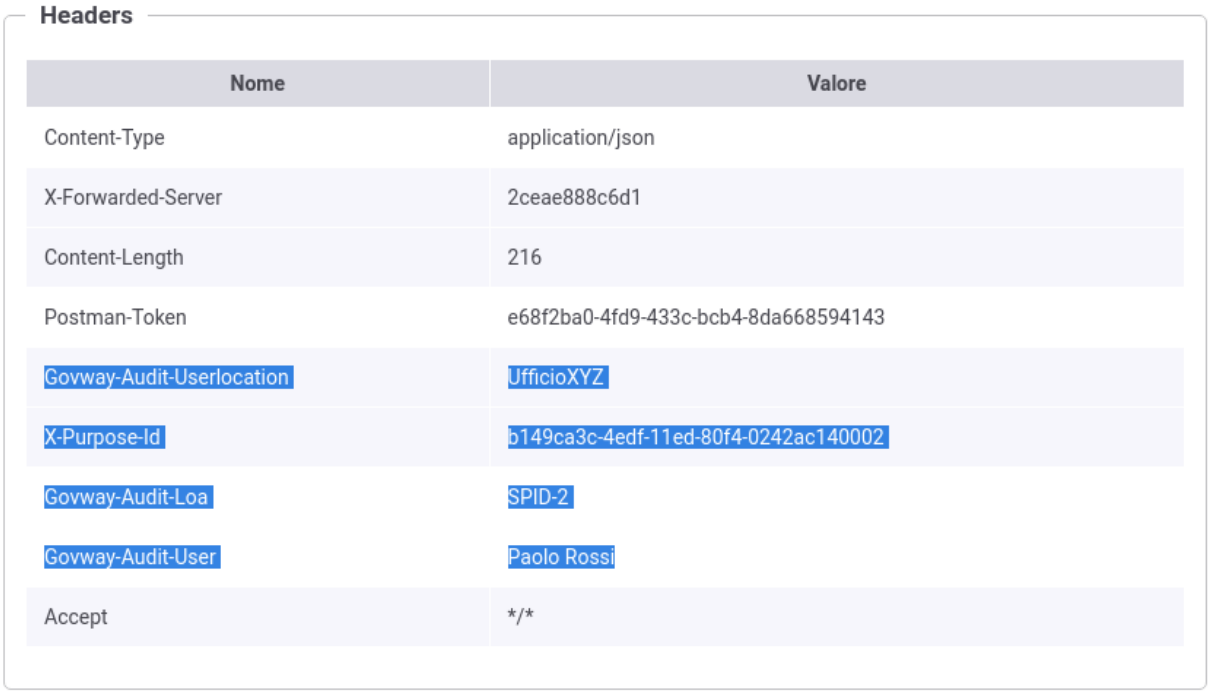


Figure3.223: Pattern Audit+PDND - Fruizione API REST, esecuzione da Postman

Le verifiche da effettuare sono le medesime di quelle descritte nello scenario *Esecuzione*. Di seguito vengono riportati solo i punti salienti in cui emerge una differenza dovuta al pattern di audit utilizzato.

- Il messaggio di richiesta inviato dal fruitore contiene tra gli header HTTP le informazioni da inserire nel token di audit (Fig. 3.224) e il purpose-id da inserire nella richiesta del voucher alla PDND.



Headers

Nome	Valore
Content-Type	application/json
X-Forwarded-Server	2ceae888c6d1
Content-Length	216
Postman-Token	e68f2ba0-4fd9-433c-bcb4-8da668594143
Govway-Audit-Userlocation	UfficioXYZ
X-Purpose-Id	b149ca3c-4edf-11ed-80f4-0242ac140002
Govway-Audit-Loa	SPID-2
Govway-Audit-User	Paolo Rossi
Accept	*/*

Figure3.224: Messaggio di richiesta in ingresso (con informazioni sull'utente fruitore inserite negli header HTTP)

- Il messaggio di richiesta inviato dal fruitore viene elaborato da Govway che, tramite la configurazione della firma digitale associata all'applicativo mittente, è in grado di produrre un token di sicurezza da inviare alla PDND con il quale ottenere indietro un voucher spendibile per il servizio desiderato. Questa parte è stata ampiamente mostrata nella scenario *Esecuzione*.

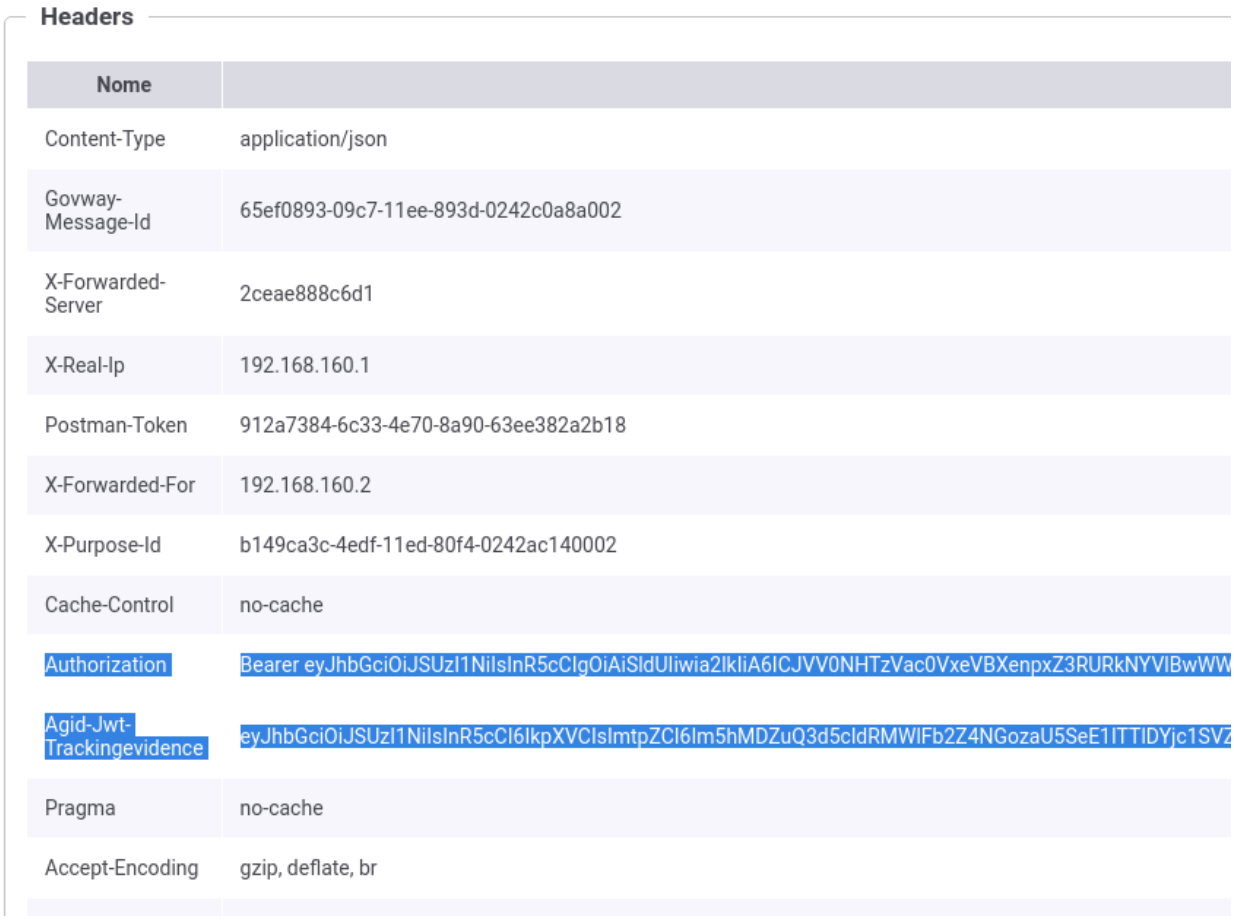
  Oltre al token della PDND, GovWay produce un ulteriore token «Agid-JWT-TrackingEvidence» previsto dal pattern «AUDIT_REST_01». Da govwayMonitor si può visualizzare il messaggio di richiesta in uscita che è il medesimo di quello in entrata con la differenza che sono stati aggiunti gli header HTTP «Authorization» e «Agid-Jwt-TrackingEvidence» che contengono rispettivamente il token ottenuto dalla PDND e il token di audit. (Fig. 3.225).

- L'header e i payload del token «Agid-JWT-TrackingEvidence» sono identici a quelli già visualizzati nello scenario di erogazione REST, relativamente al messaggio in ingresso (Fig. 3.210 e Fig. 3.212). Le informazioni inserite nel token vengono anche tracciate e sono visibili sulla govwayMonitor, andando a consultare la traccia del messaggio di richiesta (Fig. 3.226). Nella sezione «Sicurezza Messaggio» sono riportate le informazioni estratte dai token di audit.

Conformità ai requisiti ModI

I requisiti iniziali, legati alla comunicazione basata su uno scenario ModI, sono verificati dalle seguenti evidenze:

1. viene effettuata una negoziazione del voucher PDND come mostrato nelle tracce relative ai token scambiati con la PDND;
2. l'invocazione del servizio avviene fornendo il voucher della PDND precedentemente negoziato;



Headers

Nome	
Content-Type	application/json
Govway-Message-Id	65ef0893-09c7-11ee-893d-0242c0a8a002
X-Forwarded-Server	2ceae888c6d1
X-Real-Ip	192.168.160.1
Postman-Token	912a7384-6c33-4e70-8a90-63ee382a2b18
X-Forwarded-For	192.168.160.2
X-Purpose-Id	b149ca3c-4edf-11ed-80f4-0242ac140002
Cache-Control	no-cache
Authorization	Bearer eyJhbGciOiJSUzI1NiIsInR5cCIgOiAiSldUIiwia2lkIiA6ICJVV0NHTzVac0VxeVBXenpxZ3RURkNYVlBwWW
Agid-Jwt-Trackingevidence	eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6Im5hMDZuQ3d5cldRMWlFb2Z4NGozaU5SeE1ITTlDYjc1SVz
Pragma	no-cache
Accept-Encoding	gzip, deflate, br

Figure3.225: Messaggio di richiesta in uscita (con token di sicurezza inseriti nell'header HTTP)

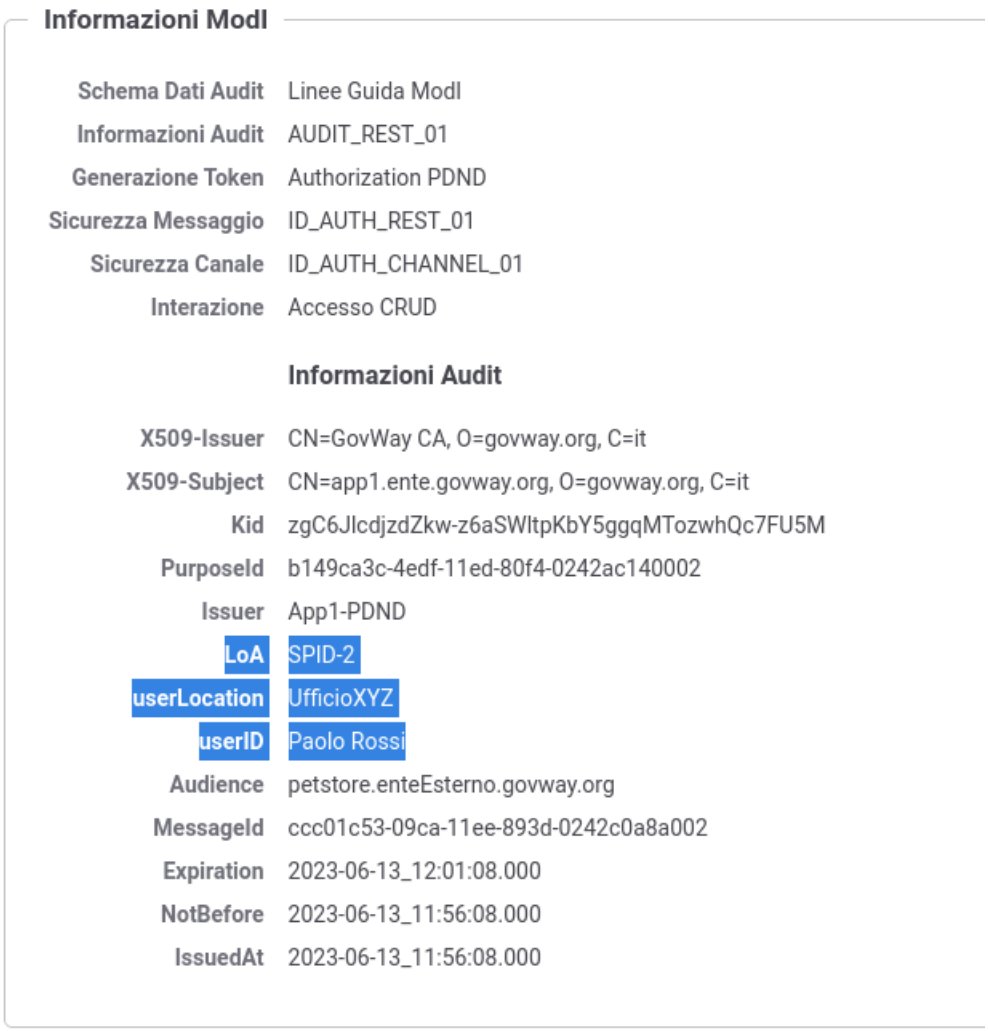


Figure3.226: Traccia della richiesta generata dal fruitore

3. viene inoltre prodotto l'header http «Agid-Jwt-TrackingEvidence» previsto dal pattern di audit «AUDIT_REST_01».

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità «ModI». Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.227: Profilo ModI della govwayConsole

La configurazione dello scenario è del tutto analogo a quello descritto nello scenario *Configurazione* con la sola eccezione del pattern di audit aggiuntivo utilizzato in questo scenario: «AUDIT_REST_01».

Registrazione API

Viene registrata l'API «PetStoreAuditPDND» con il relativo descrittore OpenAPI 3. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «ID_AUTH_REST_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND». Viene infine abilitata l'opzione "Informazioni Audit" e selezionato il pattern «AUDIT_REST_01» e lo schema dei dati «Linee Guida ModI» (Fig. 3.228). Per ulteriori dettagli sullo schema dei dati di un token di audit si rimanda alle sezioni modipa_infoUtente_audit01_schema e modipa_infoUtente_audit01_schema_custom.

Fruizione

Nella fruizione «PetStoreAuditPDND», relativa all'API precedentemente inserita, vanno indicati i dati specifici nella sezione «ModI Richiesta» (Fig. 3.229) necessari a generare il token "Agid-JWT-TrackingEvidence". In particolare è possibile specificare l'audience atteso dall'erogatore e il tempo di validità del token.

3.6.3 Erogazione API SOAP

Obiettivo

Esporre un servizio SOAP, definito tramite una interfaccia WSDL, che richieda per l'accesso oltre ai token di sicurezza descritti nei precedenti scenari anche un token aggiuntivo adibito a contenere informazioni utili all'erogatore a identificare la specifica provenienza di ogni singola richiesta di accesso ai dati effettuta dal fruitore. Il token di audit deve rispettare il pattern di sicurezza descritto nella sezione modipa_infoUtente_audit01.

Nota

Il token descritto nel pattern modipa_infoUtente_audit01 va in aggiunta rispetto agli altri token di sicurezza e quindi può essere utilizzato in combinazione con qualsiasi dei token descritti nei precedenti scenari, anche senza la PDND. In questo scenario verrà utilizzato insieme al token "Authorization" ottenuto tramite la PDND, descritto negli scenari *Pattern "ID_AUTH" via PDND*.

Sintesi

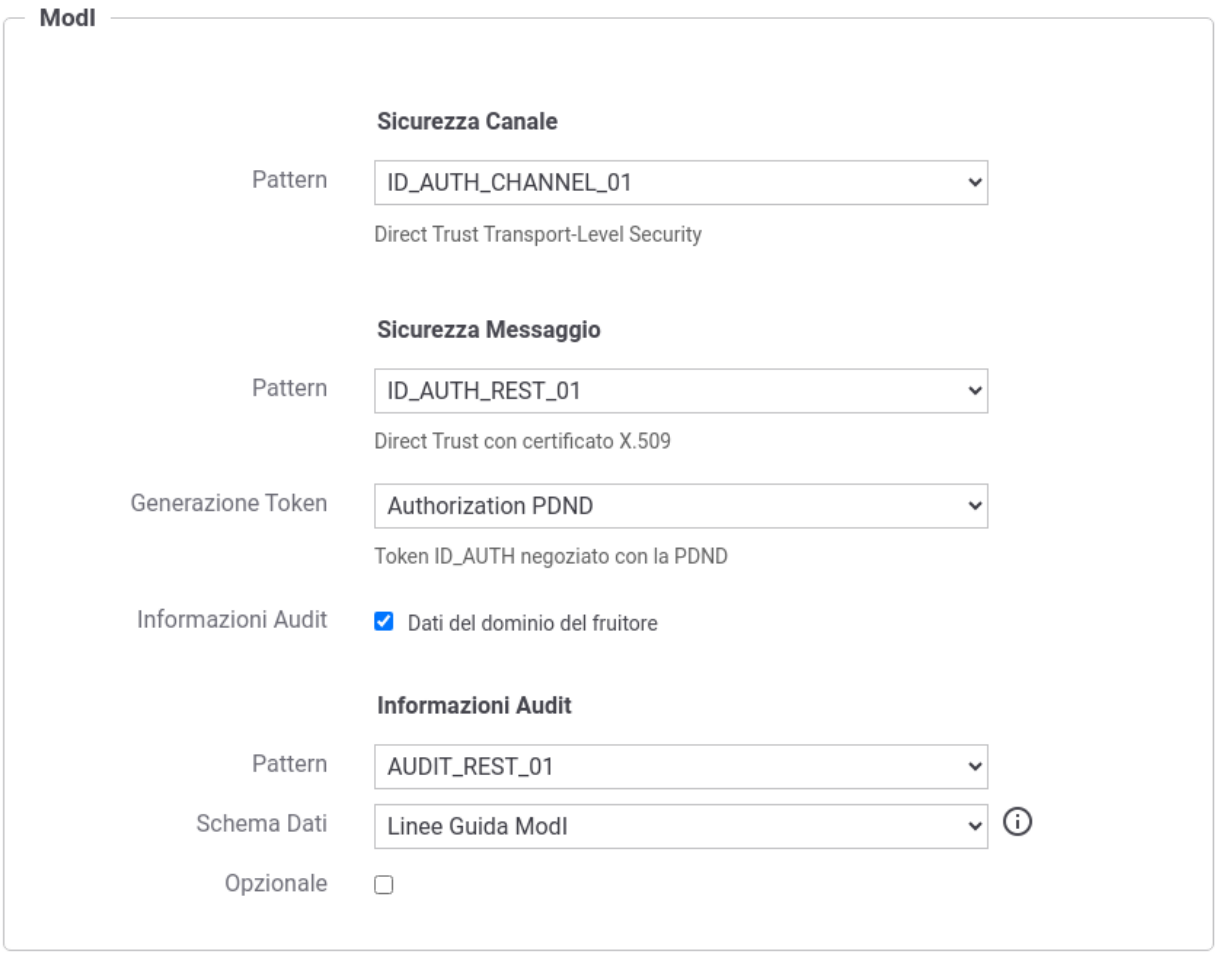


Figure3.228: Configurazione Pattern ModI «AUDIT_REST_01» sulla API REST

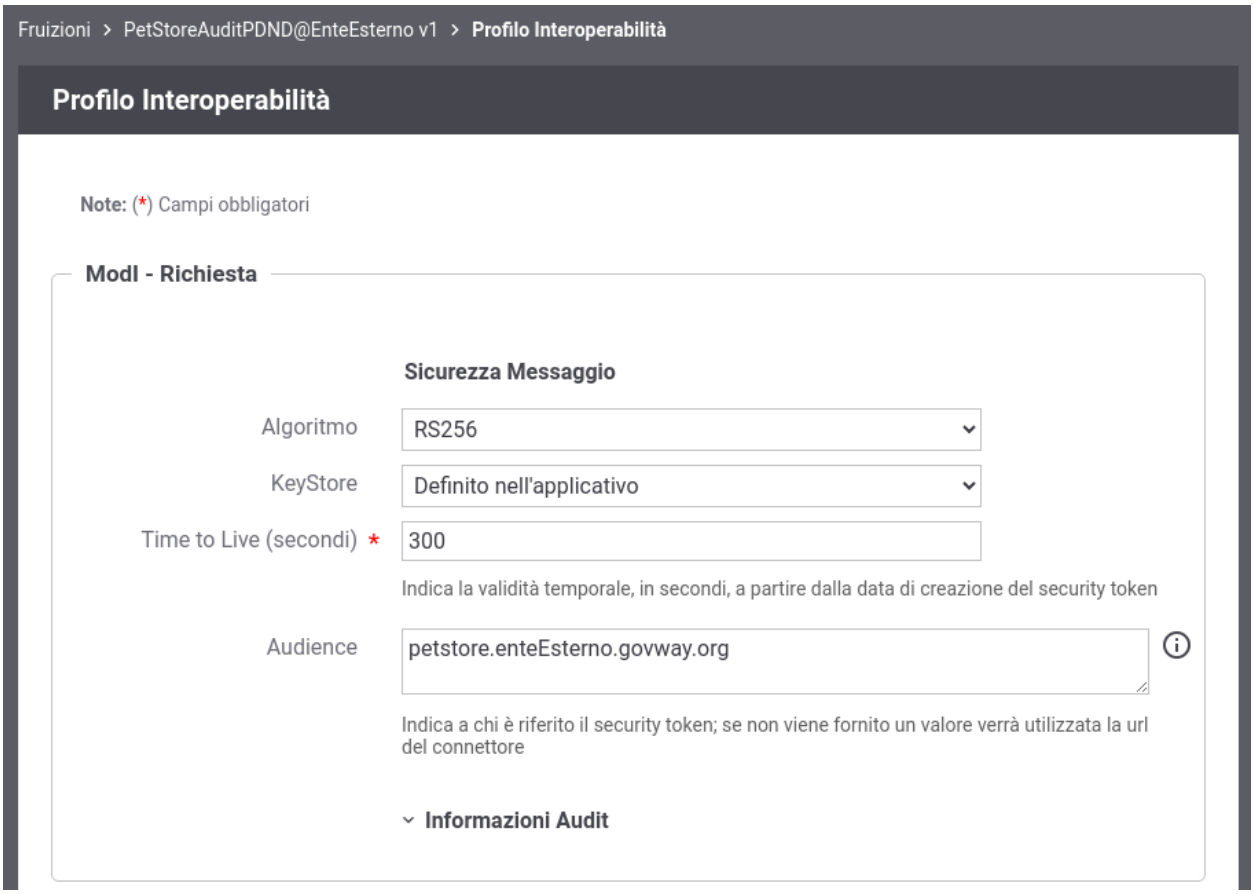


Figure3.229: Configurazione richiesta della fruizione

Mostriamo in questa sezione come procedere per l'esposizione di un servizio SOAP da erogare nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui un servizio è stato registrato sulla PDND, e i fruitori per poterlo fruire devono ottenere un voucher dalla PDND che successivamente devono inviare all'erogatore insieme alla normale richiesta di servizio. Oltre al voucher devono anche presentare il token di audit «Agid-JWT-TrackingEvidence» previsto dal pattern «AUDIT_REST_01».

La figura seguente descrive graficamente questo scenario.

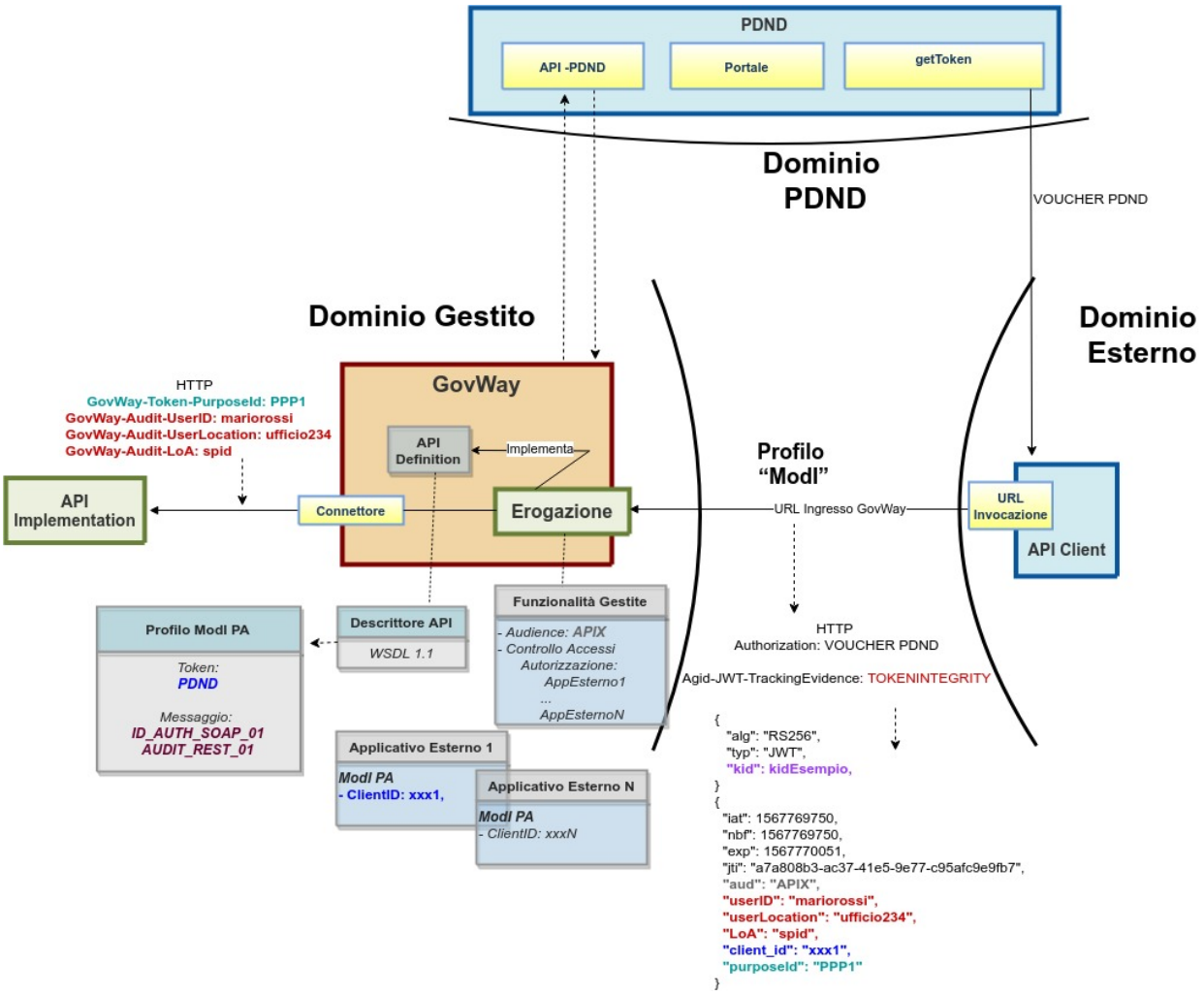


Figure3.230: Erogazione di una API SOAP con profilo "ModI", pattern AUDIT_REST_01 e pattern ID_AUTH_REST_01 via PDND

Le caratteristiche principali di questo scenario sono:

1. un applicativo eroga un servizio, rivolto a fruitori di domini esterni, in conformità al Modello di Interoperabilità AGID;
2. la comunicazione con i domini esterni avviene su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_02»;
3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND»;
4. per la fruizione viene richiesto un token aggiuntivo, conforme al pattern «AUDIT_REST_01», adibito a contenere

informazioni utili all'erogatore a identificare la specifica provenienza di ogni singola richiesta di accesso ai dati effettuta dal fruitore;

5. la validazione del token di audit viene effettuata scaricando la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd;
6. vengono inoltre recuperate e associate alla traccia maggiori informazioni sull'organizzazione afferente al "client-id" presente nel token, sempre attraverso le modipa_passiPreliminari_api_pdnd.

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.231: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione* con la sola eccezione del pattern di audit aggiuntivo utilizzato in questo scenario: «AUDIT_REST_01».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI SOAP - Audit+PDND - IN App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console govwayMonitor.

Le evidenze del processo di validazione relative al token PDND sono le medesime descritte nella scenario *Esecuzione*.

Le evindenze del processo di validazione del token di audit «Agid-Jwt-TrackingEvidence» sono le stesse descritte nello scenario *Esecuzione*.

Conformità ai requisiti ModI

La verifica dei requisiti ModI per questo scenario non differisce da quanto già descritto in *Esecuzione*.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.233: Profilo ModI della govwayConsole

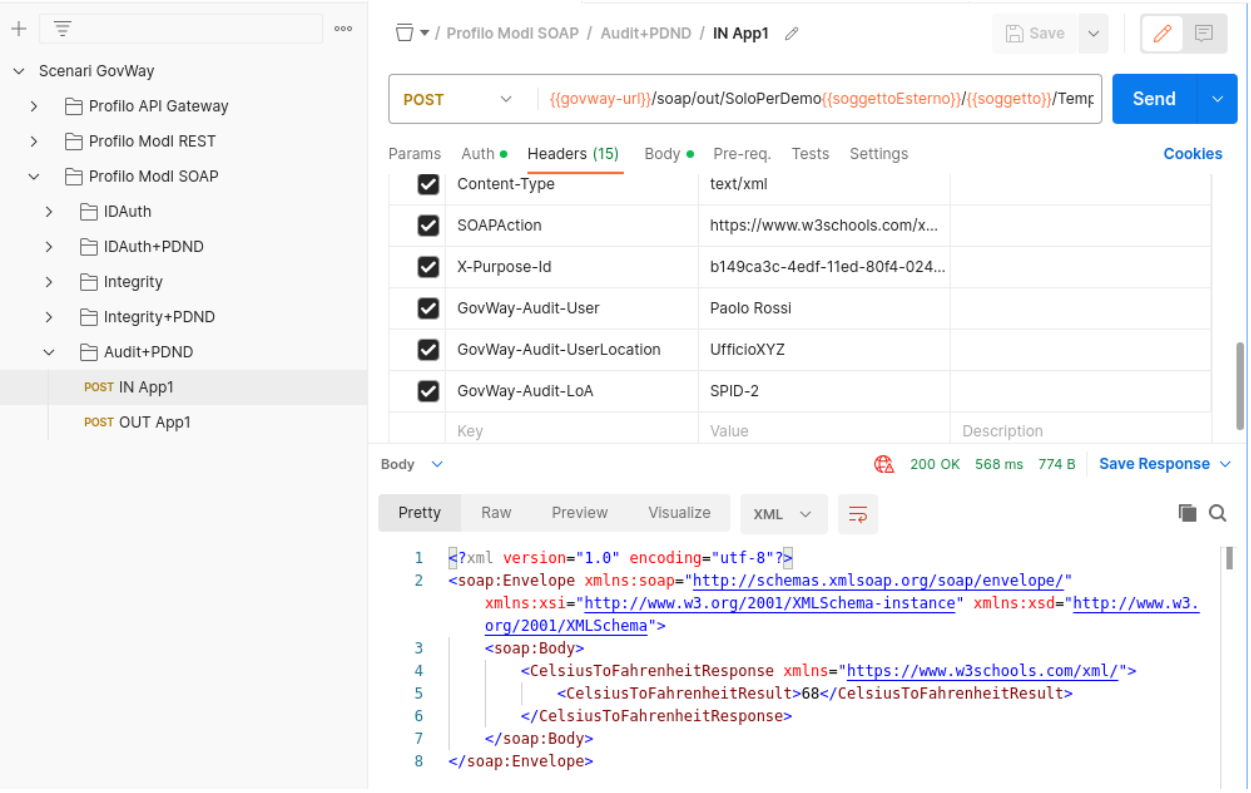


Figure3.232: Pattern Audit+PDND - Erogazione API SOAP, esecuzione da Postman

Il processo di configurazione per questo scenario è del tutto analogo a quello descritto per lo scenario *Configurazione*. Nel seguito sono evidenziate le sole differenze.

L'interfaccia wsdl del servizio soap è ottenibile all'indirizzo "https://www.w3schools.com/xml/tempconvert.asmx?wsdl".

Registrazione API

Viene registrata l'API «TemperatureConversionAuditPDND» con il relativo descrittore WSDL. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «ID_AUTH_SOAP_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND». Viene infine abilitata l'opzione "Informazioni Audit" e selezionato il pattern «AUDIT_REST_01» e lo schema dei dati «Linee Guida ModI» (Fig. 3.234). Per ulteriori dettagli sullo schema dei dati di un token di audit si rimanda alle sezioni modipa_infoUtente_audit01_schema e modipa_infoUtente_audit01_schema_custom.

Erogazione

Si registra l'erogazione SOAP "TempConvertSoapAuditPDND", relativa all'API precedentemente inserita, indicando i dati specifici nella sezione «ModI Richiesta» (Fig. 3.235) necessari per validare le richieste in ingresso relativamente al token "Agid-JWT-TrackingEvidence". Si noti come è stato selezionato un truststore basato sulla PDND al fine di scaricare la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd.

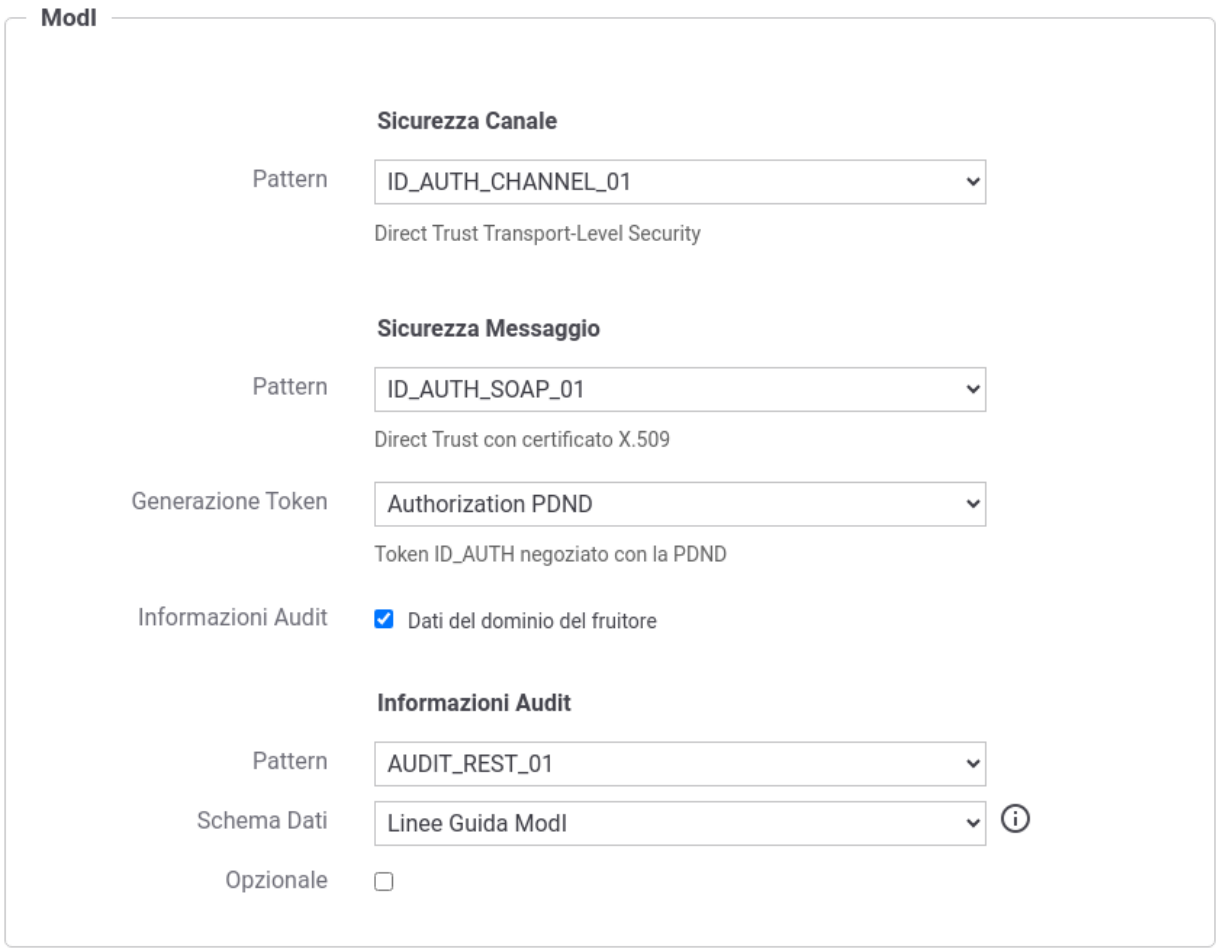


Figure3.234: Configurazione Pattern ModI «AUDIT_REST_01» sulla API SOAP

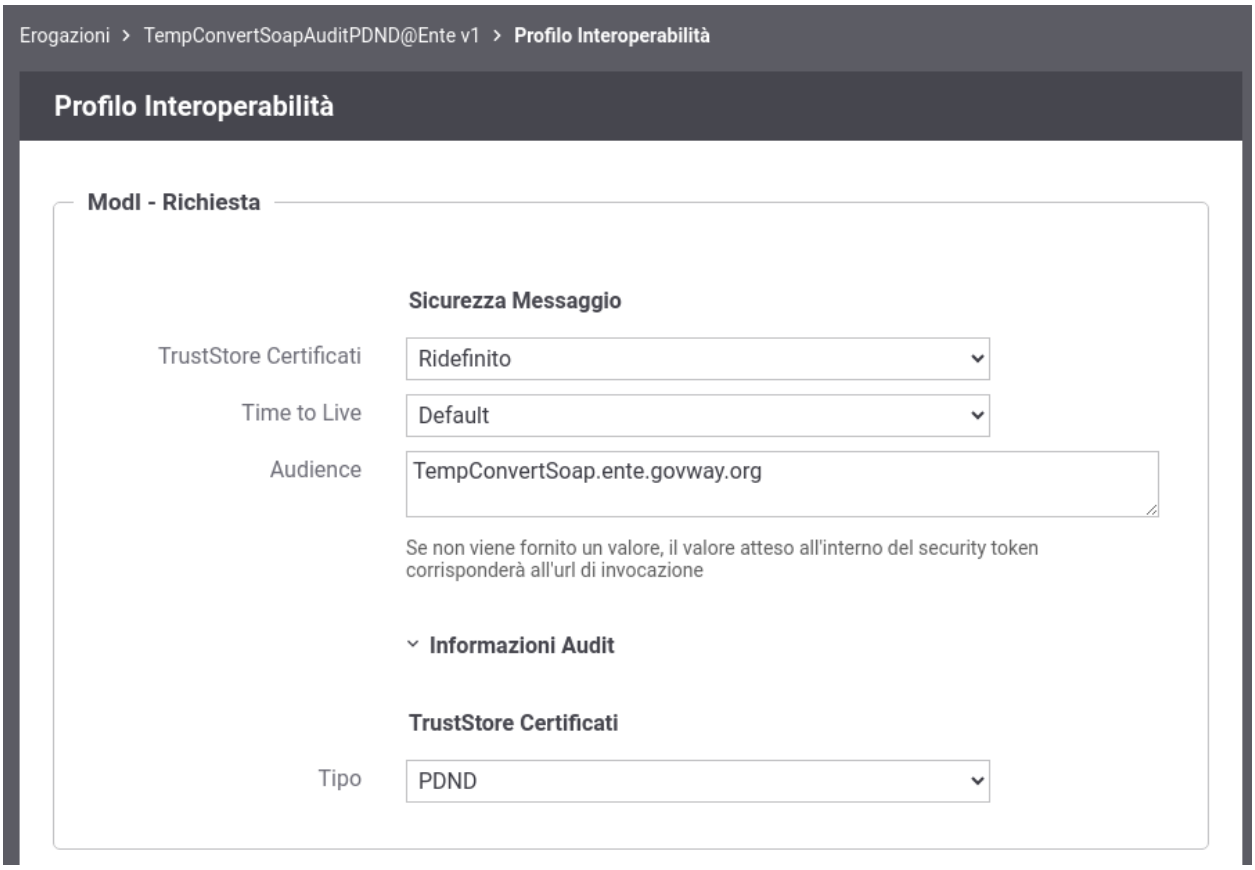


Figure3.235: Configurazione richiesta dell'erogazione

3.6.4 Fruizione API SOAP

Obiettivo

Fruire di un servizio SOAP, definito tramite una interfaccia WSDL, che richiede per l'accesso oltre ai token di sicurezza descritti nei precedenti scenari anche un token aggiuntivo adibito a contenere informazioni utili all'erogatore a identificare la specifica provenienza di ogni singola richiesta di accesso ai dati effettuta dal fruitore. Il token di audit deve rispettare il pattern di sicurezza descritto nella sezione modipa_infoUtente_audit01.

Sintesi

Mostriamo in questa sezione come procedere per l'integrazione di un applicativo con un servizio SOAP erogato nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui il servizio è stato registrato sulla PDND, e il fruitore per poterlo fruire deve ottenere un voucher dalla PDND che successivamente deve inviare all'erogatore insieme alla normale richiesta di servizio. Oltre al voucher il fruitore devo anche presentare il token di audit «Agid-JWT-TrackingEvidence» previsto dal pattern «AUDIT_REST_01».

La figura seguente descrive graficamente questo scenario.

Le caratteristiche principali di questo scenario sono:

1. un applicativo fruitore che dialoga con il servizio erogato in modalità ModI in accordo ad una API condivisa e pubblicata su PDND;
2. la comunicazione diretta verso il dominio erogatore veicolata su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;
3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_SOAP_01 via PDND»;
4. le informazioni di audit, richieste dall'erogatore per identificare la specifica provenienza di ogni singola richiesta di accesso ai dati effettuta dal fruitore, vengono inserite in un token di audit conforme al pattern «AUDIT_REST_01». Le informazioni vengono fornite dall'applicativo fruitore tramite header HTTP.

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.237: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione* con la sola eccezione del pattern di audit aggiuntivo utilizzato in questo scenario: «AUDIT_REST_01».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI SOAP - Audit+PDND - OUT App1» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto, nel corso dell'elaborazione della richiesta, andando a consultare la console "govwayMonitor".

Le evidenze del processo di validazione relative al token PDND sono le medesime descritte nella scenario *Esecuzione*.

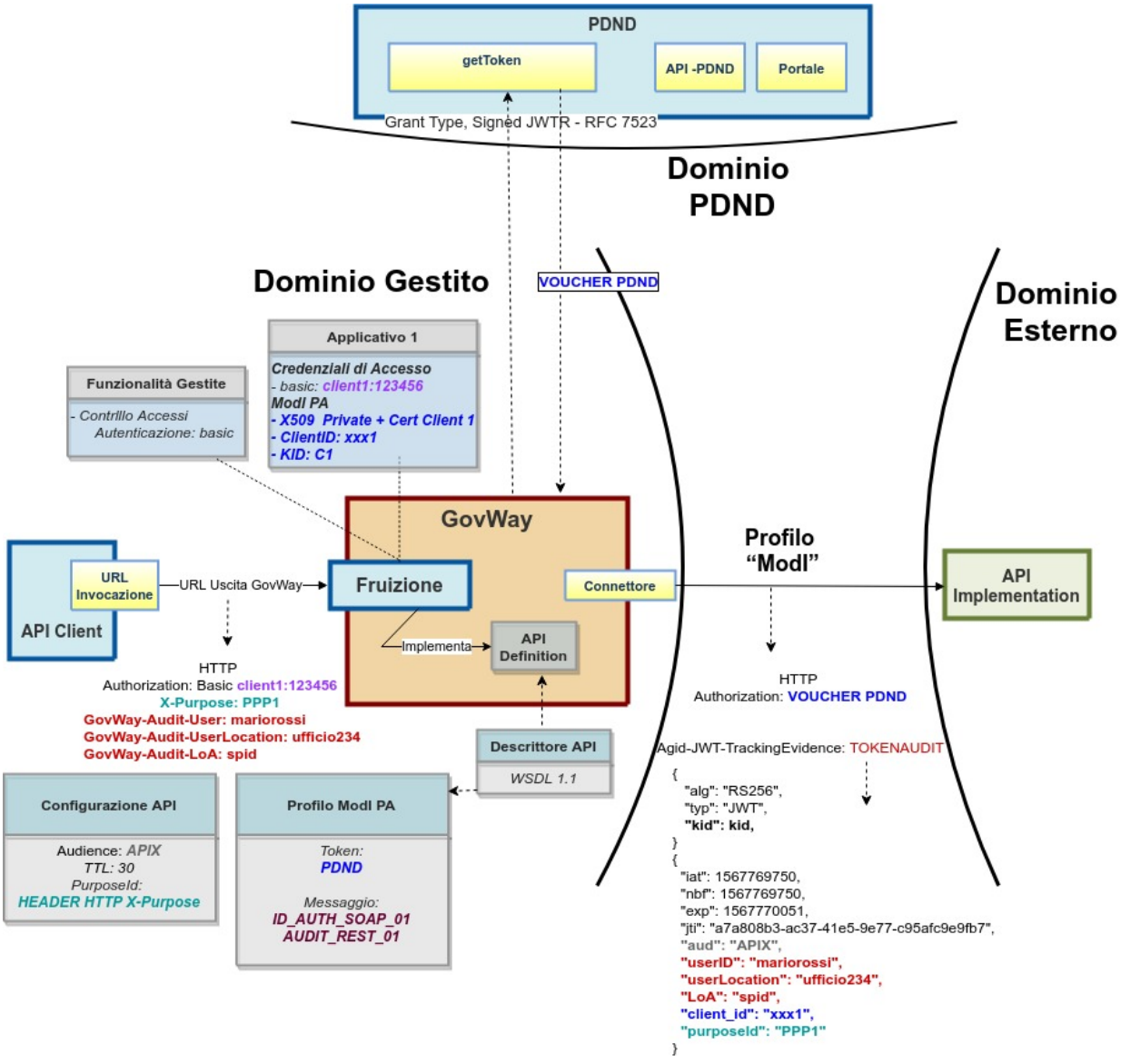


Figure3.236: Fruizione di una API SOAP con profilo "ModI", pattern AUDIT_REST_01 e pattern ID_AUTH_SOAP_01 via PDND

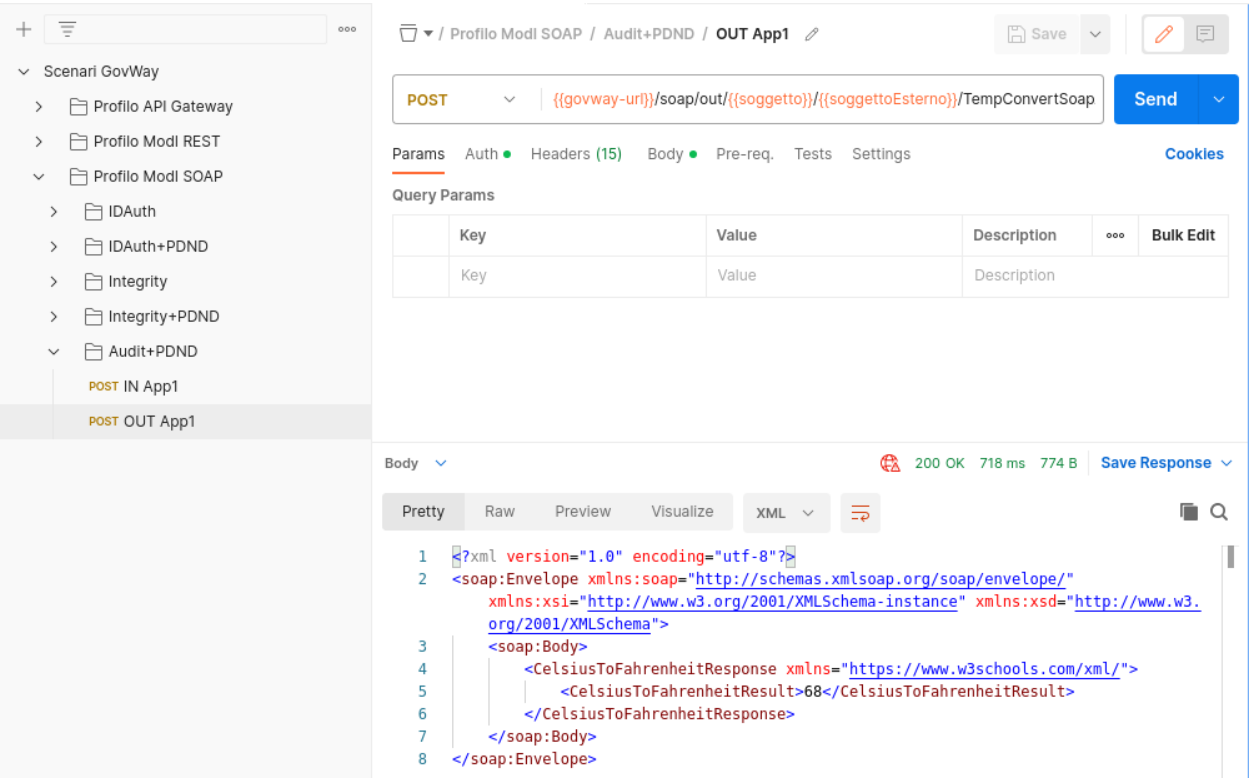


Figure3.238: Pattern Audit+PDND - Fruizione API SOAP, esecuzione da Postman

Le evindenze del processo di validazione del token di audit «Agid-Jwt-TrackingEvidence» sono le stesse descritte nello scenario *Esecuzione*.

Conformità ai requisiti ModI

La verifica dei requisiti ModI per questo scenario non differisce da quanto già descritto in *Esecuzione*.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità «ModI». Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.239: Profilo ModI della govwayConsole

La configurazione dello scenario è del tutto analogo a quello descritto nello scenario *Configurazione* con le sole differenze dovuto al differente pattern di sicurezza utilizzato «INTEGRITY_SOAP_01 con ID_AUTH_SOAP_01».

Registrazione API

Viene registrata l'API «TemperatureConversionAuditPDND» con il relativo descrittore WSDL. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «ID_AUTH_SOAP_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND». Viene infine abilitata l'opzione "Informazioni Audit" e selezionato il pattern «AUDIT_REST_01» e lo schema dei dati «Linee Guida ModI» (Fig. 3.240). Per ulteriori dettagli sullo schema dei dati di un token di audit si rimanda alle sezioni modipa_infoUtente_audit01_schema e modipa_infoUtente_audit01_schema_custom.

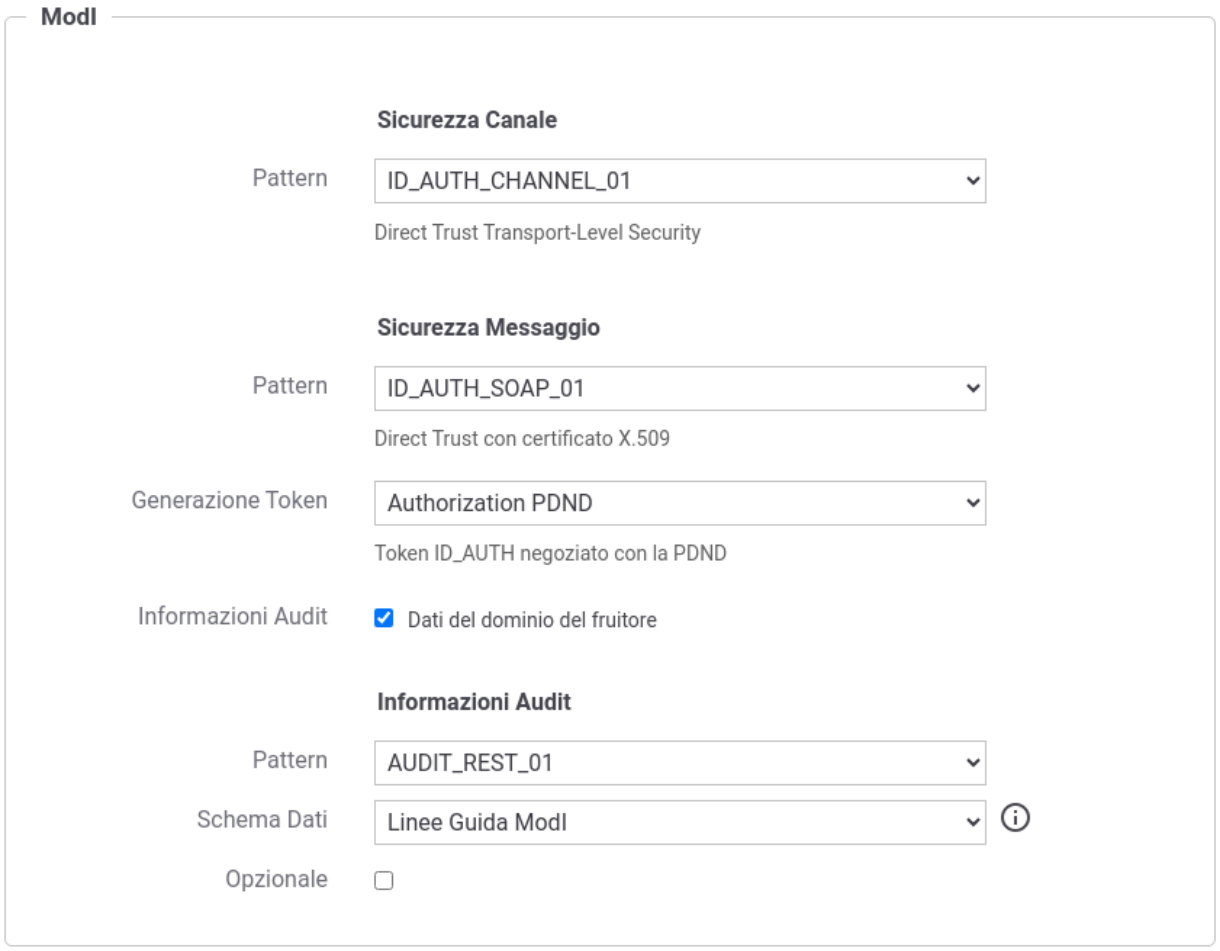


Figure3.240: Configurazione Pattern ModI «AUDIT_REST_01» sulla API SOAP

Fruizione

Si registra la fruizione SOAP "TempConvertSoapAuditPDND", relativa all'API precedentemente inserita, indicando i dati specifici nella sezione «ModI Richiesta» (Fig. 3.241) necessari a generare il token "Agid-JWT-TrackingEvidence". In particolare è possibile specificare l'audience atteso dall'erogatore e il tempo di validità del token.

3.7 Pattern "AUDIT_REST_02"

Gli scenari riportati in questa sezione riguardano API configurate con pattern modipa_infoUtente_audit02.

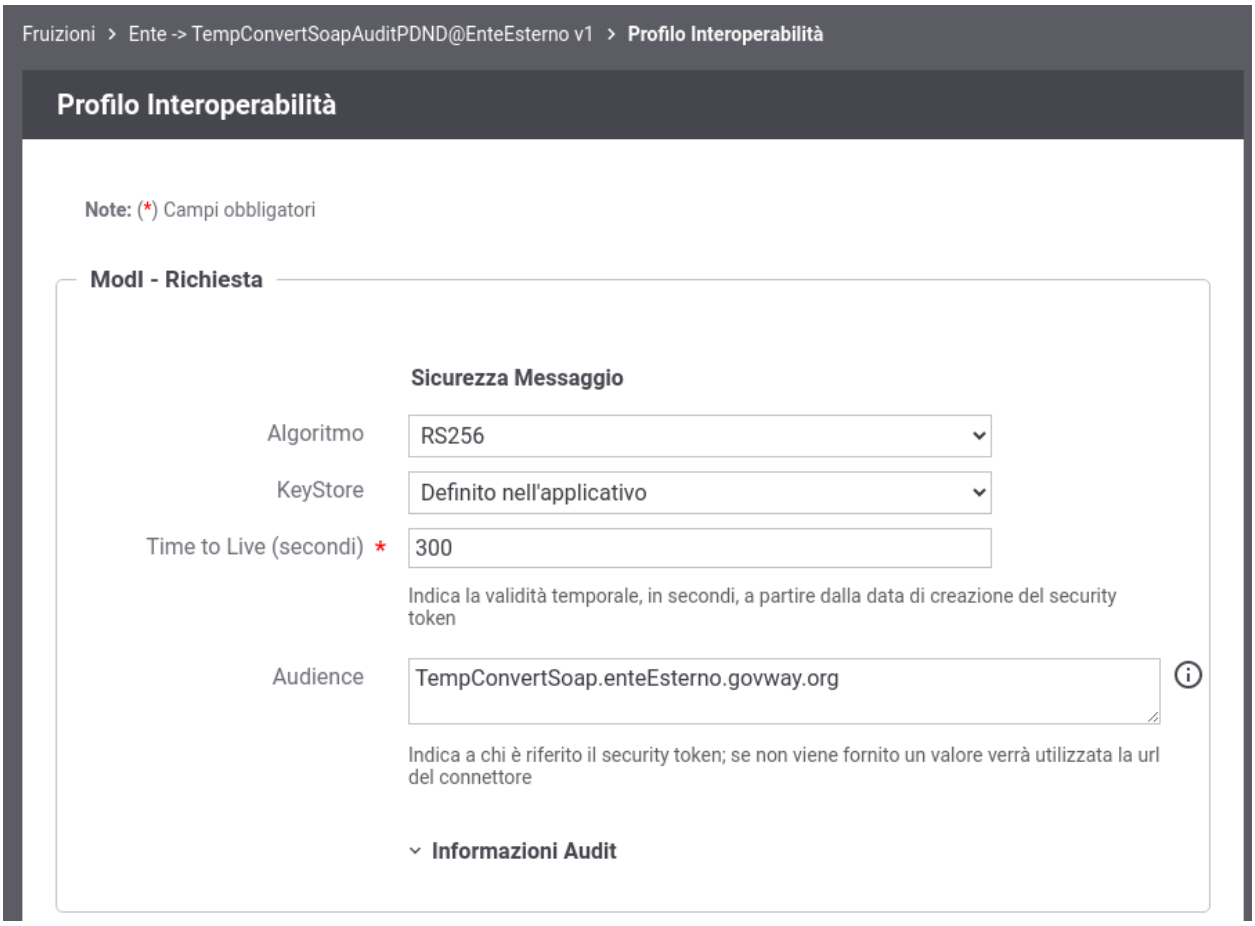


Figure3.241: Configurazione richiesta della fruizione

3.7.1 Erogazione API REST

Obiettivo

Esporre un servizio, definito tramite una API REST (OpenAPI 3.0), che richieda per l'accesso oltre ai token di sicurezza descritti nei precedenti scenari anche un token aggiuntivo adibito a contenere informazioni utili all'erogatore a identificare la specifica provenienza di ogni singola richiesta di accesso ai dati effettuta dal fruitore. Il token di audit deve rispettare il pattern di sicurezza descritto nella sezione modipa_infoUtente_audit02.

Nota

Il token descritto nel pattern modipa_infoUtente_audit02 va in aggiunta rispetto agli altri token di sicurezza e quindi può essere utilizzato in combinazione con qualsiasi dei token descritti nei precedenti scenari purchè il token "Authorization" sia negoziato tramite la PDND.

Sintesi

Mostriamo in questa sezione come procedere per l'esposizione di un servizio REST da erogare nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui un servizio è stato registrato sulla PDND, e i fruitori per poterlo fruire devono ottenere un voucher dalla PDND che successivamente devono inviare all'erogatore insieme alla normale richiesta di servizio. Oltre al voucher devono anche presentare il token di audit «Agid-JWT-TrackingEvidence» previsto dal pattern «AUDIT_REST_02». Da notare come nel pattern modipa_infoUtente_audit02 sia previsto che nel voucher della PDND sia presente il digest del token di audit utile a verificare la correlazione tra i due token.

La figura seguente descrive graficamente questo scenario.

Le caratteristiche principali di questo scenario sono:

1. un applicativo eroga un servizio, rivolto a fruitori di domini esterni, in conformità al Modello di Interoperabilità AGID e il servizio viene registrato sulla PDND;
2. la comunicazione con i domini esterni avviene su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;
3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND»;
4. per la fruizione viene richiesto un token aggiuntivo, conforme al pattern «AUDIT_REST_02», adibito a contenere informazioni utili all'erogatore a identificare la specifica provenienza di ogni singola richiesta di accesso ai dati effettuta dal fruitore;
5. la validazione del token di audit viene effettuata scaricando la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd;
6. la verifica di correlazione tra il token di audit e il token di autenticazione avviene tramite il calcolo del digest del token di audit «Agid-JWT-TrackingEvidence» e la comparazione con il valore del digest presente nel token «Authorization»;
7. vengono inoltre recuperate e associate alla traccia maggiori informazioni sull'organizzazione afferente al "client-id" presente nel token, sempre attraverso le modipa_passiPreliminari_api_pdnd.

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre

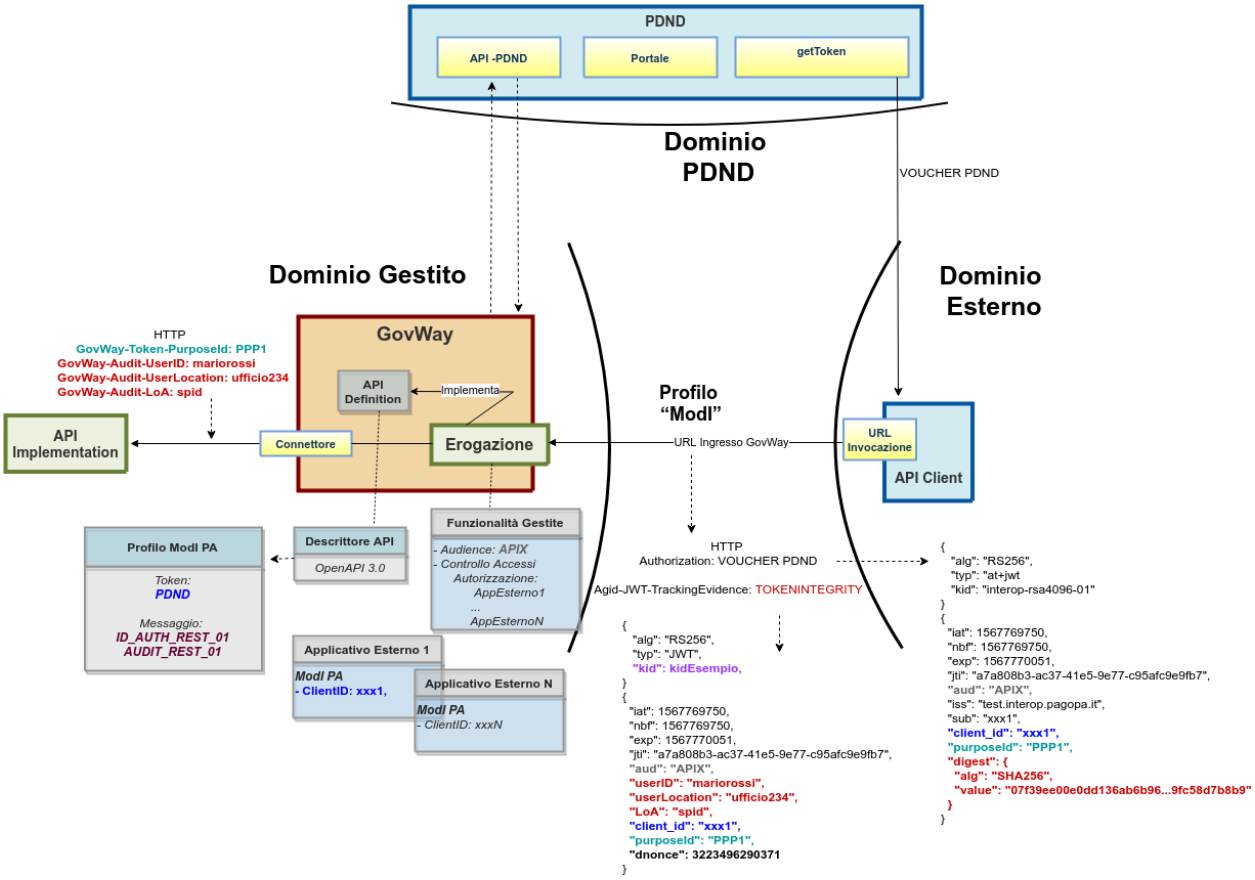


Figure3.242: Erogazione di una API REST con profilo "ModI", pattern AUDIT_REST_02 e pattern ID_AUTH_REST_01 via PDND

di selezionare il soggetto “Ente” per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.243: Profilo ModI della govwayMonitor

L’esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione*. Di seguito verranno evidenziate solamente le differenze che comporta l’utilizzo del pattern «AUDIT_REST_02» al posto di «AUDIT_REST_01».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - Audit02+PDND - IN App4» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

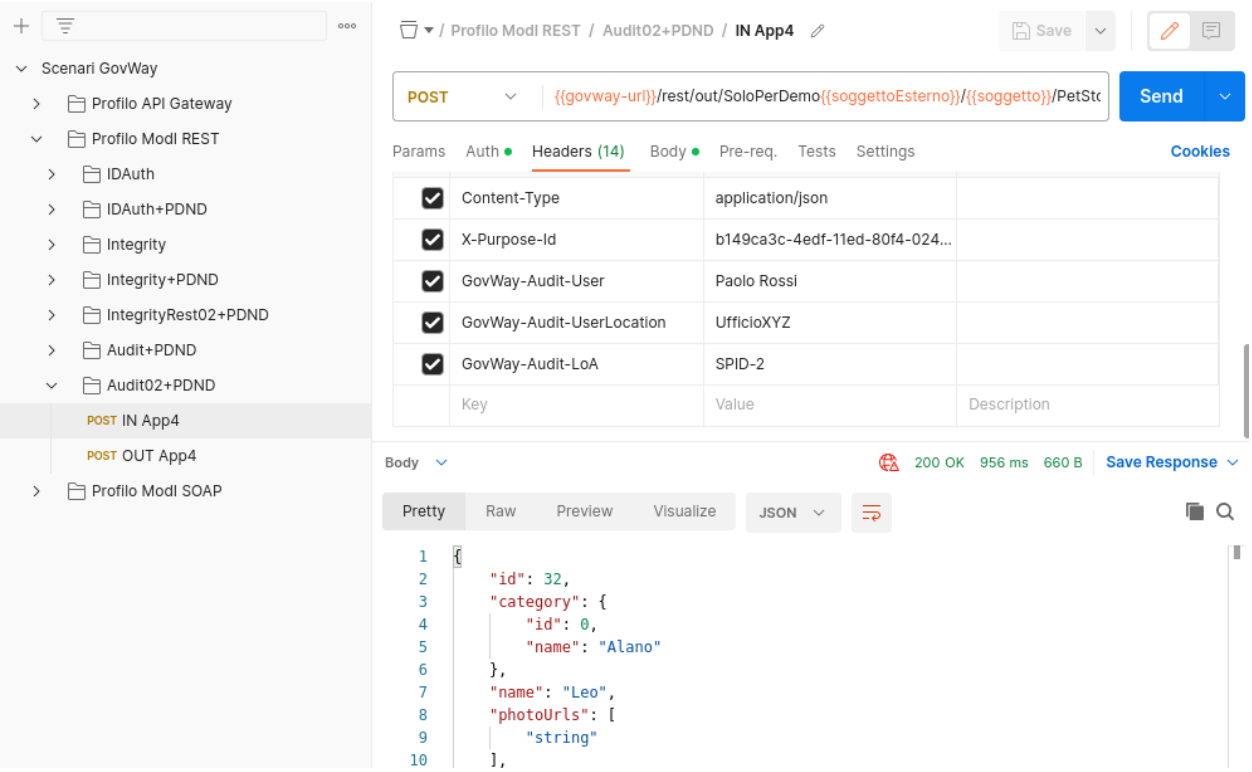


Figure3.244: Pattern Audit02+PDND - Erogazione API REST, esecuzione da Postman

Dopo aver eseguito la «Send» e verificato il corretto esito dell’operazione è possibile andare a verificare cosa è accaduto, nel corso dell’elaborazione della richiesta, andando a consultare la console “govwayMonitor”.

Le evidenze del processo di validazione relative al token PDND sono le medesime descritte nella scenario *Esecuzione*.

Le evindenze del processo di validazione del token di audit «Agid-Jwt-TrackingEvidence» sono le stesse descritte nello scenario *Esecuzione*. Di seguito viene riportato solamente un dettaglio differente presente all’interno del token «Authorization» e richiesto dal pattern «AUDIT_REST_02» per implementare la correlazione tra il token di autenticazione e il token di audit.

Analizzando il token di auth «Authorization» ricevuto nella sezione payload (Fig. 3.245) oltre alle consuete informazioni sull’identità del fruitore (client_id), i riferimenti temporali (iat, nbf, exp), l’audience (aud) e il “purposeId”

utilizzato dal fruitore per richiedere il token di autorizzazione alla PDND, è presente anche il claim "digest" utilizzato dall'erogatore per verificare la corrispondenza rispetto al digest calcolato sul token di audit «Agid-Jwt-TrackingEvidence» ricevuto.



Figure3.245: Sezione «Payload» del Token "Authorization" con pattern "AUDIT_REST_02"

Conformità ai requisiti ModI

La verifica dei requisiti ModI per questo scenario non differisce da quanto già descritto in *Esecuzione*.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.246: Profilo ModI della govwayConsole

La configurazione dello scenario è del tutto analogo a quello descritto nello scenario *Configurazione* con la sola eccezione del pattern di sicurezza aggiuntivo utilizzato in questo scenario: «AUDIT_REST_02».

Registrazione API

Viene registrata l'API «PetStoreAudit02PDND» con il relativo descrittore OpenAPI 3. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «ID_AUTH_REST_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND». Viene infine abilitata l'opzione "Informazioni Audit" e selezionato il pattern «AUDIT_REST_02» e lo schema dei dati «Linee Guida ModI» (Fig. 3.247). Per ulteriori dettagli sullo schema dei dati di un token di audit si rimanda alle sezioni modipa_infoUtente_audit01_schema e modipa_infoUtente_audit01_schema_custom.

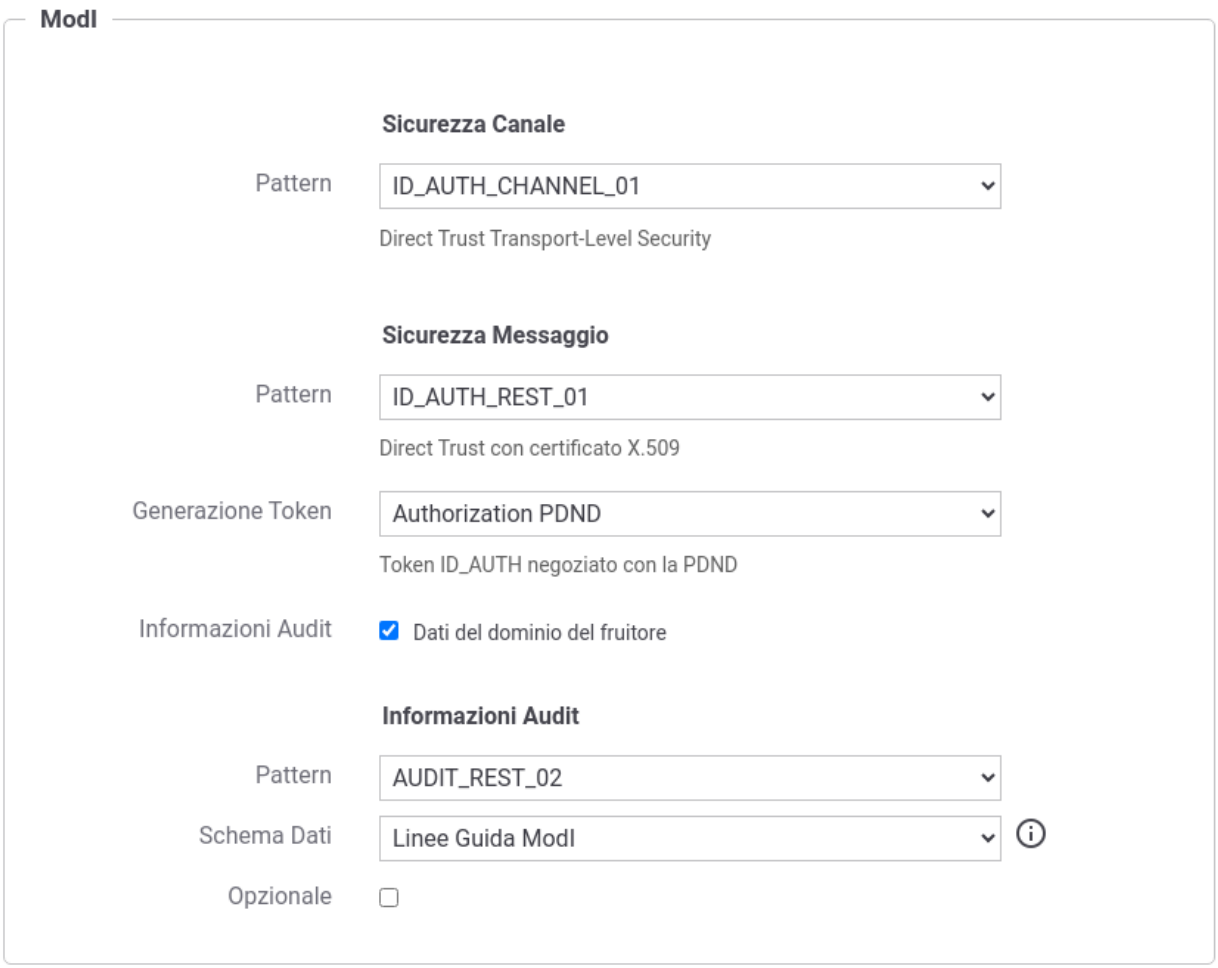


Figure3.247: Configurazione Pattern ModI «AUDIT_REST_02» sulla API REST

Applicativo Esterno

È opzionalmente possibile registrare l'applicativo esterno che corrisponde al fruitore del servizio. Questa scelta può essere fatta in base al tipo di autorizzazione che si è impostata sui fruitori. Vediamo i seguenti casi:

- Se si desidera autorizzare qualsiasi fruitore proveniente dalla PDND, questo passo può anche essere omesso. La validazione del token è sufficiente a stabilire che il fruitore ha ottenuto un voucher dalla PDND valido per il servizio invocato. Questo scenario è quello preconfigurato.
- In alternativa è possibile configurare una autorizzazione puntuale procedendo alla registrazione degli applicativi fornendo i singoli "client_id" necessari all'identificazione (Fig. 3.248).

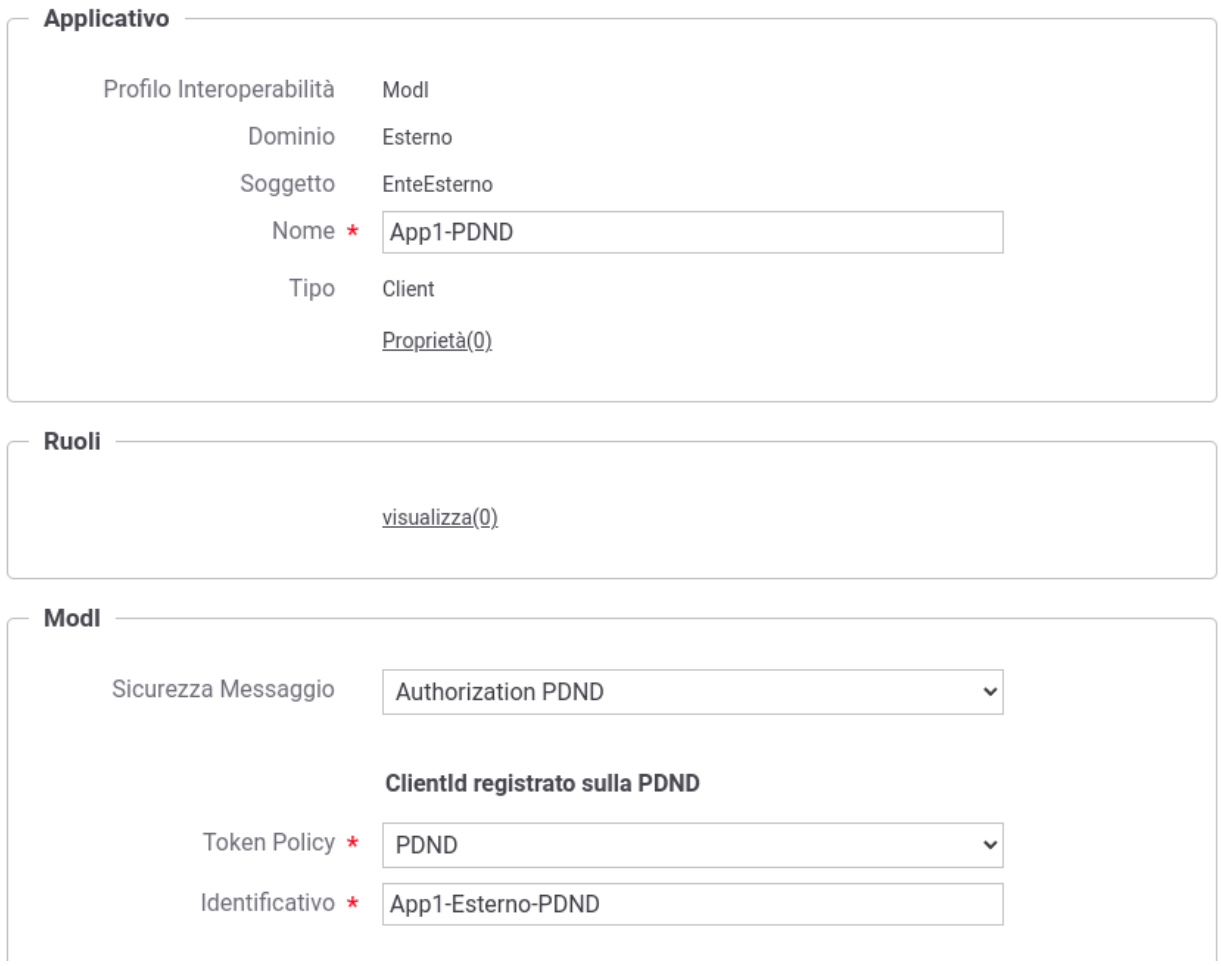


Figure3.248: Configurazione applicativo esterno (fruitore)

Erogazione

Nell'erogazione «PetStoreAudit02PDND», relativa all'API precedentemente inserita, vanno indicati i dati specifici nella sezione «ModI Richiesta» (Fig. 3.249) necessari per validare le richieste in ingresso relativamente al token "Agid-JWT-TrackingEvidence". Si noti come è stato selezionato un truststore basato sulla PDND al fine di scaricare la chiave pubblica, corrispondente al kid presente nel token, tramite le modipa_passiPreliminari_api_pdnd.

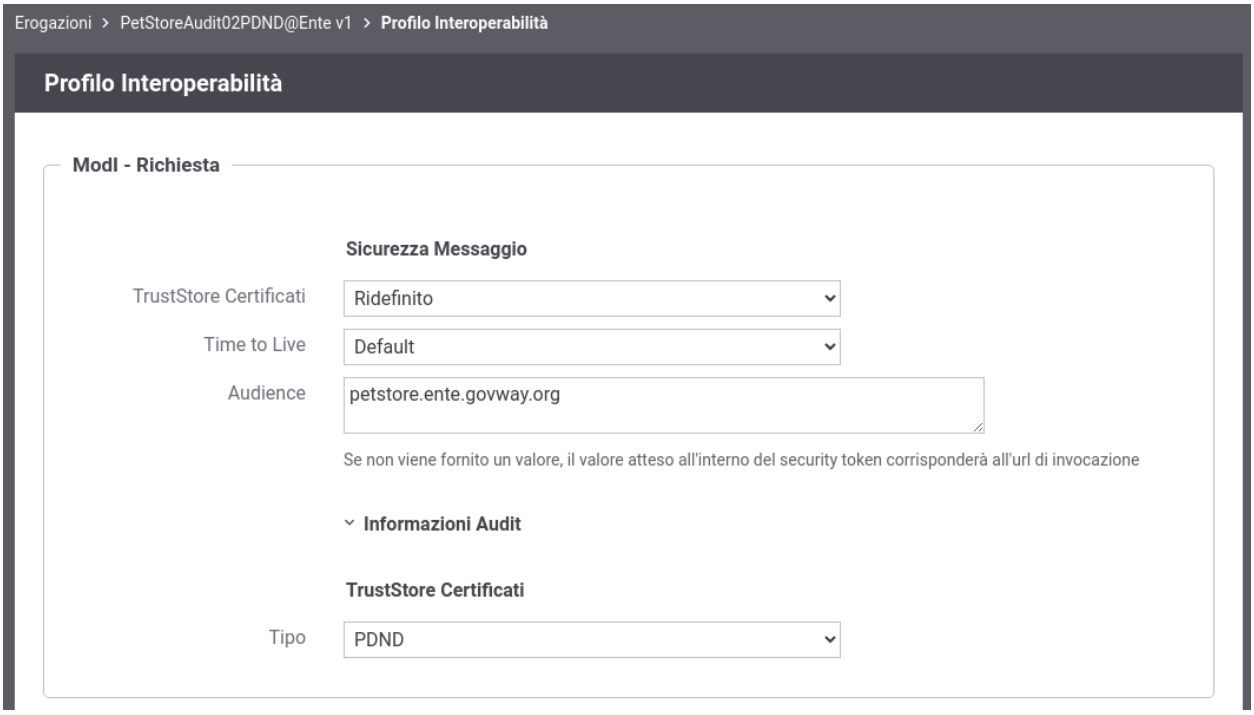


Figure3.249: Configurazione richiesta dell'erogazione

3.7.2 Fruizione API REST

Obiettivo

Fruire di un servizio REST, definito tramite una API REST (OpenAPI 3.0), che richiede per l'accesso oltre ai token di sicurezza descritti nei precedenti scenari anche un token aggiuntivo adibito a contenere informazioni utili all'erogatore a identificare la specifica provenienza di ogni singola richiesta di accesso ai dati effettuta dal fruitore. Il token di audit deve rispettare il pattern di sicurezza descritto nella sezione modipa_infoUtente_audit02.

Sintesi

Mostriamo in questa sezione come procedere per l'integrazione di un applicativo con un servizio REST erogato nel rispetto della normativa italiana alla base dell'interoperabilità tra i sistemi della pubblica amministrazione. In particolare andiamo ad illustrare lo scenario in cui il servizio è stato registrato sulla PDND, e il fruitore per poterlo fruire deve ottenere un voucher dalla PDND che successivamente deve inviare all'erogatore insieme alla normale richiesta di servizio. Oltre al voucher il fruitore devo anche presentare il token di audit «Agid-JWT-TrackingEvidence» previsto dal pattern «AUDIT_REST_02». Da notare come il pattern modipa_infoUtente_audit02 prevede che nella richiesta del voucher verso la PDND e nel voucher restituito debba essere presente il digest del token di audit che verrà poi utilizzato dall'erogatore per verificare la correlazione tra i due token.

La figura seguente descrive graficamente questo scenario.

Le caratteristiche principali di questo scenario sono:

1. un applicativo fruitore che dialoga con il servizio erogato in modalità ModI in accordo ad una API condivisa e pubblicata su PDND;
2. la comunicazione diretta verso il dominio erogatore veicolata su un canale gestito con il pattern di sicurezza canale «ID_AUTH_CHANNEL_01»;
3. l'autenticità della comunicazione tra il servizio erogato e ciascun fruitore è garantita tramite sicurezza a livello messaggio con pattern «ID_AUTH_REST_01 via PDND»;

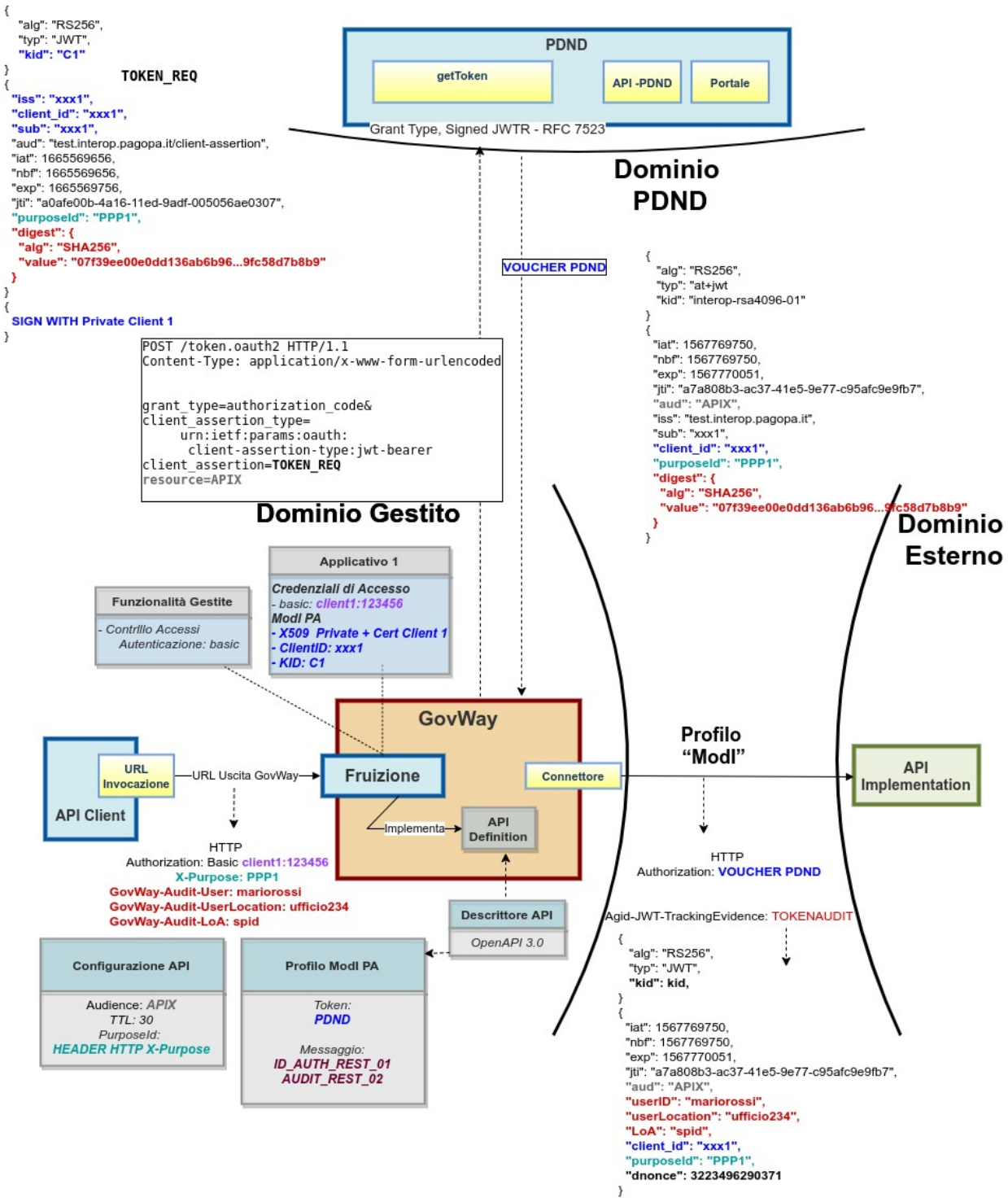


Figure3.250: Fruizione di una API REST con profilo "ModI", pattern AUDIT_REST_02 e pattern ID_AUTH_REST_01 via PDND

4. le informazioni di audit, richieste dall'erogatore per identificare la specifica provenienza di ogni singola richiesta di accesso ai dati effettuta dal fruitore, vengono inserite in un token di audit conforme al pattern «AUDIT_REST_02». Le informazioni vengono fornite dall'applicativo fruitore tramite header HTTP;
5. la negoziazione del voucher con la PDND prevede l'inserimento nella richiesta del digest del token di audit che verrà a sua volta incluso dalla PDND nel voucher restituito e sarà utilizzabile dall'erogatore per verificare la correlazione tra il token di audit e il token di autenticazione.

Esecuzione

Nota

Al fine di avere una consultazione immediata delle informazioni di interesse per lo scenario si consiglia di impostare, nella console "govwayMonitor", nel menù in alto a destra il Profilo di Interoperabilità "ModI". Si suggerisce inoltre di selezionare il soggetto "Ente" per visualizzare solamente le transazioni di interesse allo scenario e ignorare le transazioni «di servizio» necessarie ad implementare la controparte.



Figure3.251: Profilo ModI della govwayMonitor

L'esecuzione dello scenario è del tutto analogo a quello descritto nello scenario *Esecuzione*. Di seguito verranno evidenziate solamente le differenze che comporta l'utilizzo del pattern «AUDIT_REST_02» al posto di «AUDIT_REST_01».

Per eseguire e verificare lo scenario si può utilizzare il progetto Postman a corredo con la request «Profilo ModI REST - Audit02+PDND - OUT App4» che è stata preconfigurata per il funzionamento con le caratteristiche descritte sopra.

Dopo aver eseguito la «Send» e verificato il corretto esito dell'operazione è possibile andare a verificare cosa è accaduto nelle diverse fasi dell'esecuzione andando a consultare la console "govwayMonitor".

Le evidenze del processo di validazione relative al token PDND sono le medesime descritte nella scenario *Esecuzione*.

Le evindenze del processo di validazione del token di audit «Agid-Jwt-TrackingEvidence» sono le stesse descritte nello scenario *Esecuzione*. Di seguito viene riportato solamente un dettaglio differente presente all'interno del token «Authorization» e richiesto dal pattern «AUDIT_REST_02» per implementare la correlazione tra il token di autenticazione e il token di audit.

Analizzando il token di auth «Authorization», ottenuto dalla PDND ed inviato all'erogatore, nella sezione payload (Fig. 3.253) oltre alle consuete informazioni sull'identità del fruitore (client_id), i riferimenti temporali (iat, nbf, exp), l'audience (aud) e il "purposeId" utilizzato dal fruitore per richiedere il token di autorizzazione alla PDND, è presente anche il claim "digest" utilizzato dall'erogatore per verificare la corrispondenza rispetto al digest calcolato sul token di audit «Agid-Jwt-TrackingEvidence» ricevuto.

Conformità ai requisiti ModI

La verifica dei requisiti ModI per questo scenario non differisce da quanto già descritto in *Esecuzione*.

Configurazione

Nota

Per operare con la govwayConsole in modo conforme a quanto previsto dalla specifica del Modello di Interoperabilità si deve attivare, nella testata dell'interfaccia, il Profilo di Interoperabilità «ModI». Si suggerisce

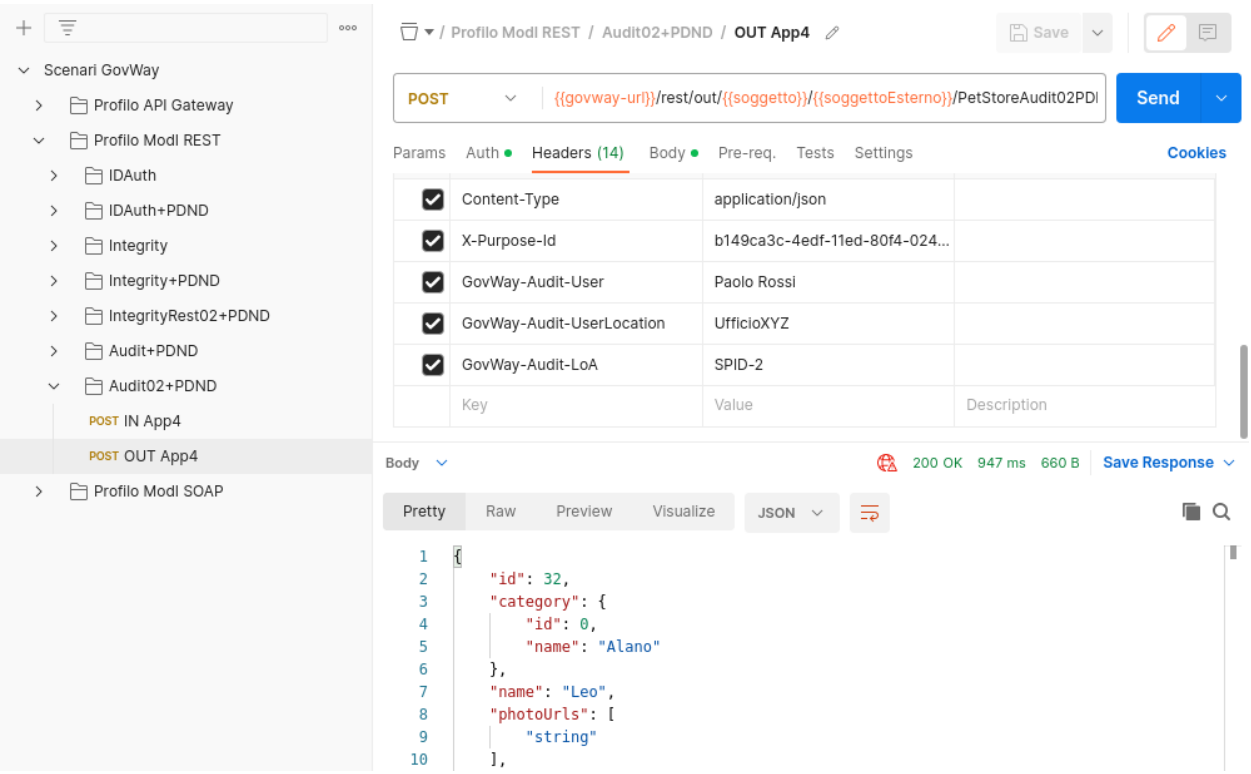


Figure3.252: Pattern Audit02+PDND - Fruizione API REST, esecuzione da Postman

inoltre di selezionare il soggetto “Ente” per visualizzare solamente le configurazioni di interesse allo scenario e nascondere le configurazioni «di servizio» necessarie ad implementare la controparte.



Figure3.254: Profilo ModI della govwayConsole

La configurazione dello scenario è del tutto analogo a quello descritto nello scenario *Configurazione* con la sola eccezione del pattern di audit aggiuntivo utilizzato in questo scenario: «AUDIT_REST_02».

Registrazione API

Viene registrata l’API «PetStoreAudit02PDND» con il relativo descrittore OpenAPI 3. Vengono selezionati i pattern «ID_AUTH_CHANNEL_01» (sicurezza canale) e «ID_AUTH_REST_01» (sicurezza messaggio) nella sezione «ModI» indicando nel campo «Generazione Token» il valore «Authorization PDND». Viene infine abilitata l’opzione “Informazioni Audit” e selezionato il pattern «AUDIT_REST_02» e lo schema dei dati «Linee Guida ModI» (Fig. 3.255). Per ulteriori dettagli sullo schema dei dati di un token di audit si rimanda alle sezioni modipa_infoUtente_audit01_schema e modipa_infoUtente_audit01_schema_custom.

Fruizione

Nella fruizione «PetStoreAudit02PDND», relativa all’API precedentemente inserita, vanno indicati i dati specifici nella sezione «ModI Richiesta» (Fig. 3.256) necessari a generare il token “Agid-JWT-TrackingEvidence”. In particolare è possibile specificare l’audience atteso dall’erogatore e il tempo di validità del token.



Figure3.253: Sezione «Payload» del Token “Authorization” con pattern “AUDIT_REST_02”

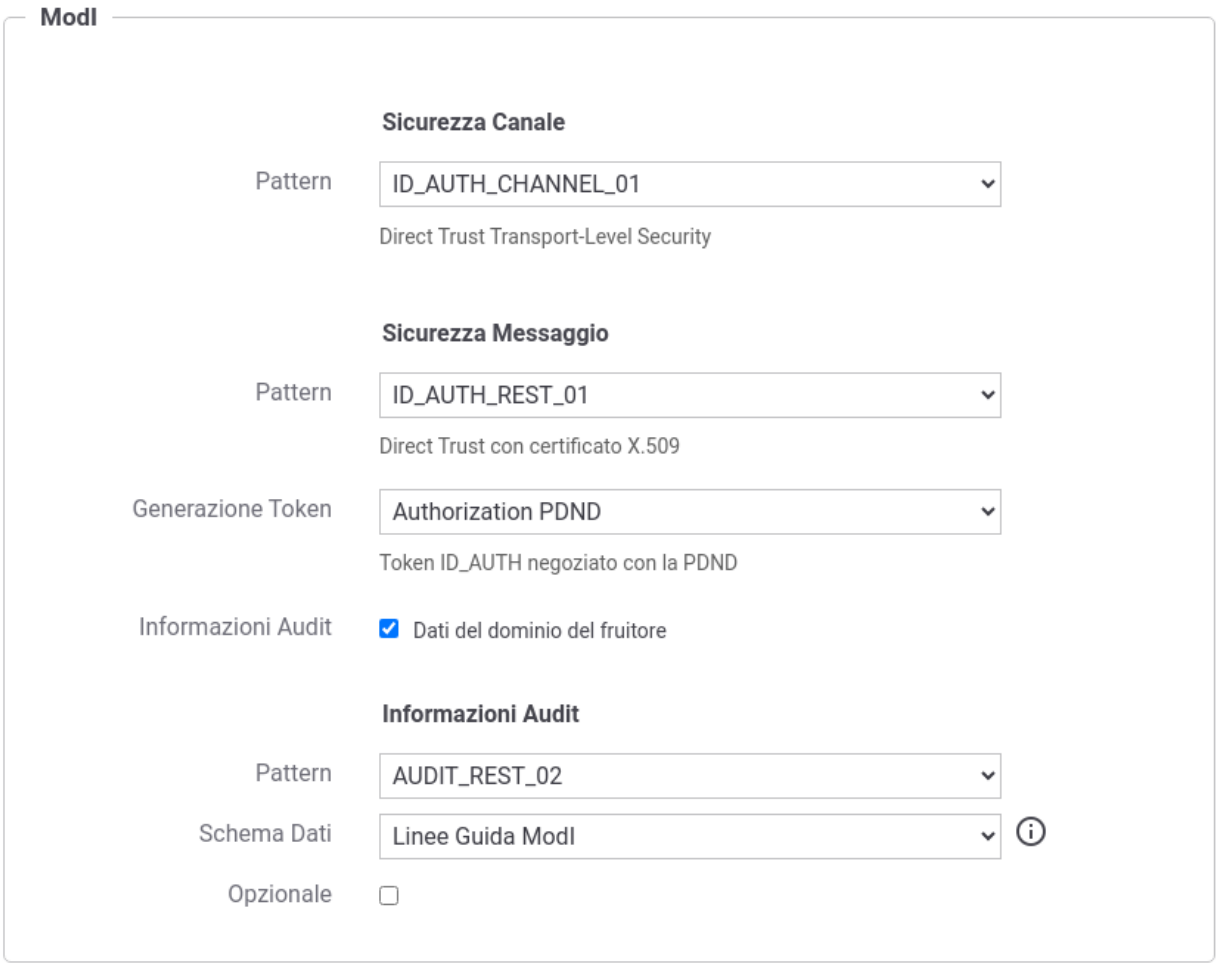


Figure3.255: Configurazione Pattern ModI «AUDIT_REST_02» sulla API REST

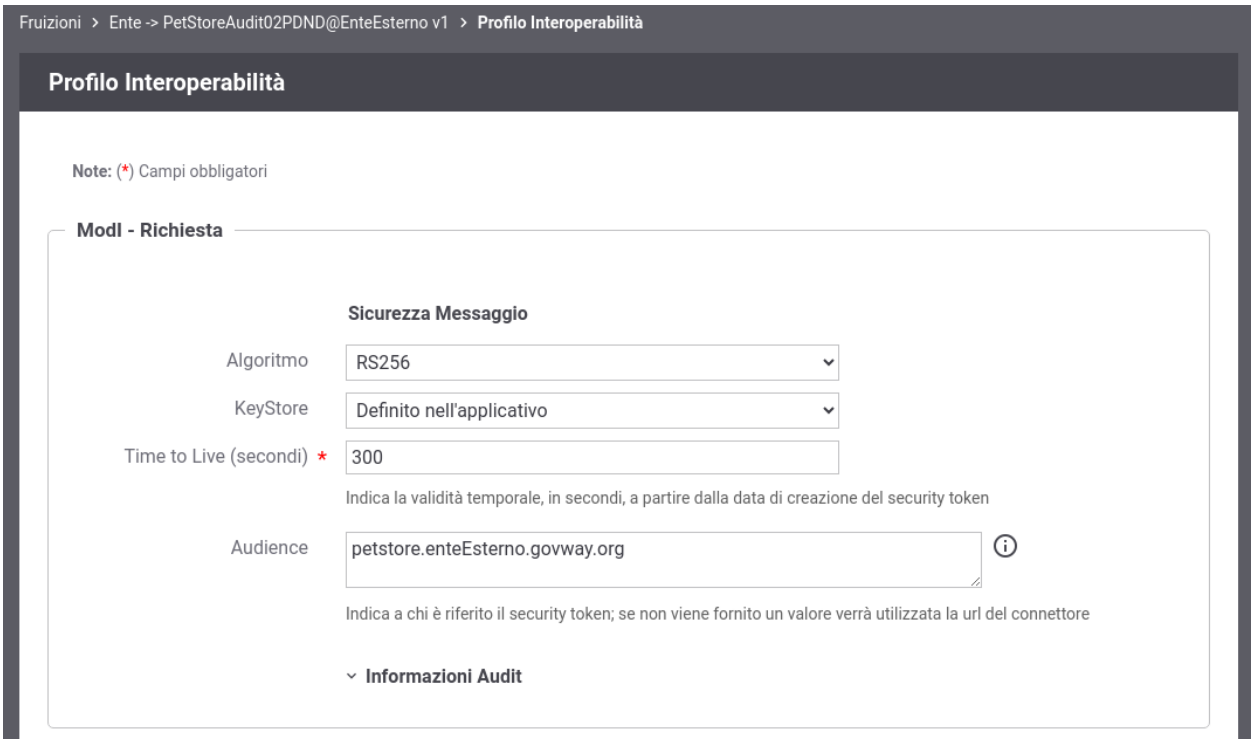


Figure3.256: Configurazione richiesta della fruizione

CHAPTER 4

Monitoraggio

In questa sezione descriviamo alcuni tipici scenari di impiego delle funzionalità di monitoraggio offerte da Govway. Il monitoraggio consente di tenere sotto controllo il traffico gestito dal gateway al fine di verificare il regolare funzionamento dei servizi, individuare situazioni anomale ed avviare l'indagine diagnostica.

Per meglio descrivere le attività tipiche della fase di monitoraggio, supponiamo di intervenire nella fase successiva all'esecuzione dei passi dello scenario «Erogazione SPID» (*Erogazione OAuth*).

La console govwayMonitor, nella sezione Monitoraggio, prevede la consultazione del traffico gestito nelle modalità «Storico» e «Live». Ciascuna di queste sezioni mostra l'elenco delle transazioni, in ordine cronologico decrescente, che soddisfano i criteri di filtro impostati (Fig. 4.1).

Le transazioni riportate nell'elenco riportano i dati per l'identificazione delle stesse, con evidenza dell'esito riportato.

A titolo esemplificativo vengono riportati di seguito due tipici scenari di indagine sul dettaglio di una singola transazione:

- *Transazione in errore*: descrive le informazioni mostrate nel dettaglio di una transazione con esito negativo, utili a identificare la causa dell'errore.
- *Transazione con esito corretto*: illustra le informazioni mostrate nel dettaglio di una transazione con esito positivo, comprese quelle relative al token presentato dal mittente.

4.1 Transazione in errore

Se apriamo il dettaglio della transazione con esito errore, relativa all'invocazione della «POST /pet» senza token, vediamo le informazioni di Fig. 4.2.

Il dettaglio della transazione:

- Il riquadro «Informazioni Generali» riepiloga i principali dati identificativi della transazione. In questo riquadro è mostrato l'esito, in questo caso negativo. Tramite il link apposito si possono visualizzare i messaggi diagnosti, utili all'identificazione del problema occorso (Fig. 4.3).

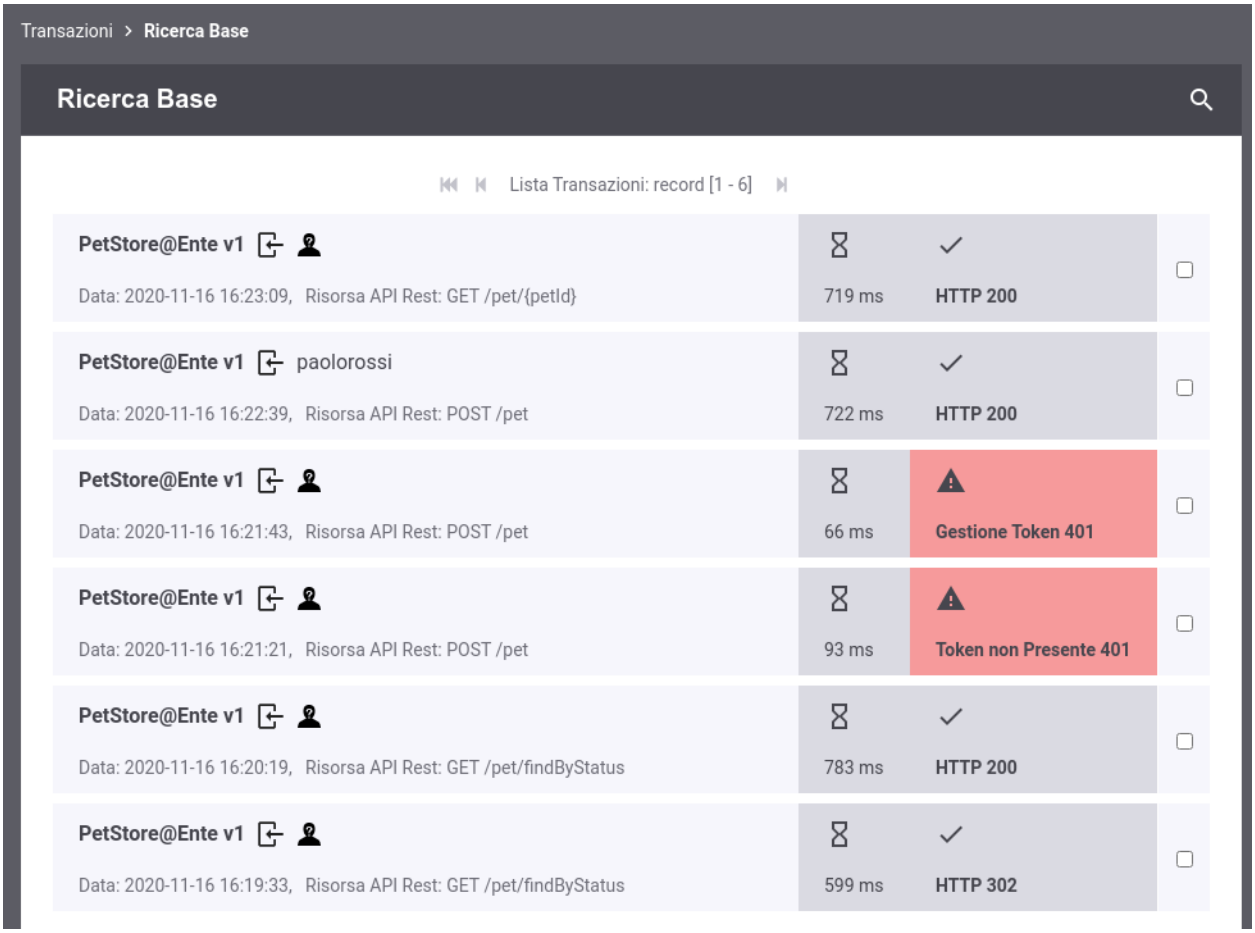


Figure4.1: Elenco delle transazioni

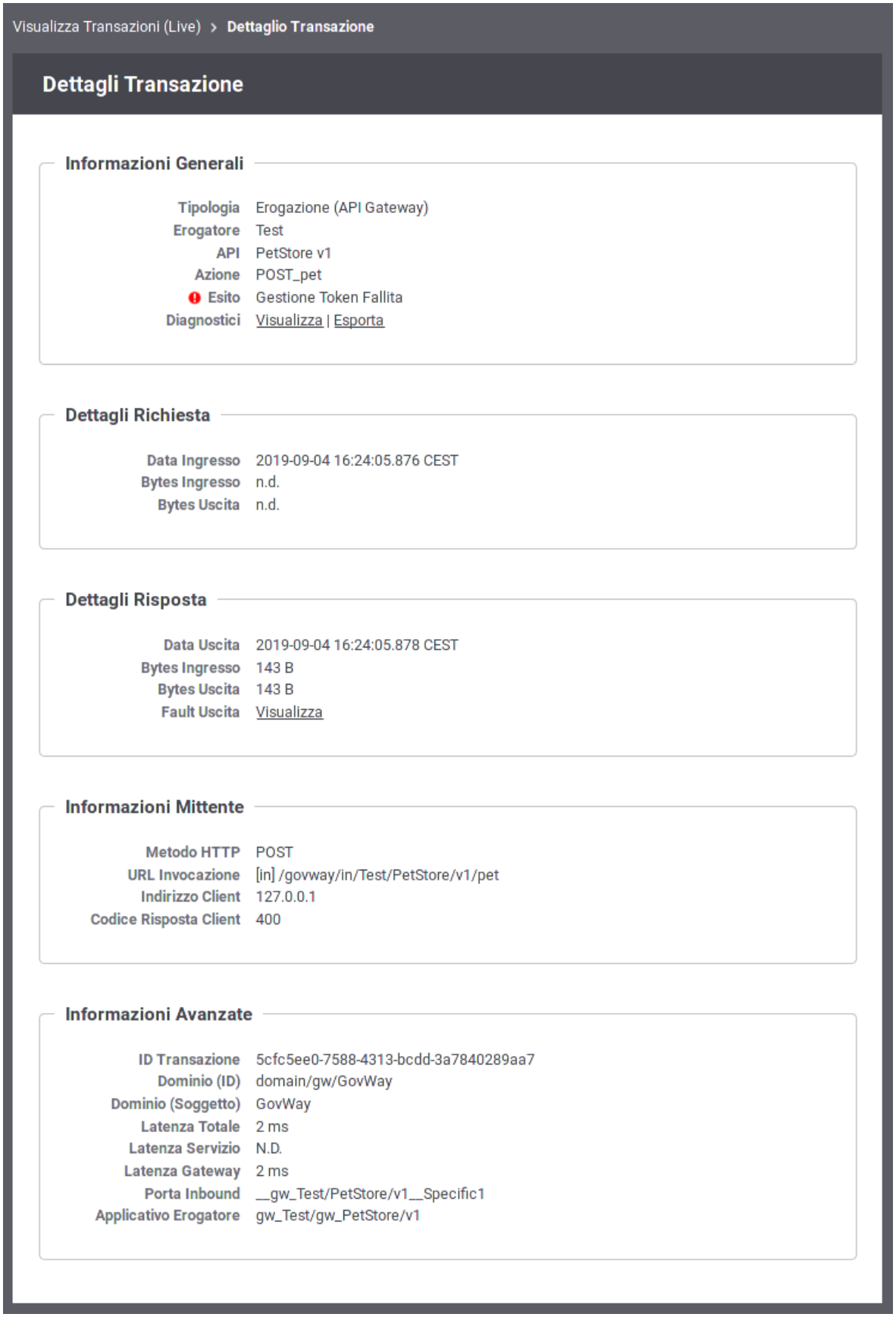


Figure4.2: Dettaglio della transazione in errore

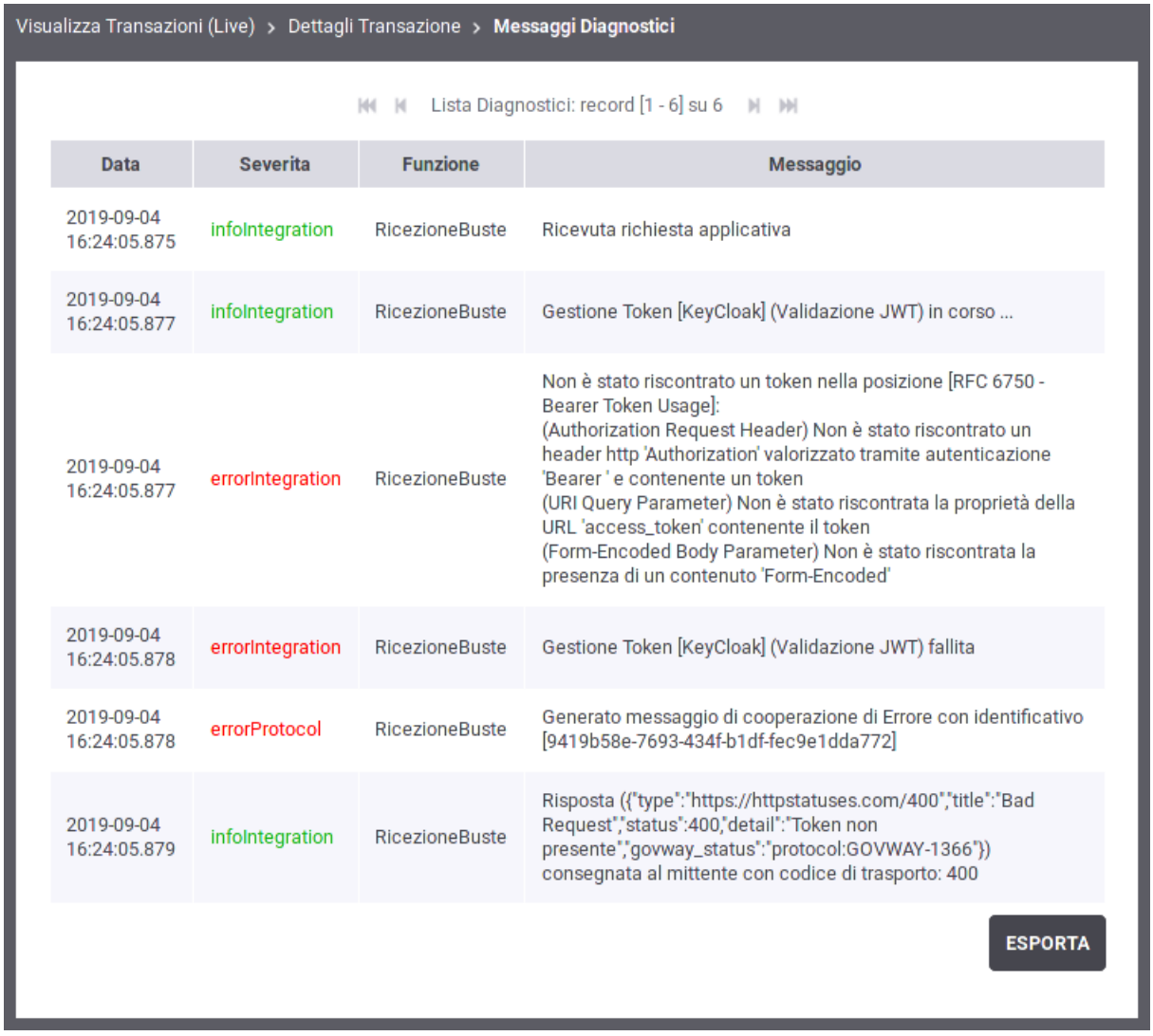


Figure4.3: Messaggi diagnostici della transazione in errore

- I riquadri «Dettagli Richiesta» e «Dettagli Risposta» forniscono informazioni specifiche relative al messaggio di richiesta e a quello di risposta. In questo caso, ad esempio, è possibile visualizzare il messaggio di fault inviato al client in risposta (Fig. 4.4).



Figure4.4: Fault in uscita

- Il riquadro «Informazioni Mittente» fornisce dettagli sulla provenienza della richiesta.
- Il riquadro «Informazioni Avanzate» fornisce dati aggiuntivi riguardo la transazione.

4.2 Transazione con esito corretto

Se apriamo il dettaglio della transazione con esito positivo, relativa all'invocazione della «POST /pet», possiamo ad esempio:

- Visualizzare le informazioni generali con l'esito dell'operazione (Fig. 4.5).

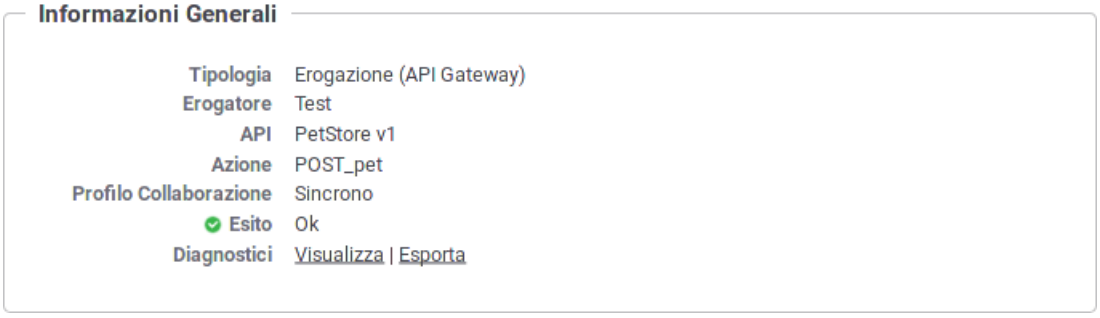


Figure4.5: Messaggi diagnostici della transazione con esito regolare

- Nel contesto delle informazioni generali si possono visualizzare i messaggi diagnostici con il dettaglio dell'elaborazione regolarmente eseguita (Fig. 4.6).

- Nel contesto delle informazioni mittente in questo caso sarà presente la sezione «Token Info» che consente di visualizzare dati inerenti il token che è stato fornito con la richiesta del mittente. Risultano immediatamente visibili le informazioni principali (issuer, subject, ...), come mostrato in Fig. 4.7.

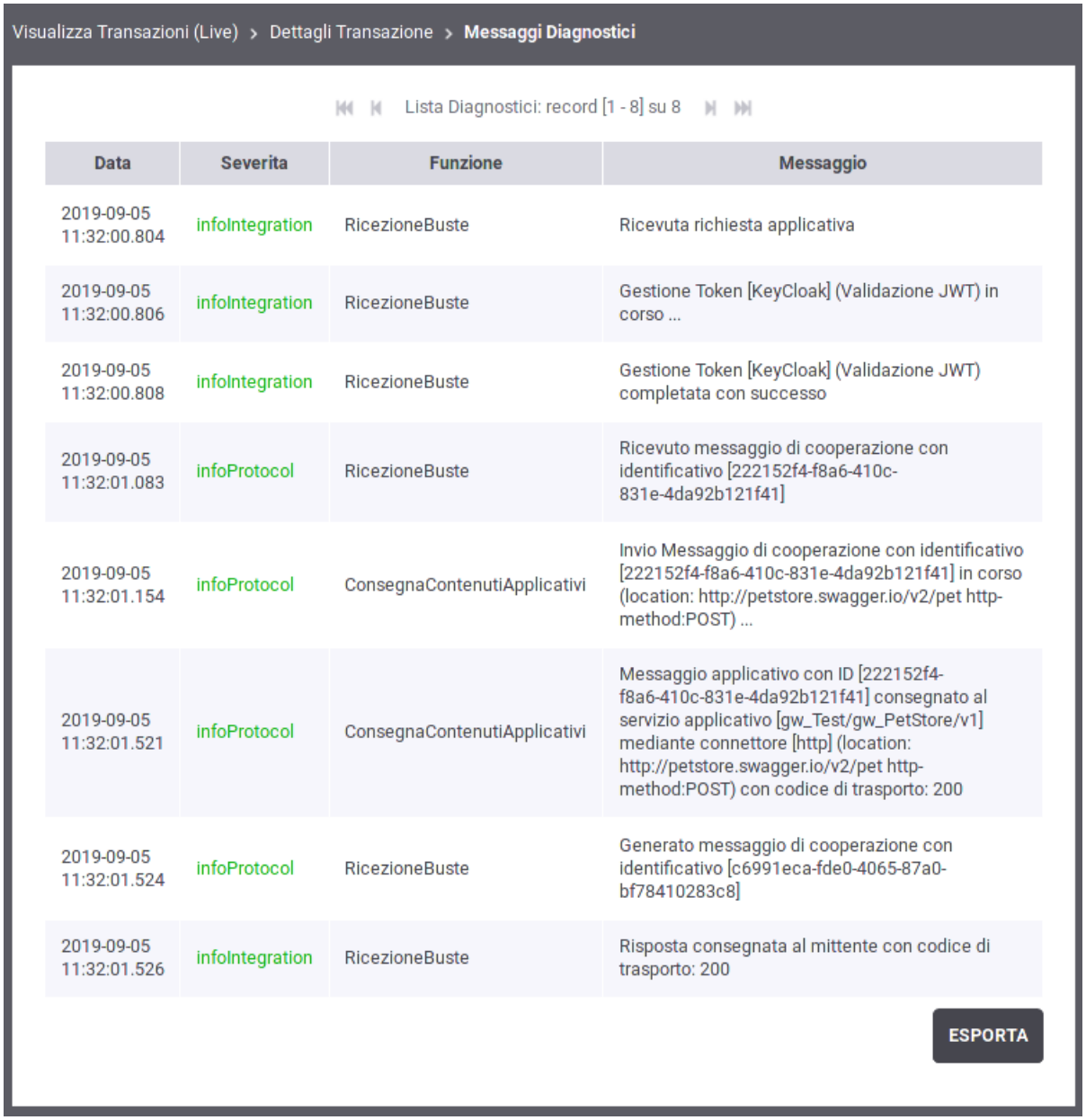


Figure4.6: Messaggi diagnostici della transazione con esito regolare

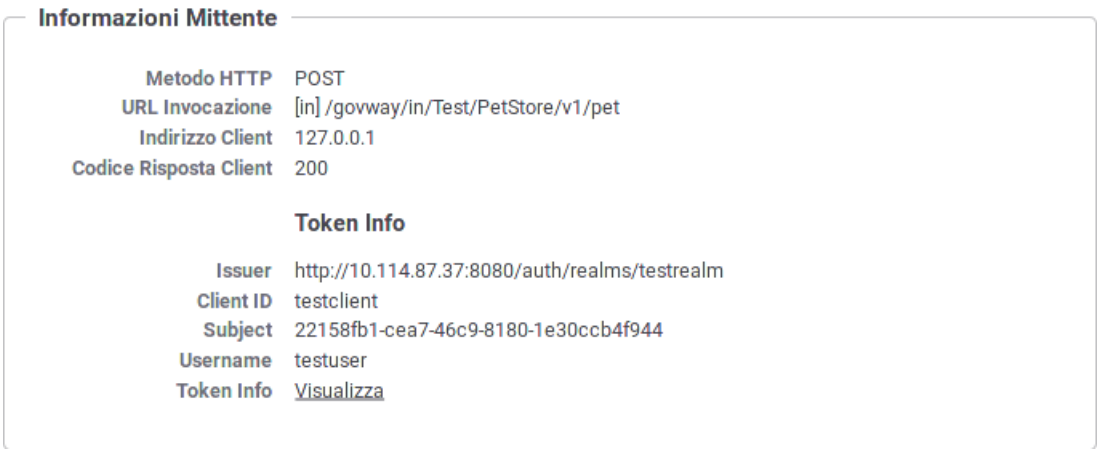


Figure4.7: Informazioni mittente con presenza del token

- Dalla sezione mittente è possibile aprire una finestra per visualizzare la versione in chiaro del token ricevuto con la richiesta (Fig. 4.8).

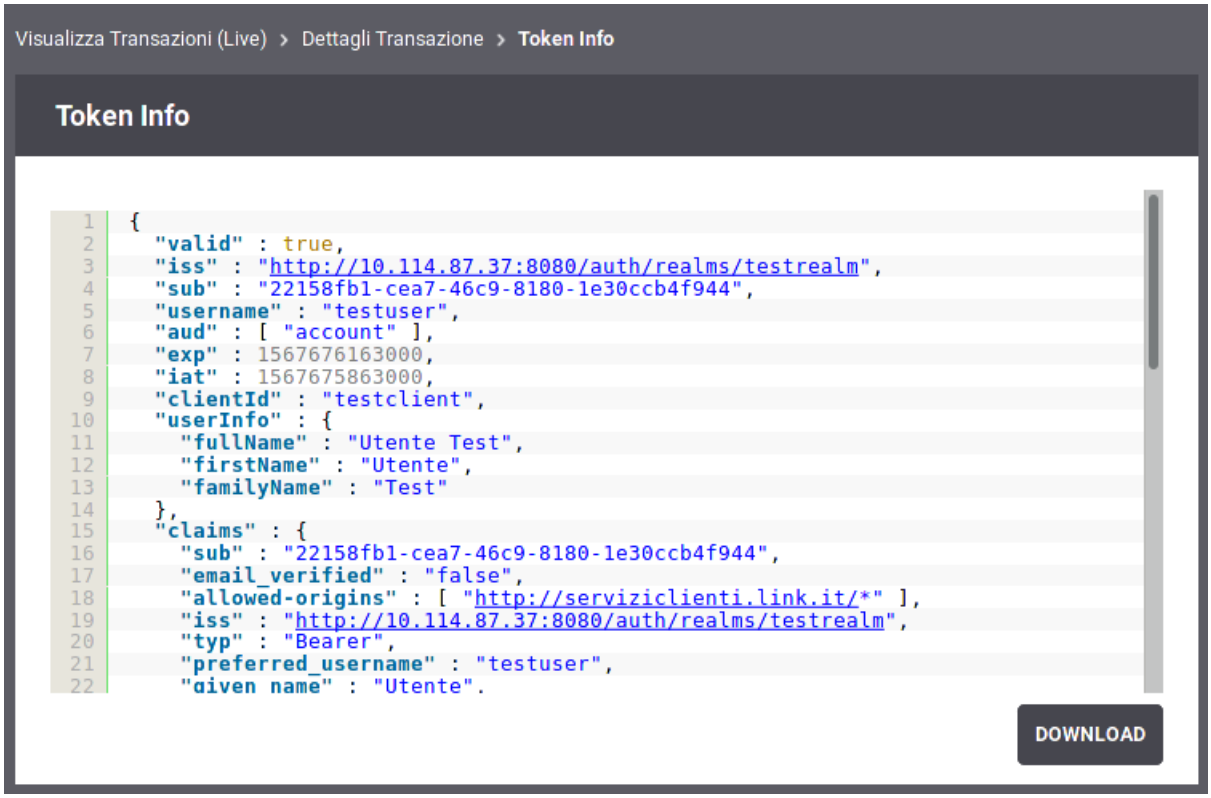


Figure4.8: Visualizzazione del token